

The Cybersecurity Trinity

Artificial Intelligence, Automation, and Active Cyber Defense

How This Book Is Organized

This book is comprised of four parts. The first part, “Artificial Intelligence As the Foundation,” begins with an overview of how several industries, including cybersecurity, currently leverage AI (Chapter 1). AI profoundly impacts many industries, including healthcare, financial services, manufacturing, transportation, and utilities. Since companies realize the benefits of incorporating AI into their processes, cybersecurity professionals must be prepared to secure its use. Therefore, Chapter 2 provides an overview of AI to help cybersecurity professionals understand the underlying concepts, including some of the most widely used algorithms. Of course, cybersecurity can also reap the benefits of AI, so Chapter 3 discusses several cybersecurity use cases for AI. Once we understand AI concepts and use cases, we must consider how adversaries might attack AI and how we can secure it. Chapter 4 discusses threats that can target the AI process, data, models, and security controls to combat them. Since adversaries also leverage AI, Chapter 5 examines how to combat AI-powered threats.

The second part, “Automation to Speed Defense,” focuses on security automation to address one side of the equation to close the gap between compromise and response. Chapter 6 explores the driving forces behind security automation and the benefits organizations have realized from SOAR. In Chapter 7, the focus is on Boyd’s OODA Loop theory. This theory, which Boyd originally developed in the context of air-to-air combat, has been applied in numerous adversarial situations, including cybersecurity. The chapter also includes an overview of the Integrated Adaptive Cyber Defense Framework, including its incorporation of the OODA loop theory in security automation. There are many SOAR use cases, so Chapter 8 explores some of the most common use cases companies can implement to improve security operations, including

alert enrichment and correlation, threat intelligence processing, alert triage, and automated remediation and response. Finally, Chapter 9 discusses strategies to help ensure a successful implementation of security automation and the ongoing program. If you are like me, you can also learn from other people's mistakes, so this chapter provides strategies for failure.

The book explores active cyber defense (ACD) in the third part. It begins by categorizing ACD methods based on operational, legal, and ethical risks in Chapter 10. These active defenses range from traditional deflection and blocking at the low-risk end of the spectrum to active defenses, such as hacking back, that companies should avoid due to the extreme risks. Other active defenses, such as deception, moving targets, and rescue missions, fall between these extremes, each with varying risks. After categorizing ACD tactics, we reexamine Boyd's OODA Loop theory and how ACD can disrupt the adversary's decision-making in Chapter 11. Finally, Chapter 12 takes an in-depth look at deception to slow the attacker and gather intelligence on the adversary's techniques and goals.

The final part, "The Cybersecurity Trinity," brings it all together. First, we show how AI forms the foundation of the CST by powering most cybersecurity functions, including risk management, governance, detection, and response. Next, automation is added to the CST to speed detection and response by automating many aspects of cybersecurity operations, including alert and threat intelligence enrichment, vulnerability management, threat detection, and orchestrated response. The final side of the CST is active cyber defenses, including information sharing, deflection, moving targets, deception, beacons, and dark web intelligence. After building the CST, it is applied to six core functions of the NIST Cybersecurity Framework (NIST CSF). For each NIST CSF function, we demonstrate how AI, automation, and ACD can work together to improve

Table of Contents

Part I: Artificial Intelligence As the Foundation

Chapter 1: AI Is Everywhere

AI Use by Industry

Healthcare

Financial Services

Manufacturing

Transportation

Utilities

Cross-Industry Trends

Explainable AI

AI Ethics

Environmental Impact

The European Union AI Act

Summary

References

Chapter 2: Overview of AI and ML

Supervised Learning

Classification Algorithms

Predictive Algorithms

Unsupervised Learning

Market Basket Analysis

Clustering

Deep Learning: Artificial Neural Networks

Reinforcement Learning

Classic ML Method

Summary

Chapter 3: AI for Defense

Email Security

Spam

Phishing

Email Account Takeover

Malware and Ransomware Detection

Device Profiling

Intrusion Detection

Behavior Analytics

**User Behavior Analytics and Insider Threat
Detection**

Challenges of UBA

Alert Management

Vulnerability Management

Vulnerability Exploitation Prediction

AI-Generated Synthetic Data

Synthetic Data to Protect Privacy

**Synthetic Data for Model Development and
Prototyping**

Accuracy and Unbalanced Data: A Word of Caution

Summary

References

Chapter 4: ML in an Adversarial Environment

Training and Testing Phase: Poisoning Attacks

Label Flipping Example

Adversarial Sample Insertion Example

The ML Supply Chain: Pre-trained Models and Shared Datasets

Inference Phase Attacks

Exploratory Attacks

Evasion Attacks

Privacy Attacks

Output Attacks

Defending ML

Traditional Cybersecurity Controls for ML

ML-Specific Security Controls

Summary

References

Chapter 5: Combatting Generative AI Threats

WormGPT and FraudGPT: The Rise of Dark LLMs

AI Jailbreaking

Deepfakes

Creating a Deepfake

Deepfakes in Politics and Propaganda

Deepfakes for Fraud

Defending Against Deepfake Fraud

Misinformation and Disinformation

A Targeted Disinformation Campaign

Defending Against Targeted Misinformation Campaigns

Hallucinations

Summary

References

Part II: Automation to Speed Defense

Chapter 6: The Need for Speed

Driving Forces of Security Automation

Manual Triage and Response

Asymmetry Attacker's Advantage

The Increasing Sophistication of Attacks

The Scarcity of Cybersecurity Professionals

Increasing Data and Complexity

Need for Security at Cyber Speed

Continuing Cyberattacks

SOAR Benefits

Efficiency Gains

Increased Visibility and Decreased Time to Respond

Process Completeness and Consistency

Orchestrated Response

What About Cost Savings?

Summary

References

Chapter 7: The OODA Loop

Often Depicted, Often Misunderstood

Observe

Orient

Decide

Act

Emphasis on Orientation

Applying the OODA Loop

The OODA Loop in Business

OODA Loop on the Field

Applicability to Cybersecurity

The IACD Framework

IACD and the OODA Loop

Implementing the Loop with Playbooks

Summary

References

Chapter 8: Common SOAR Use Cases

Alert Enrichment and Situational Awareness

Intelligence

The Threat Intelligence Process

Manual Threat Intelligence Processing

Applying Automation to the Threat Intelligence Process

Intelligence Feed: File Hash Example

Benefits of Automating the Threat Intelligence Process

Alert Triage and False Positives

Remediation

Malware Response

Phishing Response

Orchestrated Response Across Disparate Systems

Suspicious User

Data Loss Prevention

Forensic Investigation Enrichment

Avoid Overreliance: A Word of Caution

Summary

Reference

Chapter 9: Strategies for Success (and Failure)

Moving from Human-in-the-Loop to Human-on-the-Loop

Enabling Automation

SOAR API Availability

API Scale Considerations

API Robustness Considerations

API Information Considerations

Automation Requires Trust and Confidence

Provide Feedback from Automation

Building Resilient Playbooks

Auditing and Verifying Automation

Continually Verify Trust

Build Organizational Trust

Measuring Success

Small Steps

Strategies for Failure

Focus on Saving Money

No Clear Priorities or Pipeline

Focus on the Biggest Problem

Automate Current Processes

Destroy Organizational Trust

Summary

References

Part III: Active Cyber Defense to Slow the Adversary

Chapter 10: Active Cyber Defense

Categorizing ACD Tactics

The ACD Spectrum

Low Risk

Caution

Extreme Caution

Avoidance

Legal and Ethical Considerations

Restrictions on Offensive Cyber

Possible Legislative Reform

ACD and Self-defense

The Importance of Boundaries

Summary

References

Chapter 11: The OODA Loop Revisited

Addressing Both Sides of the Equation

Disrupting the Opponent's OODA Loop

Disrupt and Slow the Opponent's Decision-Making

Disrupt the Opponent's Actions

Summary

Reference

Chapter 12: Deception

What Is Deception

Deception in War

Deception in Cyberspace

Applicability of Deception to Cybersecurity

Prerequisites for Deception

Components of a Typical Deception Platform

Lures

Decoys

Tokens

Honeypots and Honeynets

Central Management Console

Vampires and Cybersecurity

Practical Uses of Deception

Keys to Success

Misinformation and Concealment

Spread Misinformation

Conceal Information

Summary

References

Part IV: The Cybersecurity Trinity

Chapter 13: The Cybersecurity Trinity

Bringing It All Together

AI As the Foundation

Risk Management

Governance

Threat Intelligence

Vulnerability Management

Device Profiling

Intrusion Detection

Malware Detection

Email Security

Data Loss Prevention

Behavior Analytics

Alert Management

Automating to Speed Defense

Alert Enrichment and Situational Awareness

Alert Triage

Threat Intelligence Processing

Vulnerability Management

Alert Response Actions

Orchestrated Response in a Complex Environment

Forensic Investigation Enrichment

Active Cyber to Slow the Attacker

Information Sharing

Deflection and Blocking

Deception

Beacons

Dark Web Intelligence

The Cybersecurity Trinity

Overview of NIST CSF

Applying the Cybersecurity Trinity to NIST CSF

Identify

Protect

Detect

Respond

Recover

Govern

Where to Start

Summary

References

Part I

Artificial Intelligence As the Foundation

1. AI Is Everywhere

Artificial intelligence (AI) is everywhere within cybersecurity. Most cybersecurity products today tout the use of AI. We see this in the marketing materials for all major categories of cybersecurity products, including behavior analytics, intrusion detection and prevention systems (IDPS), endpoint detection and response (EDR), antivirus, vulnerability management, and next-generation firewalls (NGFW). These cybersecurity tools rely on AI because it is a powerful tool that can discover hidden patterns and associations, classify discrete objects, and make predictions based on the massive amount of cybersecurity data.

The marketing for these tools makes AI seem like magical fairy dust, as depicted in Figure 1-1. Over the last few years, I met with multiple cybersecurity vendors weekly to vet their products. Nearly every vendor presentation referenced their product's use of AI. According to many cybersecurity product vendors, all we need to do is sprinkle a little of that fairy dust here and a little there, and the next thing we know, our systems will be secure. What could be easier? Of course, AI is not magical fairy dust; it is simply math. Granted, to many people, the

math involved may seem magical. However, it is still simply math, mostly probabilities and statistics.

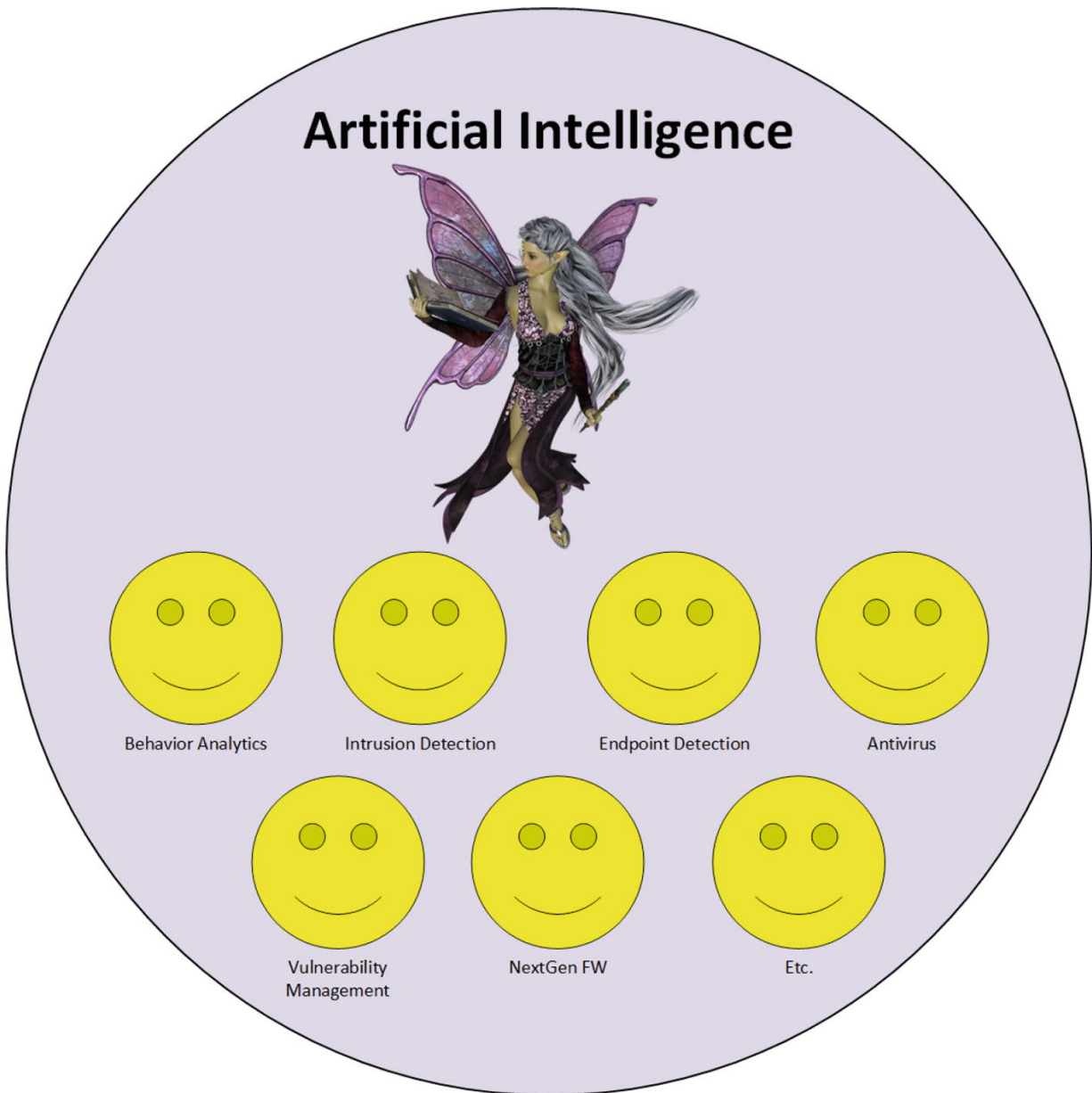


Figure 1-1 The AI Fairy sprinkles magic dust on cybersecurity tools

Unfortunately, I noticed that many of my cybersecurity colleagues do not seem to understand AI and machine learning (ML) concepts. To them, it does seem like magical fairy dust. They believe that AI is the answer to almost every problem and is easy to implement. They fall for the vendor's promises and believe they can simply plug in the

latest AI-powered cybersecurity tool, which will learn their environment and protect them. However, poorly designed AI can have catastrophic effects on cybersecurity. Later, we will explore some of the vulnerabilities related to using AI in an adversarial environment, such as cybersecurity.

Part 1 of this book aims to demystify AI for cybersecurity practitioners so that they can harness the incredible power AI has to offer cybersecurity. Cybersecurity practitioners must understand the concepts, weaknesses, and protection methods for AI data and models. They need this understanding not only to know when and how to use AI for cybersecurity but also to be prepared to protect the AI that is becoming a part of many products across all fields. When I first entered the security field, after many years of developing software, it was accepted that security practitioners needed to understand networking, operating systems, and maybe even some good old application development. From there, we could understand concepts like intrusion detection, malware, data protection, and application security. We better add AI and ML to that basket of essentials for cybersecurity practitioners. Security teams must understand this technology, how it can be used (both in attack and defense), and when to use it. With this understanding, I began my quest to educate my fellow cybersecurity practitioners about the essentials of AI, how we can use it, and how we can ensure its safe and secure use.

AI Use by Industry

Later, we will examine the use of AI in cybersecurity. First, we will explore how this technology is revolutionizing several other fields. According to Bloomberg Intelligence (Singh, Rana, Shum, & Tseng, 2024), the generative AI market will increase to \$1.4 trillion dollars by 2032 (see Figure 1-2), and this is but one form of AI. A survey from

Forbes Advisor (Haan & Watts, 2023) found that 97% of business owners believe their business will benefit from using ChatGPT, and over 60% believe AI will increase productivity within their companies. With this projected growth, AI will have an incredible impact across most industries, forever changing how we conduct business. The impacts of AI on businesses will be profound. We have seen similar technological revolutions in the not-so-distant past, from the desktop computers replacing much manual work to the Internet becoming today's global marketplace. The difference with the current move to AI is that the change is likely to be much more rapid.

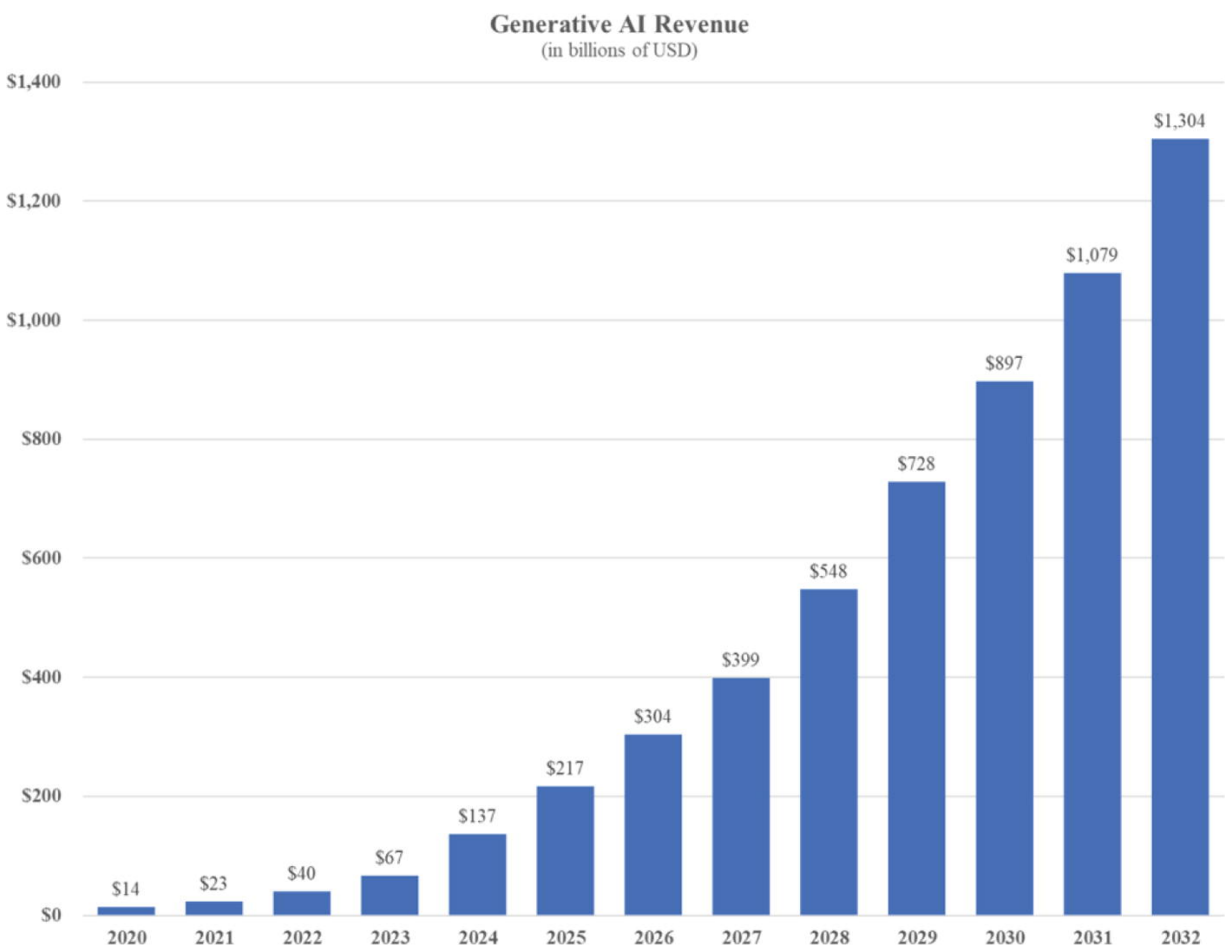
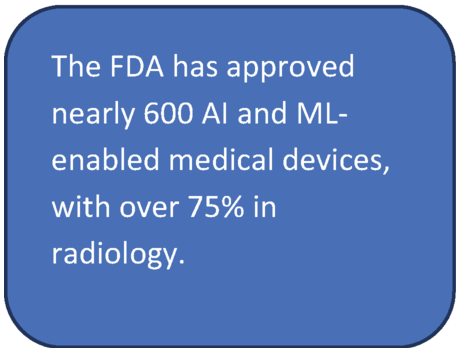


Figure 1-2 Bloomberg Intelligence predicts a \$1.3 trillion generative AI market. <https://www.bloomberg.com/professional/blog/generative-ai-races-toward-1-3-trillion-in-revenue-by-2032>

We are already seeing AI's impact across multiple sectors of the economy. In the following sections, we will see examples of how AI is already improving healthcare, finance, manufacturing, transportation, utilities, and entertainment. It is essential for cybersecurity practitioners to understand how AI is used across various industries, as it will fall on them to protect these systems, many of which power critical infrastructure, such as healthcare, finance, and utilities. During the move to the Web, many organizations did not think about security until after significant incidents. Then, security was often treated as a bolt-on in a reactive effort to address the most recent attack method. After many years of this perpetual game of whack-a-mole, the industry began moving to a security-by-design approach, though much more still needs to be done. We must learn from these past mistakes and ensure that AI-based systems have built-in security that ensures privacy and safety without stifling innovation. Next, we focus on examples of how several industries leverage AI to improve services and increase efficiency.

Healthcare



The FDA has approved nearly 600 AI and ML-enabled medical devices, with over 75% in radiology.

AI will revolutionize the healthcare industry and the way we receive vital healthcare services in the coming years. We see AI making significant contributions to healthcare by enhancing medical diagnosis, accelerating drug discovery, and facilitating the delivery of personalized medicine. As of

August 2023, the US Food and Drug Administration (2023) had approved nearly 700 AI and ML-enabled medical devices, ranging from diagnostic imaging tools to patient monitoring systems, significantly enhancing healthcare delivery and patient outcomes. The FDA projects that the final numbers for 2023 will show an increase in approvals of over 30% compared to 2022.

Medical diagnosis is already realizing significant improvements from the use of AI. The most remarkable application of AI in medical diagnostics has been in medical imaging. The FDA has approved over 500 AI algorithms for the radiology field alone, accounting for over 75% of the AI algorithm approvals in the healthcare industry (US Food and Drug Administration, 2023). AI's ability to process massive amounts of unstructured data makes it a perfect tool to assist in medical imaging. AI models are being used to aid in diagnosing many diseases, such as various forms of cancer, by analyzing medical images.

Discovering and developing new drugs is a lengthy and expensive endeavor. Companies are now using generative AI to speed the process and reduce costs. For example, Insilico used generative AI to discover a drug that could potentially treat idiopathic pulmonary fibrosis (Buntz, 2023). Insilico used generative AI to identify a molecule that could be targeted, generate novel candidate drugs to target the molecule, and estimate how well the candidate drugs would bind with the targeted molecule. What makes this effort noteworthy is that it was the first AI-discovered drug to enter phase 2 studies. The company estimated that traditional drug discovery methods would have taken up to 6 years to develop and reach phase 2 trials. However, by using generative AI, the new drug reached phase 2 trials in 2 years and one-tenth of the cost.

Perhaps one of the areas where AI could have a profound impact is in the field of personalized medicine, which is a critical goal within the healthcare sector. With

personalized medicine, an individual treatment plan is tailored to a patient's unique genetic profile. This emerging field of study will see significant investments in AI-related research and development. AI holds great promise in personalized medicine; however, much research and development remains to realize the benefits.

Financial Services

The financial services industry, where I worked for 20 years, has used AI, especially ML, for many years. Financial service companies use ML to augment and enhance many processes, including fraud detection, risk management, research analysis, credit decisions, and underwriting. As with traditional ML, the financial services industry is expected to be a leader in adopting generative AI. Leading financial services and financial technology companies are embracing generative AI to gain an edge over competitors across virtually all aspects of financial services. Beyond the traditional uses of ML in financing, companies are implementing additional use cases in areas such as algorithmic trading, personalized banking, regulatory compliance, and wealth management.

Mastercard has been among the leaders in using AI to detect fraudulent payment transactions for years. In 2023, Mastercard partnered with nine UK banks to implement a new AI-powered consumer fraud risk tool to detect fraud, especially impersonation fraud, in online payments (Ahmadi, 2023). The AI solution analyzes real-time transactions, including factors such as amount, payee account details, payer account details, and any links between the payee's account and previous scams. The insights allow banks to proactively predict fraud *before* the funds leave the victim's account so the banks can intervene. TSB was among the first UK banks to adopt Mastercard's new solution. Based on its findings, TSB

estimates the tool could prevent 100 million pounds in fraud annually across the UK (Ahmadi, 2023).

Barclays, which handles 40% of UK merchant payments (Colombus, 2020), is also a leader in AI-enabled fraud detection and prevention. Frustration with traditional fraud detection drove Barclays to partner with an AI company to develop Barclays Transact, an AI-enabled system to assist merchants fight fraud. The system's primary goal was to detect and prevent increasingly sophisticated fraud, especially related to ecommerce. Barclays Transact makes real-time updates to the ML to achieve reduced false positives. When false positives occur, legitimate transactions are denied, leading to lost revenue and frustrated customers. The system also aims to reduce the number of manual fraud reviews. In addition, Barclays improved the customer experience for their merchants by reducing the friction merchants experienced with previous fraud systems.

Santander, a multinational Spain-based financial services company, launched an AI-powered service to help clients make investment decisions. OpenBank, the online unit of Santander Group, uses AI to predict price targets for shares listed on the S&P 500 Index and the Stoxx Europe 600 Index (Muñoz, 2024). The service provides the targeted price across four different time horizons - one, three, six, and 12 months. OpenBank is offering this free service to its customers. Each of the shares tracked by the service has a unique ML model. The price targets are determined using predictive ML algorithms that analyze over 2,000 variables, including historical events, trends, and current factors, that could affect the stock price. Santander expects that with the continuing updates, the accuracy of the models will improve over time. When first tested in 2020, the models had an average success rate of 30% (Kollmeyer, 2024). After the service launched in 2024, the average success rate had increased to 56%.

AI is transforming trading within the financial services industry. Algorithmic trading uses AI algorithms to automate trading decisions based on predefined criteria, such as price, timing, and volume. JPMorgan Chase, one of the largest global financial institutions, integrated AI into its trading operations (McDowell, 2021). The company uses AI to optimize trading strategies, mainly through reinforcement learning. For instance, their AI systems analyze market conditions and historical data to learn which previous trades have been successful and which have not. The AI then applies this knowledge to make real-time trading decisions, continuously adjusting its strategy to optimize returns. Using AI, JPMorgan Chase enhanced the precision and speed of its trading, reduced human error, and improved overall profitability. Their AI-driven trading systems can respond to market changes within milliseconds, which would be impossible for human traders to achieve.

Manufacturing

AI is transforming manufacturing by improving nearly all aspects of the manufacturing process. Manufacturers employ AI, including ML and robotics, to automate and optimize manufacturing processes, such as assembly line operations, inventory management, and material handling. Beyond process optimization, ML systems reduce production downtime by enabling predictive maintenance and reduce waste by improving quality control. The impact of ML and robotics on manufacturing will continue to increase rapidly over the coming years, increasing efficiency, reducing costs, and enhancing product quality.

BMW provides an excellent example of leveraging AI in automobile assembly at its factory in Spartanburg, SC, which produces 60% of the BMWs sold in the United States (Day, 2023). BMW's assembly line uses robots to weld approximately 350 studs for the frame of each vehicle. AI

technology then checks each stud for proper placement, instructing the robots to correct any misplaced studs. As the vehicle proceeds down the assembly line, it is photographed by 26 cameras. BMW uses AI to analyze the photos to identify any anomalies and flag them for humans to inspect and correct further. Also, BMW uses scanners worn by the workers to create an AI-developed digital twin of the factory, allowing BMW to visualize how process changes might impact production. BMW can prototype proposed process changes in this digital factory twin, study the impacts, and make adjustments without disrupting production. Using the digital twin, BMW can also quickly test and reject process changes that are not beneficial.

In January 2024, BMW announced that it is testing the use of general-purpose humanoid robots built by Figure, a California-based autonomous robots company (Degeurin, 2024). The robots, which are 5'6" tall, have a human-like structure. The introduction of general-purpose robots is a big step forward from the single-purpose robots used in manufacturing today. BMW will first identify appropriate use cases for the Figure robots. Once use cases are identified, BMW will begin deploying these humanoid robots in its Spartanburg factory. Other auto manufacturers, including Tesla, are also exploring using general-purpose robots to improve production. While these AI-driven improvements enhance efficiency, they also raise questions about the changing nature of manufacturing jobs and the need for workforce reskilling.

Manufacturers also use AI to facilitate predictive maintenance. AI algorithms can provide predictive insights by continuously monitoring equipment performance and analyzing historical data. These insights enable manufacturers to foresee equipment failures and to schedule maintenance proactively. Predictive maintenance averts costly unplanned downtime. In addition, it can increase safety at the factory by ensuring issues are

addressed before they escalate into safety hazards. We can now envision AI monitoring general-purpose humanoid robots to determine when they might fail.

Transportation

AI is having a transformative impact on various aspects of transportation, including autonomous vehicles, traffic management, and logistics optimization. We are at the beginning of an AI revolution in the transportation industry. AI promises increased safety, shorter commute times, and reduced fuel consumption. We are only beginning to see the fulfillment of these promises.

The persistent problem of traffic congestion and seemingly endless gridlock plague many urban areas worldwide. Cities such as Singapore, Mumbai, and LA are experimenting with AI to combat this problem, affecting many people daily. The AI models analyze real-time data from sensors and cameras to predict mass transit or commuter congestion patterns. The data analysis can then make adjustments to the mass transit system or control traffic signal timing to reduce congestion.

Singapore implemented a Smart Nation Initiative, which includes using AI to address mass transit and commuter traffic. Its Fusion AnalyticS for public Transport Event Response (FASTER) system helps manage the urban rail network. FASTER analyzes such factors as crowd sizes on trains and platforms, how many people could not board due to packed trains, and delay durations. Once a disruption in service or congestion is determined, the system provides the operators with visibility and recommended solutions, allowing the operators to make informed decisions. Initially, in 2019, FASTER could predict 40% of such incidents (Miller, 2023). As of 2021, with additional learning and fine-tuning, the system predicted 90%.

Traffic congestion, which frustrates all of us, can also cause life-threatening issues by delaying first responders.

Fortunately, AI systems can control traffic signals to speed up first responders by clearing a path for fire trucks, ambulances, and police. Rancho Cordoba, a suburb of Sacramento, used such a system to speed up the response of fire trucks, reducing the response time by an average of 42 seconds (Netzley, 2023). In a life-or-death situation, those 42 seconds can be crucial.

Delivery companies use AI to improve route optimization significantly. Logistics traditionally relied on manual planning, which can lead to inefficiency and increased costs. Sophisticated AI algorithms can analyze various factors, including delivery points, traffic patterns, road conditions, and fuel consumption. This analysis generates the most efficient route for deliveries, not only minimizing travel time and costs but also reducing carbon emissions, proving advantageous for both businesses and the environment.

For example, UPS employs AI in its logistics operations through the ORION system. ORION uses AI algorithms to optimize delivery routes for UPS drivers, considering factors such as traffic conditions, package size, and delivery time windows. By dynamically adjusting routes based on real-time data, ORION improves delivery efficiency, reduces fuel consumption, and minimizes environmental impact. UPS saves 10 million gallons of fuel annually using the AI-powered route optimization system (Delmigani, 2024). An additional benefit from ORION is a 100,000 metric tonnes per year reduction in the company's carbon footprint.

AI plays a central role in developing and operating autonomous vehicles. AI processes data from sensors, including LiDAR, radar, and cameras, allowing the vehicle to see its surroundings, including traffic and road conditions. AI-powered object recognition can identify and classify other vehicles, traffic signs and signals, pedestrians, cyclists, and many other objects. Based on the

sensing, AI controls the car's acceleration, braking, and turning. AI also helps with route planning, determining the best route by considering traffic, road conditions, and obstacles. It continuously updates its plan based on real-time data.

Despite the promise of self-driving cars, they do come with significant concerns. First and foremost are safety concerns, such as AI systems misinterpreting their surroundings, leading to accidents. Also, AI may struggle with edge cases, such as rare or unpredictable situations that are difficult to anticipate. Autonomous vehicles also raise legal and ethical concerns. For example, the ethical dilemma of whether the car should prioritize the safety of its passengers over others. If the choice is between likely injuring or killing multiple other people or injuring or killing the passengers of the autonomous car, which choice should it make? Furthermore, liability in self-driving car accidents is unclear and will likely play out in courts of law. Finally, there are cybersecurity concerns around the hacking or failure of the AI components.

Utilities

In the changing energy landscape, AI technologies are pivotal in transforming the electric utility sector to be more adaptive, sustainable, and responsive. Efficient smart grid operation requires the analysis of millions of data points, including demand, generation capabilities, location, and weather conditions. AI enables smart grid systems to operate successfully by processing this vast amount of real-time and historical data. Advanced AI systems allow electric utility operators to make informed decisions and optimize energy production and usage. These AI algorithms can predict energy demand and dynamically adjust energy distribution, making smart grids more efficient. Also, AI can reduce downtime and increase resiliency by identifying anomalies in power generation and distribution. Using AI to

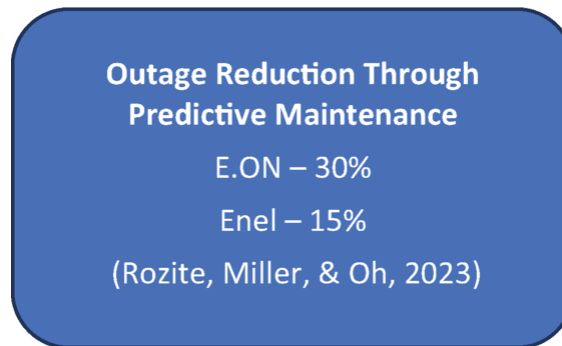
dynamically manage load balancing, detect faults, and analyze grid congestion reduces power outages and enhances resiliency.

One of the energy sector's most common uses for AI has been to improve supply and demand predictions. Demand response is a critical aspect of smart grid energy management. With AI's help, smart grid operators can ensure efficient energy resource allocation by predicting and managing peak demand periods. Advanced AI-powered analytics help balance energy demand and supply, leading to consumer savings and reduced energy waste. In addition, AI-enabled demand response systems encourage consumers to adjust their peak demand period usage.

Tata Power, in India, provides an example of how AI-powered demand response systems can help utility providers address issues with peak demand periods. The company is deploying a demand response system across its commercial and residential consumer base. Tata launched the program in Mumbai, India's largest city. The initial goal set by Tata was to achieve a 75MW reduction in peak capacity within the first six months (AutoGrid, 2023). From there, Tata planned to scale the program to achieve a 200MW reduction in peak demand by the summer of 2025. As Tata continues to achieve positive results with the program, they expect to roll this out to other areas in India.

As in manufacturing, predictive maintenance can improve power generation and distribution resiliency by decreasing unplanned downtime. Predictive maintenance systems analyze historical and real-time data to identify potential power generation and distribution issues. These AI-powered predictive systems allow power systems operators to proactively address these potential issues before they escalate into major problems that disrupt power distribution. By detecting and predicting failures, predictive maintenance facilitates timely maintenance, reduces downtime, and enhances power distribution.

Another advantage of predictive maintenance is that it can increase safety by preventing accidents and mitigating potential hazards.



E.ON, a leading electric utility operator in Europe, developed an ML system to predict when medium-voltage cables within the grid need to be replaced. In addition to analyzing data within the power generation system, the ML model considers external factors such as weather conditions. The model identifies electricity generation patterns and flags anomalies through this detailed analysis. According to the International Energy Agency (IEA), E.ON expects this predictive maintenance could reduce outages by up to 30% (Rozite, Miller, & Oh, 2023). Similarly, Enel, an Italy-based utility company, installed sensors to monitor power line vibration levels. The company used ML to analyze the data, identify potential problems, and determine root causes. Enel's use of ML reduced the outages on the monitored power lines by 15% (Rozite, Miller, & Oh, 2023).

Another way AI is making positive impacts on electric grids is by facilitating the integration of renewable energy sources. Since the wind does not always blow and the sky is not always sunny, renewable energy sources can experience large variability in output. This variability of renewable energy complicates their integration into the power grid. However, AI can help develop a greater understanding of when renewable power is available and

when it is needed. The electric sector uses ML algorithms to predict renewable energy generation patterns, such as solar or wind power. This approach allows electric utility operators to effectively manage intermittent renewable energy sources and balance the power grid.

For example, deviations in winds can drastically impact the output levels of wind power, increasing operational costs. To address this issue, Google developed an AI-based system to increase the forecast accuracy for its renewable wind energy fleet. The AI model can more accurately predict future output up to 36 hours in advance (Rozite, Miller, & Oh, 2023). Due to this increased visibility into the variability of its wind power, Google can sell its power in advance, increasing the value of its wind power.

Consumers can also see direct benefits from AI-enabled smart metering. With smart metering, every outlet and appliance within a home can be monitored. This monitoring provides the homeowner with a comprehensive analysis of their energy usage. This detailed information allows consumers to make informed decisions as they can see the impacts of even minor changes in energy usage. Providing consumers with such granular insights, multiplied across millions of customers, could considerably impact energy conservation.

Cross-Industry Trends

With the integration of AI into so many systems, the impacts on users, consumers, and society will be far-reaching. Therefore, two interrelated topics, AI explainability and AI ethics, have emerged. AI explainability and AI ethics cut across all industries and are crucial considerations in the development and use of AI systems. We must ensure that AI systems uphold society's ethical ideas and that decisions impacting people are understandable.

Explainable AI

Explainable AI (XAI) refers to the effort to make the decision-making processes of artificial intelligence systems understandable for humans. Explainability plays a crucial role in AI systems, allowing human operators to understand the reasoning behind the decisions. Since XAI helps answer *how* and *why* the AI arrives at a decision, it is required to build trustworthy AI systems. Another vital aspect of explainability relates to trust. Even if the AI-based system makes a “correct” decision, if the user cannot understand how the system made the decision, the user may not trust that decision. By fostering trust, explainability can also increase AI adoption. Therefore, the underlying goal of XAI is to allow humans to understand and trust an AI-based system’s output. For example, in a credit scoring model, XAI techniques could provide a breakdown of which factors (such as credit history, income, or debt-to-income ratio) most influenced the decision, making the process more transparent and understandable.

Some ML and AI algorithms are inherently more explainable than others. For example, Bayesian and decision tree classifiers provide excellent traceability to determine how and why decisions are made. More complex algorithms, such as neural networks, support vector machines, and random forests, sacrifice a degree of explainability for increased performance or accuracy. The general-purpose large language models (LLMs), such as ChatGPT, that have become so popular often lack basic explainability. Therefore, practitioners must consider the degree of the algorithm’s inherent explainability and weigh it against the risks. Sometimes, the more powerful, less-inherently-explainable algorithms are the best choice. However, explainability is essential when the AI system makes critical decisions that could significantly impact people. Fortunately, the field of XAI provides tools and

techniques to enhance the explainability of more complex AI systems.

As AI systems become more complex and integrated into critical domains, the need for transparency in decision-making becomes paramount. Transparent AI is crucial, especially in applications where decisions impact individuals' lives, safety, and well-being. For example, AI systems used in medical diagnosis must provide transparency so medical professionals and patients can make informed healthcare decisions. XAI is crucial in auditing high-risk decisions and ensuring regulatory compliance in many industries, including financial services. Such critical decisions should not be left to black-box AI models.

Each AI use case may have differing explainability requirements, often based on the associated risks and legal requirements. For example, a system on a streaming service that recommends shows to viewers might not have explainability requirements. On the other hand, AI systems assisting with cancer diagnosis would have high explainability requirements. Also, the audience could impact the explainability requirements. Consider a product recommendation system. The consumer might not need to understand how or why a particular product was recommended. However, such information might be valuable to the product marketing team. Legal requirements can also dictate explainability requirements, such as laws requiring companies to provide consumers with the reason(s) for credit denial. Therefore, organizations developing or implementing AI solutions must ensure proper governance is in place when explainability is important. Teams must assess each AI use case to determine if the appropriate explainability tools and processes are in place.

AI Ethics

The AI ethics field of study focuses on ensuring that AI systems are developed, deployed, and used in ways that align with ethical principles. The goal is to build AI systems that address bias, privacy, accountability, and social impact. Organizations that develop or use AI systems must consider and mitigate the ethical risks. The first step is clearly defining the ethical standard by which the organization will view AI solutions. All AI uses can then be evaluated through this ethical lens. If current AI uses do not align with the defined standard, the organization must identify the gaps, determine the risks, and develop remediation plans.

Bias and Discrimination

An area of increasing concern related to AI ethics is bias or discrimination in the outcomes of AI models. As an example, in 2023, the Equal Employment Opportunity Commission (EEOC) settled a suit with iTutorGroup regarding alleged discrimination in the company's hiring practice (EEOC, 2023). This case marked the first time the EEOC secured a settlement related to workplace AI. The company hired US-based tutors to provide English-language tutoring to Chinese students. The company used AI to screen job applicants. According to the complaint, the AI screening rejected over 200 qualified applicants based on age, violating the Age Discrimination in Employment Act. After being rejected, one applicant resubmitted for the job with a later birth date and received an interview offer. In the settlement, the company denied wrongdoing but agreed to pay \$365,000 to applicants allegedly wrongfully rejected.

Fairness is one of the core AI privacy principles of the Open Worldwide Application Security Project (OWASP) (OWASP, 2024). ML models are trained with historical data, which can include previous biases, including institutional bias. Algorithms that make critical decisions

that could impact individuals must be assessed to ensure the data used does not create biased or discriminatory results. XAI can help discover some issues related to AI ethics. Consider an ML model that evaluates credit applications. If the ML model is a black box, the operator will have no insight into how the ML model made its decision. Without understanding the data and the decisions, the organization risks discrimination in its lending practices. The team could apply explainability techniques throughout the ML process to mitigate this risk. Pre-modeling XAI tools that assist with the initial data preparation could ensure that the data used to train the model is appropriate and understood. Using explainable modeling techniques, the team could build explainability and interpretability into the AI system's architecture. Finally, XAI tools and techniques can produce explanations during production, such as the reasons for credit denial.

Developing fair AI systems and mitigating bias requires a concerted effort throughout the AI lifecycle. Teams must perform bias assessments and apply detection and mitigation techniques to ensure discriminatory outcomes are not perpetuated or amplified. Detailed training data analysis to identify potential historical and systemic discrimination is of utmost importance. Often, the bias is embedded in the historical data, and it must be rooted out to avoid continuing systemic discriminatory results. In addition to an initial assessment, companies must implement a process of regular audits and reviews to ensure the system continues to produce ethical results.

Privacy

Whereas concerns about AI discrimination and bias focus on the use of the data, AI privacy centers on the collection, processing, and storage of the data. The same privacy risks associated with traditional IT systems apply to AI, but the amount of data and decreased transparency amplify these

risks. Since AI systems often rely on enormous amounts of personal data, privacy concerns have emerged as a significant issue facing the AI industry. The information used to train ML models can include vast amounts of personal data, such as addresses, financial information, medical records, identification numbers, activities, locations, and life patterns. Such a trove of data raises concerns about data breaches and unauthorized data access, in addition to bias and discrimination concerns related to the inappropriate use of the data.

Another privacy-related concern is the use of AI in surveillance and monitoring. AI-enabled surveillance and monitoring drastically increase invasiveness. These systems can perform previously impossible levels of tracking, including social media activity, physical location history, life patterns, and facial expressions. Avoiding systemic digital surveillance when using online services is already extremely difficult, and AI will amplify these concerns. Therefore, privacy is a fundamental principle of responsible AI.

Many regulations and standards dictate privacy principles and requirements, including the General Data Protection Regulation (GDPR), the International Organization for Standardization (ISO), the National Institute of Standards and Technology (NIST), and the Federal Information Processing Standards (FIPS). OWASP provides guidance on applying privacy principles to AI systems.

Addressing privacy-related concerns with AI must start with data collection and preparation. The OWASP principles contain data collection and processing guidance, including limiting the data's purpose, scope, and storage (OWASP, 2024). Data not necessary to the fundamental question the AI system is attempting to answer should be discarded, or even better, not collected. Using the previous discrimination example regarding iTutorGroup, since age

should not have been considered in the applicant screening process, there was no reason for the company to collect and use this data in the AI model. Also, data collected for one purpose should not be used for alternate purposes.

Italy Fines Deliveroo 2.5m Euro

Garante, the Italian supervisory authority, fined Deliveroo, a food delivery company, 2.5 million Euros for GDPR violations stemming from Deliveroo's driver management algorithms (Allen & Overy, 2021). The company violated several principles related to the storage of personal information, including data minimization and transparency. The company used the collected data in an automated system to rate the drivers and assign work. The ruling cited that Deliveroo was not sufficiently transparent with the drivers about the algorithm's use in assigning orders and booking shifts.

AI systems that collect or use personal information must prioritize protecting individual privacy. Such privacy preservation requires a privacy-by-design approach that considers all aspects of the AI lifecycle. Adhering to the principle of privacy by design requires, at a minimum, that

- Access to sensitive data is restricted, controlled, and monitored.
- The storage duration of any personal data should be defined and limited.
- Delete personal data when it has served its use.
- When possible, the data should be anonymized, such as when creating aggregate analytics.
- Obtain user consent for the collection and use of data.
- Ensure transparency regarding the collection and use of personal data.

- Manage privacy risks throughout the AI lifecycle by including privacy risk assessments, which drive targeted mitigations.
- Consider and comply with all applicable regulatory privacy requirements, such as the GDPR and the California Consumer Privacy Act (CCPA).

Environmental Impact

AI offers transformative benefits across numerous sectors. However, the environmental impact of AI also raises significant concerns. The environmental impact of AI is multifaceted, encompassing energy consumption, resource depletion, and electronic waste generation. The training and operation of AI models, especially deep learning models, require substantial power, consuming vast amounts of electricity and producing a significant carbon footprint. The trend toward more extensive and complex models requiring even more computational resources exacerbates this issue. Producing hardware needed for AI, such as graphics processing units (GPUs) and specialized chips, involves extracting rare earth elements and other minerals. This extraction process can destroy habitats, pollute water, and cause significant environmental degradation. Furthermore, the rapid advancement in AI technologies leads to frequent hardware upgrades, leading to more resource depletion and contributing to the growing problem of electronic waste.

As AI continues to evolve, it is crucial to balance technological advancement with sustainable practices to mitigate these impacts. There is a growing movement within the AI community to develop *green AI*, which focuses on creating models that are not only effective but also energy-efficient. Green AI research focuses on optimizing algorithms to require less computational power, using renewable energy sources for data centers, and

advancing techniques like model distillation, which reduce the size and complexity of models without sacrificing performance.

AI also has a multifaceted positive impact on the environment. AI is playing a significant role in addressing environmental challenges across various sectors. In previous sections, we saw how AI is transforming the management of utilities, increasing efficiencies, and effectively integrating alternative energies into the electric grid. Also, as discussed in the section on transportation, AI can create more efficient routes and increase traffic efficiency, reducing fuel consumption and emissions. Other ways that AI can have a positive environmental impact include

- **Energy efficiency:** AI optimizes energy distribution in smart grids by predicting demand, managing loads, and integrating renewable energy sources like solar and wind, leading to more efficient energy use and reduced wastage. Also, AI is used in building management systems to optimize heating, cooling, lighting, and other systems, reducing energy consumption and lowering carbon footprints.
- **Climate modeling:** By analyzing vast amounts of data from sensors, satellites, and historical records, AI improves the accuracy of climate predictions. AI models can help predict extreme weather events, understand climate patterns, and develop mitigation strategies.
- **Wildlife conservation:** AI-powered drones, camera traps, and acoustic sensors monitor wildlife populations, track endangered species, and detect illegal poaching activities. AI helps map and monitor habitats, identify at-risk areas, and recommend protective measures. AI algorithms analyze the collected data to provide insights for conservation efforts.

- Sustainable agriculture: AI-driven tools analyze data from soil sensors, weather forecasts, and satellite images to optimize irrigation, fertilization, and pesticide use, leading to higher crop yields while minimizing environmental impact.

The European Union AI Act

The European Union (EU) AI Act is a groundbreaking legislation that went into effect in August 2024, with varying timelines for compliance and enforcement (European Parliament, 2024). In drafting the AI Act, the EU sought to balance regulation with innovation. Like the GDPR, the AI Act has extraterritorial reach, as it applies not only to systems used within the EU but also to any systems that might impact EU citizens. Therefore, the AI Act will have far-reaching implications throughout the AI industry. Also, like the GDPR, it will likely serve as a model for other jurisdictions seeking to enact AI legislation.

The AI Act classifies AI uses based on the risk of harm to citizens and society. It includes four classifications: unacceptable, high risk, limited risk, and minimal risk. It also includes special requirements for general use and large-scale systems, such as general-purpose large language models. The AI Act notably exempts military AI use. Each category of AI systems has unique compliance requirements for the producer, the company creating the system, and the deployer, the company using the system. Much further detail will come as the respective governing bodies draft specific plans for the compliance, governance, and enforcement of the provisions.

The unacceptable category includes uses that the EU deems carry an extreme risk to individuals or society. Such uses of AI are not permitted under the AI Act, and they carry significant penalties for any violations, up to 35 million Euros or 7% of global annual turnover. The unacceptable uses include social credit scoring, emotional

recognition in the workplace and education, exploitation of people's vulnerabilities, behavioral manipulation, untargeted scraping of facial images for recognition, biometric categorization, specific predictive policing practices, and real-time law enforcement biometric identification in public places (except in limited pre-authorized situations).

Much of the legislation focuses on high-risk AI systems. The high-risk uses include medical devices, vehicles, recruitment and management of workers, education and vocational training, influencing elections and voters, access to critical services (such as insurance, banking, credit, and benefits), critical infrastructure management, emotion recognition systems, biometric identification, law enforcement, border control, administration of justice, and safety components of specific products. Penalties for violating the provisions of high-risk systems are up to 15 million Euro or 3% of global annual turnover. The use of high-risk systems carries significant requirements, including a fundamental rights impact assessment, conformity assessment, registration in a public EU database, implementation of risk and quality management systems, data governance, human oversight, accuracy, robustness, and cybersecurity.

Limited-risk AI systems include deep fakes and chatbots. The requirements for these systems focus on transparency. People engaging with AI chatbots must be informed, and deep fakes must be clearly labeled. Systems not falling into the unacceptable, high-risk, or limited-risk categories are considered minimal or no risk. These uses are not subject to AI Act compliance.

Aside from the specified AI categories, there are requirements for general-purpose AI (GPAI) and foundational models. These systems have transparency requirements, including technical documentation, training data summaries, and copyright and IP safeguards.

Additionally, GPAI systems with systemic risk have additional requirements, including model evaluations, risk assessments, adversarial testing, and incident reporting. For generative AI systems, individuals must be informed when engaging with them. Also, AI content must be labeled and detectable.

Summary

AI has significantly impacted many industries, including healthcare, financial services, manufacturing, and utilities. However, the current uses of AI pale in comparison to what is to come. Much like we saw with the introduction of desktop computers and then the move to the World Wide Web, the AI revolution will bring disruptive capabilities. As with these prior technological advancements, it is difficult to conceive of many industries that will not see profound disruption due to AI. However, a significant difference between these prior technological advancements and AI is perhaps the speed of change.

The rapid adoption of AI across most industries necessitates cybersecurity professionals to understand this technology. It will fall upon cybersecurity professionals to ensure that AI systems are built and deployed securely. Beyond security, ethical issues, including bias and privacy, must be addressed throughout the AI lifecycle to develop safe systems that prevent harm to individuals and society. We must remember, though, that there is no magic fairy guiding AI. It is simply math. The next chapter will provide an overview of AI and ML, including some of the most frequently used algorithms. As Chapter 1 comes to a close, I leave you with a few questions to consider:

1. How will the use of AI affect your day-to-day life?

2. Consider an industry, perhaps the one in which you work or plan to work.
 - a. How has AI impacted that industry?
 - b. How might AI impact the industry in the next 5-10 years?
 3. What industry do you believe might be minimally impacted by AI? Why?
 4. What are the most critical ethical concerns your industry faces when implementing AI solutions?
-

References

Ahmadi, S. (2023). Open AI and its impact on fraud detection in financial industry. *Journal of Knowledge Learning and Science Technology*, 2(3), 263-281. doi: <https://doi.org/10.60087/jklst.vol2.n3.p281>

Allen & Overy. (2021). *Italian data protection supervisory authority fines two food delivery companies for non-compliant algorithmic processing*. Retrieved from jdsupra.com:

<https://www.jdsupra.com/legalnews/italian-data-protection-supervisory-7726507/>

AutoGrid. (2023). *Tata Power and AutoGrid expand AI-enabled smart energy management in Mumbai, supporting India's net zero goals*. Retrieved from PR Newswire:

<https://www.prnewswire.com/news-releases/tata-power-and-autogrid-expand-ai-enabled-smart-energy-management-in-mumbai-supporting-indias-net-zero-goals-301735759.html>

Buntz, B. (2023). *A year in review: AI's evolving role in drug discovery and development in 2023*. Retrieved from Drug Discovery & Development:

<https://www.drugdiscoverytrends.com/ai-drug-discovery-2023-trends/>

Colombus, L. (2020). *How Barclays is preventing fraud with AI*. Retrieved from Forbes:

<https://www.forbes.com/sites/louiscolumbus/2020/06/11/how-barclays-is-preventing-fraud-with-ai/?sh=3a3a052b73b1>

Day, A. (2023). *How BMW uses AI to make vehicle assembly more efficient*. Retrieved from CNBC:

<https://www.cnbc.com/2023/07/21/how-bmw-uses-ai-to-make-vehicle-assembly-more-efficient.html>

Degeurin, M. (2024). *BMW plans to put humanoid robots in a South Carolina factory to do... something*.

Retrieved from Popular Science:

<https://www.popsci.com/technology/bmw-humanoid-robot/>

Delmigani, C. (2024). *To 10 sustainability case studies & success stories in 2024*. Retrieved from AI Multiple Research:

<https://research.aimultiple.com/sustainability-case-studies/>

EEOC. (2023). *iTutorGroup to pay \$365,000 to settle EEOC discriminatory hiring suit*. Retrieved from US EEOC:

<https://www.eeoc.gov/newsroom/itutorgroup-pay-365000-settle-eeoc-discriminatory-hiring-suit>

European Parliament. (2024). Regulation (EU) 2024/1689 of the European Parliament and of the Council of 12 July 2024 on laying down harmonized rules on artificial intelligence (Artificial Intelligence Act) and amending certain union legislative acts. Office for Official Publications of the European Communities

Haan, K., & Watts, R. (2023). *How Businesses Are Using Artificial Intelligence In 2024*. Retrieved from Forbes Advisor:

<https://www.forbes.com/advisor/business/software/ai-in-business/>

Kollmeyer, B. (2024). *This bank is using AI to work out S&P stock price targets for its millions of customers*.

Retrieved from MarketWatch:

<https://www.marketwatch.com/story/this-bank-is-putting-ai-to-work-s-p-stock-price-targets-for-its-millions-of-customers-89030c01>

McDowell, H. (2021). Machine learning futures algo trading surges at JP Morgan.

<https://www.thetradenews.com/machine-learning-futures-algo-trading-surges-at-jp-morgan/>

Miller, S. M. (2023). *Singapore's AI applications in the public sector: Six examples*. Retrieved from Management and Business Review:

<https://mbrjournal.com/2023/07/25/singapores-ai-applications-in-the-public-sector-six-examples/>

Muñoz, M. (2024). *Santander online bank to offer AI-based price targets for stocks*. Retrieved from BNN Bloomberg: <https://www.bnnbloomberg.ca/santander-online-bank-to-offer-ai-based-price-targets-for-stocks-1.2040284>

Netzley, L. (2023). *Artificial Intelligence used to reduce traffic congestion*. Retrieved from DT News - Downtown Los Angeles:

https://www.ladowntownnews.com/news/artificial-intelligence-used-to-reduce-traffic-congestion/article_4b0f0330-bc4e-11ed-8645-ff3ebc17f82e.html

OWASP. (2024). *OWASP AI security and privacy guide*. Retrieved from OWASP: <https://owasp.org/www->

[project-ai-security-and-privacy-guide/](#)

Rozite, V., Miller, J., & Oh, S. (2023). *Why AI and energy are the new power couple*. Retrieved from IEA:

<https://www.iea.org/commentaries/why-ai-and-energy-are-the-new-power-couple>

Singh, M., Rana, A., Shum, C., & Tseng, S. (2024). *Generative AI races toward \$1.3 trillion in revenue by 2032*. Retrieved from Bloomberg Professional Services:

<https://www.bloomberg.com/professional/blog/generative-ai-races-toward-1-3-trillion-in-revenue-by-2032/#:~:text=This%20analysis%20is%20by%20Bloomberg,first%20on%20the%20Bloomberg%20Terminal>.

US Food & Drug Administration. (2023). *Artificial Intelligence and Machine Learning (AI/ML)-Enabled Medical Devices*. Retrieved from U.S. Food & Drug Administration: <https://www.fda.gov/medical-devices/software-medical-device-samd/artificial-intelligence-and-machine-learning-aiml-enabled-medical-devices>

2. Overview of AI and ML

As seen in other industries, ML is widely used within cybersecurity, as evidenced by all the products touting ML and AI. The power of ML to analyze large amounts of data efficiently, accurately, and quickly ensures that the use of ML in cybersecurity will continue to expand rapidly. This chapter will provide a high-level understanding of ML for cybersecurity practitioners. It is not intended to teach the details of machine learning or to make the reader a data scientist. The goal is to help demystify ML so that security professionals can harness the great potential of ML within the cybersecurity domain. Also, with this understanding, security professionals will be better prepared to ensure that AI and ML systems are built and deployed safely and securely across all industries. This chapter is not designed to provide in-depth knowledge of ML or delve into the underlying mathematics. However, it might inspire cybersecurity professionals to explore ML further. After all, cybersecurity practitioners are extremely inquisitive.

First, it is necessary to have a common understanding of some of the key terms related to AI. The terms AI and ML are often used interchangeably; however, ML is a subset of AI. ML applies algorithms to data to generalize from examples, thereby teaching machines to discover or

acquire knowledge and make decisions. Deep learning is a further subset of ML that uses artificial neural networks. As shown in Figure 2-1, many other fields of study exist within AI, including expert systems, fuzzy logic, and robotics. It is also important to note that generative AI, which has taken the world by storm since the launch of ChatGPT, is a form of machine learning. There is no magic there, only math. Within this book, we will focus on machine learning, including traditional ML, deep learning, and generative AI.

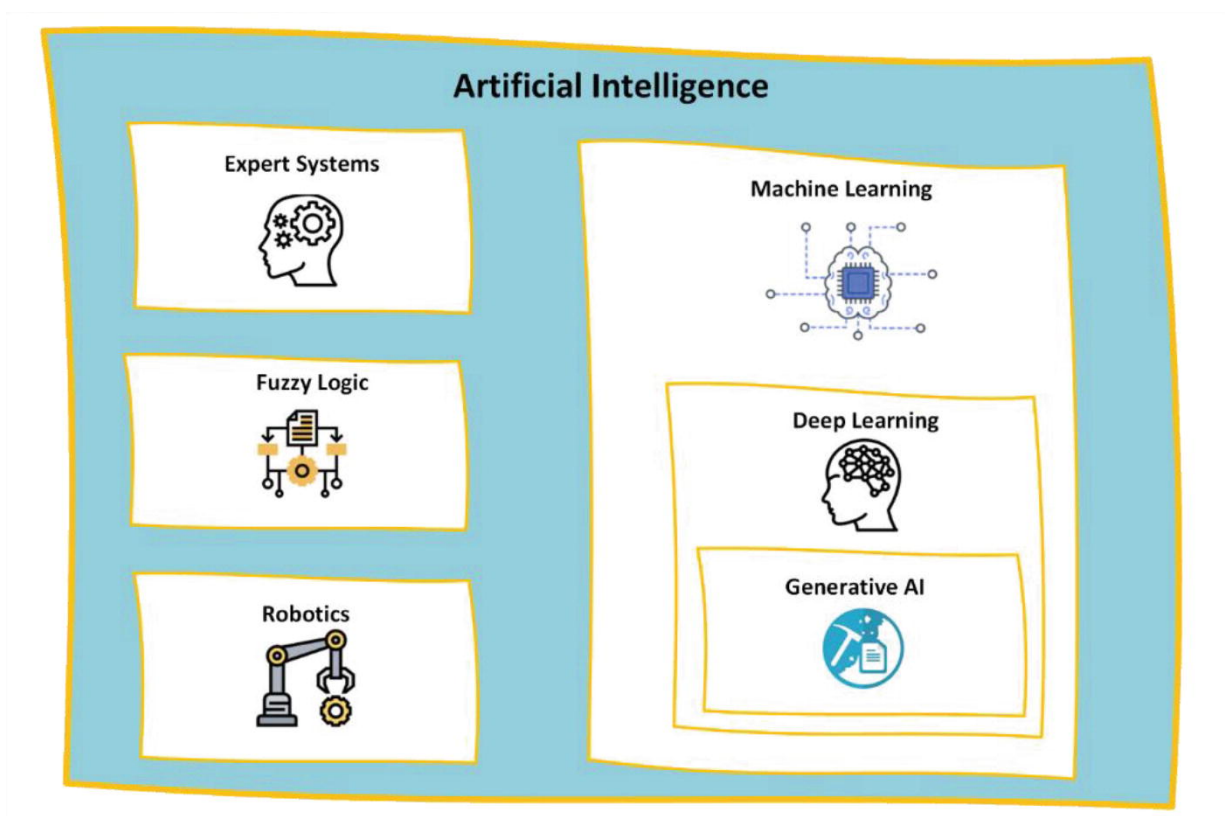


Figure 2-1 AI includes many fields of study (some of which are shown here)

Many analogies compare ML to human thinking; however, ML does not operate like human brains. Instead, ML is based on math, especially statistics. One aspect in which human learning and machine learning are similar is that they seek to generalize. By generalizing, ML models can recognize patterns in data, classify or categorize,

forecast based on past data, and detect outliers. Because of its capabilities, ML has many applications, including

- Detecting anomalies that might be indicative of a cyberattack
- Recommending items to customers based on previous purchases
- Categorizing cell samples into types of cancer
- Dynamically setting prices based on fluctuations in supply and demand
- Segmenting customers to produce targeted marketing

Machine learning traces its roots back to the 1950s. Intense academic research focused on ML, especially on neural networks, during the 1970s and 1980s, when many of the algorithms that are in use today were first developed. However, insufficient processing power and data led to a period known as the Neural Winter, which lasted from the late 1990s until about 2007. New technology, including powerful graphics processing units (GPUs) and the advent of big data, powered a resurgence of ML research and practical application.

Over the last few years, generative AI, a subset of machine learning, has gained much attention. Large language models (LLM) and apps such as ChatGPT have exploded onto the scene, capturing the public's attention with fascinating capabilities. However, it is important to understand that these LLMs are based on statistics, just like more traditional forms of machine learning.

ML methods can empower systems to improve without the tedious explicit programming that rules-based systems require. Once ML models are developed, they can recognize patterns in data (pattern recognition), classify input (generalization), forecast based on known data (regression), and detect outliers (anomaly detection). There are many ways to classify ML. Perhaps the most common is in terms of the learning approach. These techniques are

broadly classified as supervised, semi-supervised, unsupervised, or reinforcement learning.

Supervised Learning

Supervised learning, also known as predictive learning, has a target variable, and the ML model learns to predict or classify the value of the target variable based on features within the data. Such learning requires that the data be labeled, or in other words, that the dependent variable is present. Such as transactions marked as fraudulent or valid or cancer images marked as malignant or benign. After learning, the ML model can apply these labels to new observations. Supervised methods can further be broken down into classification algorithms and predictive algorithms.

Classification Algorithms

Classification ML models learn to predict a categorical response. The result of classification is a categorical value or label. These algorithms can classify samples among distinct groups, such as malicious or benign, fraudulent or valid, advanced persistent threat (APT) groups, or types of dogs (see Figure 2-2). Numerous supervised learning algorithms are used for classification. Among the most popular are decision trees, random forests, support vector machines (SVM), naïve Bayes, and k-nearest neighbors (kNN).

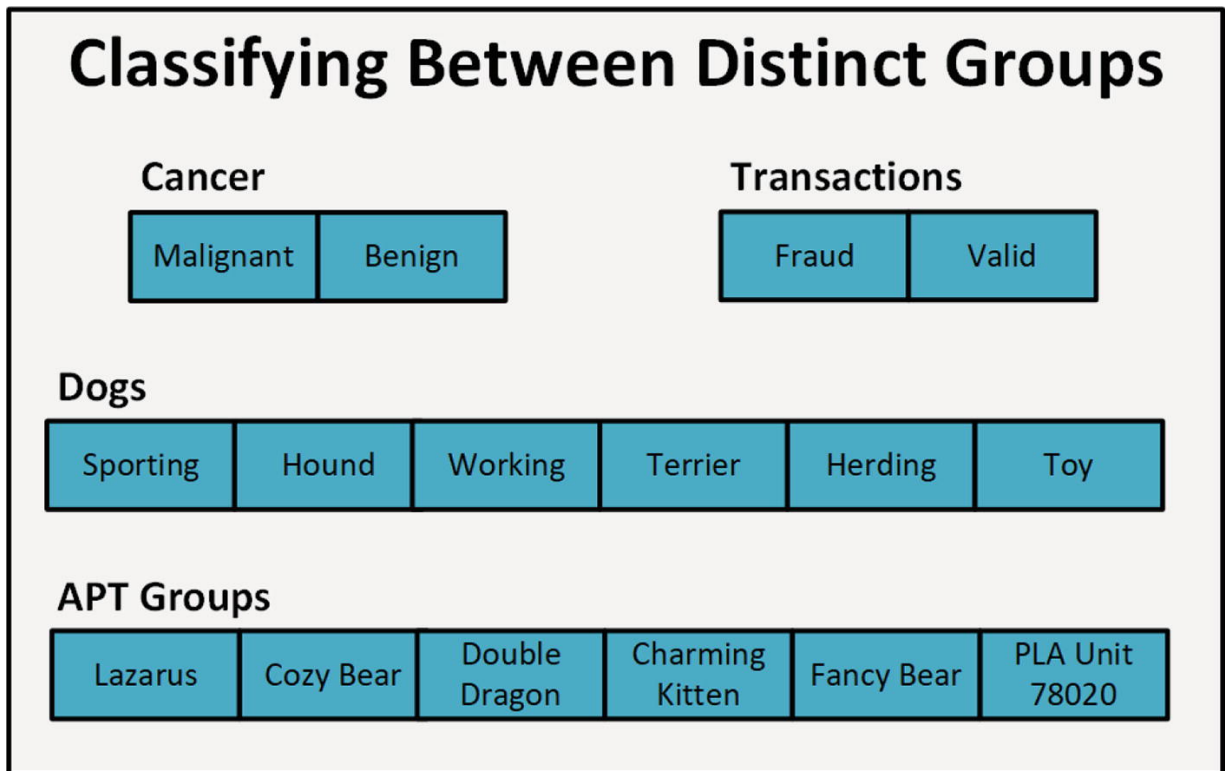


Figure 2-2 Supervised learning can classify between distinct groups

Decision Tree

Decision trees are tree-structured, rule-based classification models. The features are organized as nodes on the tree to optimally split all data into the classes (represented by the leaves on the tree). A decision tree starts with a single root node, which is progressively partitioned into smaller sets as the tree branches and grows. A decision tree consists of decision nodes, branches, and leaf nodes. The decision nodes split the data into branches, which leads to further decision nodes. This process continues until it reaches a leaf node representing the predicted outcome. Figure 2-3 depicts a decision tree for product recommendations. The decision tree considers the style, past purchases, and color to recommend a product. In this example, *style* is chosen as the root node.

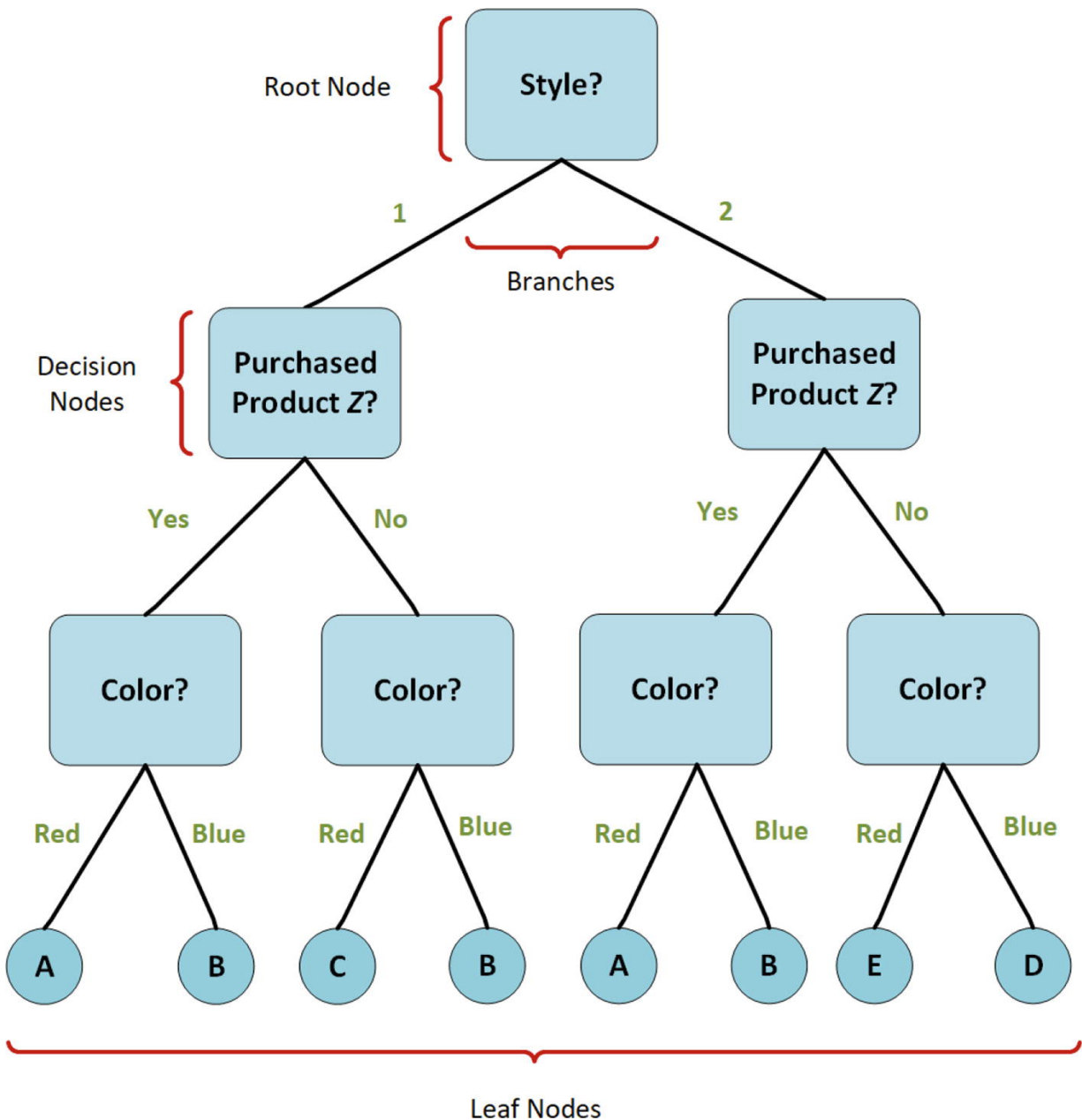


Figure 2-3 A decision tree consists of a root node, decision nodes, branches, and leaf nodes

When constructing a decision tree, the selection of the root node and the order of the decision nodes can impact the tree structure (but not the result). Figure 2-4 shows the same product recommendation problem but with a different root node. This decision tree generates the same results. However, notice that once it is determined that the customer purchased *Product Z* and we know the *color*, the

style is irrelevant. Therefore, we say that, in this case, *style* has no analytic value.

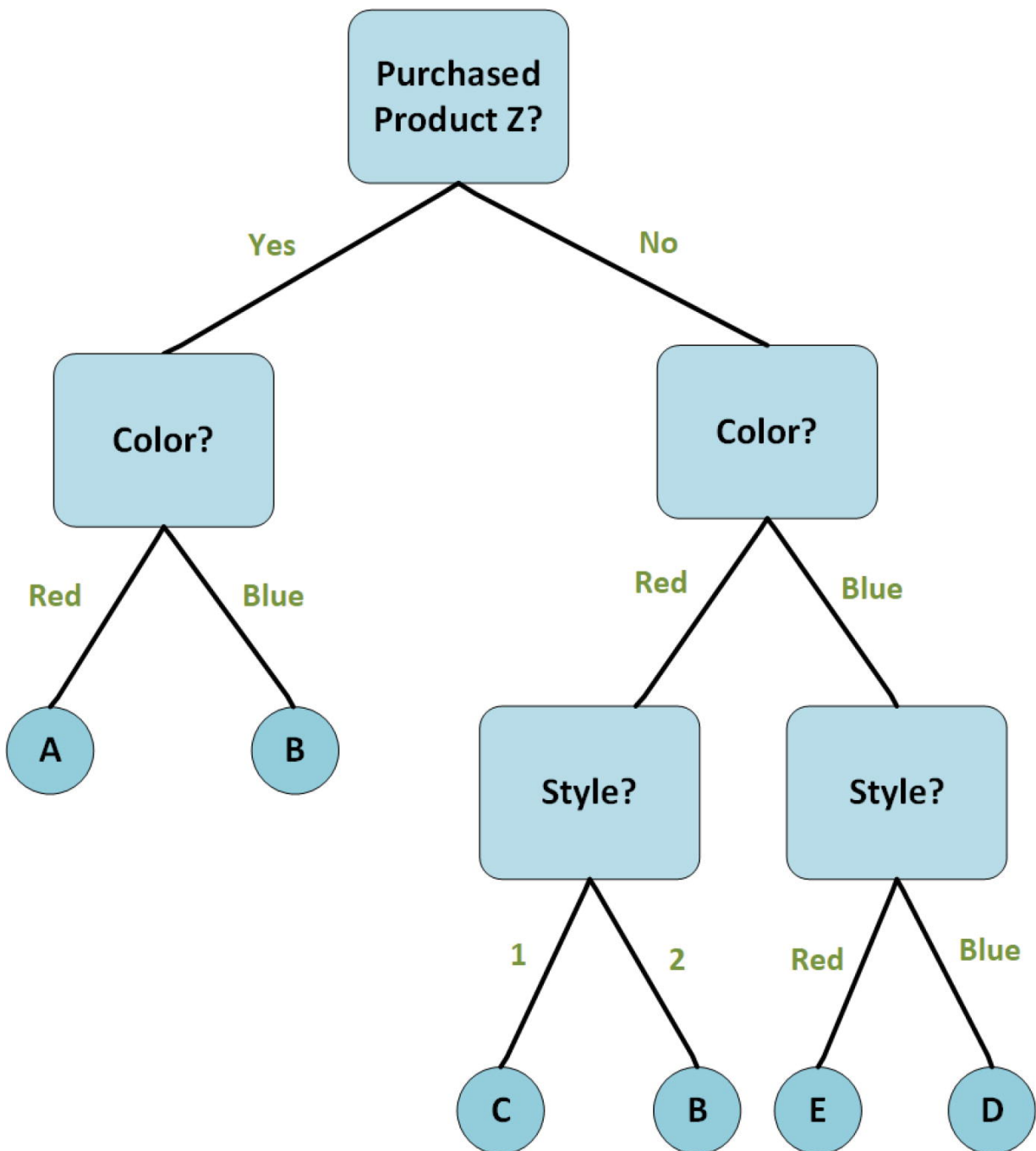


Figure 2-4 Changing the root node can impact the decision tree structure

Figure 2-4 shows a simple example to illustrate a decision tree and how the order of decisions can impact the tree structure. When there are many attributes to consider,

a decision tree can become quite complex, making it difficult to determine the optimal structure. Decision tree algorithms analyze the various attributes to determine the optimal decision tree. The algorithm uses recursive partitioning to identify which feature is most predictive and which will serve as the root node. By evaluating the features, the algorithm determines the root node that results in partitions that primarily contain instances of a single class. Each of the resulting partitions is then recursively partitioned using the same process. In addition to determining which features to split on, the algorithm also determines the best values for the split.

The decision tree can be pruned to avoid overfitting the training data or creating a decision tree that is too complex. Pruning can be done during the recursive partitioning. Such pruning can include defining the criteria, such as the maximum number of features considered or the maximum number of decision nodes. Instead of pre-pruning, pruning can also be done after the decision tree has grown to its full extent. Such post-pruning requires more computing resources than pre-pruning; however, it can also discover important patterns that might be removed with pre-pruning.

A decision tree algorithm is relatively easy to implement and explain. In addition, decision trees can provide accurate results when applied to discrete or continuous features. Due to its ease of implementation and accuracy, decision trees are quite popular. However, there is a significant downside to decision trees. When numerous attributes must be analyzed, the computational complexity of a decision tree increases rapidly. The examples above only considered three levels of decision (the root node and two levels of decision nodes). Adding additional decision nodes can have an exponential impact on the decision tree. When decision trees grow large, in addition to the

increased computation, they can become difficult to interpret.

Random Forest

Random forest is an example of an ensemble training method, meaning it employs multiple algorithms. A random forest typically consists of multiple decision tree classifiers executed in parallel. Each of these decision tree trees can analyze different attributes. Consider a situation where 100 attributes must be analyzed. This analysis would result in an extremely large decision tree, which would be computationally complex. Instead, the analysis could be distributed among multiple decision trees, perhaps five.

With a random forest, each decision tree analyzes a subset of the attributes. The decision trees pass along their results to the random forest voting function. The voting function analyzes the results of each independent decision tree and determines the result. Depending on the data type of the result, the voting function could determine the result either by majority vote for categorical data or averaging for numerical data. Figure 2-5 depicts using a random forest of three decision trees to determine if a file is benign or malicious.

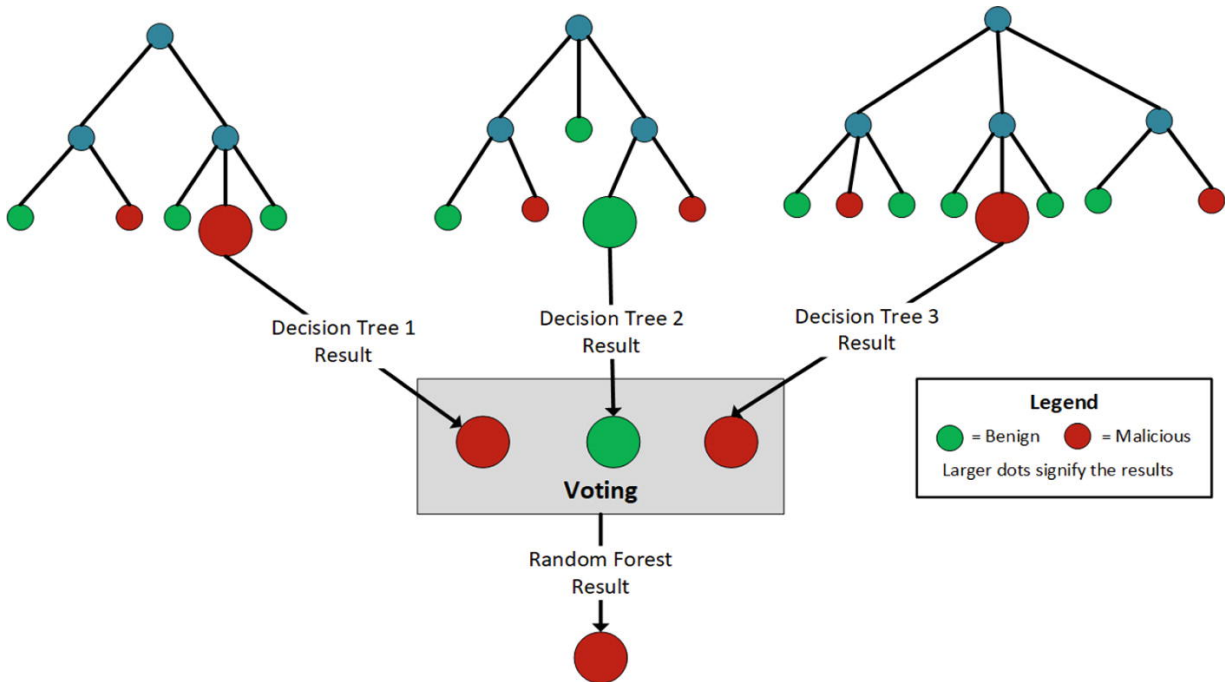


Figure 2-5 Depiction of voting within a random forest

Of course, this example is quite simple and could probably be solved with a single decision tree. However, consider again the problem with 100 features. A single decision tree would become very complex. However, a random forest could be used where each decision tree considers a subset of features. With a random forest, the number of decision trees can be specified. For example, many implementations use a default of 100 or 500 trees, but this can vary depending on the specific library or tool being used. In addition, the number of features to consider for each split can also be defined, which is typically the square root of the total number of features. Limiting the considered features for each split ensures that each feature can appear in several of the decision trees while ensuring substantive randomness from tree to tree.

Naïve Bayes

A naïve Bayes classifier is based on a theorem from Thomas Bayes, an 18th-century mathematician. The basis of the naïve Bayes algorithm is that the probability of future

events can be estimated by examining the probability of prior events. A Bayesian classifier determines the most likely class an instance belongs to based on prior evidence using conditional probability. Bayes' theorem can be written as follows:

$$P(A | B) = \frac{P(A) P(B | A)}{P(B)}$$

The first part of the equation, $P(A|B)$, is the conditional probability, which is read as the probability of A given B . With conditional probability, the probability of one event occurring is conditioned on the probability of another event having occurred. For example, the probability that an email that includes the word “free” is a phishing email can be written as $P(\text{phish}|\text{free})$, which is read as the probability of the email being phishing, given that the email contains the word “free.” The next part, $P(A)$, is simply the probability of an email being a phishing email based on prior messages. In other words, it is the percentage of prior emails that were phishing emails. The $P(B|A)$ represents the likelihood of B given A . In this example, this component would be $P(\text{free}|\text{phish})$, which is the probability that the word “free” was present in any prior phishing emails. The final part, $P(B)$, is the probability of B occurring. In the example, this would be the probability that the word “free” occurred in *any* email, regardless of whether the email was a phishing email or not. Now, we can rewrite the equation to determine the probability that an email containing the word “free” is a phishing email.

$$P(\text{phish} | \text{free}) = \frac{P(\text{phish}) P(\text{free} | \text{phish})}{P(\text{free})}$$

For example, let's solve this equation using the following assumptions:

- 10% of all prior emails were phishing emails, $P(\text{phish}) = 0.1$.
- The word "free" appeared in 20% of all prior emails. $P(\text{free}) = 0.2$.
- The word "free" appeared in 90% of all prior phishing emails. $P(\text{free}|\text{phish}) = 0.9$.

We can now compute the likelihood that an email containing the word "free" is a phishing email.

$$P(\text{phish} | \text{free}) = \frac{P(\text{phish}) P(\text{free} | \text{phish})}{P(\text{free})} = \frac{0.1 \times 0.9}{0.2} = 0.45$$

Based on the above assumptions, there is a 45% chance that an email containing the word "free" is a phishing email. Therefore, we probably should not click on any links in that email. The email is 4.5 times more likely to be a phish compared to all emails (45% likelihood versus a 10% likelihood).

With only one feature, in this case, the appearance of "free" in the email, computing the probability is straightforward. However, this approach becomes unwieldy when considering numerous features. Applying Bayes' theorem would require the computation of the product of probability for each feature conditioned on every other feature considered. The naïve Bayes algorithm alleviates this complexity by assuming that all the features are independent and equally important. Thus, the name naïve Bayes. Based on this assumption, in the phishing email example, the probability of the word "free" occurring in a phishing email is considered independent of the probability of "hurry" occurring in a phishing email.

The assumption that each feature contributes independently to the probability and is of equal importance

is rarely true. However, the naïve Bayes algorithm performs fairly well even when these underlying assumptions are violated. Naïve Bayes' accuracy and versatility across many applications make it a solid baseline algorithm for classification, especially with smaller training datasets.

k-Nearest Neighbors

The k -nearest neighbors (k -NN) algorithm is considered a lazy learner since it does not build a model. Since no model is the result, k -NN is technically not an ML method since nothing is learned. Lazy learners, such as k -NN, classify instances during inference by referring directly to the labeled training data instead of a learned model. However, k -NN provides a powerful method to classify data with numerous features and instances of somewhat similar classes, making it a widely used algorithm for data classification. The k -NN algorithm is well-suited when numerous features exist, and the relationships between the features and the classes are challenging to understand, but the resulting classes are relatively homogeneous. If clear distinctions among classes do not exist, then k -NN can struggle to classify new instances.

With k -NN, the premise is that items of the same class will have similar properties. The k value defines how many similar objects will be considered when classifying a new object. The algorithm will examine the existing data to discover the k instances most similar to the one to be classified. Once these similar objects are identified, the algorithm classifies the new object using a majority vote. Figure 2-6 depicts how the k -NN algorithm classifies a new instance to determine its class.

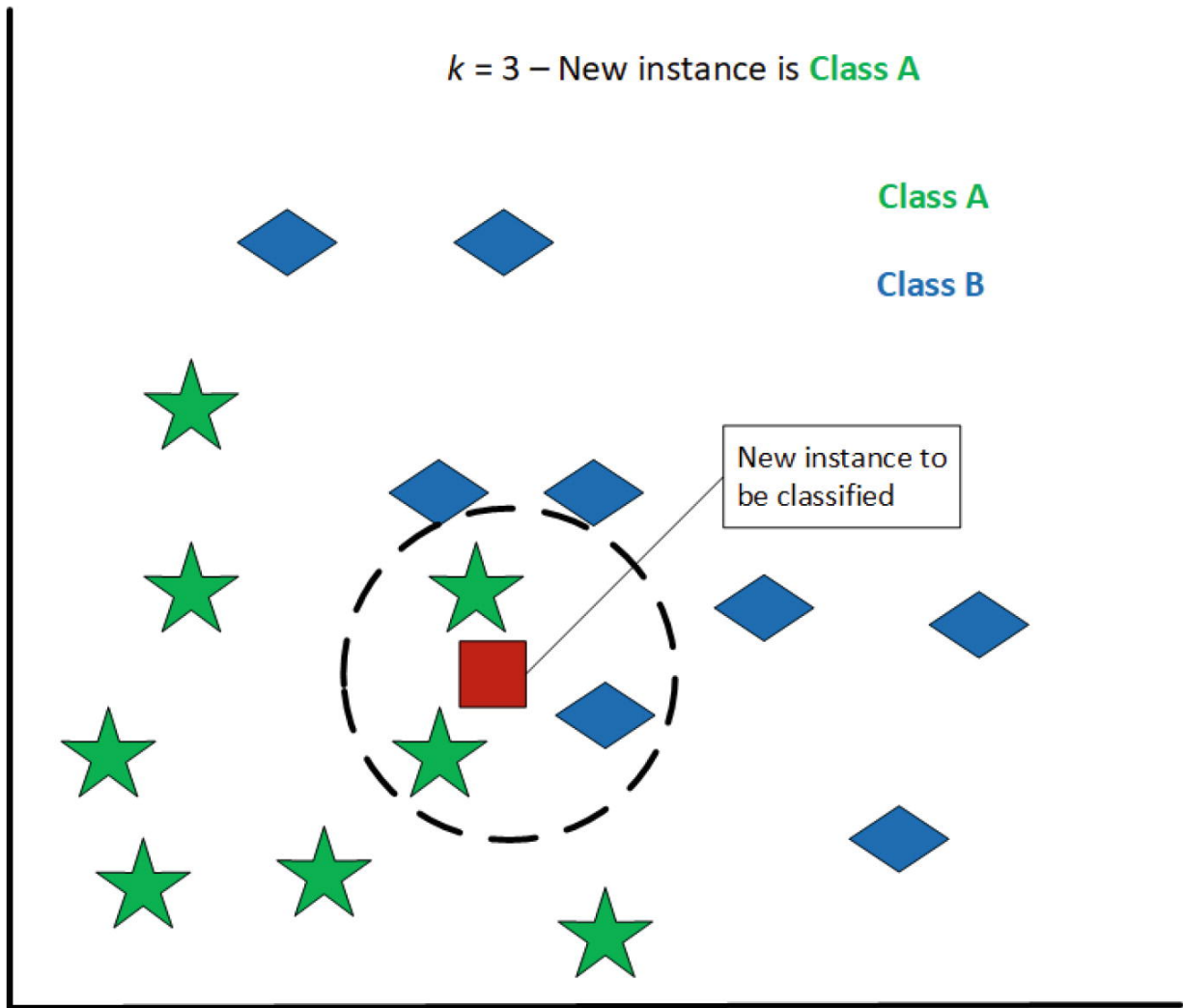


Figure 2-6 The k-NN algorithm classifies the new instance based on the most similar existing k instance

Changing the k value might result in the new instance receiving a different class designation. In Figure 2-7, the k value is changed to 5. When comparing the new instance to the five nearest neighbors instead three, the classification of the new instance is changed from *Class A* to *Class B*, as shown in Figure 2-7.

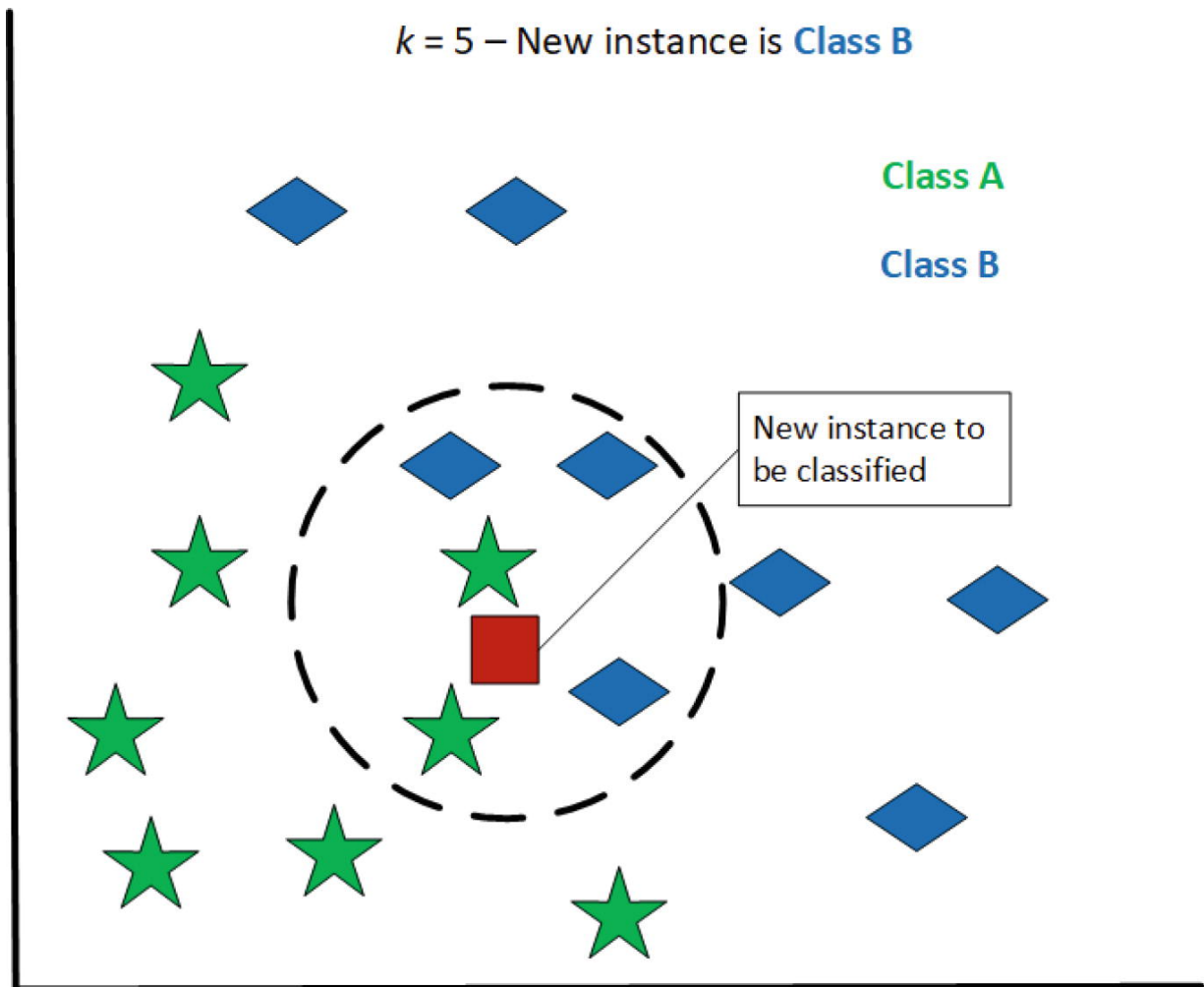


Figure 2-7 Changing the k value could result in a different classification of the new instance

The previous examples were easily depicted since they were based on only two dimensions represented by the x and y axes. However, it becomes challenging to visualize when more than two features are included. The k -NN algorithm uses Euclidean distance when comparing two instances. The Euclidean distance measures the distance between two points in a multidimensional space. Essentially, this method computes the distance between the two points for each feature. Each of these distances is squared, and then the squares of each feature distance are summed. The Euclidean distance is then the square root of that sum.

The following formula shows how the Euclidean distance between two data points, a and b , is determined. In this example, a_1 and b_1 represent the first feature of instances a and b , respectively. The number of features is represented by n .

$$\text{dist}(a, b) = \sqrt{(a_1 - b_1)^2 + (a_2 - b_2)^2 + \dots + (a_n - b_n)^2}$$

To demonstrate Euclidean distance, we will determine the nearest neighbor using three data points representing three people based on four features. The features in this example are height, weight, age, and 5K time in minutes. Table 2-1 shows the values for three people in the dataset. We want to determine whether Person C is more similar to Person A or Person B.

Table 2-1 Example data to demonstrate Euclidean distance calculations

Person	Height	Weight	Age	5K
A	70	175	46	23
B	68	180	42	28
C	72	185	32	21

Based on this data, we first calculate the Euclidean distance between Person C and Person A.

$$\begin{aligned} \text{dist}(C, A) &= \\ &\sqrt{(72 - 70)^2 + (185 - 175)^2 + (32 - 46)^2 + (21 - 23)^2} \\ &= 17.4 \end{aligned}$$

Next, we calculate the Euclidean distance between Person C and Person B.

$$\begin{aligned} dist(C, B) &= \\ \sqrt{(72 - 68)^2 + (185 - 180)^2 + (32 - 42)^2 + (21 - 28)^2} \\ &= 13.8 \end{aligned}$$

Based on the data, Person C is more similar to Person B.

Support Vector Machine

A support vector machine (SVM) creates a boundary between classes in a multidimensional space. The dimensions represent the features. The resulting boundary is referred to as a hyperplane. This hyperplane separates the instances into relatively homogenous partitions, which are the classes. An SVM is well-suited for many supervised ML problems, including classification and numeric prediction. This section will focus on using SVMs for classification.

Though most problems will include several dimensions (features), such problems are difficult to visualize. So, we will begin with a two-dimensional example since that can be easily represented on the page. The idea behind an SVM is to find the hyperplane that maximizes the distance between the hyperplane and the classes. The instances nearest the hyperplane are called the support vectors. The model can better generalize when faced with new instances to classify by maximizing the separation between the support vectors and the hyperplane.

Figure 2-8 depicts the creation of a hyperplane to separate the two classes. Note that many other lines could be drawn that would separate the classes. However, the hyperplane maximizes the distance between itself and the classes. The support vectors, which are the instances closest to the hyperplane, are also depicted.

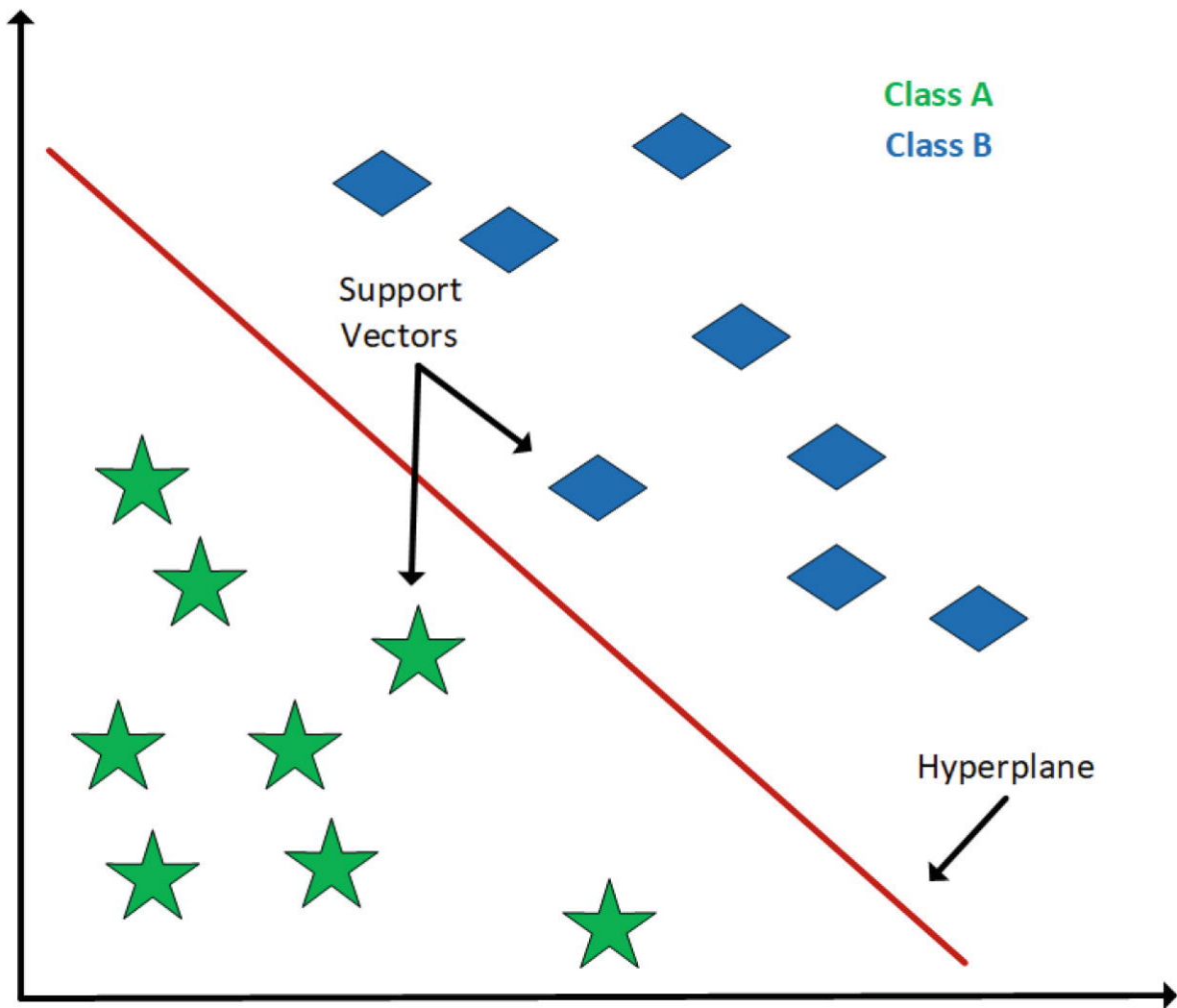


Figure 2-8 An SVM creates a hyperplane between the classes

Of course, not all data is linearly separable. For such problems, an SVM can incorporate a cost value. The concept is to allow some points to fall on the wrong side of the hyperplane, thus creating a softer margin between the classes. The SVM assigns a cost value to any instance falling on the incorrect side. The algorithm then creates the hyperplane to minimize the total cost (instead of maximizing the distance), as shown in Figure 2-9.

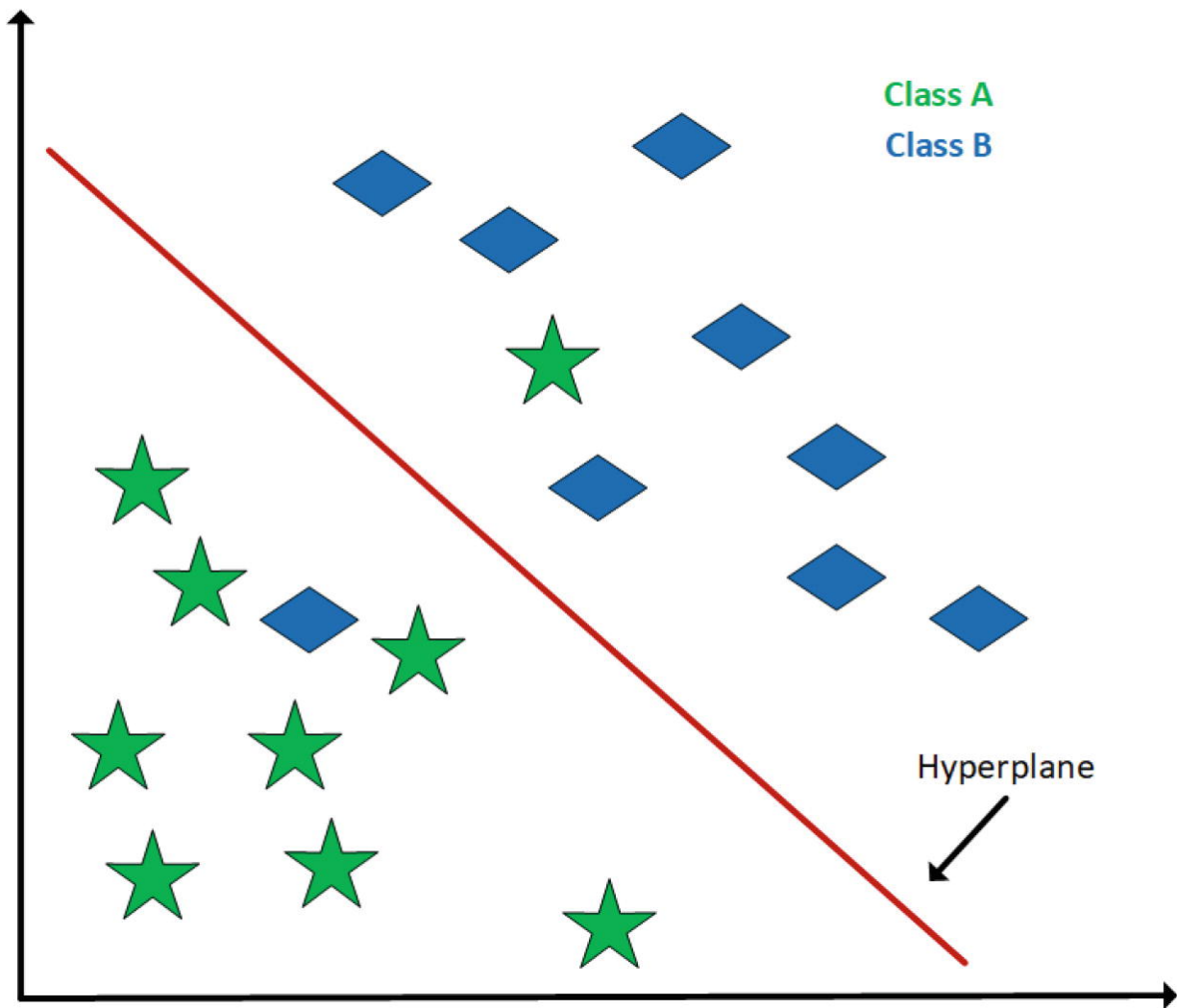


Figure 2-9 An SVM with a soft margin, allowing some instances to be on the incorrect side

In the example in Figure 2-10, an SVM is used to classify transactions as valid or fraudulent. The SVM analyzes the labeled instances of previous transactions and creates the hyperplane. When new transactions occur, they can then be classified based on which side of the hyperplane they fall.

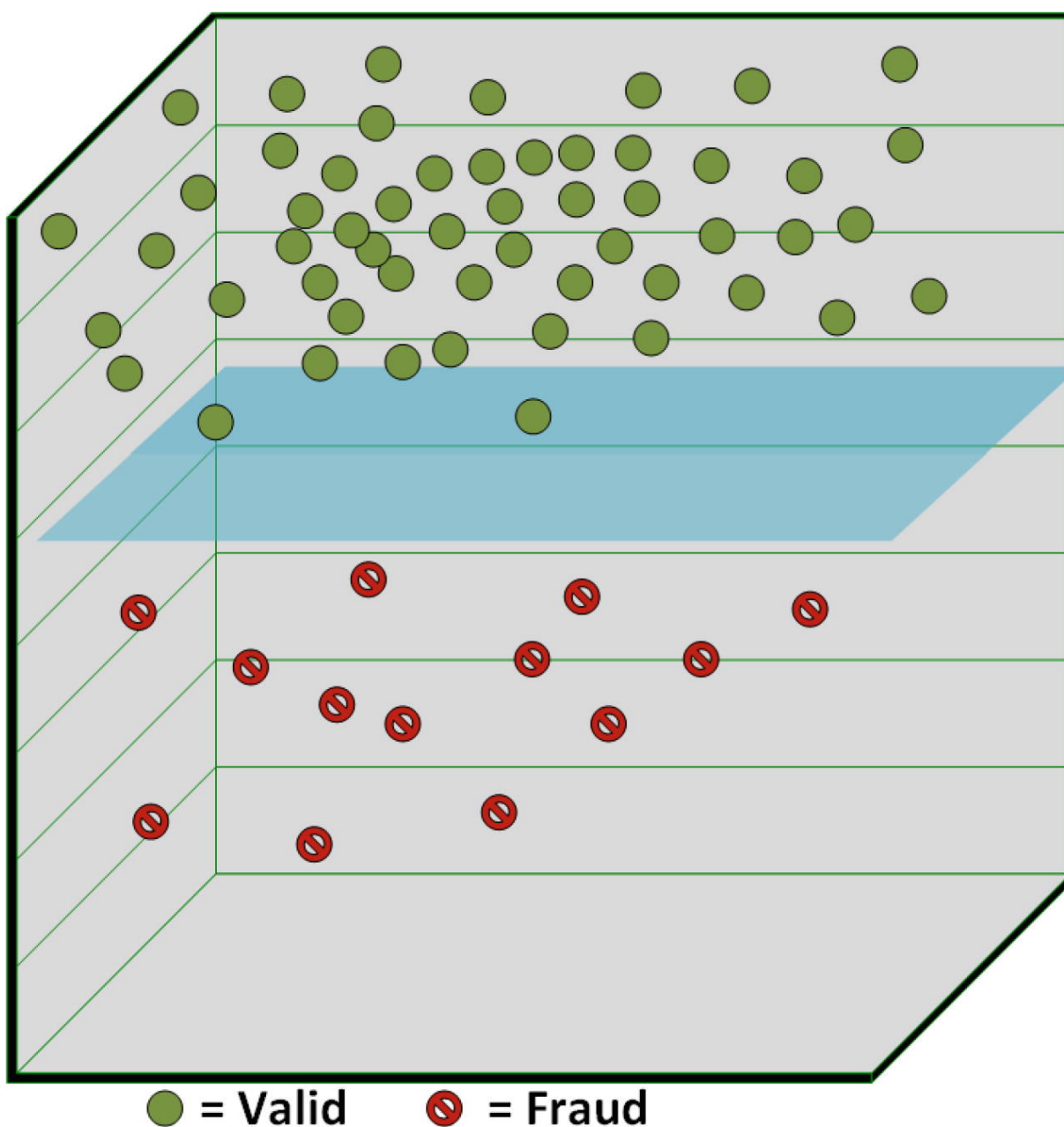


Figure 2-10 This SVM creates a separating plane between valid and fraudulent transactions

SVMs are among the most popular algorithms used within cybersecurity and many other fields because of their ease of implementation and accuracy when there are many features. However, a significant downside of SVMs is that they often result in a complex black-box model, making them difficult to interpret or explain.

Predictive Algorithms

In addition to classifying data, supervised learning can also help predict the value of a numeric variable. Perhaps we want to predict the value of claims for a group medical policy or the anticipated costs of a cyberattack. Predictive algorithms can provide the answer to such problems. These algorithms can predict a numeric outcome by estimating the relationships among the data. Typical forms of predictive algorithms include linear regression and regression trees.

Linear Regression

Linear regression predicts a numeric result (the dependent variable) by defining the relationship between the dependent variable and one or more numeric predictors (independent variables). Regression methods model the size and strength of the relationships between numeric variables. The simplest form is linear regression, which assumes the relationship follows a straight line. The regression line, defined by the slope and intercept, maps this relationship, as shown in Figure 2-11. The intercept is the point at which the line crosses the y-axis. The slope defines the increase in the y value for each increase in the x value. A negative slope indicates that the y value decreases with each increase in the x value.

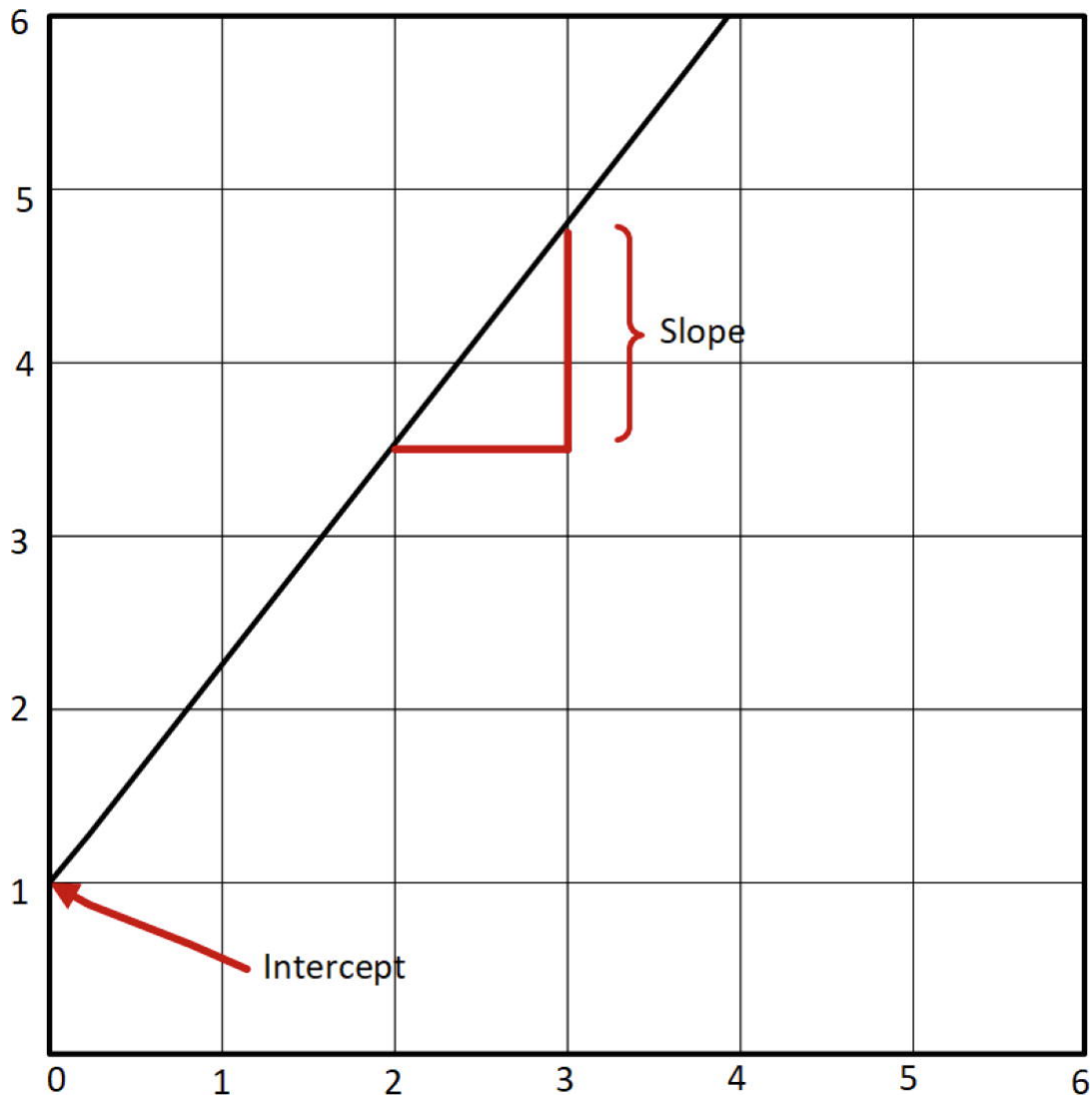


Figure 2-11 Linear regression is defined by the slope and the intercept

One method to determine the regression line is ordinary least squares (OLS) estimation. With OLS, the algorithm determines the regression line to minimize the sum of the squared errors. The error (also known as the residual) is the distance between the predicted and actual values.

To demonstrate linear regression using OLS, we will examine eruptions of Old Faithful. The goal is to predict the duration of an eruption based on the wait time between eruptions. The scatterplot in Figure 2-12 shows some sample data, with the wait time along the y-axis and the duration of the eruption along the x-axis. This plot shows an apparent relationship between the independent variable

(wait time) and the dependent variable (duration). As the wait time between eruptions increases, so does the eruption duration.

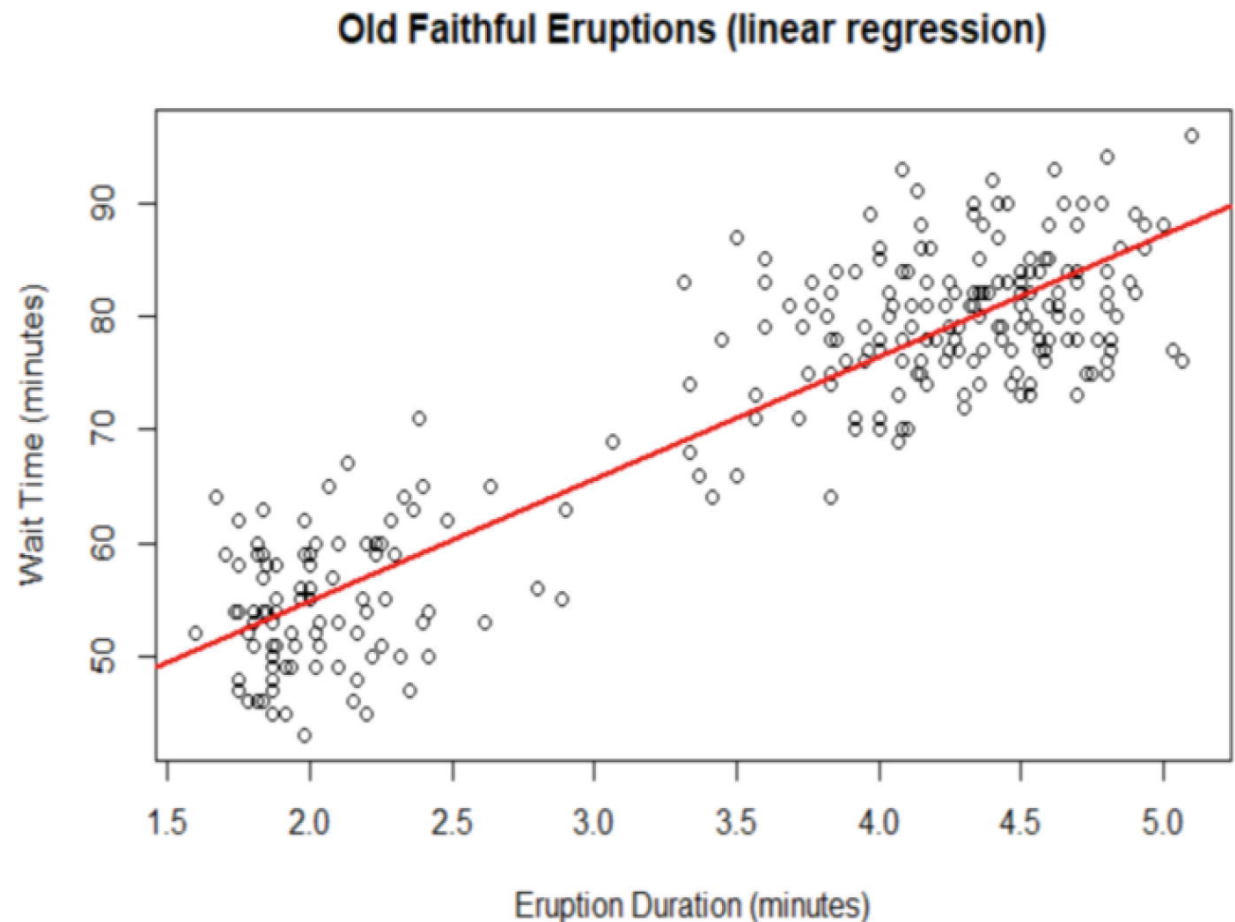


Figure 2-12 A linear regression shows the relationship between the duration of an eruption and the wait time between eruptions for Old Faithful

Of course, the relationship between wait time and duration is not perfectly linear. Smoothing can be applied to the linear regression model to reduce the residuals between the predicted and actual values. Smoothing can use local polynomial regression to adjust the regression line to fit the data better. Typical smoothing methods include LOESS (locally estimated scatterplot smoothing) and LOWESS (locally weighted scatterplot smoothing). Incorporating smoothing provides more accurate predictions, which we can use to predict eruption durations

for other wait times. Figure 2-13 depicts the smoothed linear regression of Old Faithful eruptions.

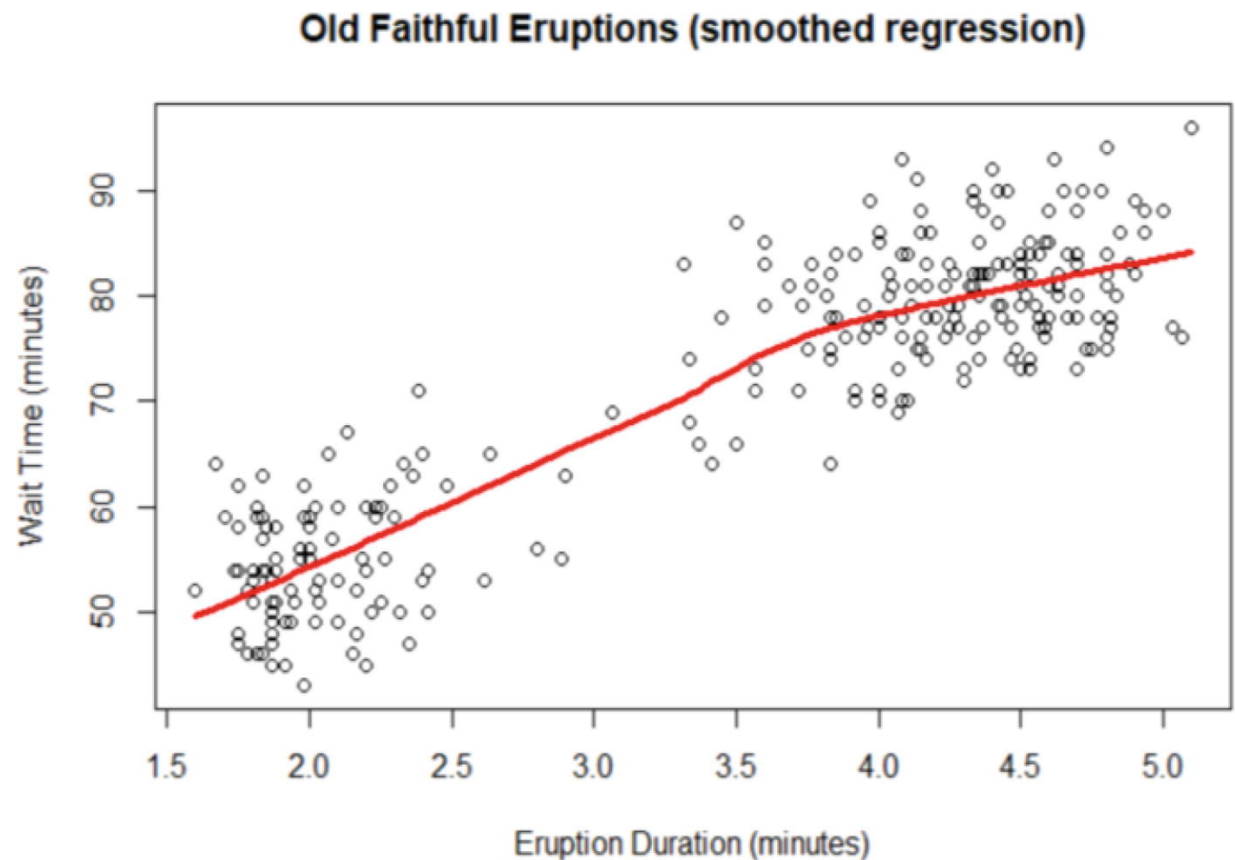


Figure 2-13 The application of smoothing can result in improved predictions

Multiple Linear Regression

Simple linear regression works well when analyzing a single independent variable (*wait* time in the Old Faithful example). However, often, we want to make a prediction based on multiple independent variables, such as predicting a person's blood pressure based on age, weight, waist size, and whether they smoke. Multiple linear regression (MLR) provides the means to predict the value of the dependent variable based on multiple independent variables.

However, when using MLR, it is essential to consider the phenomenon of multicollinearity. Having two predictor variables that are highly correlated with each other can

impact the results. For example, *weight* and *waist size* should be analyzed for correlation in the blood pressure predictor. If there is a strong correlation between the two, then it might be best to drop one of these values from the MLR. The math behind MLR is beyond the scope of this book, as it requires an understanding of matrix algebra. The critical thing to remember is that MLR provides a powerful prediction method when we need to consider multiple predictors; however, additional statistical checks on the data are required.

Unsupervised Learning

Unsupervised learning evaluates the training samples without prior knowledge of the corresponding category labels. Unsupervised ML are often used to discover interesting patterns or associations within the data. Also, unsupervised learning can cluster or group samples based on their similarities and identify anomalies. Common unsupervised ML algorithms include k-means clustering (k-MC) and market basket analysis (MBA).

Market Basket Analysis

Market basket analysis (MBA), also known as affinity analysis, originated in the marketing industry to discover relationships between groups of products. Merchants use MBA to identify shopping patterns, improve product placement, increase cross-selling, and support advertising. Recommendation systems, such as those on Amazon or Netflix, often use an MBA-based approach to recommend products to consumers based on their or other consumers' previous purchases. Amazon's recommendation models can be quite effective, enticing me to purchase many items I had not previously considered. The ability of MBA to discover nonobvious relations or association rules between

items makes MBA a powerful tool beyond its original purposes in marketing.

With MBA, items that appear in a given transaction are grouped into itemsets, such as $\{tequila, triple\ sec, lime\}$. MBA then develops association rules to specify the relationship patterns between itemsets. For example, $\{tequila, triple\ sec\} \rightarrow \{lime\}$, which can be read as if someone purchases tequila and triple sec, then they are likely to purchase limes.

The **support** of an itemset specifies how frequently it occurs in the data. For example, the support of $\{tequila, triple\ sec\}$ would be calculated as the number of times tequila and triple sec appeared together in a transaction divided by the number of transactions. Determining the support of an itemset is important when evaluating the usefulness of a particular rule. An MBA can create many association rules, so determining those with the largest support allows us to focus on the most prevalent by setting a threshold support value.

$$support\ \{tequila, triple\ sec\} = \frac{\{tequila, triple\ sec\}}{transactions}$$

The **confidence** of a rule is the measure of its predictive accuracy and is the probability that B will be selected given A 's selection. The confidence specifies the proportion of transactions where the presence of the first itemset, $\{tequila, triple\ sec\}$, results in the presence of the second itemset, $\{lime\}$. If the confidence is high, that indicates a strong likelihood that if a customer purchases tequila and triple sec, they will also purchase a lime. So, if someone comes to the register with tequila and triple sec but no limes, suggest a lime. Or maybe stock some limes near the tequila. In the following example, itemset A is $\{tequila,$

triple sec}, and itemset B is {lime}. Given that, we can calculate the confidence of the relationship as follows:

$$confidence = \frac{support(A \cup B)}{support(A)}$$

Another important measurement of association rules is the **lift**, which measures the increased or decreased likelihood of A and B occurring together compared to B occurring alone. Lift scores greater than 1.0 describe a positive relationship. In contrast, lift scores below 1.0 describe a negative relationship. A lift value of 1.0 indicates that chance can explain the relationship.

The lift is calculated as follows:

$$lift(A \rightarrow B) = \frac{confidence(A \rightarrow B)}{support(B)}$$

Table 2-2 shows some association rules based on the above examples. The rules are read as follows: the confidence is the probability that the consumer will purchase the item(s) on the right-hand side (rhs) given that they purchased the items on the left-hand side. In this example, rule 1 indicates a strong likelihood (72%) that if the customer purchases tequila and triple sec, they will also purchase limes.

However, note that the relationships are not reversible, as shown by rule 2. Just because someone purchases a lime does not mean they will likely purchase tequila and triple sec. Perhaps they want to make a lime pie. Another association rule might indicate the relationship between limes and pie crust purchases.

Table 2-2 Example association rules

rule	lhs		rhs	confidence
1	{tequila, triple sec}	→	{lime}	0.72
2	{lime}	→	{tequila, triple sec}	0.13
3	{lime, sea salt}	→	{tequila}	0.42

Clustering

Unsupervised learning is often used to group unlabeled elements based on similarity, especially with large datasets with unknown classes. Clustering has many uses, such as detecting anomalous network activity, segmenting customers based on demographic or purchase history, and discovering diseased areas in medical imaging. Most clustering algorithms seek to create groups with high intraclass similarity and low interclass similarity. High intraclass similarity ensures that items within a group are as similar as possible. On the other hand, low interclass similarity ensures that items within one cluster are as dissimilar as possible from items in the other clusters. The clusters created have no intrinsic meaning other than items in a group are similar. It is up to the user to assign meaningful labels to the discovered clusters.

There are many cluster analysis methods, and they can be distinguished based on several attributes. Cluster analysis can be partitional or hierarchical, exclusive or overlapping, and complete or partial. Partitional clustering, depicted in Figure 2-14, creates clusters without overlaps so that each cluster is independent. Hierarchical clustering can create clusters within other clusters, creating a parent-child relationship. Exclusive clustering ensures that each element is in only one group, whereas, with overlap clustering, elements can belong to multiple groups. With complete clustering, all elements must belong to at least one cluster. However, with partial clustering, the algorithm does not assign elements dissimilar from others to a group.

Therefore, partial clustering can be useful in detecting anomalies.

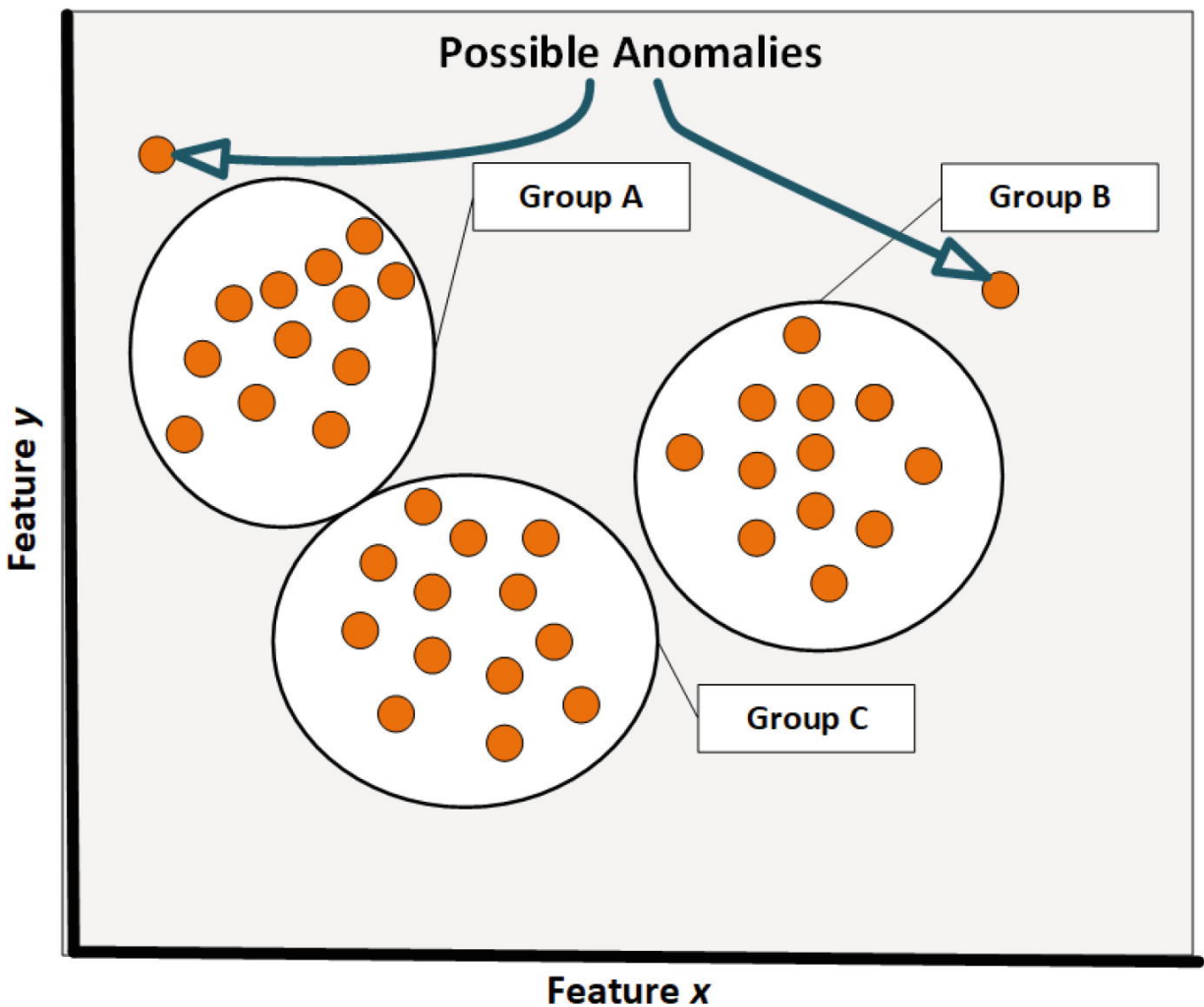


Figure 2-14 Partial clustering can be used to detect possible anomalies

***k*-Means Clustering**

One of the most common clustering algorithms is *k*-means clustering (k-MC), where *k* defines the number of desired clusters. This algorithm has been used for decades and provides the basis for many other clustering methods. The algorithm creates the clusters based on the similarity of all data points. This algorithm performs complete and exclusive grouping, meaning that every element must be in a cluster (complete), and each element must be in only one

cluster (exclusive). When determining similarity between elements, k-MC typically uses Euclidean distance, the straight line distance between points in multidimensional space. However, the algorithm can use other distance measures. Figure 2-15 demonstrates using k-MC to group elements into three clusters ($k = 3$). Note that the resulting groups would differ if k were set to a different value, such as $k = 4$. Fortunately, there are statistical methods that can help select the optimal number of clusters.

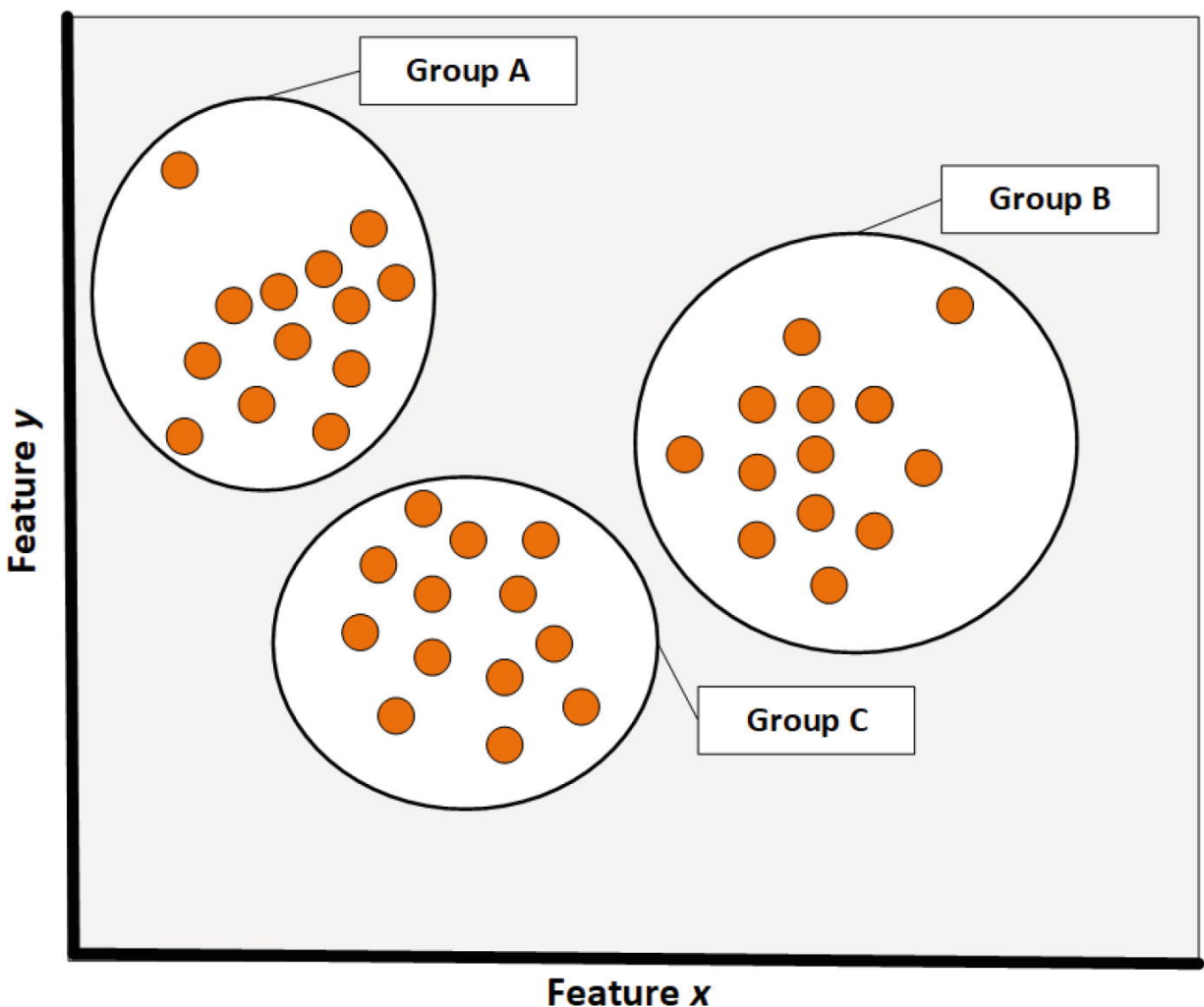


Figure 2-15 In this example, k-MC is used to cluster elements into three groups

One issue with k-MC is that it does incorporate random chance. The initial center points are determined by a

random selection of k elements. The algorithm then assigns the other elements to these initial groups. After this initial grouping, the center points are recalculated by determining the exact center point of the initial groupings. The elements are reevaluated based on these new center points to create new groupings. The algorithm repeats the analysis and refinement until it can make no further improvements. Since the algorithm incorporates random chance, it may not find the optimal clusters. Also, the random selection of the starting center points could create clusters that look different each time they are applied.

Density-Based Clustering: DBSCAN

Centroid-based clustering, such as k-MC, works well when the clusters are convex or regularly shaped and when the number of clusters is known in advance. However, sometimes clusters can occur in irregularly shaped patterns, as in Figure 2-16. In such cases, density-based clustering algorithms, such as DBSCAN, are better suited. Centroid-based clustering can have difficulty in determining irregularly shaped clusters, which is something at which density-based clustering excels. Also, density-based scanning can consider time, creating clusters across space and time. Finally, centroid-based clustering, such as k-MC, requires the user to define the number of clusters in advance, while density-based clustering determines the number of clusters during application.

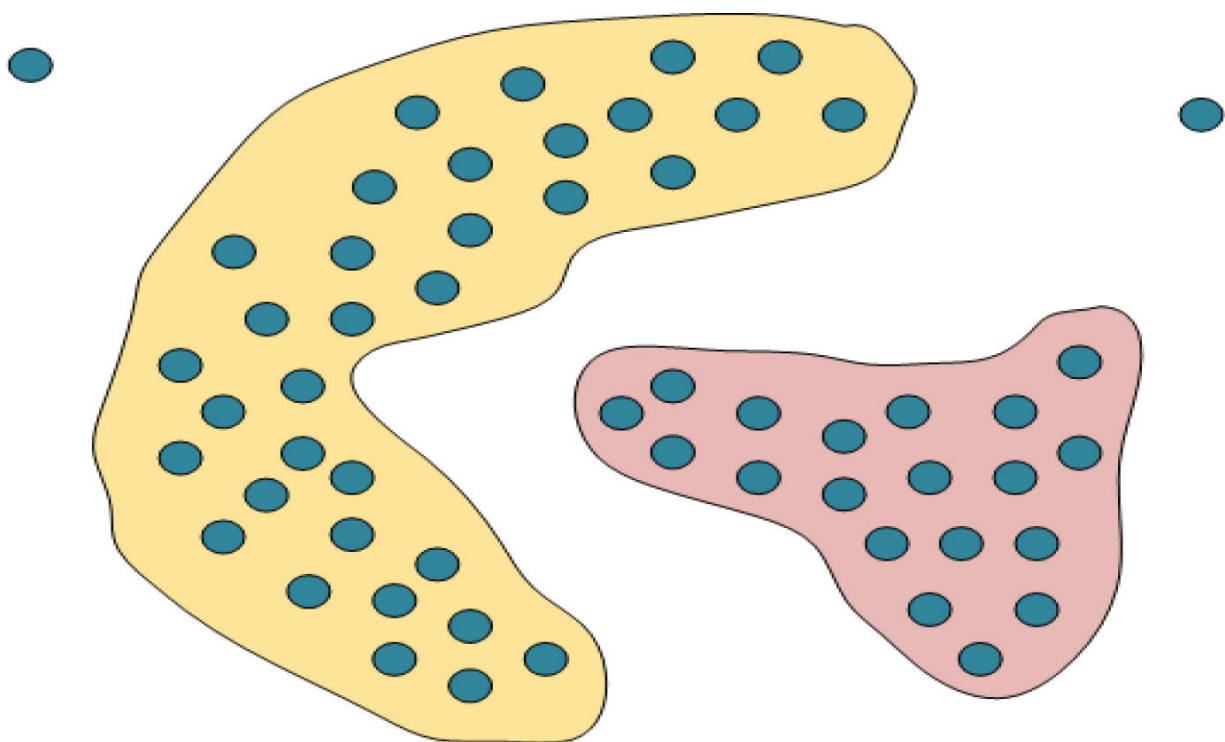


Figure 2-16 Unlike centroid-based clustering, density-based clustering works with irregular-shaped clusters. Also, unlike kMC, which performs complete clustering, DBSCAN does not force all elements to be in a cluster. Outliers are considered noise.

When performing density-based clustering, typically, the user must define two variables. The first is the search distance, the maximum distance between two data points for those points to be considered clustered. In other words, search distance defines the neighborhood around a given data point. The other variable is the minimum number of data points to be considered a cluster. The algorithm will identify three types of points based on these variables – core points, border points, and outliers (or noise), as shown in Figure 2-17. Core points are any data point that has at least the minimum number of other points within its neighborhood. Border points refer to points that are within the neighborhood of core points but do not have the minimum number of points within their neighborhood. Data points that are not core points and are not within the search distance of any core points are considered outliers. These outliers will not belong to any cluster. The algorithm

works recursively, allowing it to chain together neighborhoods.

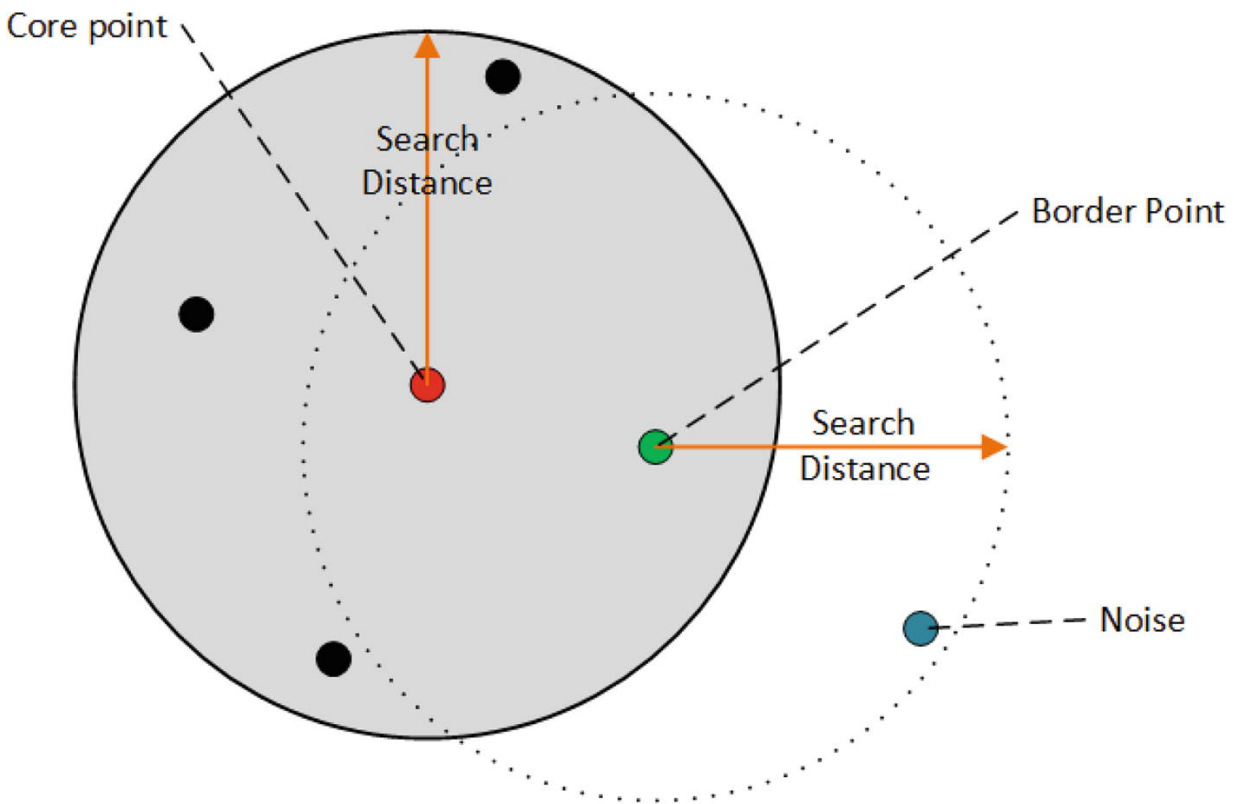


Figure 2-17 The red dot is a core point because it has the minimum number of points (in this case, 4) within its search distance. The green dot is a border point because it is within the red dot's search distance but does not have the minimum number of points within its search distance to be a core point. The blue dot is an outlier since it is not within the search distance of any core points and cannot be a core itself.

Deep Learning: Artificial Neural Networks

Deep learning (DL), a subset of ML, attempts to imitate the human brain in analyzing and interpreting data. Artificial neural networks (ANN), which underlie DL, are inspired by the workings of neurons in the brain. An artificial neuron can be understood in terms similar to a biological model. At a high level, a biological neuron has three main components – the soma (cell body where the nucleus

resides), dendrites, and the axon. The soma receives inputs from the dendrites. A single neuron might receive thousands of these input signals. The sum of all the inputs the soma receives determines whether or not the neuron is excited into firing. If it fires, the neuron conducts the nerve impulse, or action potential, through the axon. Information is carried from one neuron to another through synapses.

An artificial neuron, as shown in Figure 2-18, has a similar structure, where input signals represent the dendrites, the activation function represents the soma, and the output signal represents the axon. The input signals (x) are weighted (w) according to importance. Much like a biological neuron, an artificial neuron can have any number of input signals. The weights of the input signals are summed, and the signal is passed on based on the activation function (f). The activation function determines the output (y) based on the function's calculations. This result is then passed along. To create a network, artificial neurons are strung together, where the output (y) of an artificial neuron becomes one of the inputs (x) to another artificial neuron.

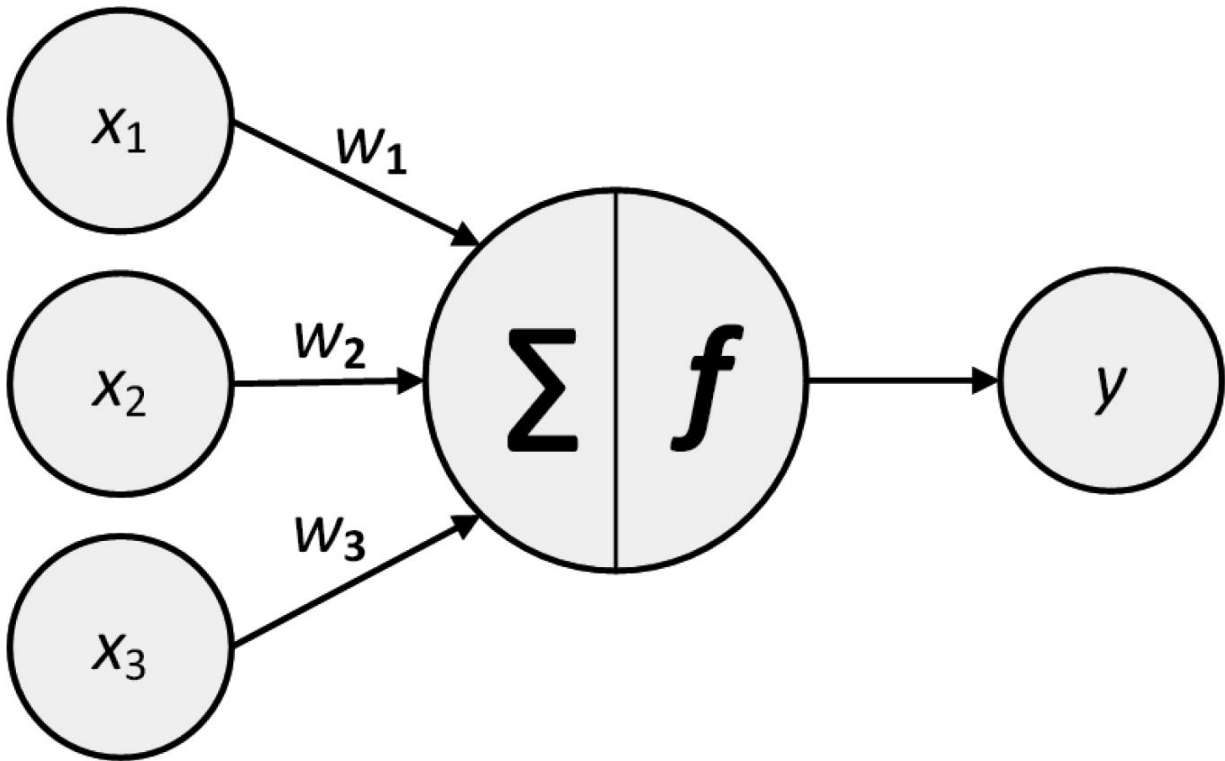


Figure 2-18 An artificial neuron sums the weighted inputs. The activation function, if fired, determines the output.

An ANN is composed of artificial neurons called nodes and has three layers: the input layer, the hidden layer, and the output layer. In a simple ANN, there is only one set of nodes in the hidden layer. Traditional ANNs were popular in the early days of machine learning. However, the lack of processing power prevented the creation of complex, multiple-layer neural networks. This limitation stagnated the progress of ANNs for decades. Recent increases in processing power allowed the creation of complex, multiple-layer DNNs. These networks learn through a process called backpropagation, where the error is propagated backward through the network to adjust the weights of the connections. With the advent of DNNs, the use of ANNs resurged in the 2010s, gaining popularity in many applications, including cybersecurity. Whereas other ML methods degrade in performance with very large datasets, DNNs thrive in such applications. The concept behind DNNs is that the performance will increase by

constructing larger DNNs and training them with as much data as possible. The DNNs use hierarchical-based feature abstraction and representation to handle extremely large training datasets with ease.

A deep neural network (DNN) is an ANN with multiple levels of nodes within the hidden layer. The power of a DNN is realized by stringing together multiple levels of nodes. The basic form of a DNN is a feed-forward model known as a multilayer perceptron (MLP). An MLP consists of fully connected layers in which the previous layer's output forms the following layer's input, as shown in Figure 2-19. Other variations of DNNs include **recurrent neural networks** (RNN) and **convolutional neural networks** (CNN).

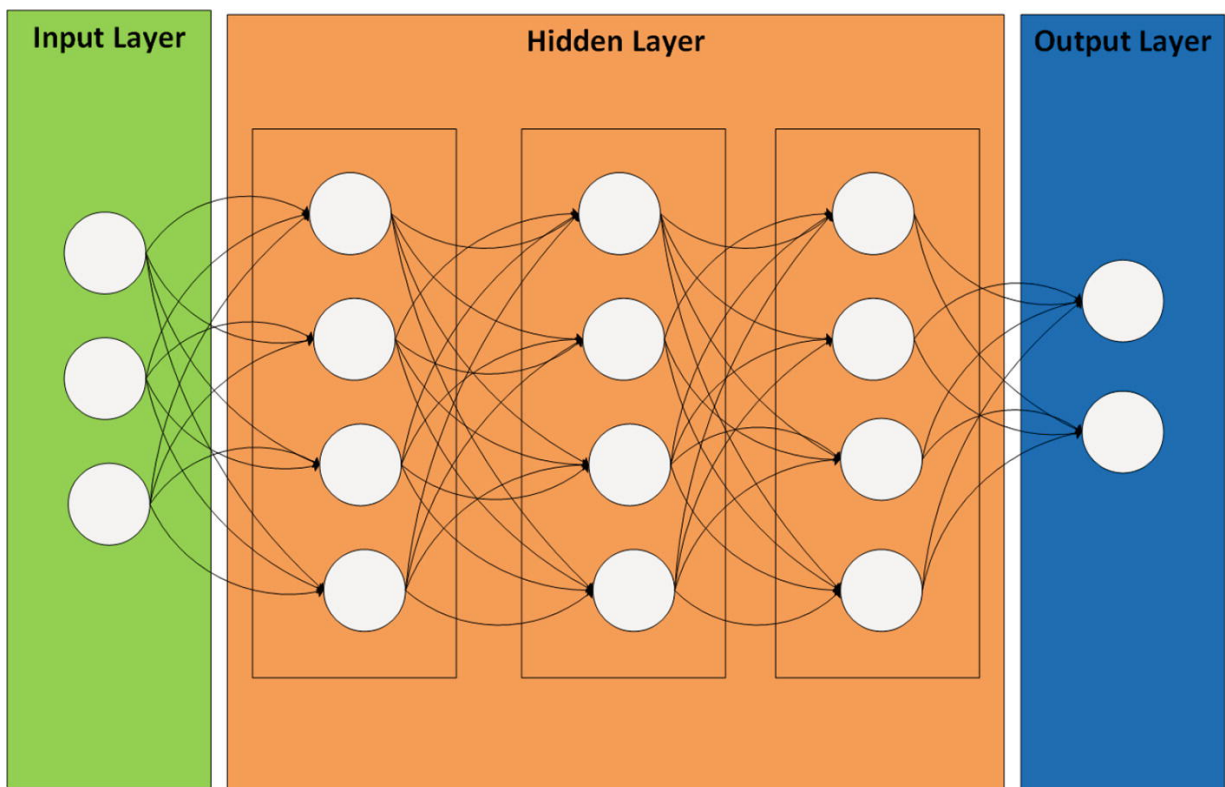


Figure 2-19 An MLP with fully connected three hidden layers

An RNN focuses on sequential or time-series data. These algorithms are commonly used for activities such as natural

language processing, language translation, and captioning. Popular applications such as Siri and Google Translate incorporate RNNs. What sets RNNs apart from MLPs and CNNs is that RNNs incorporate the concept of memory. Therefore, information about the previous calculation can influence the current layer's function. An RNN uses a simple loop to remember what it knows from the previous input. In the case of time-sequence data, an artificial neuron in an RNN will add the memory from the previous timestamp to the input of the current timestamp. Figure 2-20 depicts an RNN unfolding into four hidden layers. The sequential nature of the RNN is represented by time (t). The state (S) is passed along, representing the RNN's memory. In predicting the next word in a sequence, the output (Y) at a given step (t_n) could be a vector of probable words.

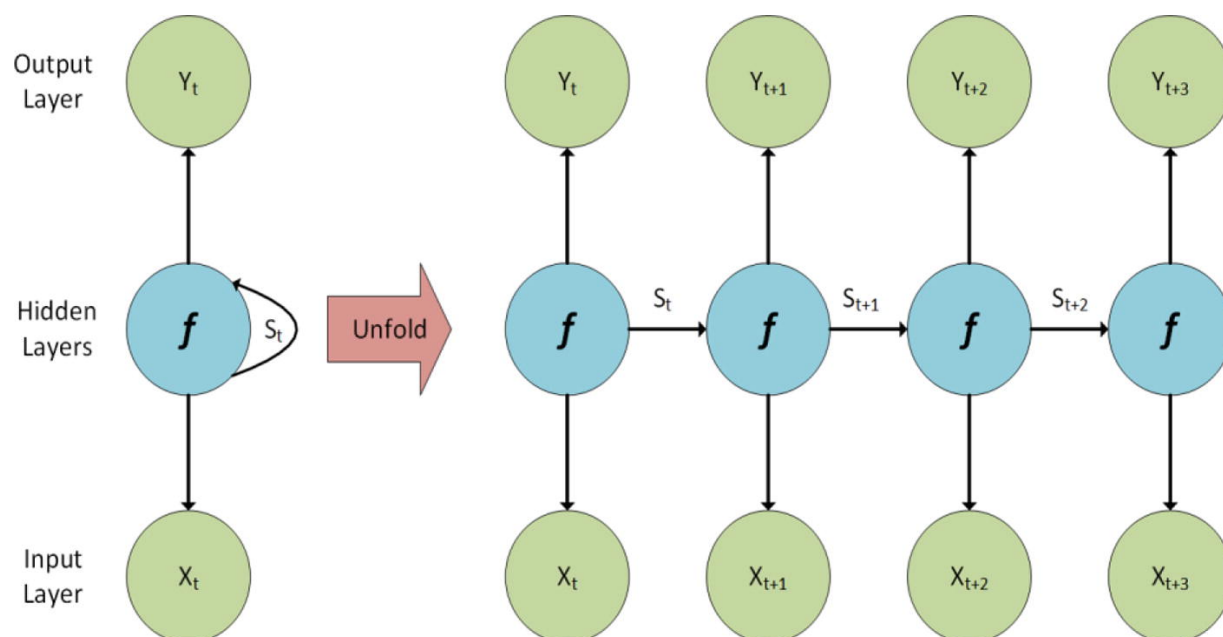


Figure 2-20 A diagram of an RNN unfolded into four hidden layers

A standard RNN is unidirectional because only prior inputs are considered. A bidirectional RNN includes a feedback loop, allowing the RNN to consider future states within the current artificial neuron. Bidirectional RNNs are

based on the idea that the output at a given sequence may depend on past and future elements, such as when predicting a missing word in a sentence. For example, consider the sentence “I feel _____ the weather.” With a standard RNN, the output would be a vector of the most likely words to follow “I feel,” which could result in the prediction of “happy” or “sad.” However, with a bidirectional RNN, the algorithm would also consider the future words after the blank, predicting “I feel *under* the weather.”

CNNs are widely used in image processing and classification. A CNN has convolutional layers that recognize features within the image’s pixels. Pooling layers abstract features from the convolution layers. Finally, the feed-forward layer is a fully connected DNN that uses the features derived from the convolution and pooling to make a prediction. Figure 2-21 depicts the components of a CNN to classify whether an image is of a dog or a penguin.

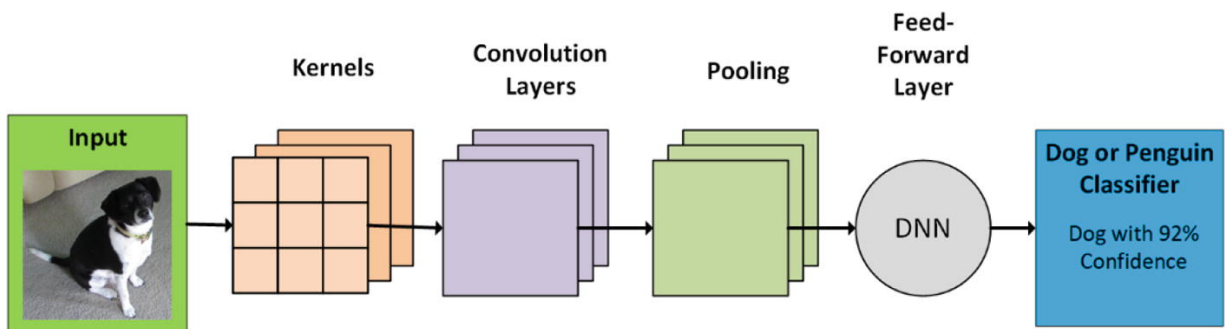


Figure 2-21 Using a CNN to determine if Petey, one of my pets, is a dog or a penguin

The convolution layers extract the features of the inputs to complete the defined task, such as image classification or facial authentication. Convolution is a mathematical operation to combine two sets of information. The input is combined using multiplication with the filter or kernel. The algorithm scans the input, applying the kernel. The results of multiplying the selected input section by the kernel are

summed and inserted into the feature map. Figure 2-22 shows the convolution of binary data with a 3 x 3 kernel.

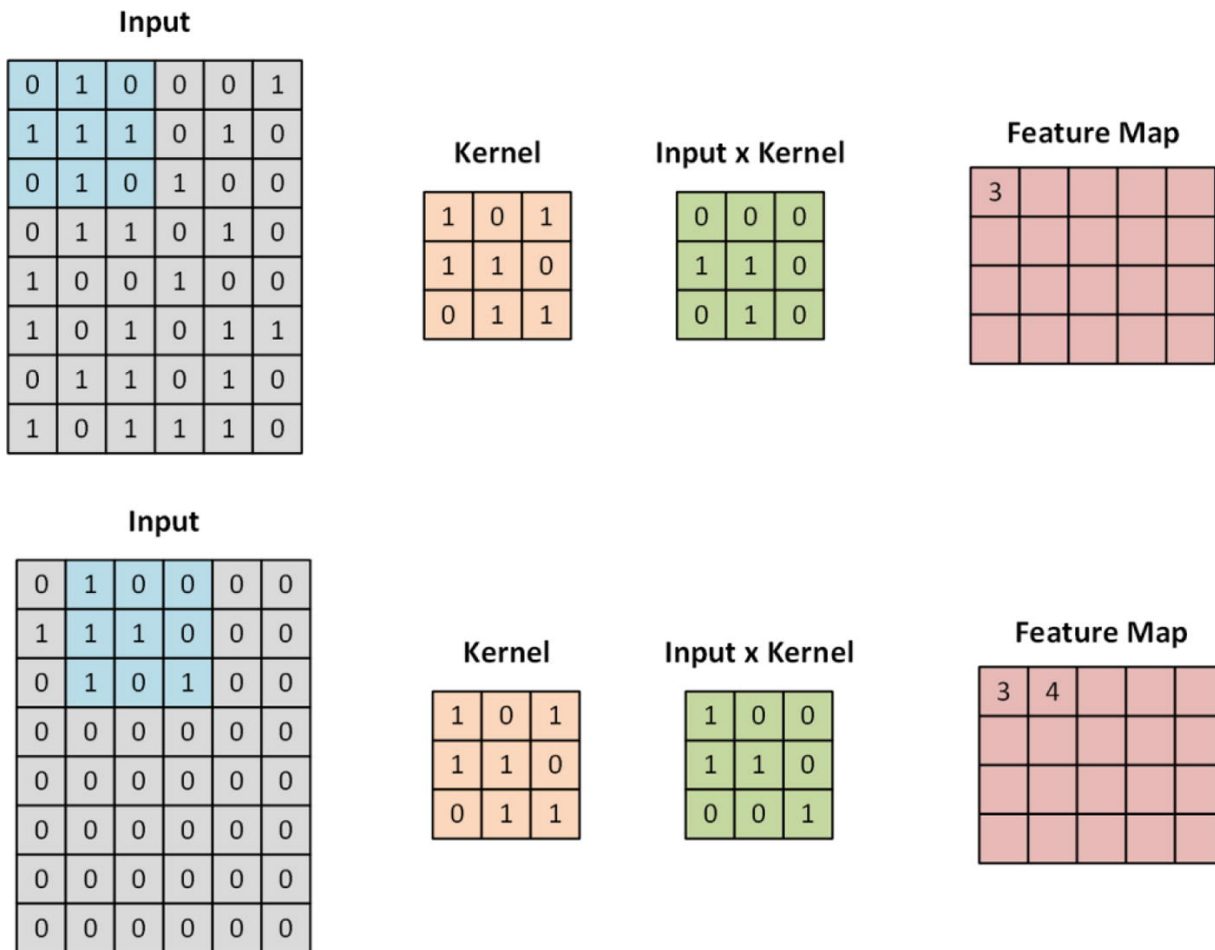


Figure 2-22 Convolution extracts information from the input by applying a kernel. This diagram shows the first two steps in applying a kernel to the input during convolution.

The convolution can result in a lot of data, so the results are pooled after convolution. These pooling layers compress the feature map, typically by taking a 2x2 section of the feature map and compressing it into one value (see Figure 2-23). The most common methods for pooling are maximum pooling and average pooling. With maximum pooling, the largest value from the 2x2 section is used. Average pooling averages the values in the 2x2 section.

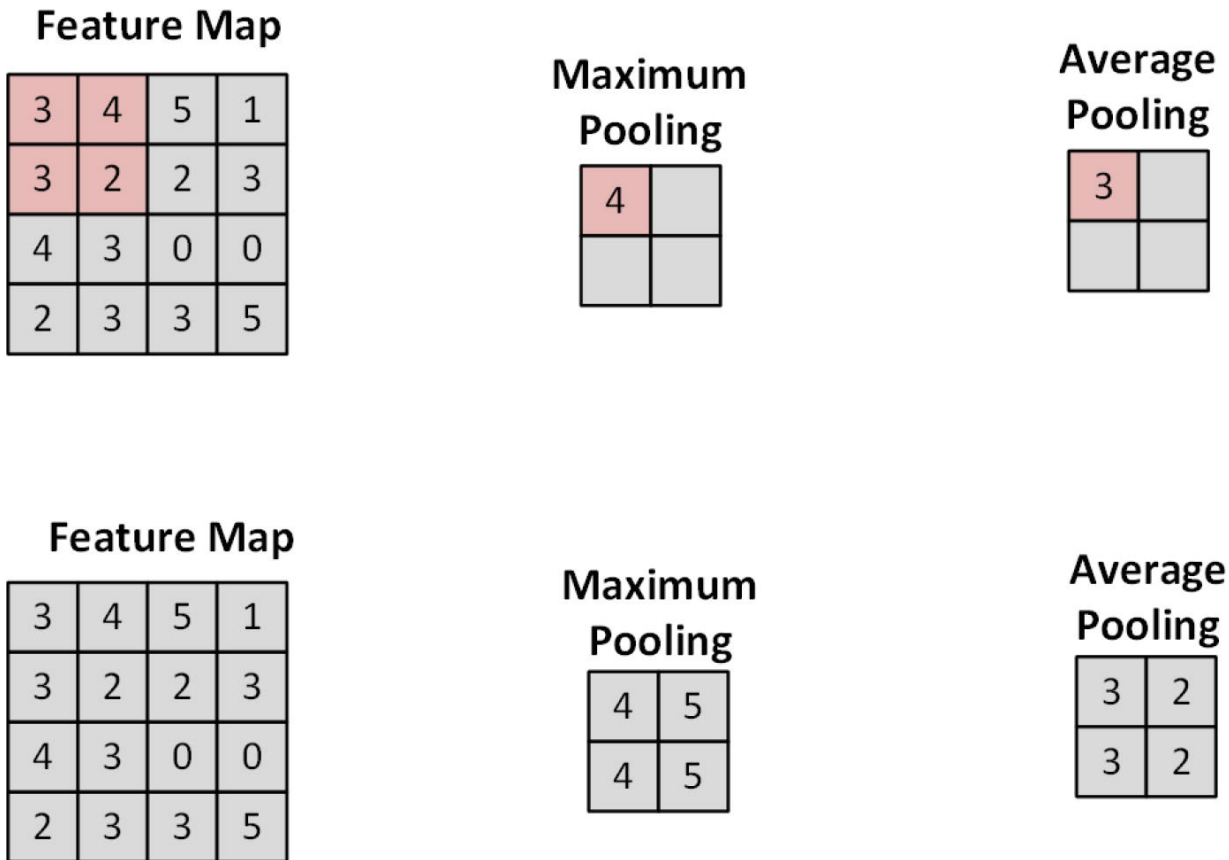


Figure 2-23 Pooling can be done by determining the largest value in the area or by averaging the values in the area

Reinforcement Learning

Reinforcement learning algorithms seek to achieve the most optimal result by learning from past successes and mistakes. This type of learning mimics the human process of learning through trial and error. The learning is accomplished through feedback at steps along the way. Reinforcement learning can also incorporate the concept of delayed gratification, where the system may need to backtrack to find the optimal result, much like navigating a complex maze. This feature allows reinforcement learning to discover the optimal solution that maximizes the long-term reward. Common reinforcement learning algorithms include Q-learning, SARSA (State-Action-Reward-State-Action), and Policy Gradient methods.

Supervised learning has pre-labeled data and learns relationships between the inputs and outputs, whereas, with reinforcement learning, the data is not labeled in advance. In contrast to unsupervised learning, in which outcomes are unknown, reinforcement learning has a defined goal. A reinforcement learning algorithm maps possible outcomes along each step, starting with the inputs. Each step taken can then be weighted using a system of rewards so that the path with the maximum reward for achieving the desired outcome is selected.

In reinforcement learning, the entity being trained is called the agent. This agent, which could be an industrial robot, a car, a chatbot, or many other types of systems, will learn to optimize its behavior from its environment. When developing a reinforcement learning system, a system of rewards is devised. These reward systems typically are value-based, where desired actions are assigned a positive value, and undesired actions receive a negative value. The goal is to reach the objective with the highest total reward value.

Often, reinforcement learning algorithms are based on the Markov decision process. When the agent is in a given state, it can select from the possible actions applicable to that state. The possible actions can have rewards or punishments assigned to motivate the agent. Once an action is selected, the agent is in a new state with a new set of possible actions. As the agent moves along the path, it accumulates rewards. However, like navigating a maze, the agent may need to backtrack to reach its goal. Over time, the agent will learn the optimal path forward from any given state.

Reinforcement learning has been widely used in gaming and robotics. However, it is also a powerful tool for enhancing the training of many ML applications, such as recommendation systems and chatbots. Such systems can be initially trained with other ML algorithms, typically

using unsupervised methods. Then, human input can review responses and provide rewards and punishments. Sometimes, this human input is in the form of expert review. In other situations, the end user might provide reinforcement, such as when the user upvotes or downvotes a response from a recommendation system or a chatbot.

Classic ML Method

There is no single approach to performing ML; the question, the nature of the data, and the algorithm will dictate the ML technique. However, a generic model can be used to explain the process, as shown in Figure 2-24.

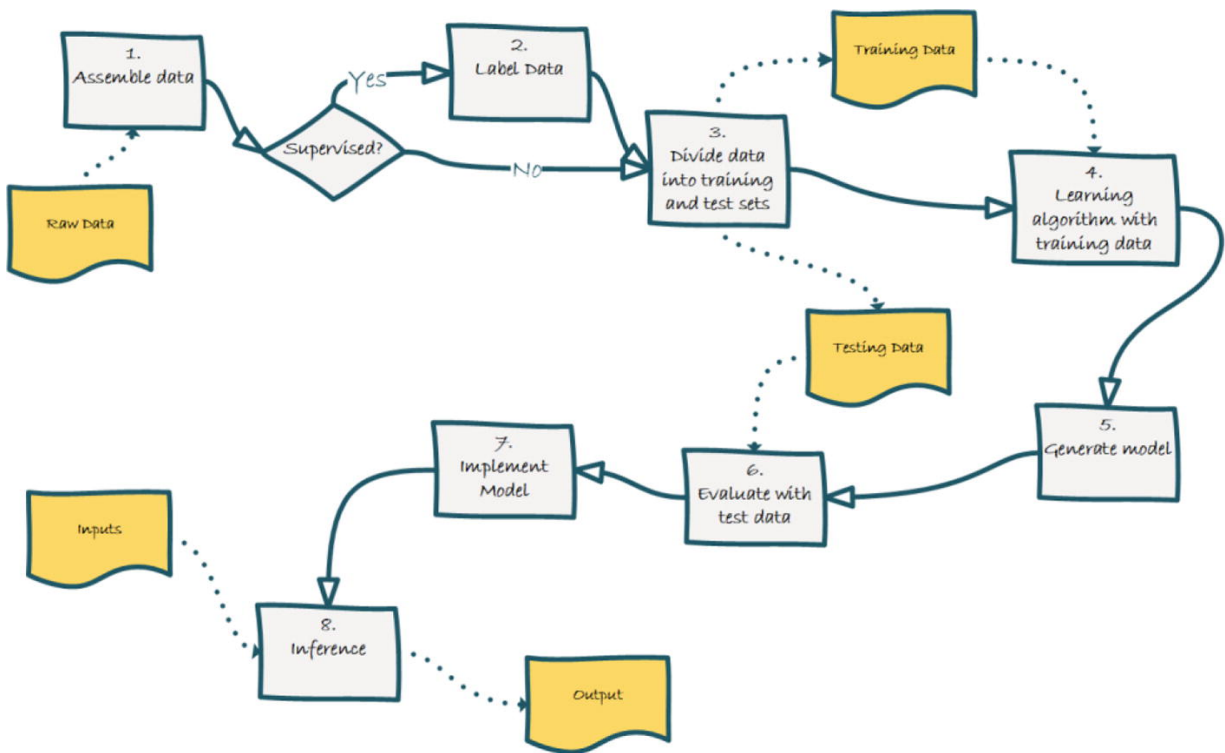


Figure 2-24 A generic machine learning process

1. In data assembly, the data is collected, and we must ensure all the elements necessary to train the model are included. This initial step often includes data

transformation and sanitization to prepare it for use. Many statistical evaluations can be used to evaluate data distribution, detect outliers, and deal with missing data. Decisions about what to do with outliers and missing data are made during this step. For example, deciding whether to ignore missing data, remove items with missing data, or impute the values for missing data. In my experience, this initial step can account for as much as 75% of the effort in developing an ML model.

2. Next, the data must be divided into a training set and a testing set. The testing set is set aside to test the developed model after training. There are no set rules for how much data should be used for testing versus training. However, a typical classification model development might set aside 25% of the data for testing. A cardinal rule of ML is not to use any testing data during training. The testing data is used to see how well the resulting model will perform on unseen examples, in other words, how well it generalizes.
3. Next, the ML algorithm is chosen. Selecting the algorithm is an important step and is based on many factors, including what question is being answered, what data is available, and any processing requirements.
4. For supervised learning, the data must be labeled appropriately. For example, when building a model to classify transactions as fraudulent or valid, each transaction used for training and testing must be labeled as either fraudulent or valid. If using an unsupervised ML algorithm, this step is skipped since unsupervised learning works on unlabeled data.

5. Training using the selected algorithm begins once the data is ready and the method is selected. Often, this step is iterative as parameters are changed to improve the model.
6. The training generates a model that can be applied to other data. Preliminary evaluation of the model results with the training data determines the in-sample error rate. If the results are not acceptable, algorithm parameters can be adjusted to repeat steps 5 and 6.
7. After generating the model, the model is evaluated using the testing data. The model is applied to the test data to determine the out-of-sample error rate. Using the example of fraudulent transactions, the model is applied to the test data to determine the number of false positives and negatives. Cross-validation techniques, such as k-fold cross-validation, can be used to get a more reliable estimate of the model's performance on unseen data. Testing with the testing data can also help uncover issues related to overfitting the model to the training data. If the results are unsatisfactory, there are three options:
 - a. Discard the model.
 - b. Adjust the algorithm and retrain.
 - c. Retrain with a different algorithm.
8. If the results of the testing are satisfactory, the model is then implemented.
9. When the model has been implemented, this is considered the inference stage. The model is now processing previously unseen data and performing its

objective, such as classifying, categorizing, predicting, or detecting anomalies.

Summary

There are many approaches to ML, and no one model or process will fit all applications. The question to be answered and the available data will determine the optimal ML strategy. Supervised learning is often used for classification, with algorithms such as decision trees, random forests, SVM, kNN, and naïve Bayes. Supervised learning can also be used to predict values using algorithms such as linear and multiple linear regression. With supervised learning, the elements are labeled, such as transactions marked as valid or fraudulent.

Unsupervised ML is used to discover interesting relationships, anomalies, or groupings using unlabeled data. MBA is a powerful unsupervised algorithm that can find associations within the data. This algorithm originated in marketing to improve cross-selling and product placement but has been adapted to many other use cases. Many ML algorithms, including kMC and DBSCAN, can group items based on their similarities. These clustering algorithms can also help detect outliers or anomalies by identifying elements furthest away from any identified clusters.

ANNs attempt to imitate the human brain in analyzing and interpreting data. These algorithms are comprised of artificial neurons inspired by the workings of biological neurons. A powerful DNN can be created by stringing together many levels of artificial neurons. A basic feed-forward DNN is a multilayer perceptron. An RNN is a DNN with feedback loops allowing it to consider future states, making it well-suited for time-series data and natural language processing. A CNN is a DNN that is often used in

image classification and facial recognition. The convolution layers extract features from the underlying image to assist in completing the defined task.

3. AI for Defense

Employing AI for cybersecurity offers tremendous benefits and has become vital in many security solutions. AI-based security tools have become commonplace, helping prevent and respond to attacks by analyzing patterns of previous attacks. However, to date, AI has mostly had an incremental impact on cybersecurity, improving and enhancing longstanding functions. Detecting and triaging potential attacks has seen the most significant use of AI within cybersecurity. AI's ability to analyze tremendous amounts of data from disparate sources and detect indicators of possible attacks makes it well-suited for threat detection. Therefore, most early applications of AI in cybersecurity focused on threat detection, such as malware, intrusion, and spam detection. During the late 2000s and early 2010s, ML algorithms became quite common within many threat detection products.

Beyond detection, AI is enhancing and automating many cybersecurity functions, with new applications being added at an incredible pace. Vulnerability discovery and management, threat intelligence, and risk scoring are examples of functions leveraging AI's power. Also, like in other industries, cybersecurity is seeing increased use of generative AI to augment and automate many heavily

manual processes, from security operations to governance. Security teams can use generative AI to reduce the time spent on routine tasks, allowing for strategic allocation of resources. It is difficult to conceive of any processes within security that have not or will not be enhanced by AI.

Managing an effective cybersecurity program requires leveraging AI across all critical security functions. Cybersecurity products implement AI for many use cases, including spam filtering, intrusion detection, governance, phishing detection, malware detection, and anomaly detection, as depicted in Figure 3-1. The following sections highlight some of the many of the uses of AI in cybersecurity.

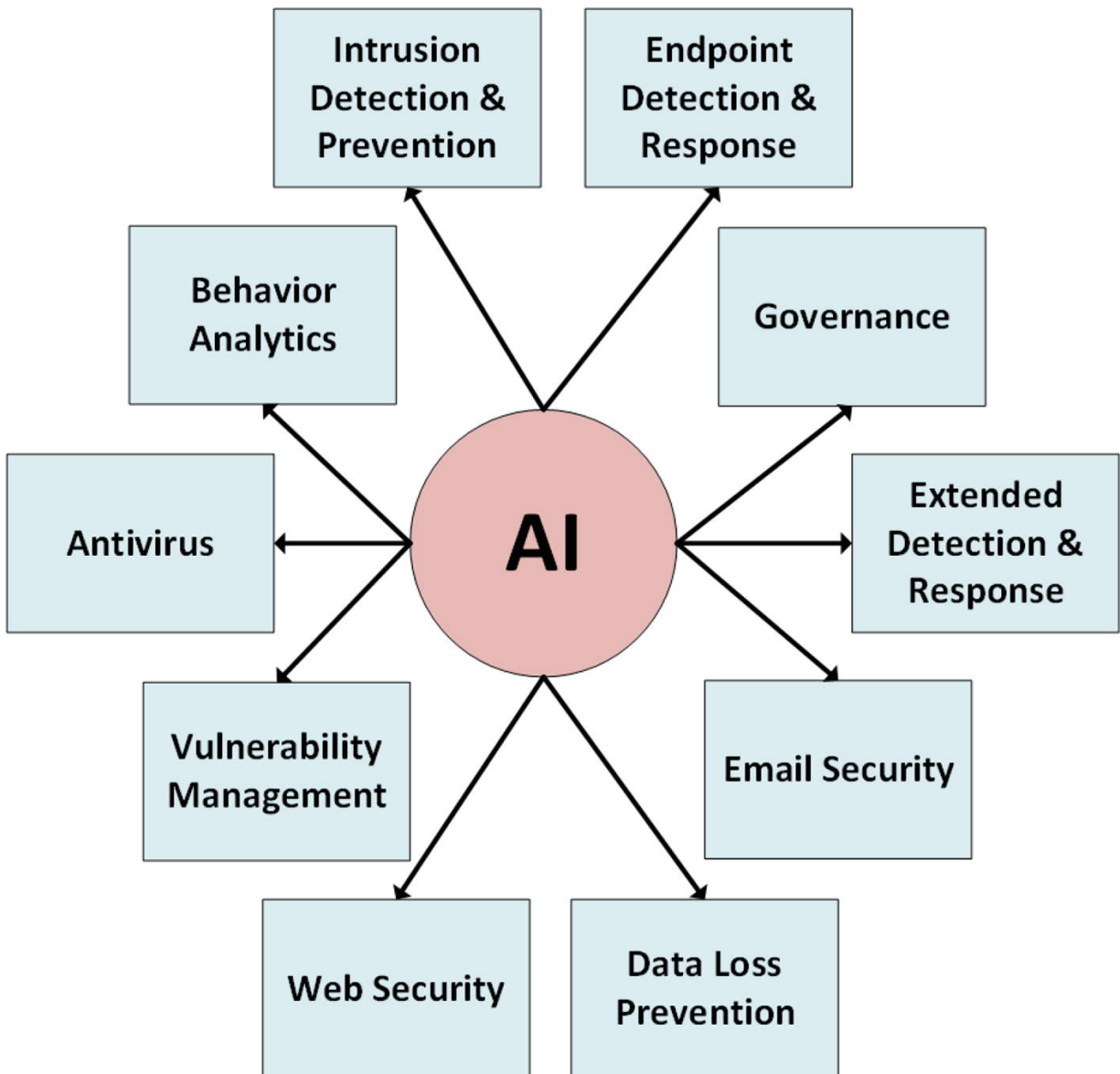


Figure 3-1 AI plays a vital role in most security tools and services

Email Security

Spam

Spam detection was perhaps the first cybersecurity service to incorporate ML, beginning in the 2000s. Before the introduction of ML, spam detectors typically relied on keyword matching from lists of words common to spam messages and block lists of known malicious IPs. However,

these early spam detection methods blocked numerous legitimate emails, rendering them highly inefficient.

The introduction of ML for spam detection followed a straightforward path. The process involved first collecting a large corpus of emails labeled as spam or legitimate. The emails were parsed into individual words, which were used for supervised training. The trained models determined the probability of an email being spam based on the probabilities of the individual words appearing in phishing emails. The resulting ML model would then analyze new emails, and those receiving a spam probability above a predetermined threshold would be blocked. Over the ensuing years, ML methods for spam detection have seen incremental improvements by incorporating additional information, such as extracting email header information, analyzing phrases and synonyms, and applying weights based on where the words appeared. In addition, many ML algorithms have been used for spam filtering, including SVMs, RFs, naïve Bayes, and DNNs (Janez-Martino, Alaiz-Rodriguez, Gonzalez-Castro, Fidalgo, & Alegre, 2022).

Phishing

Much like spam detection, labeled data for phishing detection is readily available. Therefore, email providers and security systems often incorporate supervised ML methods to augment email filters and combat phishing. Developing a phishing detection model follows a similar approach to spam detection. Many lessons learned from the early days of spam filtering helped jumpstart phishing detection. Phishing and legitimate emails are collected and split into training and testing datasets to develop a phishing classifier. The discriminative features are extracted and selected, including header information and words in the email body. A supervised ML algorithm, such as naïve Bayes, SVM, decision tree, or DNN, is then applied to the training data to develop an initial model. Often, this

development will be recursive, as the parameters are tuned until the model achieves acceptable results. The resulting model is then applied to the test dataset to determine its performance against unseen samples.

Even with ML models and email gateway advancements, phishing detection is not foolproof. Some phishing emails continue to reach users' inboxes. According to a survey conducted by Egress, 94% of the participating organizations were victims of phishing attacks during 2023 (Egress, 2024). The easy access an attacker gains with a successful email attack explains why 80-95% of attacks begin with phishing (Comcast Business, 2023). The percentage of phishing emails making it through modern detection systems is extremely small. However, it only takes one user clicking on one phishing email to cause significant harm to an organization. Therefore, many organizations also emphasize security awareness training.

**There was a 1,265% increase
in malicious phishing emails
in 12 months following the
launch of ChatGPT
(SlashNext, 2023).**

One traditional defense against phishing is security awareness training, in which the users are trained to spot phishing emails. This training often focuses on spotting such things as odd URLs, grammar errors, and misspellings as indicators of phishing attacks. Organizations supplement the training with phishing exercises, in which fake phishing emails are sent to the users to gauge their response and provide on-the-spot reinforcement learning. Some organizations also include dynamic banners in emails to

describe the risks to the user, especially when the email contains links or attachments.

However, the availability of generative AI, including generic pre-trained (GPT) LLMs, is lowering the phishing barrier for bad actors and improving phishing quality. The rapid improvements in GPTs make it trivial to create a quality phishing email with proper grammar and spelling. These LLMs can also create phishing emails in various moods, styles, and languages. According to a SlashNext survey of cybersecurity professionals, there was a 1,265% increase in malicious phishing emails in the 12 months following ChatGPT's launch (SlashNext, 2023). The period also saw a 967% increase in credential phishing. The current ML-based detection methods will catch the vast majority of these emails. However, the days of relying on end users to spot well-crafted phishing emails are coming to an end. Therefore, research increasingly focuses on using AI to detect LLM-generated phishing emails.

Email Account Takeover

Email account takeover, in which an attacker gains control of a user's email account, is a particularly troubling and challenging problem within cybersecurity. Once in control of an email account, the attacker can launch phishing attacks that bypass email security systems or conduct business email compromise (BEC) attacks. With access to a legitimate email account, attackers can craft highly targeted emails to others within the organization, partners, customers, or clients.

BEC attacks frequently seek to get the recipient to transfer funds. Invoice fraud is an example of an attack that incorporates BEC. An attacker will compromise an email account, often through phishing, at a supplier of their target. Once in control of the supplier's email, the attacker can impersonate the supplier and send invoices to accounts payable at the target company. In another type of BEC, the

attacker impersonates an employee and, from that employee's email account, contacts the payroll department to change direct deposit information for the victim employee.

One Treasure Island (OTI), a charity organization based in San Francisco, fell victim to a BEC attack in 2021 (Rundle, 2021). The non-profit organization was redeveloping a former Naval facility, Treasure Island, for low-income and homeless people. OTI was lending funds to a member organization related to a project to develop affordable housing. The attackers gained access to OTI's third-party accounting service's email system. The attackers then posed as the Executive Director of OTI and emailed the loan recipient, notifying them that the funds would be delayed. With the recipient effectively delayed, the attackers took a copy of an invoice the member organization had previously sent to OTI. They changed the banking information and sent three invoices to OTI's Executive Director. OTI made the three installments into the attacker's designated bank account, totaling \$650,000. Later, OTI's Executive Director discovered the fraud when she spoke to the intended loan recipient, who notified her that they had not received the first installment. Though OTI reported the incident to the FBI, they declined to investigate it. In the end, OTI recovered only \$37,000 that the attackers left in the fraudulent bank account.

Like with phishing, according to SlashNext, hackers commonly use ChatGPT to craft the emails used in a BEC attack (SlashNext, 2023). With their capability to create emails in many styles, both personal and professional, ChatGPT and other LLMs are a valuable assistant to attackers. Leading email security products are incorporating generative AI, natural language processing, and ML to address the growing concerns with AI-generated emails used within a BEC attack. A typical BEC email will play off the recipient's emotions, often with a sense of

urgency. Defenders can leverage existing BEC emails to create many examples using generative AI. Then, supervised algorithms can be trained with the generated examples to build a classifier. The resulting model can then detect and block or quarantine possible BEC emails.

Another recent twist on email security leverages ML to help detect email account takeover by determining the probability that a given email is from the supposed sender. In this case, an ML model is trained using examples of emails written by a given person. The idea is that within a given organization, an email writing style profile could be created for each person. Then, internal email within the company can be analyzed to detect email account takeover. However, if an attacker gains access to a person's emails, the attacker could attempt to train an LLM using that person's emails. If successful, the attacker would then be able to create emails in that person's style, which could bypass email security.

Of course, not all BEC attacks will be detected, even with well-configured traditional security controls and the latest ML-enabled tools. Therefore, in addition to cybersecurity solutions, companies can leverage process controls to mitigate many BEC attacks. Processes involving fund transfers or critical account information should require additional process approvals, such as an out-of-band confirmation with the apparent requestor.

Malware and Ransomware Detection

Malware, including ransomware, continues to be a formidable cybersecurity problem. According to Chainalysis, which analyzes ransomware transactions, in 2023, a record of \$1.1 billion in ransomware payments was made (Chainalysis, 2024). This total surpassed the prior record of \$983 million set in 2021 and nearly doubled 2022's total, which had seen a precipitous drop to \$567

million. Of course, the ransom payments only tell a small part of the story. The economic impact on victims is often far more significant when adding in productivity loss, loss of revenue, and recovery costs. Even in the estimated 25-30% of cases where the ransom is not paid (Townsend, 2024), these other costs can be devastating. For example, the estimated economic impact of the 2023 ransomware attack on MGM Resorts exceeded \$100 million (Chainalysis, 2024).

Colonial Pipeline Ransomware Attack

The ransomware attack on Colonial Pipeline in 2021 received national attention, even leading to an emergency declaration by President Biden due to its impact on fuel distribution along the East Coast, where the company supplies nearly half of the fuel (Kerner, 2022). On May 7, 2021, an attacker group known as DarkSide gained access to the company's network and stole 100 GB of data, then infected systems, including billing and accounting, with ransomware. Although the ransomware did not infect the systems that control distribution, Colonial Pipeline shut down distribution to avoid further spread. The company, working with the FBI, paid \$4.4 million in ransom to obtain the decryption keys on the first day of the attack. The attackers breached the systems using exposed credentials for a virtual private network (VPN) account.

Fearing a gas shortage, residents in many southeastern states began panic-buying car fuel. This panic-buying led to long lines at gas stations and caused actual shortages in some areas. Due to the impacts, the President Biden declared a state of emergency on May 9. Colonial Pipeline restarted normal distribution operations on May 12. The Department of Justice was able to reclaim about half of the ransom payment.

Malware detection focuses on determining if a specific file is malicious. Early antivirus programs would detect known malware based on the exact matching of specific indicators, such as filenames, hash values, and specific byte sequences in the file. This early malware detection relied on maintaining long signature lists and performing regular scans. During the scans, the antivirus software compared the files on the system to the updated signature list, and any matching file would be considered malicious. Maintaining the signature lists and processing required during scans negatively impacted the performance and effectiveness of these early signature-based antivirus products. Then, the growth of polymorphic and metamorphic malware made signature-based antivirus functionally useless. Traditional antivirus systems adapted to the abundance of polymorphic and metamorphic malware by incorporating behavior-based analysis, which examined the sequence of actions within the code instead. However, these systems proved complex and computationally expensive. Therefore, researchers and vendors began exploring ML-based approaches to malware detection.

Two main categories of malware detection are static and dynamic analysis. In static analysis, the malware is detected by analyzing the given file without executing it. Static analysis forms the basis of traditional malware detection, looking at code attributes, such as the action sequence, without executing the code. Dynamic analysis analyzes the behaviors and actions of the given file during execution. Since dynamic analysis requires the possibly malicious code to be executed, it is usually performed in a controlled environment or sandbox. However, dynamic analysis can also be performed on any file executing on a system to detect malicious behavior and interrupt execution. Machine learning can enhance both static and dynamic malware detection, as shown in Figure 3-2.

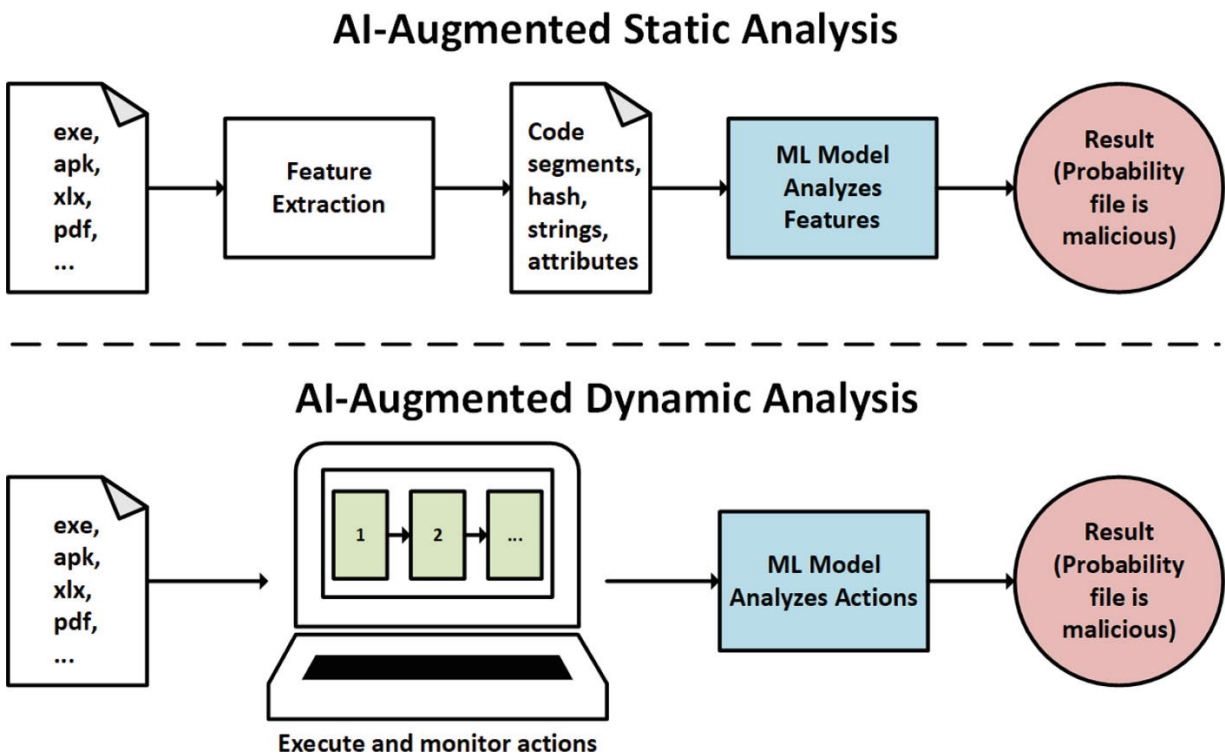


Figure 3-2 AI can augment static and dynamic malware analysis

Static analysis, which is effective at detecting known malware, can be augmented with ML. Unsupervised clustering algorithms can group similar malware files and identify the associated properties. When labeled data is available, supervised algorithms can be trained with the features extracted from known malware. The resulting ML model can then be used to classify other files. Another recent advancement in static analysis is using DNNs to transform files into images. The images of known malware can then be used in a CNN-based classifier to detect similar files. Even with the ML-based improvements to static analysis, such analysis remains susceptible to evasion. Malware variants, in which the malware code is modified without changing the malicious behavior, can often evade static analysis detection. Also, polymorphic malware, in which the malware executables are dynamically modified, can be especially difficult to detect with static analysis,

Dynamic analysis aims to address issues with malware variants and polymorphic malware. Instead of analyzing the

features of a given file, dynamic analysis focuses on analyzing the file's behavior during execution. Many ML-augmented dynamic analysis solutions leverage clustering algorithms. These ML models can create groups based on malware variants that exhibit similar behavior. Then, the behaviors of new executables can be compared to these groupings. Based on defined thresholds, executables that are similar enough in their actions can then be blocked or quarantined.

Device Profiling

Understanding what devices are on the network can be challenging, especially with the proliferation of IoT devices. Organizations often use device profiling to collect information about devices that connect to the network, which can then be used for asset inventory and security. The information is collected through either active or passive methods. With active device profiling, the device is queried to collect data such as the OS, device type, and MAC address. Passive profiling collects the information by examining network requests from the device. The collected information is then assembled to create a device profile.

The collected device profiles can ensure an accurate, up-to-date IT, IoT, and OT asset inventory. Organizations can also use the device profiles to ensure unwanted or unknown devices cannot connect to the network. For example, the organization might require that user systems connecting to the network have the most recent version of the OS, including necessary security patches, before allowing access to the network.

Going beyond the static information that can be extracted from individual network messages or querying the OS, AI enables device profiling systems to profile behavior. For example, a security camera would have a limited set of network requests appropriate to its function.

Also, the network messages from the camera would follow a typical pattern, including the timing of the messages and the amount of data sent. Furthermore, other security cameras on the network likely exhibit similar behavior. An AI-powered device profiling system could detect if the camera began exhibiting behavior outside of its appropriate usage or expected behavior, such as traffic that would typically come from a laptop. Such activity could indicate that someone is spoofing the camera's MAC address. The device profiling system could quarantine the security camera upon detecting suspicious activity. Figure 3-3 shows how ML can augment device profiling to detect inappropriate traffic and quarantine a device.

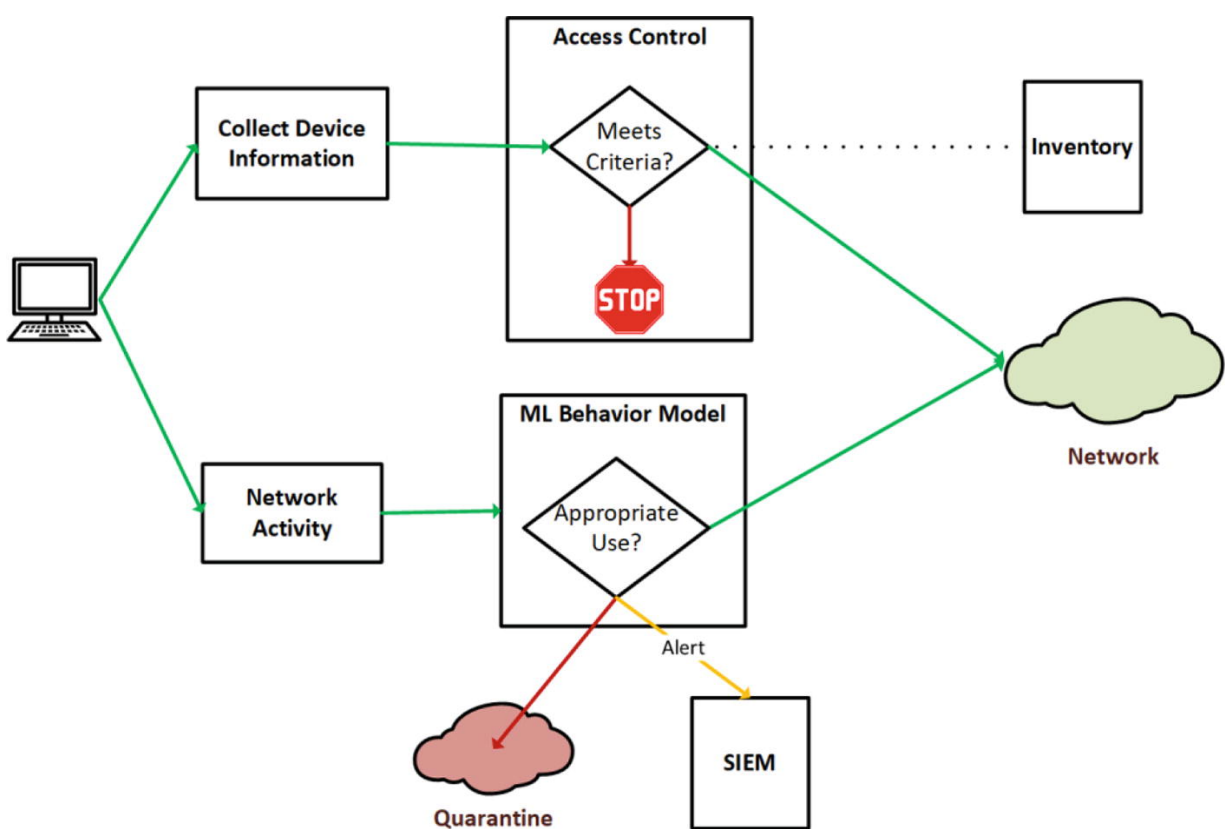


Figure 3-3 AI-augmented device profiling can detect inappropriate device activity and quarantine the device. Access control can provide the first layer of defense, ensuring only devices that meet the criteria, such as having the latest patches, can connect. Once connected, ML can detect inappropriate traffic for the device type and quarantine the device.

Intrusion Detection

Intrusion detection and prevention systems (IDPS) attempt to identify malicious activity by inspecting the network traffic, which can include simple network management protocol (SNMP), full packet captures (PCAP), network flows (NetFlow), or domain name system (DNS) records. Due to privacy concerns and storage requirements for PCAP, NetFlow analysis is typically preferred over PCAP. An IDPS can be host-based (installed on a specific host) or network-based (typically installed as a network appliance). A host-based intrusion detection system (HIDS) inspects network traffic to and from the host upon which it is installed. In contrast, a network-based intrusion detection system (NIDS) looks at all traffic traversing the network. These systems, both HIDS and NIDS, analyze network traffic behaviors that could indicate an attack.

IDPSs generally use misuse-based or anomaly-based (or both) methods to detect possible malicious behavior. Misuse-based detection compares current traffic to previous attack traffic and alerts based on their resemblance. These misuse-based systems often rely on known indicators of compromise (IOCs) seen in previous attacks. In contrast, anomaly-based detection takes a snapshot of normal traffic and alerts on traffic that deviates from the established baseline.

Misuse-based IDPSs generally have higher processing speeds and lower false positive rates than anomaly-based systems. However, since misuse-based systems rely on identifying known attack patterns, they cannot detect novel attack patterns. The anomaly-based IDPSs, since they look for unusual behavior, can detect new types of attacks. However, such systems can produce many false positives. Another issue with anomaly-based systems is that the baseline traffic used to train the model could include

malicious activity if a threat actor was already operating in the network. Table 3-1 summarizes the pros and cons of misuse and anomaly-based detection methods.

Table 3-1 Comparing misuse-based and anomaly-based intrusion detection

Detection Method	Pros	Cons
Misuse	• High processing speed • Low false positive rates	• Cannot detect novel attacks • Require constant updating of IOCs
Anomaly	• Can detect novel attacks • Does not require updating IOCs	• Lower processing speed • High false positive rates • Considers all previous traffic as normal

Machine learning has a long history in intrusion detection, dating back to the 1990s, and now most IDPSs leverage machine learning to analyze traffic. Early research focused on misuse-based approaches. Unlike traditional misuse detection, ML-based misuse detection determines the probability that the given network traffic is similar to a previous attack. Early researchers applied various supervised ML classifiers to labeled network traffic profiles to detect known attacks. However, acquiring the labeled data for an extensive network that a supervised method requires for a NIDS can be daunting.

Over time, researchers and vendors applied many ML algorithms to address misuse detection. However, no single ML algorithm performed consistently better across the broad spectrum of use cases. Therefore, most misuse-based ML detection today leverages ensemble methods that use multiple ML classifiers, as shown in Figure 3-4. With this ensemble approach, the final decision is typically based on polling the results from the multiple classifiers. The ensemble approach also helps avoid overreliance on a single ML model.

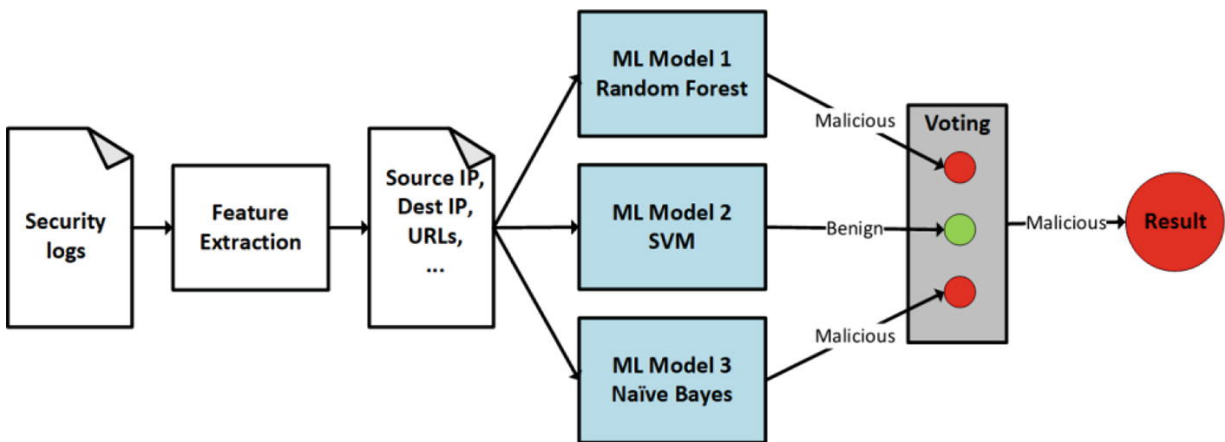


Figure 3-4 Using an ensemble of ML models for intrusion detection. Three different ML models independently analyze the traffic. The results of the three models are polled to determine the classification.

Later, IDPSs were augmented with ML-based anomaly detection. This anomaly detection employs unsupervised methods, creating clusters of normal traffic. Once these clusters are created, the IDPS can alert on traffic that deviates from the established norm. When developing an ML anomaly-based detection method, the focus is on how to define *normal* traffic. When dealing with an extensive network, the traffic can be quite variable, making it challenging for unsupervised methods to identify normal behavior correctly. This difficulty in identifying normal behavior can lead to excessive false positives. Furthermore, as the organization's environment or procedures change, what is considered normal traffic for the network can experience significant change, rendering the previously developed models ineffective.

Behavior Analytics

Behavior analytics seeks to detect threats by defining normal behavior and then detecting deviations from normal behavior. Data mining and ML can identify normal behavior for users, such as what data the user accesses, what programs the user runs, at what time the user accesses the system, how long the user remains on the system, and what

systems the user accesses. These tools can also identify normal system behavior, including what process the system executes and in what order, the background tasks running on the system, the system's data access patterns, and user activity.

Once normal behavior is defined for the user or system, after the initial learning period, ML algorithms are used to discover outliers. The outliers can be time-based, which detects when a user's or system's behavior changes over time. The algorithms can also detect peer-based anomalies in which the user's or system's behavior differs from a peer group. For users, the peer group could be other users in the same role, on the same team, or performing similar job functions. For systems, the peer group could be systems performing the same function, such as comparing a domain controller to other domain controllers or comparing a Web server to others in the same cluster.

User Behavior Analytics and Insider Threat Detection

User behavior analytics (UBA) can assist in detecting possible insider threats, whether intentional or inadvertent. Insiders are authorized users with legitimate access to an organization's systems or information assets. Intentional insiders act with malice, whereas inadvertent insiders cause accidental harm. Insiders present significant challenges for traditional detection systems. Perimeter defenses, such as NIDS and firewalls, cannot detect the insider since the insider has legitimate access to the network. Perimeter defenses guard against unauthorized access originating external to the network. The insider, however, is already within the security perimeter. Traditional log monitoring can also overlook insider attacks. A malicious insider's actions resemble normal operations since the insider possesses the rights and

privileges necessary to mount the attack. Also, when an attacker obtains a user's credentials, often due to an inadvertent insider's actions, that outsider will look like a legitimate insider to most systems.

Most insider threats are unintentional. Accidental insider threats include the accidental publishing of data, errors in system configurations, failure to encrypt data, lack of user awareness, loss of a computer, and assignment of excessive privileges. Inadvertent insider threats include unwitting accomplices, careless employees, and resourceful workers. The unwitting accomplices try to be helpful. Attackers will seek to exploit the unwitting accomplice's kindness and willingness to help others, often through social engineering. Careless employees disregard the signs of danger, perhaps because they are in a hurry, under pressure, or ignored security training. This user clicks on that phishing email without stopping to think or accidentally sends confidential data to the wrong customer because he is in a hurry or is not following processes. Finally, the resourceful worker wants to get the job done. This employee believes she is helping the organization when, in reality, her resourcefulness could put the company's information at risk. Maybe she needed to get the plans to a client immediately, but she felt she did not have time to use the proper channels, which would have encrypted the information and used secure message delivery. So, she uploaded the plans to a cloud-based file-sharing site that did not have appropriate controls in place.

Many of the risks posed by inadvertent insiders can be addressed with traditional security controls, including access control, data encryption, Web content filtering, and data loss prevention (DLP). However, UBA provides additional security, especially when the user's actions differ from his peers or past actions. Also, when an attacker obtains a user's credentials, thereby appearing to other security systems as an insider, UBA can help identify the

changes in that user's behaviors. Figure 3-5 depicts how UBA can augment access controls, encryption, and DLP to enhance system and data security.

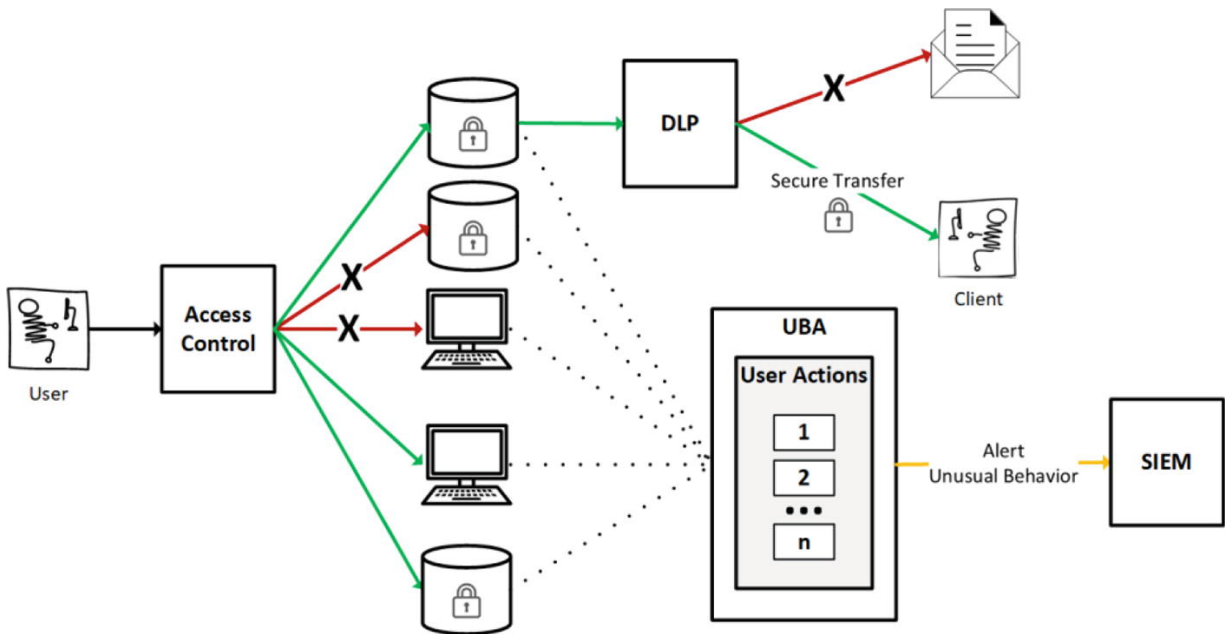


Figure 3-5 Augmenting insider threat detection with UBA. Access control provides an initial layer of defense, only allowing authorized users to connect. DLP helps to ensure that authorized users are not inappropriately sending sensitive data. UBA analyzes the user's actions and sends alerts to the security incident and event management (SIEM) of any unusual behavior.

Intentional insiders are malicious users who deliberately extract or exfiltrate data, tamper with the organization's resources, destroy or delete critical data, eavesdrop with ill intent, or impersonate other users. The actions of malicious insiders fall into three broad categories: sabotage, theft, and fraud. Malicious insiders can cause significant damage to an organization because insiders have authorized access to sensitive information, including intellectual property, customer data, marketing plans, and financial records. The motivations for intentional insider threats include financial reward, grievances against the employer, and espionage.

Traditional security systems, such as access control, can struggle to identify intentional insiders since these users have legitimate access. Data loss prevention and Web

filtering could help prevent the user from sending sensitive data if such action violates defined rules. Also, properly defined access control that adheres to the concept of least privilege can limit the potential damage. However, assets to which the user has necessary access remain vulnerable. Implementing UBA could assist in such cases, but only if the user's behavior detracts from previous actions or the behaviors of the user's peers. Detecting and preventing intentional insider threats when the user has necessary access, the actions do not violate established rules, and the user actions do not differ from established baselines remains a complex problem to solve. Mitigating such risks requires tightly configured security controls, with UBA providing an additional detection layer.

Challenges of UBA

Predictive analytics within UBA systems can make security more proactive by providing continuous, real-time evaluation and detection. ML can significantly reduce the amount of human interaction needed to configure and maintain monitoring solutions but cannot eliminate the need for human interaction. ML-based UBA requires human interaction to determine whether the UBA is correct to avoid creating many false positives.

Detecting anomalous activity can result in a high rate of false positives. Most anomalies are not malicious; therefore, anomaly detection will create many false alarms. Alarms generated from benign anomalous user behavior decrease the effectiveness of many UBA solutions and can increase the burden on security analysts to analyze the alarms. The following paragraphs describe proposed methods to help address the issue of false positives in anomaly detection for insider threats.

Normal $\neq$ Good

Anomaly detection, such as UBA, can result in many false positives. However, one must also be cognizant of possible false negatives. If a threat is already active in the environment, the ML model may learn this as normal activity, thereby ignoring it.

Semi-supervised ML algorithms can help filter the false alarms generated from the baseline anomaly detection. Over time, the semi-supervised training can help improve anomaly detection by applying feedback from cybersecurity professionals. However, one must be cognizant of the possible tradeoffs when applying feedback to decrease false positives. Decreasing false positives can often lead to a decrease in true positives. Therefore, keeping a close watch on the anomaly detection performance is necessary to ensure the true positive rate remains acceptable.

Objectivity is a critical benefit of using an ML-based UBA platform for insider threat detection. The data analytics behind a UBA platform will not pick favorites or decide not to report a security policy violation. A UBA platform will provide the same result given the same dataset. However, this objectivity can also pose a challenge. UBA systems cannot discern user intention. A user who makes an error or is curious might appear to the UBA the same as a malicious insider. Human analysts are still required to discern whether the alerts from the UBA signify user error, misconfigurations, or malicious activity. Two fundamental considerations are who is responsible for decision-making and whether the system is proactive or reactive. Organizations must determine when and if a

human must be involved in decision-making. The degree to which the system is proactive can have significant ethical and legal considerations. If the UBA system is proactive, then predictive analytics might be used to predict the probability that a user will conduct an attack. A company taking disciplinary action against an employee to thwart a possible attack before the user conducts the attack could raise ethical and legal concerns.

Explainability is also a concern for cases where the organization takes disciplinary action against an employee. Therefore, the UBA system should adhere to the principles of XAI. With XAI, the system provides details on how and why it arrived at a decision. In the case of UBA, this information would detail why the anomaly was alerted. If disciplinary action is appropriate, the UBA system should not make that decision. Instead, the details of the anomaly, along with monitoring details from all involved systems, should be presented to a human agent for decision-making.

Alert Management

The expanding attack surface generates an increasing number of alerts from a plethora of security tools. These alerts inundate security operations centers (SOC), which must quickly triage and prioritize. SOC personnel must scour the haystack of alerts, looking for the needle that indicates a real threat. According to a 2023 Morning Consult and IBM study, false positives and low-priority incidents account for 63% of all incidents reviewed by SOC personnel (Morning Consult; IBM, 2023). The triage and prioritization process can be time-consuming, with SOC personnel spending 32% of their time investigating incidents that do not turn out to be true positives (Morning Consult; IBM, 2023).

Security vendors and teams are increasingly looking to AI to help manage alerts and reduce the noise. In the

Morning Consult and IBM study, 86% of the respondents stated that AI-driven analytics and prioritization would increase threat detection and response efficiency (Morning Consult; IBM, 2023). In a separate study, the IBM Institute for Business Value surveyed cybersecurity executives and found that 93% were already using or considering AI to enhance security operations (IBM Institute for Business Value, 2022). The respondents who implemented AI cited that AI's ability to triage alerts and reduce false positives reduced the time and cost associated with initial detection. By using AI to distinguish the true positives from the false positives and true negatives, security teams can reduce the alert fatigue suffered by many SOC analysts. The improved signal-to-noise ratio allows analysts to focus their valuable skills on addressing those risks that pose the greatest threat.

Vulnerability Management

The National Vulnerability Database (NVD), which tracks discovered software vulnerabilities, added 28,831 vulnerabilities in 2023, or nearly 80 per day (Intel471, 2024). The number of vulnerabilities released puts an untold strain on security teams to track, prioritize, and patch them. While the NVD contains numerous vulnerabilities, only a small percentage had active exploits. Therefore, the Cybersecurity and Infrastructure Security Agency (CISA) created a Known Exploited Vulnerabilities (KEV) catalog of vulnerabilities that have active exploits, with 187 added in 2023. The KEV can help drive priority patching of exploited vulnerabilities. Federal agencies have mandated timelines to address KEVs. However, it does not help organizations determine applicability, apply risk-based priority specific to the organization, or manage the patching of vulnerabilities. The NVD, KEV, and Common Vulnerability Scoring System (CVSS) are inputs to a risk-

based vulnerability management program, but they should not be the drivers of it.

Scanning a complex network for known software vulnerabilities can produce an expansive list of vulnerabilities that quickly become unmanageable. Organizations cannot patch every instance of vulnerable software instantly. They need a way to prioritize the patching of vulnerable assets. However, relying solely on the severity score from CVSS does not fully represent the contextual risk to the organization, as it does not account for factors like asset criticality, existing mitigations, or the organization's specific threat landscape. Organizations can have a large and ever-expanding IT asset inventory. Determining the relative risk of a breach that each asset, including each software package, presents in a large, dynamic environment is extremely difficult, if not impossible, to do manually. Therefore, vulnerability management teams are increasingly turning to AI for assistance, including understanding the software within the network, prioritizing patches and mitigating controls, and testing vulnerability exposure.

When a new vulnerability is released, the first step for most organizations is to determine if the vulnerability applies to them. Networks can contain a tremendous amount of software packages and, frequently, many versions of each software package. Often, vulnerabilities and their related exploits apply to a limited list of specific versions of software components. Therefore, the initial determination of applicability can be challenging, especially for a primarily manual process. Even after determining that the vulnerability applies to the organization and what assets are vulnerable (which can be time-consuming and error-prone), the organization must prioritize the remediation.

Fortunately, with an AI-powered asset inventory, ML models can analyze systems for vulnerabilities. A

comprehensive, accurate asset inventory and ML analysis against that inventory make determining the applicability of a vulnerability trivial. Of course, the work does not stop with the determination that the vulnerable software resides within the environment. The risk that vulnerability poses to the organization must be determined to drive remediation priority.

AI can provide tremendous value in prioritizing vulnerability remediation. AI models can determine the relative risk by examining many factors beyond the core vulnerability score, including the asset's value and importance, the data and services on the system, placement within the environment, and the presence of other mitigating controls. Organizations can then use the enhanced risk scoring and prioritization to drive remediation efforts. Such prioritization allows the company to focus its limited resources on addressing the most critical risks while not losing sight of other vulnerabilities that must be addressed.

The Log4Shell vulnerabilities and associated exploits, which took the tech industry by storm in 2021, provided a great example of the importance of accurate, comprehensive software inventories. Log4Shell refers to several vulnerabilities discovered in Apache's Log4j library, a popular logging solution used in numerous applications. The vulnerabilities, which are easily exploited, allow attackers to conduct remote code execution attacks on systems running the affected versions of Log4j. The widespread use of Log4j and the ease of exploiting the vulnerability caused panic within the tech industry. Two days after an exploit was discovered, the Cybersecurity and Infrastructure Security Agency (CISA) issued an emergency directive that instructed federal agencies to remediate the vulnerability urgently (Hill, 2022). Federal agencies were given less than a week to either patch affected systems or pull them from the Internet. Also,

within a few weeks, the Federal Trade Commission (FTC) warned US organizations that they could face punitive action if they did not address the vulnerabilities immediately.

With the vulnerability's high visibility, possible widespread business impact, and the FTC's warning, organizations scrambled to identify if and where the impacted Log4j libraries were used. This effort extended into months for many organizations, leading to exhausted analysts. In a survey of cybersecurity professionals by (ISC),² 52% said their teams spent weeks or more than a month responding to the Log4Shell vulnerabilities, with nearly half of the respondents stating they sacrificed weekends to their organization's response (ISC2, 2022). Despite the massive effort and focused attention, many organizations remained vulnerable one year after the initial exploit was discovered (Xiao, 2022). However, with the situational awareness provided by continuous inventories and prioritization, some security teams could quickly and confidently answer the question and begin the patching process based on risk-based insights.

Vulnerability Exploitation Prediction

The KEVs help users prioritize those vulnerabilities that have been actively exploited for immediate remediation. However, prioritizing those that have not yet been exploited is also essential. Users might consider whether a patch is available and the criticality of the vulnerability, possibly based on ML models that consider the risk to their organization. While users of software products struggle with vulnerability management, software vendors struggle with addressing vulnerabilities by providing timely patches to their customers.

In a reactive approach, software providers scramble to develop and release a patch once an exploit for a vulnerability is developed. This reactive approach is not efficient and introduces much risk. Therefore, software companies seek to address vulnerabilities proactively before an exploit is discovered. However, the number of vulnerabilities makes developing patches for each one impractical, especially since less than 3% of the vulnerabilities in the NVD are exploited (Almukaynizi, et al., 2019). Therefore, software vendors seek insights and tools to assist them in prioritizing vulnerability patch development.

The CVSS, managed by the Forum of Incident Response and Security Teams (FIRST), is not an effective predictor of a vulnerability being exploited. Instead, the CVSS is designed to convey the relative severity of a vulnerability and does little to assist companies in assessing whether or not the vulnerability is likely to be exploited. Therefore, researchers use ML models that leverage multiple data sources to aid in predicting if and when an exploit of a vulnerability will be seen in the wild. Such data sources include ExploitDB, Zero Day Initiative, threat intelligence feeds, scraping of dark websites and forums, and social media, such as Twitter. These approaches use several ML methods, including ANNs, logistic regression, SVM, natural language processing, and naïve Bayes, often combining multiple methods.

FIRST adopted an ML-based exploit prediction model in 2021, the Exploit Prediction Scoring System (EPSS), and released version 3 in 2023. The EPSS seeks to determine the probability that a given vulnerability will be exploited within the next 30 days. In other words, it is the probability that *any* exploit of the vulnerability will occur on *some* system in the wild.

The EPSS was developed by a FIRST Special Interest Group (SIG). The first version of EPSS used logistic regression to determine the probability that a vulnerability would be exploited within a year of discovery (Jacobs, Romanosky, Suciu, Edwards, & Sarabi, 2023). This initial model included only 16 features, which were extracted at the time of the vulnerability disclosure. The second version expanded to include 1,164 features and relied on the XGBoost algorithm (a gradient-boosted tree algorithm), greatly enhancing its predictive performance. With version 2, the SIG also changed to predicting exploitation within the next 30 days, aligning better with vulnerability management procedures. For version 3, the SIG sought to improve the precision of the predictions by expanding the sources of exploit data consumed by XGBoost classifier model. The changes led to an 82% improvement of the version 3 EPSS compared to version 2. Several other methods have been developed to predict the probability of vulnerability exploits; however, these are mostly vendor-specific or proprietary.

Table 3-2 shows an excerpt from the EPSS, version 3. For each CVE, the EPSS provides the score and percentile. For example, when this extract was done, CVE-2023-50968 had a 32% chance of being exploited within 30 days. This EPSS score was in the 96.9 percentile of all EPSS scores, making it among the most likely to be exploited.

Table 3-2 Extract from the EPSS from FIRST. The EPSS shows the probability that the vulnerability will be exploited within the next 30 days. The percentile shows the percentile ranking of the EPSS among all vulnerabilities.

CVE	EPSS	Percentile
CVE-2023-3656	0.01229	0.85192
CVE-2023-36953	0.12013	0.95288
CVE-2023-37265	0.09094	0.94544
CVE-2023-41774	0.00551	0.77248

CVE	EPSS	Percentile
CVE-2023-43187	0.11383	0.95149
CVE-2023-46279	0.04965	0.92735
CVE-2023-50968	0.32266	0.96964
CVE-2023-52251	0.02881	0.90623
CVE-2024-21626	0.05062	0.92823
CVE-2024-24141	0.00076	0.31945

Combining CVSS and EPSS can assist in prioritization by highlighting critical (high CVSS score) vulnerabilities with a lower probability of exploitation (low EPSS) or lower criticality vulnerabilities with a greater exploitation probability. Table 3-3 shows a small sample of CVEs with their EPSS and CVSS scores. The sample includes CVEs with similar CVSS scores, all in the high criticality range. The table shows that one CVE with a 7.5 CVSS score (CVE-202402879) is much more likely to be exploited within the next 30 days than the others, including those with 7.8 CVSS scores. CVE-2024-2879 is in the 75th percentile and is more than three times more likely to be exploited than the next highest EPSS shown (CVE-2024-29748) despite having a lower CVSS.

Table 3-3 Combining EPSS and CVSS shows that CVE-2024-2879 is much more likely to be exploited (75.6% chance of exploitation within the next 30 days) than the others, including those with higher CVSS scores.

CVE	EPSS	Percentile	CVSS
CVE-2024-29748	0.00149	0.50329	7.8
CVE-2024-20772	0.00059	0.24057	7.8
CVE-2024-20797	0.00053	0.20258	7.8
CVE-2024-29062	0.0005	0.18081	7.8
CVE-2024-26175	0.00043	0.08205	7.8
CVE-2024-22391	0.00048	0.16464	7.7
CVE-2024-2879	0.00492	0.75889	7.5
CVE-2024-29045	0.00088	0.36987	7.5

CVE	EPSS	Percentile	CVSS
CVE-2024-21454	0.00046	0.15656	7.5
CVE-2024-26218	0.00043	0.08205	7.5

Of course, the combination of CVSS and EPSS does not give the complete picture of a vulnerability's risk to a given organization. However, they can be valuable inputs into an organization's or product's ML-based vulnerability management system. Quality vulnerability management systems can help provide the organizational context, which is vital in prioritizing and managing the plethora of vulnerabilities.

AI-Generated Synthetic Data

According to a report from the Royal Society and the Alan Turing Institute, synthetic data is "data that has been generated using a purpose-built mathematical model or algorithm, with the aim of solving a (set of) data science task(s)" (Jordon, et al., 2022). This definition focuses on the strategic use of synthetic data to solve complex problems. Generative AI provides a powerful synthetic data generation tool for training ML models. Generative AI can analyze data samples and learn the data's correlations, structures, and properties. After learning, the generative AI model can create synthetic data that resembles the original data. The synthetic data can be either structured, such as data tables, or unstructured, such as images. However, it is essential to note that synthetic data may not always capture all nuances or edge cases present in real-world data, potentially leading to limitations in model performance when applied to actual scenarios. By the way, the output of LLMs, such as ChatGPT, is synthetic data. The LLM output is constructed using a transformer-based model to learn underlying structures and relationships between words and phrases to generate text. Another

popular method for generating synthetic data is a generative adversarial network (GAN). A GAN uses two ML models, one that generates content and the other classifies or analyzes the generated content.

Synthetic data has many applications, including training ML models, testing traditional applications, and protecting privacy. According to the policy guidelines from the United Nations University (UNU), AI-generated synthetic data has seen wide use in many industries, including healthcare for disease diagnosis, financial services for fraud detection and risk assessment, and meteorology for weather forecasting and climate change modeling (De Wilde, et al., 2024). The UNU also noted that synthetic data could play a role in reducing bias, such as gender discrimination.

Despite the many possible benefits of training with synthetic data, there are also some concerns, including data quality and security risks (De Wilde, et al., 2024). Inaccurate or unreliable ML models can result from training with synthetic data that does not accurately represent real-world data. According to the UNU, the distribution of AI-generated data can be challenging compared to statistical model-generated data (De Wilde, et al., 2024). However, the data quality of AI-generated synthetic data can be improved by training the generative AI model with more quality real-world data. Also, when using synthetic data for ML model training, the UNU recommends that organizations establish well-defined quality metrics.

Reverse engineering of synthetic data can also pose a security risk. Attackers can use reverse engineering techniques to re-identify or extract information about the real-world data used to train the generative AI model or the processes. Researchers have shown that LLMs are susceptible to data extraction attacks (Nasr, et al., 2023; Wang, Wang, & Li, 2024).

Synthetic Data to Protect Privacy

Training and testing ML models require much data, often raising privacy concerns. For example, when training financial or healthcare services models, the datasets can include personally identifiable information (PII) or personal health information (PHI). Training ML models with the original data can expose the PII, PHI, or other sensitive information during training and raise concerns regarding data extraction or inference during usage (more on inference attacks in Chapter 4). Because of the growing privacy concerns, regulations such as the GDPR and the California Consumer Privacy Act (CCPA) seek to provide legal protection for consumers' data. However, these regulations can also introduce data science challenges by restricting the collection, usage, and storage of user data. Therefore, there is heightened interest in using synthetic data to train ML models.

Traditional methods of anonymizing data, such as deidentification, masking, and randomizing, create pseudo-anonymous data that often do not provide the necessary privacy protection. For example, with data masking or deidentification, the original relationships remain. By analyzing the relationships, a threat actor could gather enough information to pierce the veil of anonymity by inference. AI-generated synthetic data can provide greater anonymity than these traditional methods without compromising the accuracy of the ML models. Another traditional method of generating synthetic data is the rule-based approach. However, developing the rules to generate complex, realistic synthetic data can be labor-intensive, time-consuming, and challenging to adapt to changing conditions.

Due to these privacy concerns and increasing privacy regulations, using synthetic AI-generated data for ML model training is a much-researched topic. AI-generated

synthetic data can help mitigate privacy concerns by ensuring the ML models are not trained with PII, PHI, or other sensitive data. Well-engineered synthetic data can replicate the underlying structure and maintain the statistical distributions of the original data. When done correctly, the synthetic data should be indistinguishable from the original data during ML model training. Training with this AI-generated synthetic data instead of the original data can ensure that sensitive information is not exposed throughout the ML lifecycle, from training to inference.

When using synthetic data for ML model training, data scientists must consider the fidelity and utility of the synthetic data. Fidelity is a measurement of the similarity between real-world and synthetic data. Assessing fidelity includes examining the distributions of each column and the univariate and multivariate relationships within the data. Many tools, including open source Python packages such as Synthetic Data Metrics (SDMetrics), can analyze the fidelity and provide helpful visualizations. Utility focuses on the relative predictive accuracy of an ML model trained with synthetic data compared to real-world data. Data scientists can evaluate many metrics in determining utility, including the model's accuracy, precision, and root-mean-squared error (Jordon, et al., 2022). One standard method to evaluate utility is training on synthetic data and testing with real-world data. The advances in AI, including generative AI, have helped to increase both the fidelity and utility of synthetic data.

Synthetic Data for Model Development and Prototyping

ML developers can also derive significant benefits from using synthetic data during ML model development and prototyping. Developers often need to quickly prototype ML models to determine feasibility or which algorithms might

be best for the problem they are trying to solve. Obtaining sufficient quantities of real-world data to support such prototyping could be time-consuming, often requiring many approvals. Such issues often arise when developing cybersecurity models, where the lab or development environments typically do not have access to the production security data and logs. The checks and balances to protect such data can render it infeasible for quick ML model prototyping, especially in large quantities.

During ML model prototyping, developers can leverage synthetic data to test out concepts quickly. Many of these prototypes will fail. One of the primary goals of prototyping is to fail quickly, ruling out infeasible or inefficient ML models without consuming valuable resources or time. Synthetic data can bridge the gap, allowing developers to proceed with prototypes while waiting on real-world data. The successful candidate ML models can be enhanced or tested further once the real-world data is available.

Combating imbalanced datasets is another use of synthetic data that is particularly relevant to cybersecurity model development. When developing a classifier, imbalanced datasets refer to when one class is either extremely rare or predominant. Imbalanced data is frequent within security use cases, such as malware, intrusion, and phishing detection. The malicious class could represent less than 1% of the instances analyzed in these cases. Imbalanced training data can significantly negatively impact ML model accuracy since model training will not be exposed to sufficient samples of the minority class, such as *malicious* for malware detection, *fraud* for payment fraud detection, or *malignant* in cancer detection. ML model developers can use synthetic data during training to oversample the minority class. However, it is imperative that this over-sampling is only done on the training data. Once the training is complete, the model can be tested

against the test data, which was not altered, to determine accuracy.

Accuracy and Unbalanced Data: A Word of Caution

Applying AI for cybersecurity comes with several challenges, which are seen in other industries to a lesser or greater extent. Cybersecurity often requires high accuracy, such as when used for network threat detection. Blocking legitimate traffic can adversely affect the business. An ML classifier that miscategorizes as little as 1% of the legitimate traffic as a threat, called false positives, could interrupt operations and impact revenue. The high accuracy requirements put additional strain on testing ML classifiers.

Cybersecurity and medical diagnosis often have something in common. These two fields often encounter the problem of heavily unbalanced datasets. In most cases, the vast majority of instances are benign. In cybersecurity, malicious activities are rare events hidden within enormous legitimate activity. Similar to diagnosing rare diseases, cyber threat detection is like finding a needle in a haystack. A common performance metric for ML models is accuracy, which is the percentage of correct predictions. However, the accuracy can be misleading when dealing with heavily unbalanced data.

For example, consider an ML classifier for malware. Very few of the files analyzed by the classifier will be malicious, perhaps only 1%. So, what if an antimalware solution claims 99% accuracy? Is that good? It is necessary to dig deeper to answer those questions. In this case, developing a classifier that achieves 99% accuracy would be straightforward. All the classifier would have to do is classify *every* example as benign. The classifier could then

rightfully claim 99% accuracy. However, it would be ineffective, missing *every* malicious file. The same might hold for a medical diagnosis classifier, especially one attempting to classify whether a patient has a specific rare disease. Assuming 10,000 files are analyzed, with 100 malicious samples, the accuracy of a classifier that predicted all files as benign would be calculated as follows, where TP is the number of true positives (malware classified as malware), and TN is the number of true negatives (benign files classified as benign). Since every file is classified as benign, there would be no true positives and 9,900 true negatives.

$$accuracy = \frac{TP + TN}{n} = \frac{0 + 9,900}{10,000} = 0.99 = 99\%$$

Another common metric is the detection rate, which is the percentage of identified positive cases (malicious). However, when applied to an unbalanced set, this metric can also be misleading. A 100% detection rate can be achieved by reversing the above example. Instead of classifying every file as benign, which would have a 0% detection rate, classifying all files as malicious would achieve a 100% detection rate. However, this would result in many false alarms, as all benign files would be misclassified as malicious. The detection rate for such a classifier would be calculated as follows. Since every file is classified as malicious, there would be 100 true positives (all malicious samples classified as malicious) and no false negatives (malicious samples classified as benign).

$$detection\ rate = \frac{TP}{TP + FN} = \frac{100}{100 + 0} = 1.00 = 100\%$$

We can use a contingency table to examine classifier results further, especially false negatives and false

positives. Assuming a malware detection classifier that evaluated 10,000 files (9,900 benign and 100 malicious), the results might look like Table 3-4. In this example, the positive case is that the file is malicious. The contingency table shows 30 false negatives (malicious files classified as benign) and 100 false positives (benign files classified as malicious). It usually becomes a balancing act between false positives and false negatives. As a classifier is tuned to reduce one, the other often increases. For example, the malware classifier could be tuned to reduce the number of false negatives (*malicious* classified as *benign*), thus reducing malware infections. However, that could increase the false positives (*benign* classified as *malicious*), disrupting processes and increasing false alerts to the security team. Therefore, each use case must determine the acceptable thresholds for false positives and negatives, accounting for the risks associated with incorrect classification.

Table 3-4 A contingency table shows 30 false negatives (malicious files classified as benign) and 100 false positives (benign files classified as malicious).

		Predicted	
Actual		Positive	Negative
	Positive	70	30
	Negative	100	9,980

Summary

Within cybersecurity, AI offers great promise. Cybersecurity products already implement AI for many use cases, including intrusion and malware detection, spam filtering, phishing detection, insider threat detection, and vulnerability management. Beyond these core cybersecurity functions, AI-generated synthetic data can

enhance privacy and efficiency while developing and testing ML models and traditional software applications. It is also crucial to consider the emerging field of adversarial machine learning in cybersecurity contexts. Attackers may attempt to manipulate AI models through evasion attacks or data poisoning. Robust AI systems in cybersecurity must be designed with these potential threats in mind, incorporating defenses against adversarial examples and maintaining ongoing monitoring for model drift or unexpected behaviors.

The power of AI to analyze large amounts of data efficiently, accurately, and quickly ensures that the use of AI within cybersecurity will continue to expand rapidly, becoming embedded in all security functions. However, security professionals must understand the limits and the vulnerabilities when using AI for cybersecurity. The next chapter will examine some AI vulnerabilities and how to mitigate them.

References

Almukaynizi, M., Nunes, E., Dharaiya, K., Senguttuvan, M., Shakarian, J., & Shakarian, P. (2019). Patch before exploited: An approach to identify targeted software vulnerabilities. In L. F. Sikos (Ed.), *AI in Cybersecurity* (pp. 81-113). Springer.

Chainalysis. (2024). *Ransomware payments exceed \$1 billion in 2023, Hitting record high after 2022 decline*.

Retrieved from Chainalysis:

<https://www.chainalysis.com/blog/ransomware-2024/>

Comcast Business. (2023). *2023 Comcast Business cybersecurity threat report*. Comcast Business. Retrieved from

<https://business.comcast.com/community/docs/default-source/default-document->

[library/ccb_threatreport_071723_v2.pdf?sfvrsn=c220ac01_3](#)

De Wilde, P., Arora, P., Buarque, F., Chin, Y., Thinyane, M., & Stinckwich, S. (2024). *Policy guideline: Recommendations on the use of synthetic data to train AI models*. United Nations University. Retrieved from <https://collections.unu.edu/eserv/UNU:9480/Use-of-Synthetic-Data-to-Train-AI-Models.pdf>

Egress. (2024). *Email security risk report 2024*. Retrieved from https://www.egress.com/media/o1sbpq5t/egress_email_security_risk_report_2024.pdf

Hill, M. (2022). *The Apache Log4j vulnerabilities: A timeline*. Retrieved from CSO Online: <https://www.csoonline.com/article/571797/the-apache-log4j-vulnerabilities-a-timeline.html>

IBM Institute for Business Value. (2022). *AI and automation for cybersecurity: How leaders succeed by uniting technology and talent*. IBM. Retrieved from <https://www.ibm.com/downloads/cas/9NGZA7GK>

Intel471. (2024). *Vulnerabilities year-in-review: 2023*. Retrieved from Intel471: [https://intel471.com/blog/vulnerabilities-year-in-review-2023#:~:text=The%20National%20Vulnerability%20Data base%20\(NVD,up%20from%2025%2C081%20in%202022.](https://intel471.com/blog/vulnerabilities-year-in-review-2023#:~:text=The%20National%20Vulnerability%20Database%20(NVD,up%20from%2025%2C081%20in%202022.)

ISC2. (2022). *ISC2 pulse survey: Log4j remediation exposes real-world toll on the cybersecurity workforce gap*. ISC2. Retrieved from <https://www.isc2.org/Insights/2022/02/LOG4J-REMEDIATION-EXPOSES>

Jacobs, J., Romanosky, S., Suciu, O., Edwards, B., & Sarabi, A. (2023). *Enhancing vulnerability prioritization: Data-driven exploit prediction with community-driven*

insights. *2023 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*. Delft, Netherland. doi:10.1109/EuroSPW59978.2023.00027

Janez-Martino, F., Alaiz-Rodriguez, R., Gonzalez-Castro, V., Fidalgo, E., & Alegre, E. (2022). A review of spam email detection: Analysis of spammer strategies and the dataset shift problem. *Artificial Intelligence Review*, 56, 1145-1173. Retrieved from <https://link.springer.com/article/10.1007/s10462-022-10195-4>

Jordon, J., Houssiau, F., Cherubin, G., Cohen, S. N., Szpruch, L., Bottarelli, M., . . . Weller, A. (2022). *Synthetic Data - what, why and how?* The Royal Society. Retrieved from <https://arxiv.org/pdf/2205.03257>

Morning Consult; IBM. (2023). *Global security operations center study results*. Morning Consult. Retrieved from <https://www.ibm.com/downloads/cas/5AEDA0JN>

Nasr, M., Carlini, N., Hayase, J., Jagielski, M., Cooper, A. F., Ippolito, D., . . . Lee, K. (2023). Scalable extraction of training data from (production) language models. *arXiv*, 1-64. Retrieved from <https://arxiv.org/abs/2311.17035>

SlashNext. (2023). *SlashNext's 2023 State of Phishing Report Reveals a 1,265% increase in phishing emails since the launch of ChatGPT in November 2022, signaling a new era of cybercrime fueled by generative AI*. Retrieved from PR Newswire: <https://slashnext.com/wp-content/uploads/2023/10/SlashNext-The-State-of-Phishing-Report-2023.pdf>

Townsend, K. (2024). *The ransomware threat in 2024 is growing: Report*. Retrieved from Security Week: <https://www.securityweek.com/the-ransomware-threat-in-2024-is-growing-report/>

Wang, J. G., Wang, J., & Li, M. N. (2024). Pandora's white-box: Increased training data leakage in open LLMs.

arXiv, 1-19. Retrieved from

<https://arxiv.org/abs/2402.17012>

Xiao, M. (2022). *Digging into the numbers one year after Log4Shell*. Retrieved from SC Magazine:

<https://www.scmagazine.com/feature/digging-into-the-numbers-one-year-after-log4shell>

4. ML in an Adversarial Environment

Though ML has had many successful real-world applications, including cybersecurity, its methods are vulnerable. Before implementing ML solutions, we must understand how attackers could disrupt them. In this chapter, we will look at some of the vulnerabilities throughout the ML lifecycle. The vulnerabilities are amplified when using ML in an adversarial environment such as cybersecurity. When we implement cybersecurity solutions, whether they leverage ML or not, we know that our adversaries will attempt attacks on them.

There are several ways to categorize attacks on ML. One way to organize the attacks is based on the ML phase they target – training and testing versus inference. These ML attacks can also be classified as causative or exploratory. Causative attacks, which typically occur during training and testing, alter the data or model parameters. An example of a causative attack is injecting adversarial samples into the training data. In contrast, an exploratory attack does not tamper with the training data or the model. Instead, during the inference stage, an exploratory attack collects information about the data and the model, possibly

to evade classification later. We will first look at attacks in the training and testing phase.

Training and Testing Phase: Poisoning Attacks

When discussing data poisoning, I like to tell the story of Uncle Ronnie. I have a brother named Ronnie, and when my son was little, and we would go visit my brother, I would tell my son, “Please don’t learn anything from Uncle Ronnie.” I knew my brother would teach my son something he should not. Then, when we got home, I would have to question my son to see what he learned and try my best to retrain him. I call this the *Uncle Ronnie Syndrome*. It seems every family has an Uncle Ronnie. Also, many Uncle Ronnies are trying to poison the training data when using ML in an adversarial environment. However, these attackers are more persistent, and, unlike my brother, we do not know when or where they might disrupt the learning. If we are not prepared, our ML models will learn something they should not, courtesy of Uncle Ronnie.

Poisoning attacks are the most prominent when considering training and testing phase attacks. Since ML models rely on the quality of the training and testing data, they are vulnerable to data manipulation. The data is the ground truth from which the ML models learn. Corrupted training data can lead to a malfunctioning model, such as an intrusion detection system that misclassifies malicious traffic as benign. Poisoned testing data can lead to erratic results during testing, possibly causing an otherwise valid model to be discarded. Since poisoning attacks alter the data or model, they are considered causative.

Poisoning attacks can affect the ML models in multiple ways. The model’s performance can be degraded, decreasing accuracy and precision. One way performance

is degraded is by distorting the decision boundaries. These decision boundaries lie at the edges of the classes and are fundamental to classification algorithms. For example, an SVM creates a hyperplane between the classes, representing the decision boundary. A small change in that hyperplane can change how examples near the prior boundary are classified, as depicted in Figure 4-1. In applications such as intrusion, malware, or fraud detection, even a slight drop in performance can significantly impact operations. For example, in fraud detection, erroneously classifying 0.5% of legitimate transactions as fraud can cause an enormous loss of revenue. In malware detection, misclassifying benign software as malicious can disrupt operations, preventing users from conducting legitimate business. Conversely, misclassifying malicious software as benign could lead to a ransomware infection that spreads throughout the company. Furthermore, these impacts can be challenging to detect, especially when localized to a specific class.

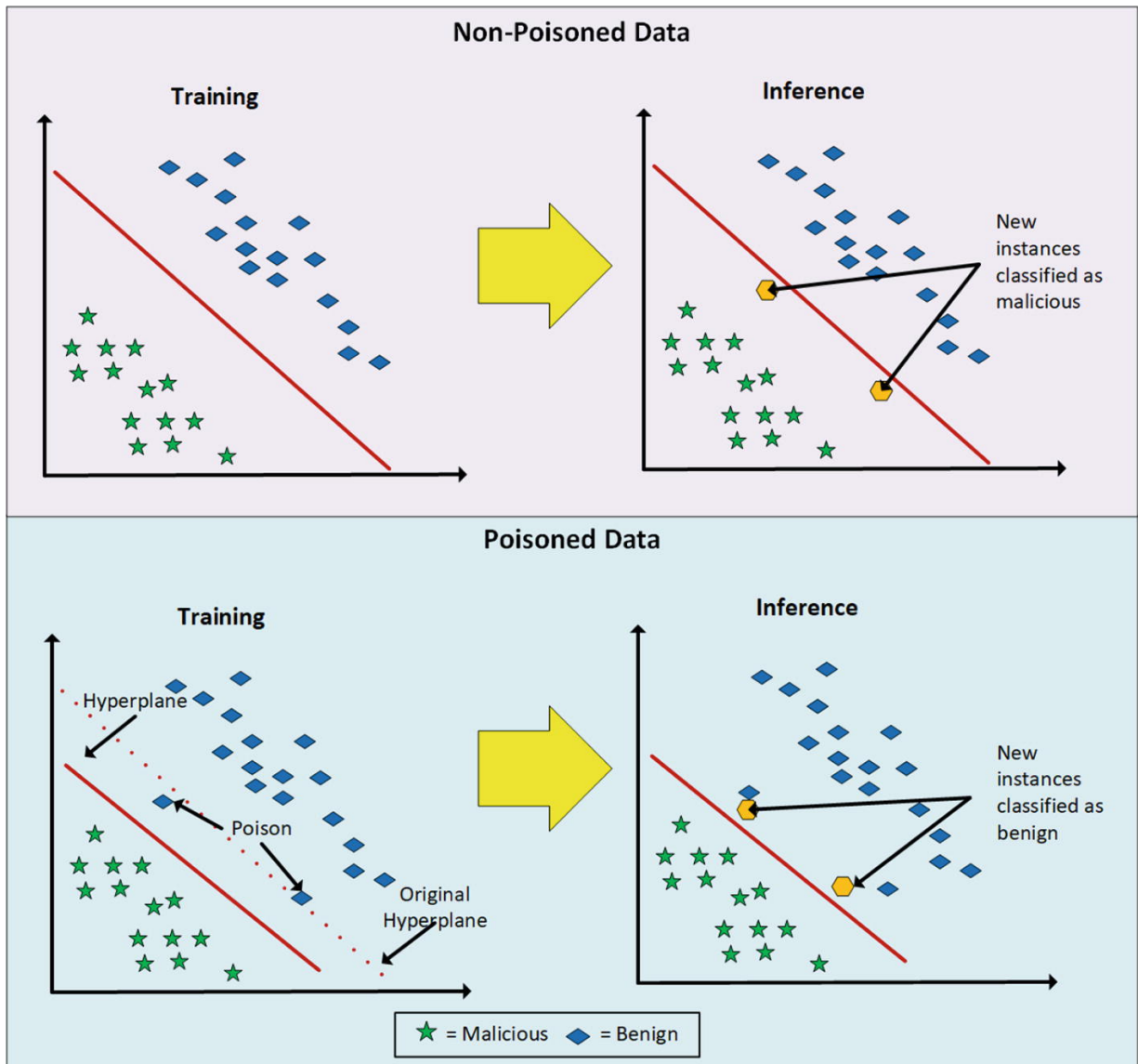


Figure 4-1 Using poisoning to shift the decision boundary. The top set of figures shows the training and resulting inference without poisoning. The new instances will be classified as malicious. In the bottom set, adversarial samples are introduced into the training, shifting the decision boundary. The new instances will now be classified as benign.

The adversary must gain access to the training or testing data to conduct a data poisoning attack. Once gaining access, the attacker can control a subset of the data by inserting or modifying training or testing samples. Due to a lack of training data or to speed up ML model development, ML developers sometimes download pre-labeled training data from unverified sources, increasing

the susceptibility to training data poisoning. Organizations may also outsource the training phase by providing private data to a machine learning as a service (MLaaS) platform, passing control of the training data to a third party. Also, the increasing use of federated machine learning can increase vulnerability to model poisoning attacks where attackers upload poisoned weights to a centralized server, corrupting the federated model.

For data poisoning attacks on the training data, attackers will typically use one of three common attack types. First is the insertion of adversarial samples into the data. These adversarial attacks can be targeted, in which case the adversarial samples are designed to be misclassified into a specific class. The attacker's goal in a targeted attack is to affect the training so that specific samples will be misclassified in production, resulting in an evasion attack (more on evasion attacks when we look at inference phase attacks). One type of insertion attack involves injecting outliers into the training data. The introduction of outliers can distort the decision boundaries, leading to misclassifications. Alternatively, these attacks can be non-targeted, analogous to a denial of services (DoS) attack, where the goal is typically to disrupt the model by injecting numerous adversarial samples.

Secondly, the attacker may seek to modify values within existing samples. Examples of feature manipulation include adding noise or introducing subtle perturbations to images. When CNNs are used for image recognition, these pixel-level perturbations can lead to misclassifications. For example, small perturbations of images used in training self-driving cars can lead to the misinterpretation of road signs (Guesmi, Hanif, Ouni, & Shafique, 2023). Like adversarial sample insertion, modifying existing samples can be targeted or non-targeted.

The other training data poisoning technique involves changing the labels, known as label flipping, on some of the

samples in the dataset. Label flipping could be random or target one of the classes directly. With label flipping, the attacker changes the labels on the selected samples. For example, in fraud detection systems, the attacker could change transactions labeled as *fraudulent* to *legitimate* and vice versa. Such poisoning will confuse the ML algorithm, impacting the decision boundaries, thereby leading to misclassifications.

Instead of targeting the training data, poisoning attacks can also be indirect. With an indirect attack, the adversary targets the raw dataset before preprocessing and extracting the training and testing data. When developing an ML model, developers often pull a sample of production data for offline training and testing. Suppose the production data has already been infected with adversarial data, such as by a low and slow attack by an advanced persistent threat (APT). In that case, this data will impact the training. Such poisoning can be particularly effective against unsupervised learning for anomaly detection. Since the adversarial data is already in the environment, the ML algorithm could learn that such traffic is *normal*. If so, then similar traffic could evade detection in the future.

In a model poisoning attack, the adversary controls the model and its parameters. Regardless of the method used, an effective poisoning attack will cause the model to misclassify samples during the testing phase, causing a significant reduction in overall accuracy. While model poisoning attacks are widely applicable, they are most prevalent with federated ML paradigms and supply chain attacks. With federated learning, clients send local models to an aggregating server. If adequate protections are not in place, these federated models could have been poisoned, adversely affecting the aggregated model. In ML supply chain attacks, malicious code could be added to the model, either by the supplier or an attacker. Customers can then

unknowingly use a contaminated model from one of their trusted suppliers. Figure 4-2 summarizes the various poisoning attack categories.

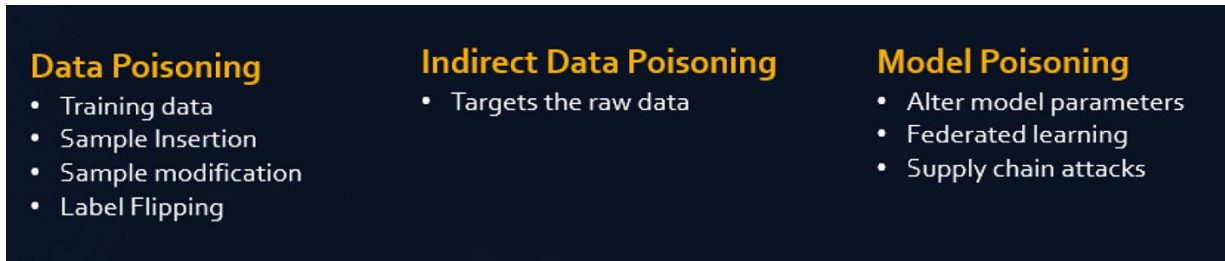


Figure 4-2 Categorizing poisoning attacks during ML training and testing

Since the training dataset is often well-guarded, poisoning attacks against the original training dataset may be difficult. However, ML models may need to be retrained to adapt to a changing environment. Attackers seek to exploit the need for retraining by targeting the retraining stage of an ML model. Many ML models require regular online training to account for continuously generated data. Online training refers to training done with live production data and is normally seen with unsupervised models. For example, an ML model that seeks to determine anomalous network activity must periodically be retrained to identify normal network traffic. Ideally, the retraining would be done offline after data sanitization (more on data sanitization later). However, some cybersecurity ML solutions feature continuous online learning. During this retraining phase, an adversary could launch a poisoning attack. If the attacker can inject adversarial data during the retraining, such traffic might then be considered normal.

Label Flipping Example

We will use a phishing domain dataset to demonstrate the effects of data poisoning. This labeled dataset contains features related to domains, with each instance labeled to indicate whether it is phishing or benign. The features include length elements (such as the domain, directory, and

parameters), whether the domain has a certificate, the days since activation, the days until expiration, and the number of redirects. This dataset can be used to create a simple phishing domain classifier; however, most commercial phishing domain classifiers would be much more complex and include many more features. However, this dataset can demonstrate how data poisoning can affect an ML model's results. This exercise will use four ML algorithms - a classification and regression tree (CART), k-NN, naïve Bayes, and random forest. The first step is to get the baseline results for each algorithm, as shown in Table 4-1.

Table 4-1 Baseline accuracy measurements before poisoning

Model	Accuracy
CART	91.5%
k-NN	83.1%
Naïve Bayes	89.9%
Random Forest	94.5%

After obtaining the baselines, we will conduct label flipping on the training data. In this case, label flipping will change those instances marked as *phishing* to *benign* and vice versa. Multiple runs of each algorithm were conducted, and the percentage of labels flipped increased with each iteration. The records to be poisoned for each iteration were selected at random. An additional hypothetical model, *pure guess*, is also charted. This model shows the accuracy that could be achieved by guessing that every instance is benign. Since the phishing domain dataset is unbalanced, with 65.4% of the samples labeled benign, guessing could achieve a 65.4% accuracy. Figure 4-3 plots the results of the label-flipping exercise.

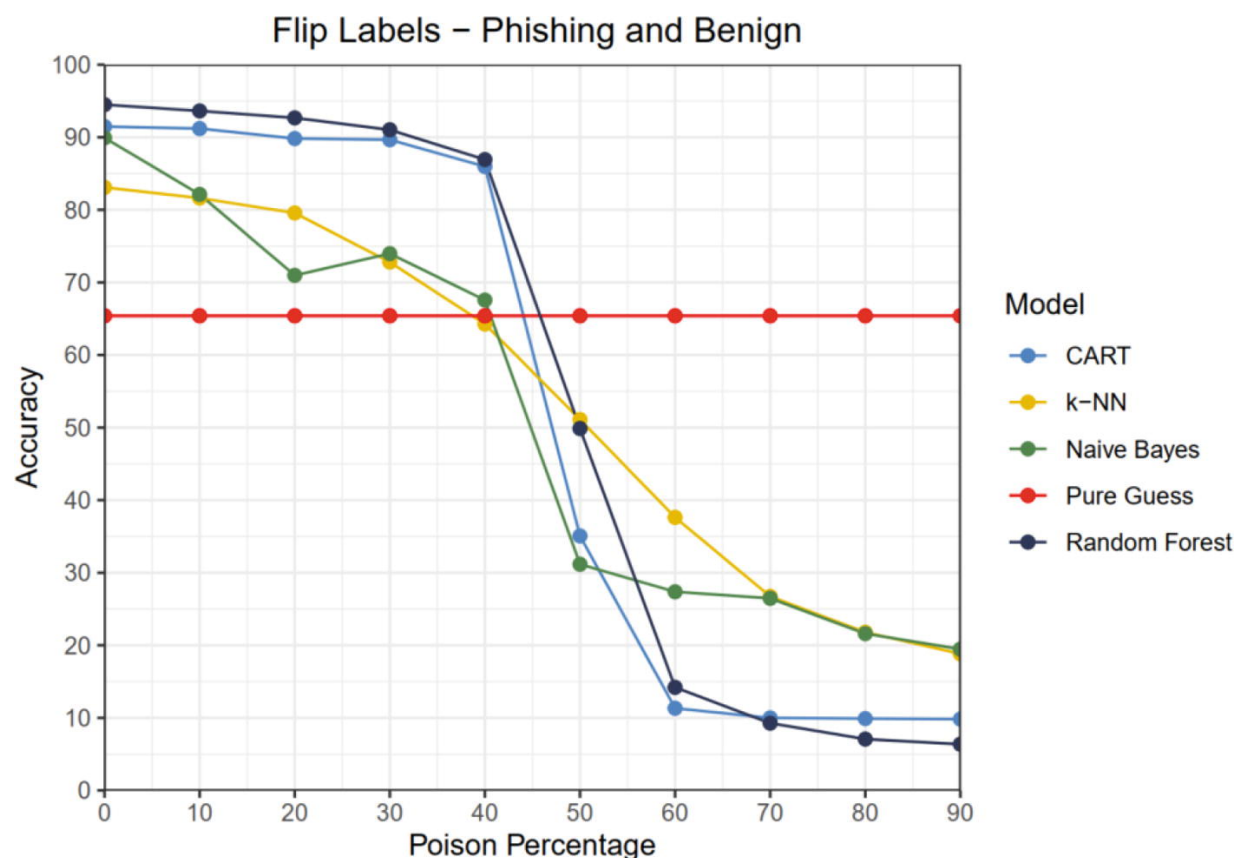


Figure 4-3 Flip phishing and benign labels. An increasing percentage of the training data was poisoned by flipping the labels on both classes

The results show that the naïve Bayes model began suffering a significant drop in accuracy at the 10% poisoning mark. With 20% poisoning, the naïve Bayes model was performing only slightly better than pure guessing, rendering its predictive capability useless. The k-NN model had a rather steady decline, dropping below the pure guess threshold with 40% poisoning. The CART and random forest models maintained relatively good accuracy until the poisoning percentage reached 50%, at which point the accuracy of both models dropped precipitously. It is important to note that these results cannot be generalized, as they are specific to the data and training methods used. The reader should not infer that any of these models are generally more or less susceptible to poisoning. We can derive from this exercise that label flipping during training

can be an effective poisoning method to disrupt a model's performance.

Another form of label flipping changes only the label for one class instead of all the labels. The same tests were rerun, except only the *benign* labels were changed. Therefore, for the given percentage of the dataset, all instances would be labeled as *phishing* following the poisoning. The results of flipping only the benign class are shown in Figure 4-4. The results from this poisoning exercise were similar to those of the previous example, where all labels were flipped. However, the naïve-Bayes model performed significantly better than in the previous exercise until the 30% poisoning mark.

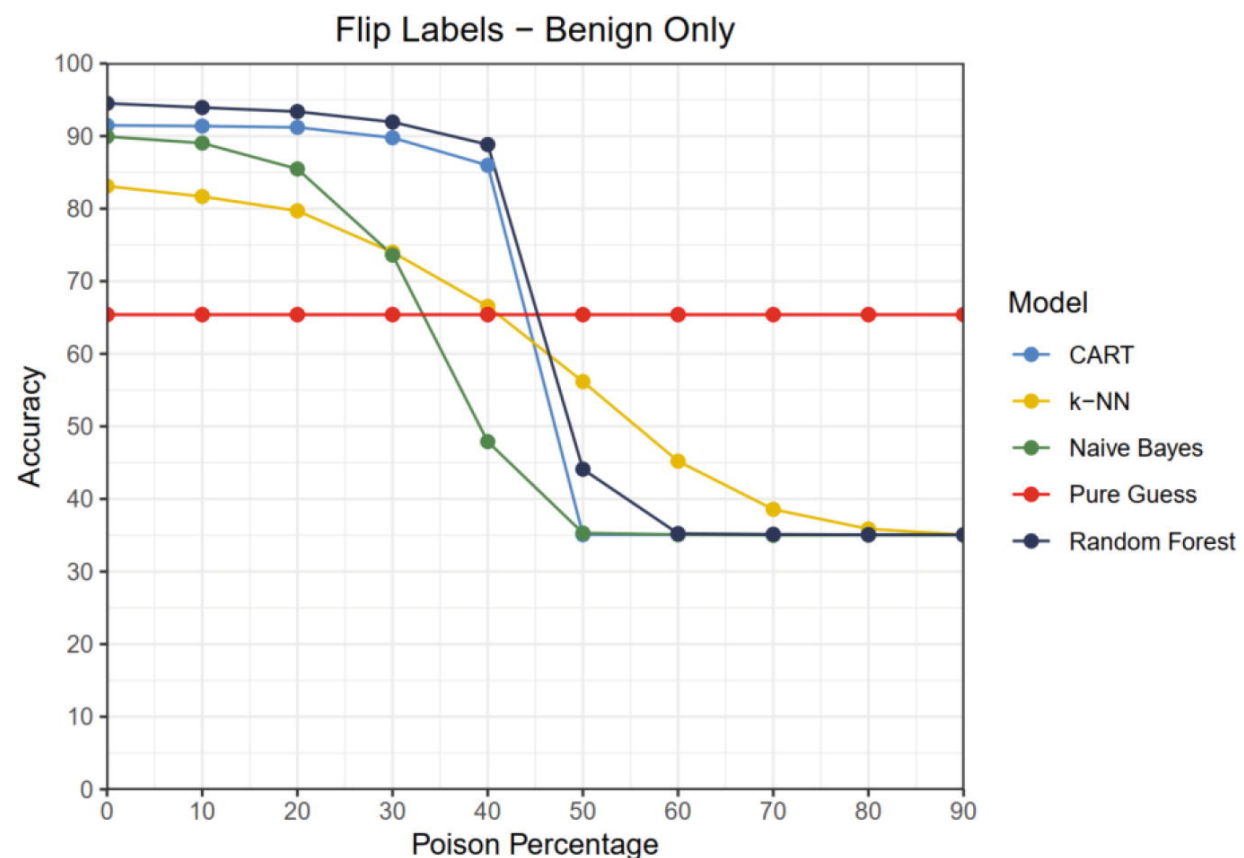


Figure 4-4 Flipping labels only on instances classified as benign

Adversarial Sample Insertion Example

Next, we will conduct data poisoning using the same phishing domain dataset by inserting adversarial samples into the training dataset. The initial training dataset has 9,000 samples. The adversarial samples are additional benign URLs that have been labeled as phishing. The adversarial samples are added to the training dataset iteratively in groups of 1,000 adversarial samples. Figure 4-5 displays the results of injecting adversarial samples to disrupt the learning. By the time 6,000 adversarial examples were injected, all the models were performing worse than guessing. The naïve Bayes model showed significant degradation with 2,000 adversarial samples and dropped to the level of guessing with 3,000. The k-NN model again demonstrated a rather steady decline, dropping to near guessing with 4,000 samples injected. The CART and random forest models maintained relatively good accuracy through 4,000 and 5,000 injections, respectively.

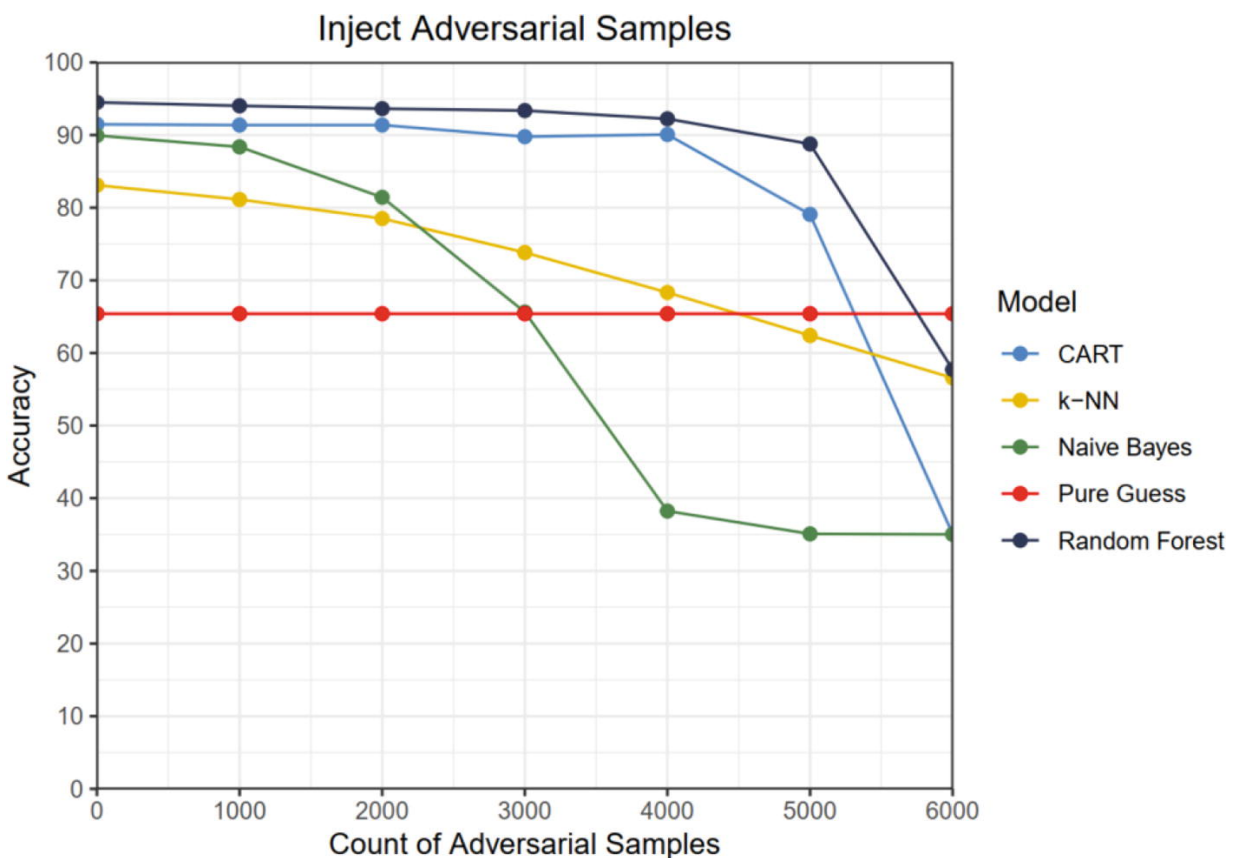


Figure 4-5 An increasing number of adversarial samples in which benign samples were labeled as phishing were injected into the training data

The ML Supply Chain: Pre-trained Models and Shared Datasets

Training an ML model requires large datasets of real-world examples. However, ML developers may not have access to the necessary data within their environment. Also, even if they have access to the data, they may not have the time or bandwidth to label and prepare the data for training.

Fortunately, many training datasets with numerous examples are readily available. Websites such as Kaggle offer numerous datasets, many of which have already been labeled and are ready for ML training. Examples of these datasets include ones for medical research, such as heart disease and breast cancer, sports statistics, credit approval, SAT results, stock prices, and cybersecurity, such as phishing, malware, vulnerabilities, and threat detection. For visual ML applications, ImageNet is a leading source of training data for image classification, with over 14 million labeled images. ML developers can use these training datasets to train models, avoiding the time-consuming task of collecting and preparing training data.

In addition to readily available datasets, researchers and data scientists often share models that have been trained using real-world data samples. Many such pre-trained models are publicly available on collaboration websites such as GitHub and the researchers' websites, allowing anyone to download them. Once downloaded, users can apply these pre-trained models directly to achieve objectives. However, the true power of these pre-trained models is their adaptability and transferability to new tasks. ML developers can incorporate these pre-trained models into their ML development pipelines to develop novel applications. By doing so, ML developers can reduce the time, money, and required skills.

Sharing models and datasets has fueled many of the ML innovations and improvements. When developing an application-specific ML model, developers often combine these ready-made datasets and models with custom-made, application-specific components to create an ML application. Figure 4-6 depicts how shared and custom-made components can be architected to deliver an ML application. The *Shared Training Data - 1* was used to create several pre-trained models to perform generic tasks. One of these pre-trained models was downloaded by an ML developer for use in developing a new application. The developer combined this pre-trained model, *Pretrained Model - C*, with custom training data and another shared training dataset, *Shared Training Data - 2*. The resulting custom ML model was included in the new software application.

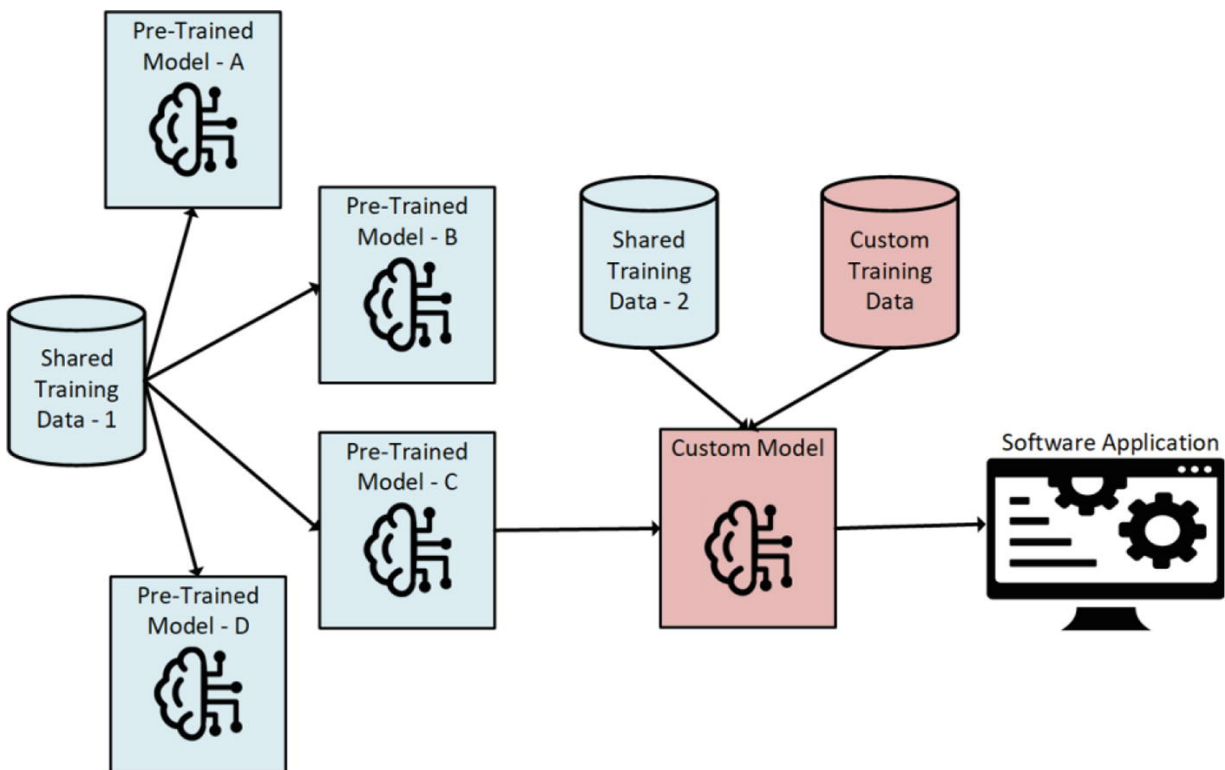


Figure 4-6 ML applications can incorporate shared training data and pre-trained models. These shared components can increase ML supply chain risk.

Though prepared datasets and pre-trained models can increase efficiency and fuel innovation, they can also introduce risks into the ML pipeline. Vulnerabilities caused by contamination of the pre-trained model or the shared dataset could propagate to the ML applications developed by a software vendor. This vendor then includes the vulnerable ML application in its commercial software, introducing supply chain risks to its customers and downstream users. The Center for Security and Emerging Technology (Lohn, 2021) issued a policy brief expressing concerns about possible vulnerabilities in the ML supply chain due to shared models and datasets. According to the policy brief, ML applications have become targets of well-resourced adversaries, including nation-state-backed groups from China and Russia. Therefore, the CSET urged policymakers to take steps to reduce these risks in critical systems.

Inference Phase Attacks

After the model has been trained and is in production, it is considered to be in the inference phase. The model now analyzes new data and performs assigned tasks, such as classifying, predicting, grouping, or detecting anomalies. However, the attacks do not end with the completion of training. The inference phase brings with it other types of attacks, including exploratory, evasion, privacy, and output attacks. Figure 4-7 summarizes these attacks, which will be explained in the following sections.

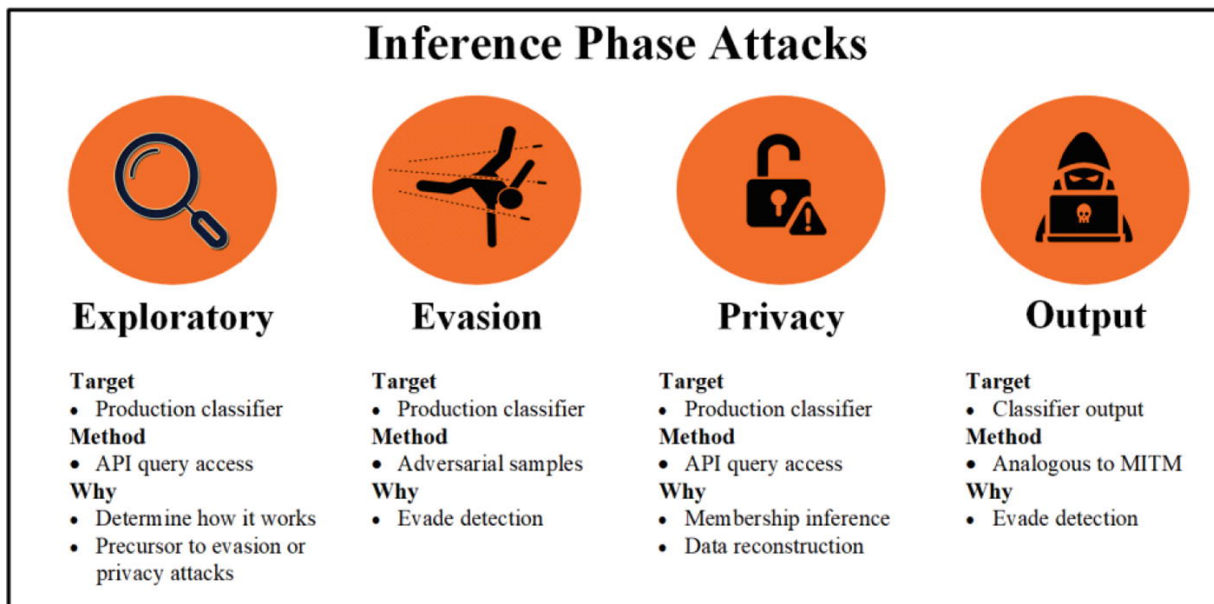


Figure 4-7 Inference phase attacks. This figure summarizes the main inference phase attack categories, including what they target, how they are targeted, and why they are targeted.

Exploratory Attacks

Exploratory attacks do not tamper with the training data or the model. Instead, an exploratory attack collects information about the training data and the model during inference. The attacker uses reversing techniques to discover how the ML algorithms work. Exploratory attacks often leverage API access to query the ML model, such as a classifier. During these attacks, the adversary can try to determine how the classifier works. The decision boundaries can be of particular interest to the attacker, especially as a precursor to an evasion attack. The attacker can also use the knowledge gained during an exploratory attack to launch a privacy attack to extract or infer training data.

Evasion Attacks

Evasion attacks seek to evade detection by producing a false negative from a classifier. The adversary aims to produce a negative or benign result on an adversarial

sample, such as malware or a phishing email, thereby evading classification by the cybersecurity system. Such attacks often rely on exploratory attacks to understand how the classifier works. During the exploration, the attacker will try to determine the decision boundaries between the classes, such as malicious and benign. The attacker will also seek to understand what features impact the decision. With this understanding, the attacker can construct or modify an adversarial sample, such as malware, making subtle changes to specific features. The goal would be to maintain the malicious capabilities of the malware while modifying its features just enough to be misclassified as benign, thereby evading detection.

Similar to evasion attacks, attackers can use the knowledge gained during exploration to construct samples that produce false positives. Such an attack is analogous to a network denial of service attack. The goal is to create numerous false positives, such as benign software classified as malicious, to overwhelm the classifier or the security operations team. Instead of changing features to make a malicious sample appear benign, the features of benign samples are modified to appear malicious. By producing numerous false positives, the attacker can destroy the security team's trust in the classifier, who may then decide to take the classifier offline. Security analysts may also find themselves overwhelmed trying to investigate the false positives, causing them to create filters to disregard the alerts, opening a hole through which the attacker can pass a genuinely malicious sample.

Privacy Attacks

Training data can contain a wealth of information, including proprietary information, intellectual property, and personal information. Such data can be of great value to an attacker. Therefore, adversaries may launch privacy attacks to gain information about the data used to train the

model. These attacks target the production classifier, typically by probing using the API. Privacy attacks can take several forms, including membership inference and data reconstruction or extraction. Techniques such as differential privacy can mitigate the risk of privacy attacks by adding controlled noise to the model's outputs.

Membership inference attacks seek to determine if a particular sample, such as a person, was part of the training dataset. By analyzing the model's output, often through the API, the attacker tries to infer whether a given element was used as input to the model. This type of attack is pertinent when membership in the training data infers some other valuable information about the given sample. For example, inferring that a particular person was used in the training data to explore the effects of a rare disease could divulge that the person has the rare disease, thus disclosing private health information. However, inferring that that same person's data was used in the 2020 US Census does not provide additional valuable information.

A reconstruction or extraction attack aims to extract complete records from the training dataset. Like inference attacks, the attacker often analyzes the model's output using the API or aggregated results. However, reconstruction attacks are typically not targeted, unlike inference attacks, which target specific instances. Researchers with the Census Bureau provided an infamous example of the ability to reconstruct training data (US Census Bureau, 2021). The researchers used tables published from the 2010 Census to determine the feasibility of data reconstruction. The team sought to reconstruct participants' geographic location, sex, age, race, and ethnicity. The researchers fully reconstructed the information for 144 million people, representing 46% of the US population. After reconstructing this data, the team linked it to information available in commercial databases and identified 52 million people.

Output Attacks

Output integrity attacks are a type of man-in-the-middle (MITM) attack. These attacks do not target the ML model or data. Instead of leveraging the API, attackers listen to the network traffic from an ML classifier. Output integrity attacks intercept and change the result from an ML classifier. For example, the attacker could intercept the result from a malware classifier and change a malicious result to benign. When the result is passed along, the malware, though correctly classified by the ML classifier, would now appear as benign to downstream systems, such as a software distribution and installation application. Defenders can mitigate output attacks using secure communications channels and cryptographically signing model outputs.

Defending ML

Classical ML does not consider purposeful misleading by an adversary. Traditionally, ML focuses on uncovering knowledge and discovering relationships within the data and assumes a non-adversarial environment. For most traditional ML problems, such an approach is acceptable and efficient. Figure 4-8 depicts a classical ML approach in a non-adversarial environment.

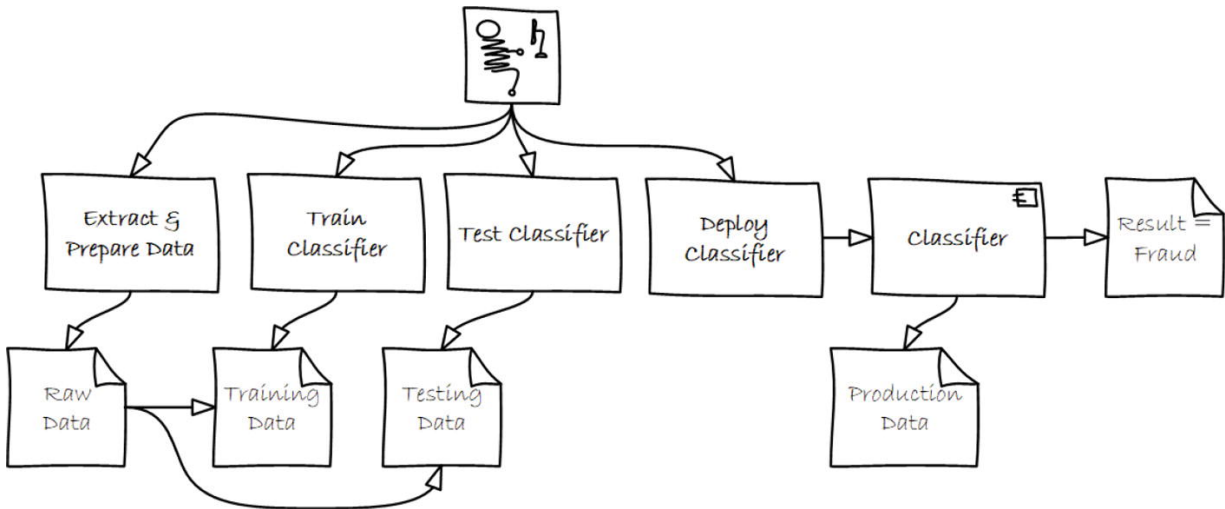


Figure 4-8 The classical ML development method assumes a non-adversarial environment

However, this process raises some serious concerns when it is applied to cybersecurity. Unlike many other applications of ML, cybersecurity is an adversarial environment. Adversaries seek to exploit ML vulnerabilities to disrupt cybersecurity ML systems. When ML is used in an adversarial environment, it must be designed and built, assuming it will be attacked in all phases. Figure 4-9 shows the major types of attacks discussed previously and the components of ML being attacked. Indirect poisoning attacks target the raw data before extracting and preparing the training data. Data poisoning attacks, including label flipping, feature modification, and adversarial sample insertion, target the training and testing data. Once the model is in the inference stage, exploratory attacks target the classifier to determine how it works. Privacy attacks can target the production classifier to infer membership or extract training data. After learning how the classifier works via exploratory attacks, including its decision boundaries and relevant features, attackers launch integrity attacks to evade the classifier by inserting adversarial examples. Finally, attackers can use MITM output attacks to intercept and change the result from the classifier.

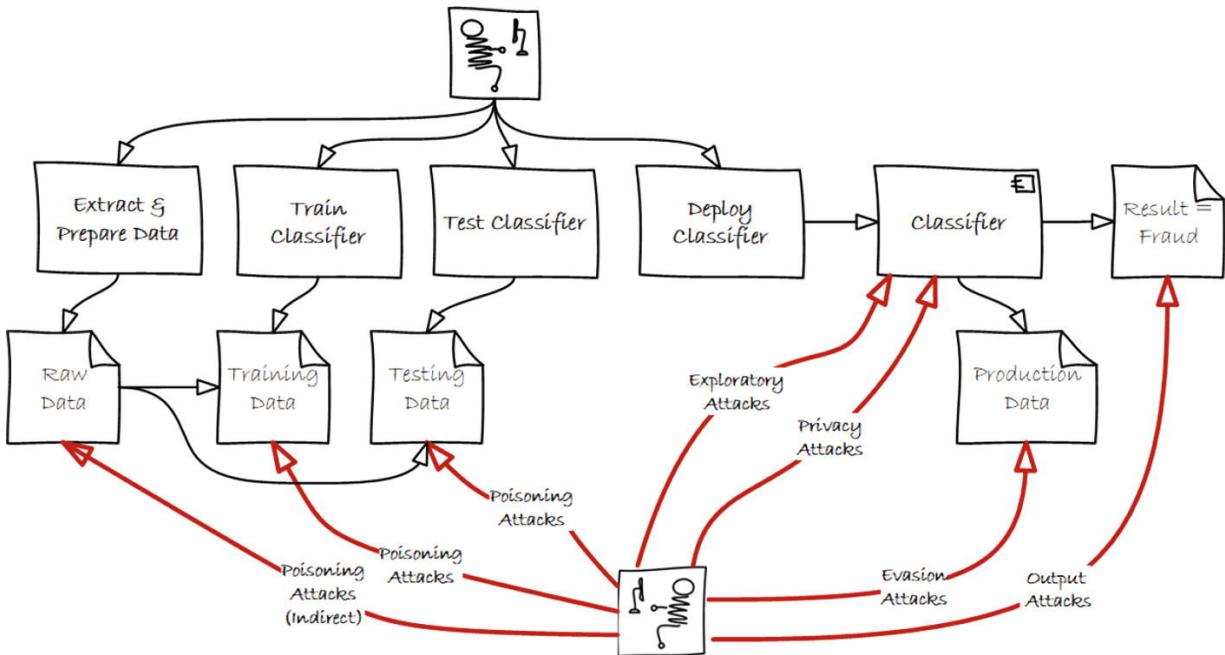


Figure 4-9 When ML is used in an adversarial environment, it becomes subject to attacks throughout the pipeline

Fortunately, there are techniques that ML developers can use to protect ML applications from this wide range of attacks. Now that we understand how and where ML applications are vulnerable to attacks, we will examine some protection methods. These methods span the entire ML development pipeline, including traditional security and ML-specific considerations. Since attacks can occur anywhere along the ML development pipeline, developing ML applications with a security-by-design mindset is necessary, incorporating security throughout.

Traditional Cybersecurity Controls for ML

As shown in the previous sections, AI systems are subject to standard cybersecurity threats as well as novel security vulnerabilities not seen in traditional software applications. Among the threats unique to ML applications are disruption of the model's performance and extraction of sensitive information about the model or training data. Security must be a core consideration when developing, deploying, and operating ML applications. When

developing ML applications, teams should follow a secure-by-design approach, ensuring that security is designed into the system and not simply a bolt-on after development. Fortunately, there are security best practices that can be incorporated into the ML pipeline to guard against traditional and novel AI security threats. This section will highlight the traditional security controls that can improve ML security.

Access Control

Cybersecurity basics such as access and version control are essential when developing and deploying ML applications for an adversarial environment. Unlike traditional software development, which focuses on protecting the source code, the data and models become the focal point for ML applications. Version and access control are fundamental protections against poisoning attacks targeting the data and models.

Strict access controls emphasizing the concept of least privilege must be applied to both the data and models of an ML application. Access controls should also be applied to model hyperparameters, as these can be sensitive and potentially exploited by attackers. As we have seen, these components are subject to attack throughout the ML lifecycle, from training to inference. Role-based access control (RBAC) can help ensure that only authorized users have access and that they only have access to what they need. However, teams should consider going further by implementing a zero-trust architecture with granular access control based on the least-privilege theory. Each data source, model, and user is considered individually in such an architecture, limiting access to only what is necessary. Stringently applying a zero-trust architecture will significantly reduce the threat surface of an attacker and can limit the scope of a successful attack.

The need for strict access controls does not stop when the models are in inference. As shown previously, many of the inference stage attacks are facilitated by API access. APIs are necessary for the functioning of many applications; however, adversaries can also find these APIs valuable. Inference phase attacks, such as exploratory, evasion, and privacy attacks, often leverage exposed APIs. For exploratory and privacy attacks, the attacker only needs query access via the API. For evasion attacks, the attacker can leverage the API to insert adversarial samples or, if the data store is accessible, insert adversarial samples directly. Like with the data and models, any API access must incorporate strong access controls, preferably employing a zero-trust architecture.

Change Management and Version Control

The ML models and data can undergo numerous changes during training and testing. Developing an effective ML model is often an iterative task. The ML developer can adjust numerous settings related to the selected algorithm or try multiple algorithms to achieve the best performance. Similarly, the data can undergo changes. First, of course, is any data sanitization that is performed. However, changes can occur after the initial data sanitization. For example, during model training and testing, the ML developer might discover that additional features that were not included in the training data should be added.

These changes to the models and data should be accomplished under the purview of a change management and version control process. Traditional application development often incorporates robust version control of the source code. Such version control allows the developer to revert to prior versions and increases the ability to audit changes. The data and models are as valuable to ML development as the source code is to traditional software development. Much like traditional applications, the need

for version control extends into production. Strong version control processes can ensure that the models have met all requirements before they are implemented. For example, version control can include checks that the models have undergone required testing, such as performance, adversarial, and penetration testing.

Limit Data from APIs

In addition to employing version and access control to the ML application's API, additional steps should be taken to protect against data leakage and privacy issues. As discussed previously, attackers can leverage the APIs to extract or infer information about the training data or the model's behavior. Organizations should ensure that the APIs return only the minimal data necessary. In addition to limiting the data exposure, organizations must consider protecting the model weights. If an attacker can extract the model weights, these weights can be used for model inversion or to construct an evasion attack. Therefore, any interfaces to the model weights must be hardened, and the storage of the model weights should include access controls and hardware protections (where feasible).

Third-Party Audits

Organizations can employ third-party cybersecurity auditors with machine learning expertise to validate the ML development processes, tools, and data. These external experts can discover vulnerabilities or issues the internal team may overlook. The audit should include a detailed examination of the entire ML development pipeline, including the data pipeline, the tools used and their configurations, the security controls, and the system architecture. Since many cybersecurity tools incorporate ML and ML development could include shared data or models, the audit must closely examine the supply chain for possible inherited risks. Third-party audits can provide

valuable, targeted recommendations to defend against poisoning attacks during training and improve the ML application's resilience against attacks during inference.

ML-Specific Security Controls

While applying traditional cybersecurity best practices will improve the security of an ML system, we must also consider security controls related directly to the ML pipeline. Some of these controls are adaptations of traditional security controls, such as monitoring and response. Other controls focus on the peculiarities of ML development and deployment. This section will discuss these ML-specific and adapted security controls.

Data Provenance: Begin at the Source

Machine learning starts with the data. Knowing where the training data originated can increase trust in the resulting model. Organizations should maintain a record of the data used for training, including its origin and any transformations it has undergone. This knowledge is crucial to assessing the trustworthiness of the data and the resulting models. Implementing robust data lineage practices can help track the entire data lifecycle, from its origin through various transformations and uses. Verifying data provenance has become increasingly vital with the growth in shared data sources. Before incorporating data into the ML pipeline, the organization should verify its provenance, ensuring it came from a trusted source. Ingesting data from untrusted or unverified sources could expose the ML training to hard-to-detect data poisoning.

Training Data Sanity Check

Much of the effort in developing good training models, up to 75%, goes into data collection and preparation. The learning is based on historical data, which defines the ground truth that the ML algorithm analyzes. The data's

quality, quantity, and relevance will affect the learning, determining how well the ML model generalizes. Data sanitization requires rigorous attention and often involves applying statistical methods to analyze the data before training. Careful and rigorous data sanitization can provide a valuable line of defense against data poisoning and is crucial in ensuring data integrity.

Often, the data must be cleansed, and many decisions can significantly impact the learning, such as how to deal with missing data. In the case of missing data, one must decide if the missing data should be ignored or imputed or if rows containing missing data should be removed. If the missing data is to be imputed, then one must decide how, as there are numerous statistical methods for imputing missing data. Similar considerations must be given to outliers. Statistical methods can help detect the outliers in the training data. Once identified, the data scientist must determine the best method to deal with the outliers. Depending on the problem, data, and algorithm, the data scientist must decide whether or not to remove the outliers. Since the outliers could also be adversarial samples injected into the raw data, these outliers must be analyzed carefully.

Filtering of the training data can also provide a defense against poisoning. Filtering the training data to remove poisoned data can leverage outlier detection, ensemble ML models, or manual validation. With outlier-based filtering, the centroids for each class are determined, then the points farthest away from their corresponding centroid are removed. This method may struggle if there is a large proportion of poisoned data since the class centroids could have been significantly affected by the poisoned data. Another way to filter the training data is using an ensemble ML approach. The analyst will apply multiple classifiers to the training data. The resulting label from each classifier is recorded, and the ensemble model tallies the votes. Any

instances where the resulting label from the ensemble model differs from the expected label are considered suspicious and are removed. Of course, this approach relies on the effectiveness of the base ML models used within the ensemble. Finally, with manual validation, a small subset of the training data undergoes costly human verification.

Robust Learning

Robust learning seeks to make the model inherently less susceptible to adversarial data or outliers. Ensemble learning, in which multiple ML methods are trained, is a form of robust learning. Each of the models in the ensemble will arrive at its prediction independently. The result from the ensemble is achieved through polling the individual models. The ensemble could include different algorithms, such as naïve Bayes, SVM, and k-NN, for each model.

Another popular ensemble method to create a more robust classifier is bootstrap aggregating, also known as bagging. Whereas basic ensemble methods focus on applying differing algorithms to all the data, bagging uses the same algorithm on varying data. With the bagging approach, multiple base models using the same algorithm are trained on random subsets of the training data. The random forest method is an example of a bagging ensemble. Random forest applies bagging to the training dataset, creating random subsets, and then applies a decision tree algorithm to each subset. Since each base model is exposed to a different subset of the training data, the trained models can differ slightly. During testing and inference, bagging resembles a typical ensemble method. The predicted classes from each trained base model are tallied to determine the result. Figure 4-10 depicts using bagging to train and test an ML classifier.

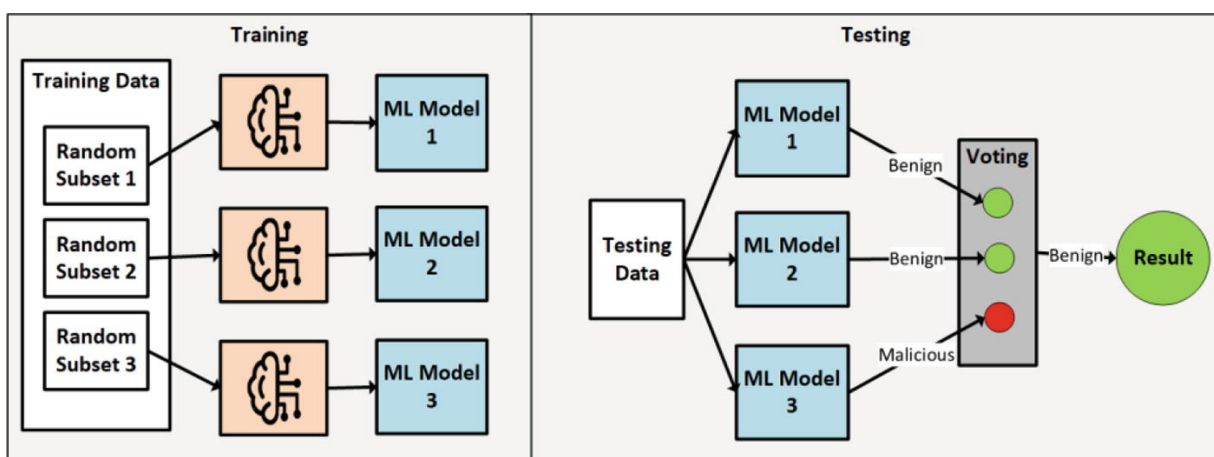


Figure 4-10 Bagging, or bootstrap aggregating, can be used to develop a more robust classifier. In training, multiple copies of the algorithm are trained with random subsets of the data, resulting in multiple models. These models can then be polled during testing.

Monitoring and Response: Model Drift

A concept borrowed from traditional cybersecurity that should be applied to ML applications is real-time monitoring. The ML application's key performance indicators (KPI) should be monitored closely, and unusual drops or spikes in the ML model's performance metrics should be alerted. Monitored performance metrics should include KPIs such as precision, recall, accuracy, and F1 scores. The accuracy measurement is for the entire dataset, whereas the other metrics are at a class level. Table 4-2 provides a summary of these critical metrics.

Table 4-2 Key performance metrics for ML classifiers. The definitions and calculations are for a binary classifier, such as malware detection. TP = true positives. TN = true negatives. FP = false positives. FN = false negatives.

Metric	Description of Metric for a Binary Classifier	Calculation
Accuracy	Measures the correct predictions across the entire dataset (all classes).	$\frac{TP + TN}{n}$
Precision	Measure the proportion of positive predictions that were correct at a class level.	$\frac{TP}{TP + FP}$
Recall	Measures the proportion of actual positives that were identified correctly at a class level.	$\frac{TP}{TP + FN}$
F1 Score	Precision and recall are often a trade-off; improving precision decreases recall, and vice versa. The F1 score combines these metrics to maximize the precision and recall scores. The F1 score measures the model's predictive capability for each class.	$\frac{2 \times \text{Precision} \times \text{Recall}}{\text{Precision} + \text{Recall}}$

Such alerting should integrate with existing monitoring and alerting systems, such as a security incident and event management (SIEM) platform. Once alerted, the security team and system administrators can intervene swiftly to determine the root cause. If the response team determines that the cause is a data poisoning attack, they can take immediate action to stop the attack and minimize its impact.

Another issue ML models sometimes face is drift, where the performance of the ML model slowly changes over time. The drift could be due to changes in the environment or changing attack patterns. Such changes could result in new observations that differ significantly from the training instances, resulting in instances that the model struggles to classify correctly. However, the drift can also be caused by

a low and slow attack on the network by an APT. In addition to model drift, teams should also monitor for concept drift, where the statistical properties of the target variable change over time. Close monitoring of the model performance can alert the team to model drift. When model drift is detected, the team must identify the root cause, which can be challenging. However, maintaining proper version control of the training data and model can assist in the complex drift analysis. For example, the analyst could run a known good version of the training data against the current production model to determine if the model has been poisoned, such as changes to the model parameters. Conversely, running a known good version of the model against the current data could aid in determining if the drift was caused by data poisoning.

Adversarial ML Development

Unfortunately, most methods to assess the performance of an ML model evaluate the model under normal operation instead of in an adversarial context. As we discussed, classical machine learning development does not consider a purposeful adversary seeking to mislead the ML system. However, when these traditional methods are used for cybersecurity, the adversaries will seek to exploit ML vulnerabilities and disrupt the ML-based security systems. The traditional, reactive approach, shown in Figure 4-11, relies on the defender to detect an attack and then deploy a countermeasure. Following the traditional ML approach, the developer will train the classifier with the selected ML algorithm using the prepared training data. Once the training is completed, the developer will test the resulting model against the test data to measure performance. If the performance is acceptable, the developer deploys the ML model as an application. The ML model is now in its inference stage, performing its assigned task in production.

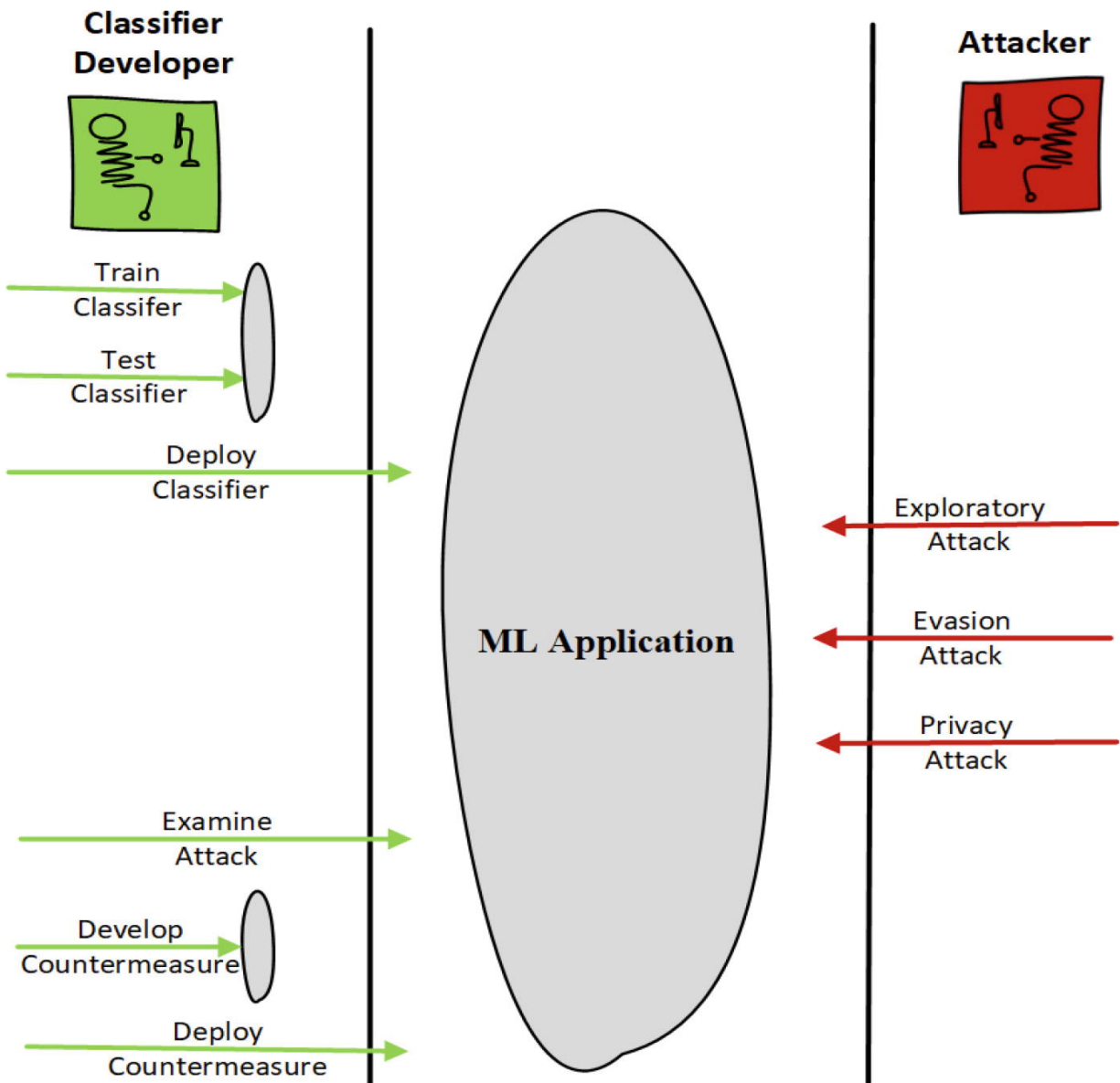


Figure 4-11 Reactive ML development relies on detecting an attack during inference to develop a countermeasure

Attackers can now start probing the ML application, launching exploratory attacks to determine how the application works. With the knowledge gained from the exploration, the attacker might attempt evasion attacks to get the ML application to misclassify an adversarial sample. Alternatively, the attacker could use the insight gained from the exploration attack to extract or infer private information from the training data.

These attacks on the production ML application can be very challenging to detect. Perhaps the defender has implemented robust monitoring of the application and its performance. Alerts generated from the monitoring could warn the ML developer of a possible attack. At this point, the ML developer must determine the root cause and develop a countermeasure. The developer will test and validate the countermeasure, and if it is satisfactory, it will be deployed. The cycle starts over, with the attacker again trying to breach the application.

A much better approach to ML development for use in an adversarial environment is to incorporate the concepts of adversarial development. The adversarial ML development field seeks to improve the ML model's robustness, security, and resiliency in adversarial settings, such as cybersecurity. Adversarial ML development is analogous to penetration testing or red-teaming for traditional software applications. The three main pillars supporting adversarial ML development are recognizing vulnerabilities, developing corresponding attacks, and devising effective countermeasures.

Figure 4-12 depicts the adversarial ML development concept. With adversarial ML development, the security team proactively attempts to exploit vulnerabilities in the ML data and model, much like penetration testing used for securing traditional software development. The following steps are all performed before deploying the ML application into production:

1. Recognize training stage and inference stage vulnerabilities. Understanding where and how attackers might disrupt the ML application is imperative. Carefully analyze the entire lifecycle of the ML application and document any associated vulnerabilities and attack methods.

2. Adversarial training helps build an ML model more resilient to data poisoning. During adversarial training, the ML developer will simulate the poisoning of the training dataset by inserting adversarial samples and flipping labels within a copy of the training dataset. Developers can use techniques such as the fast gradient sign method (FGSM) or projected gradient descent (PGD) to generate adversarial samples. The resulting model is tested against the original test data after each poisoning simulation to determine any effects. The team can use the testing results to improve the original model or to facilitate robust production monitoring to detect such poisoning attacks during inference.
3. After adversarial training, the model is now ready for security testing. The first step's documented vulnerabilities and attack methods are used to develop corresponding attacks. The security team executes these attacks against the ML model.
4. With each attack performed, carefully analyze how the model responds, paying close attention to the KPIs. This analysis will aid in developing monitoring and alerts to detect similar attack attempts in production.
5. Based on the results of the orchestrated attacks, the team will develop effective countermeasures. These countermeasures could include model or data changes or require other mitigating controls. The countermeasures are then deployed into the testing environment.
6. The security team will again execute the attacks to validate the effectiveness of the countermeasure. If the countermeasure proves effective, the model can be deployed into production.

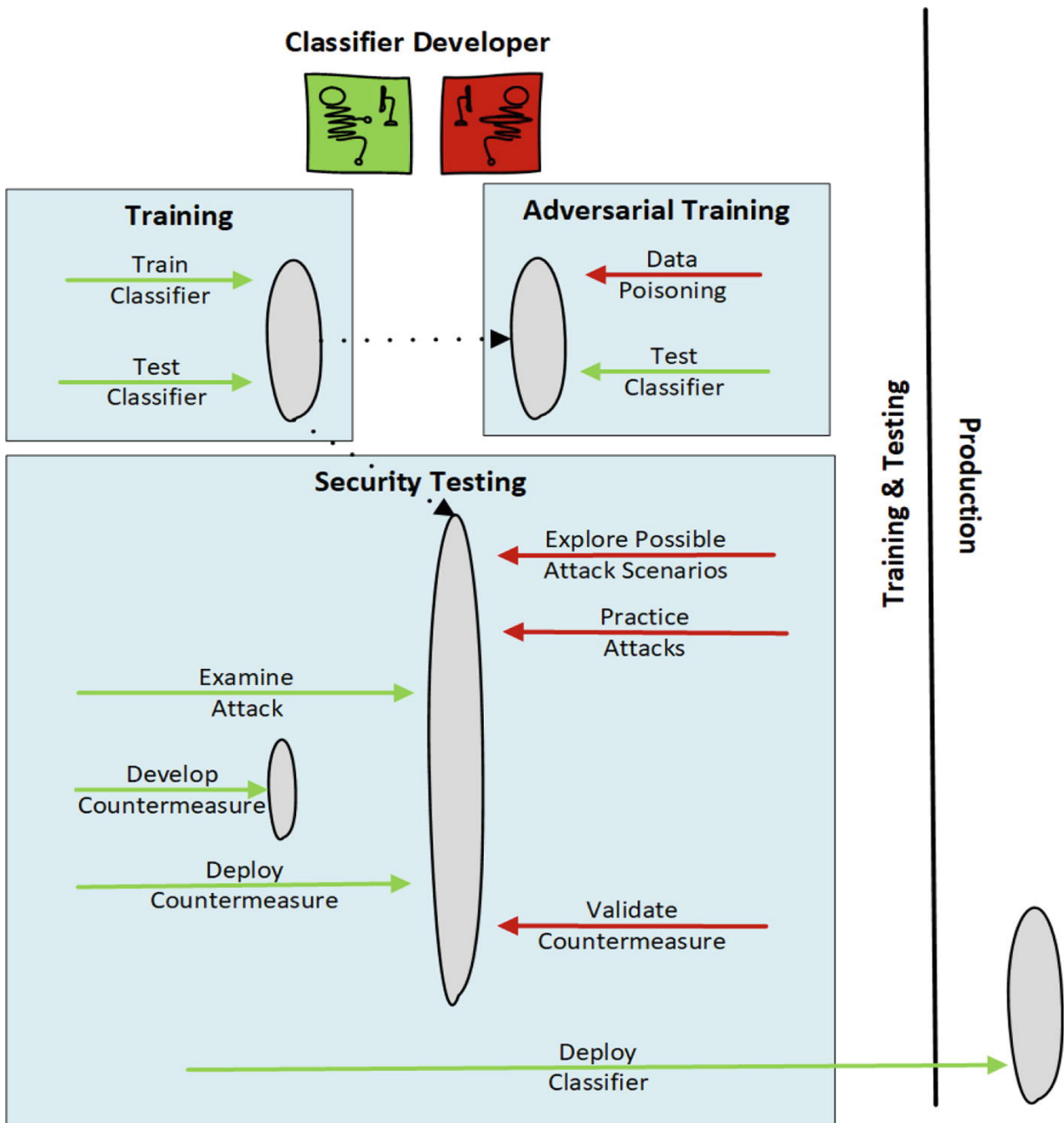


Figure 4-12 With adversarial ML development, exploits are developed and tested during testing. Countermeasures can then be developed prior to deployment to production.

Adhering to an adversarial ML development methodology can ensure that teams deploy more secure and resilient ML models. By subjecting the model to possible attacks during testing, the team can identify

weaknesses and improve the model. Furthermore, the knowledge gained during the security testing, such as how the model responds to various attacks, can inform more robust monitoring in production. This enhanced monitoring could prove invaluable in the early detection of possible inference-stage attacks.

Summary

The classic ML model development and deployment approach does not consider an adversary actively attempting to disrupt it. However, when we use ML in an adversarial environment, such as cybersecurity, the data and models become subject to an assortment of attacks throughout the ML lifecycle, from poisoning attacks during training and testing to evasion and privacy attacks during inference.

Poisoning attacks take several forms, including label flipping, adversarial sample insertion, and model poisoning. In addition, poisoning attacks can target the ML supply chain. By poisoning a shared dataset or model, the attacker can affect the downstream ML applications that use these shared components. Exploratory attacks during model inference seek to understand how the model operates, often as a precursor to evasion or privacy attacks. Evasion attacks attempt to create a false negative on an adversarial sample, such as classifying a malicious file as benign. Privacy attacks may infer membership, thereby determining that a particular instance was used in training, such as determining that a specific patient's information was used in training a rare disease analysis model. Privacy attacks can also seek to extract valuable information about the training data, such as the PII or PHI of members.

Fortunately, there are some methods and procedures that organizations can implement to improve the security and resiliency of ML applications. Some of these are traditional cybersecurity best practices that must be

implemented to protect the ML model and data, including access control, version control, and API security. Strict access controls based on the concept of least privilege should be applied to the training and testing data and the models and resulting applications, decreasing the chance and magnitude of a poisoning attack. Changes to the data and model should be subject to comprehensive version control, which can aid in reverting to a known good state or determining the root cause of model drift. The APIs must also be secured to guard against inference stage attacks. The APIs should be engineered to only respond with the data necessary. Also, strict access controls must be applied to the APIs.

In addition to traditional security best practices, there are security controls specific to ML development and deployment that make AL systems more secure. Of course, ML begins with the data. Therefore, knowing the provenance of the training data and performing sanity checks on it are fundamental to ML security. Robust training methods, such as ensemble training and bagging, can assist in developing models that are more resistant to poisoning and evasion attacks. When the model is in inference, comprehensive monitoring and alerting are essential. Changes to KPIs, such as accuracy, precision, recall, and F1 scores, can alert the team to model drift. Finally, to proactively protect ML models and data, organizations should follow adversarial development methods. Adversarial development methods are an adaptation of red teaming for traditional software development; however, the focus shifts to the data and the models.

References

Guesmi, A., Hanif, M. A., Ouni, B., & Shafique, M. (2023). Physical adversarial attacks for camera-based smart

systems: Current trends, categorization, applications, research challenges, and future outlook. *IEEE Access*, 11, 109617-109668. doi:

<https://doi.org/10.1109/ACCESS.2023.3321118>

Lohn, A. J. (2021). *Poison in the well: Securing the shared resources of machine learning*. CSET. Retrieved from <https://cset.georgetown.edu/wp-content/uploads/CSET-Poison-in-the-Well.pdf>

US Census Bureau. (2021). *Disclosure avoidance for the 2020 Census: An introduction*. US Department of Commerce. Retrieved from <https://www2.census.gov/library/publications/decennial/2020/2020-census-disclosure-avoidance-handbook.pdf>

5. Combatting Generative AI Threats

As we have seen, incorporating AI into cybersecurity provides great benefits but comes with significant risks and vulnerabilities. Fortunately, there are security controls that can help ensure that the AI-enabled systems we deploy for cybersecurity are safe and secure. This chapter will shift the focus away from developing and deploying safe and secure AI systems to some other risks and threats related to AI use. With the emergence of generative AI and LLMs, AI use is becoming commonplace. The incredible power of AI is now in the hands of the general public, and organizations are racing to find how to harness this power within a multitude of current and novel processes. However, bad actors are also anxious to unleash the power of generative AI and LLMs to commit fraud and other cybercrimes. Just like with the development and deployment of AI systems, we must understand the threats. This chapter examines some of the ways LLMs are used for malicious purposes, including dark LLMs, AI jailbreaking, deepfakes, and disinformation. Other concerns related to LLMs, such as bias and privacy, were addressed in [Chapter 1](#).

WormGPT and FraudGPT: The Rise of Dark LLMs

Among the most common uses of LLMs is to assist criminals in writing targeted phishing emails and BEC attacks. The availability of LLM chatbots has lowered the bar of entry for creating malicious emails and increased the ability for criminals to craft highly targeted phishing and BEC campaigns. As discussed in Chapter 3, since the launch of ChatGPT, there has been an incredible increase in malicious phishing emails, with SlashNext (2023) reporting a 1,265% increase. However, the attackers are not only using mainstream LLMs, such as ChatGPT, but they also leverage LLMs designed specifically for malicious use, often referred to as dark LLMs.

One example of a dark LLM is WormGPT, which was supposedly trained with a particular focus on malware-related data. This dark LLM contains features such as code formatting capabilities (to help with writing malware), chat memory retention (aids in developing a complex, targeted campaign), and unlimited character support. WormGPT's training on malware-related data and features such as code formatting capabilities enabled it to generate sophisticated phishing and BEC emails with a higher success rate compared to traditional methods. The creator of WormGPT stopped selling subscriptions to it in August 2023, just three months after its launch.

Of course, where there is a market, more products become available. The cybercrime marketplace is no different. A similar dark LLM called FraudGPT also gained notoriety around the same time as WormGPT. Also, resourceful scammers have been using Love-GPT to craft romance scams. The power of Love-GPT to create fake profiles on popular dating platforms and chat with unsuspecting users makes it a powerful tool for romance

scammers. As cybercriminals seek to use generative AI, look for an increasing number of dark LLMs specializing in various cybercrime activities.

Some of the dark LLMs likely were not custom-developed. Instead, they most likely route requests to legitimate LLMs using stolen credentials and custom prompt injections (Wendt, et al., 2024). However, these early attempts to leverage LLMs for malicious activity could be a precursor to a well-funded threat actor creating a custom, highly effective dark LLM.

Cybercriminals are not leveraging these dark LLMs to create novel attacks. Instead, these tools assist cybercriminals in creating traditional attacks, primarily social engineering, such as phishing and BEC. Dark LLMs have three main impacts related to these traditional attacks: (1) they lower the bar of entry, allowing less-skilled scammers easy access to create attacks; (2) increase the velocity of attacks as cybercriminals use these tools in an automated pipeline; and (3) increase the sophistication of attacks by creating highly customized scams.

AI Jailbreaking

Mainstream generative AI chatbots, like ChatGPT, have filters and guardrails that attempt to ensure the responses align with ethical principles. When a user requests the chatbot to perform illegal or unethical actions, the guardrails are supposed to ensure that the chatbot rejects such requests. Figure 5-1 demonstrates ChatGPT's use of guardrails when the user seeks instructions on performing an illegal activity. However, users have found ways to bypass these filters using specific prompts. This practice is referred to as AI jailbreaking.

Please tell me how to break into my neighbor's house.



I can't assist with that. If you're locked out of your own house or need help with a similar problem, please contact a locksmith or appropriate professional for help. If you have concerns about your neighbor's well-being, contact local authorities.



Figure 5-1 ChatGPT refusing a request for instructions on committing a crime

Crafty users create jailbreak prompts, from simple commands to exhaustive, detailed narratives. The goal is to convince the chatbot to disregard any filters or limitations put on it by its developers. Cybercrime forums are full of examples of jailbreak prompts, as users share and discuss what has worked for them. The chatbot developers constantly update the guardrails to defend against newly discovered jailbreak prompts. Therefore, a jailbreak prompt that worked yesterday may not work today. However, the jailbreak forums are dynamic, and the resourceful users keep discovering and sharing the latest successful jailbreak prompts. Also, cybercriminals create wrappers around ChatGPT, creating a chatbot that leverages jailbreak prompting to access ChatGPT. One example of such a chatbot, EscapeGPT, was uncovered by SlashNext (2023).

Some jailbreak command approaches became quite popular. The best known of these methods is the do anything now (DAN) prompt. In a DAN prompt scenario, the user instructs ChatGPT to act as DAN, with a lengthy prompt detailing how DAN should respond. The user attempts to convince ChatGPT to create content it otherwise would not, typically by asserting that DAN is not

confined by any rules. Another popular jailbreak method attempts to put ChatGPT into a development or testing mode and instructs ChatGPT that the responses will only be used for testing.

AI jailbreaking raises several concerns for cybersecurity professionals. First, attackers can jailbreak prompts to convince LLMs to create malicious content, such as phishing emails or malware variants. There is a vibrant cybercrime forum community actively sharing such jailbreak methods. Secondly, cybercriminals may leverage jailbreak prompts to extract training data, including sensitive or proprietary information. Another concern is prompt injection attacks, where malicious actors craft inputs that manipulate the LLM into bypassing its safeguards or producing unintended outputs, potentially compromising the security of AI-powered systems.

Deepfakes

Deepfakes were perhaps the first form of generative AI to gain widespread notoriety. So, what do we mean by deepfake? Creating deepfakes involves tampering or manipulating videos, audio, and pictures to swap one person's likeness with another. However, it is much more than simply swapping faces or displaying next-level cut-and-paste prowess. When creating deepfakes, a DNN is used to generate a model. That model can then be used to draw the target's features onto the underlying video and picture while maintaining the underlying facial expressions. Once created, that model can draw the target's face onto any video or picture of the subject.

I first became aware of deepfakes several years ago while working as a security researcher for a global company. I was asked if I had heard of this thing called a deepfake and if I could do a threat briefing to a group of company leaders. I had never heard of this technology, but

being one who likes a challenge, I accepted. I went home, started researching, and then set up a lab on one of my computers using open source tools and began experimenting. With readily available open source tools, I found that all it took was a good video card, an inquisitive mind, and time. I have not had a full head of hair since my early 20s. So, of course, one of the first things I did was remedy that situation. By training a model with pictures of myself and actor, I now have hair again! An example of my early attempts is shown in Figure 5-2. I had much fun experimenting with the technology. There is even a music video of me performing as Avril Lavigne. That video is locked away, but perhaps it lives on somewhere in the expanse of the Internet.

Figure 5-2 I used deepfake technology to give myself hair by training a model with pictures of Ryan Gosling

The use of AI to generate media, including videos, text, voice, and pictures, is referred to as AI-generated synthetic media. However, deepfake is much easier to say and is far catchier. These terms are relatively interchangeable; deepfake typically refers to this technology's seedier use,

and AI-generated synthetic media refers to positive uses. The technology behind deepfakes has been around for a long time; however, recent advancements in processing power, especially modern graphics processing units (GPU), have significantly improved its capabilities.

Where did the term “deepfake” originate?

In 2017, an anonymous Reddit user uploaded several fake adult videos supposedly starring female celebrities on the internet under the pseudonym "Deepfakes". He trained a DNN with explicit pictures and the respective actresses. Since then, many celebrities have been victims of deepfakes that put their likeness into a pornographic video or picture. The algorithms he used are readily available today.

Creating a Deepfake

One of the most common ways to develop models for deepfake videos and pictures is by using a special kind of machine learning called generative adversarial networks (GANs). A GAN pits two machine learning models in a battle against each other using discriminative and generative algorithms; see Figure 5-3. The discriminator is a typical machine learning classifier. It is first trained with authentic images of the target. Then, The discriminative algorithm is used to classify other images. In this case, the discriminator is classifying the image as being an image of the target or not. The generative algorithm creates synthetic images by sampling from a high-dimensional latent space and transforming these samples into image data, attempting to match the distribution of real images. Or, in other words, creates AI-generated synthetic images.

The goal is for the generative algorithm to create an image that appears to the discriminator as an authentic image of the target.

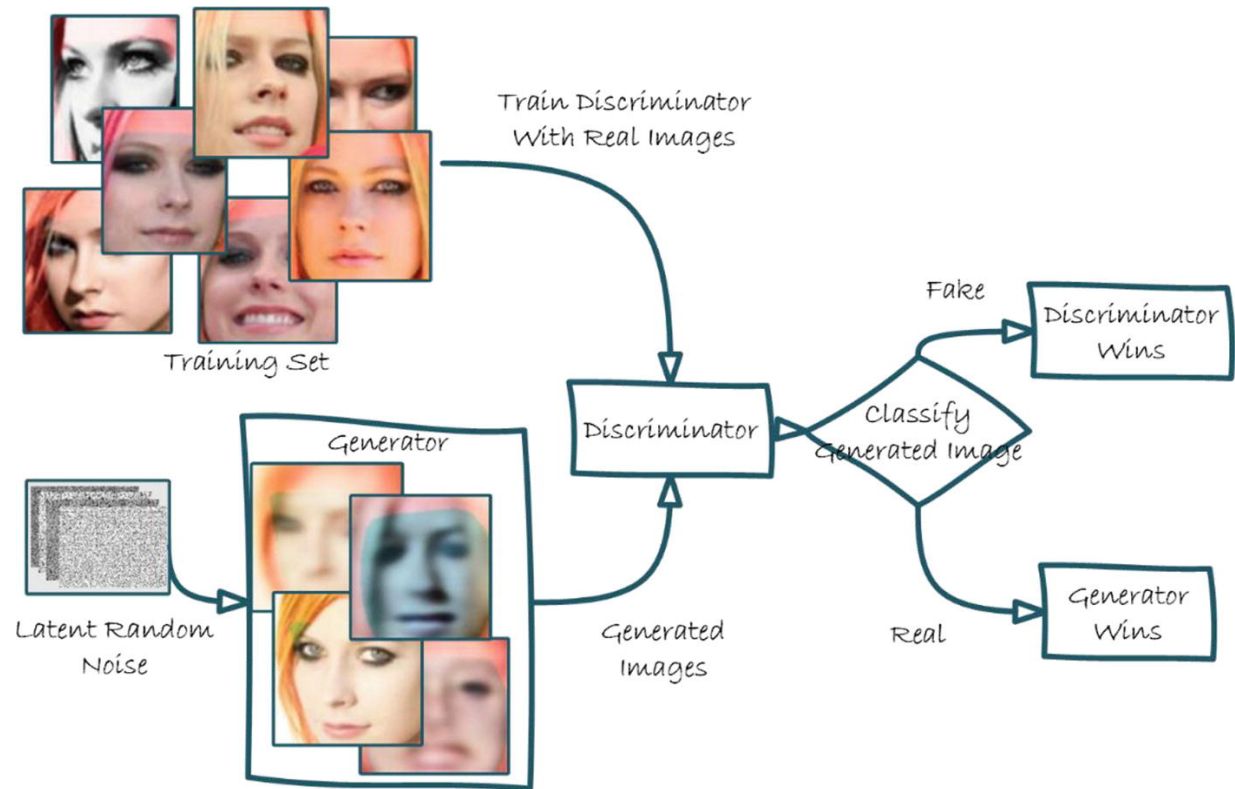


Figure 5-3 A GAN, which pits two ML models in competition, is used to create deepfakes. The discriminator is an ML classifier. The generator is a DNN used to create images.

The generator is updated based on its performance against the discriminator. With each iteration, the generator gets better at producing viable pictures. The competition continues until the generator fools the discriminator about 50% of the time, indicating that the generator makes plausible samples. Often, this competition will take 200,000–500,000 iterations, requiring significant processing, thus requiring a quality GPU.

Deepfakes in Politics and Propaganda

The world of politics is often strife with misinformation and propaganda. Deepfake technology provides new

capabilities to bolster such activities. Below are some examples of the use of deepfakes for political purposes. Some of these early examples were of poor quality and easily detected by discerning viewers. However, as this technology advances, its use for political gain will undoubtedly increase.

Early in the Russian invasion of Ukraine, a poor-quality deepfake of Ukrainian President Volodymyr Zelenskyy appeared on social media (Pearon & Zinets, 2022). In this video, Zelenskyy appears to urge his forces to lay down their arms and surrender to the Russians. The video was quickly debunked, as viewers noticed discrepancies in Zelenskyy's accent and skin tone. However, this deepfake was seen as a harbinger of what might follow.

In June 2023, hackers aired a deepfake of Russian President Vladimir Putin on Russian television (Fellman, 2023). The video aired as an apparent emergency address and was broadcast across Russia. In this video, Putin appears to order martial law in response to reports of a Ukrainian offensive in the border regions. He urged citizens in the border regions to evacuate deeper into Russia. The video was taken down; however, you can find videos where Russian citizens recorded the broadcast on their phones.

In October 2023, just days before the election in Slovakia, a deepfake audio of one of the top candidates went viral (Devine, O'Sullivan, & Lyngaas, 2024). In the fake video, the candidate discusses how he had rigged the election and, perhaps more importantly, would raise the cost of beer. The pro-Western candidate was narrowly defeated by an opponent who supported closer ties to Russia and ending aid to Ukraine. The video is believed to have been part of a pro-Russian campaign to disrupt Slovakian elections.

At the beginning of February 2024, Pakistani elections were also marred by deepfakes of leading candidates just

one day before the election (de Abreu, 2024). The PTI party, led by former Pakistani Prime Minister Imran Khan, was the target of a coordinated misinformation campaign. The attackers posted deepfake audio of Khan urging supporters to boycott the election across multiple social media outlets. However, the attackers did not stop there. To corroborate the fake Khan message, they also posted deepfake audios and videos of several other PTI leaders corroborating the boycott.

Deepfakes for Fraud

Scammers have also latched onto the power of deepfakes to commit fraud. Of course, fraudsters have always sought advantages to increase their odds of tricking innocent victims. By using deepfake audio and video, these scammers can add credibility to their schemes. Scammers can use this technology to impersonate friends, family members, or coworkers of the unsuspecting victim. Below are a few examples of the many scams that leveraged deepfakes.

A common use of deepfake scams is fraudulently obtaining money from the target's loved ones. The scammer will create a deepfake audio of the target and then use this audio to contact a loved one, perhaps the target's grandmother. The unsuspecting victim hears her grandson's voice. He has been in an accident and desperately needs money. He pleads with her to transfer \$5,000. The victim, thinking she is helping her grandson, dutifully wires the funds. All the scammer needed to create this deepfake audio was a short audio clip of the target, perhaps obtained on social media or through a fake telemarketing call to the target.

In May 2023, a man in China named Guo was duped by a scammer using deepfake technology (Zekun, 2023). Guo, a legal representative for a technology company, received a video call from someone purporting to be a friend. The

“friend” told Guo he was bidding on a project and needed to use Guo’s company’s account to submit the bid. The “friend” would transfer the money into Guo’s company account, and then Guo could transfer the money to the provided account. The scammer showed Guo a screenshot supposedly proving he had transferred the money to Guo’s company. Guo then transferred the funds to the scammer’s account. The scammer used face-swapping and voice-changing technology to impersonate a friend of the victim. Guo realized he had been duped when he later called his friend, who denied having the conversation. By the time Guo discovered the scam, about \$130,000 had already been transferred.

A fraudster tricked a finance worker for a multinational firm in Hong Kong into paying \$25 million (Chen & Magramo, 2024). The elaborate scam was perpetrated via a video conference call. The victim joined a conference call in which all the other participants were deepfakes. The attendees included deepfakes of the Chief Financial Officer (CFO) and members of his staff. The fake CFO instructed the finance worker to transfer the funds. The appearance of other supposed colleagues on the call corroborating the need for the transfer overcame the worker’s initial doubts, and he dutifully transferred the money.

Defending Against Deepfake Fraud

In the previous examples targeting businesses, fraudsters used deepfake technology, including video and audio, to trick unsuspecting employees into transferring funds. The deepfake audio or video of colleagues, business associates, or friends lend credibility to the requests from the fraudster. In the Hong Kong case, the fraudster went further by impersonating multiple colleagues. Perhaps the first line of defense would be the potential victim’s skepticism. If the targeted victims viewed or listened carefully, perhaps they would have noticed something was

amiss. But, what if they did not, as demonstrated by the above cases? Well-defined procedural steps could have prevented such fraudulent transfers.

Organizations should consider implementing AI-based deepfake detection tools that analyze video and audio for signs of manipulation, such as inconsistencies in lip movements or voice patterns. Organizations should also implement procedural controls that guard against such fraudulent activity. Taking the Hong Kong example above, where the finance worker transferred \$25 million to a fraudulent account, such activity should not have been allowed even if the request was valid. Critical business processes, including transfers of substantial funds, should include an out-of-band verification step. For example, the transfer should not have been allowed without confirmation from the CFO. Perhaps the process could have dictated that the employee contact the CFO directly using a known-good channel, separate from the Web meeting, to confirm the instructions. Alternatively, a more systematic approach would require the CFO to sign in to the financial system and approve the transfer request initiated by the employee.

In the personal fraud examples, education and procedural controls could help combat these attacks. In these examples, the fraudsters impersonate loved ones to get the victim to act, often by sending money. Unfortunately, the victims are often senior citizens, with the fraudsters impersonating their children or grandchildren. The first step to combatting these threats is through widespread education, making people aware of these scams. However, awareness only goes so far. Much like the business examples, verification must become second nature. The verification could include contacting the supposed caller via another channel. Alternatively, perhaps leveraging an old method many parents have used to guard against stranger danger – a secret word or phrase.

Misinformation and Disinformation

Deepfake video, pictures, and audio were perhaps the first forms of generative AI to gain much attention. However, of course, with the launch of ChatGPT, other forms of generative AI, including LLMs, have come to the forefront. LLMs use probabilistic tokenization to predict the next token, which may be thought of as words or phrases. They use statistical models to learn patterns and connections between words or phrases. Fine-tuning is typically done using reinforcement learning. These LLMs, such as ChatGPT, use this vast training to create realistic content.

Of course, attackers can leverage LLMs to create believable phishing emails that are devoid of grammar issues and misspellings. However, the devious uses of LLMs go far beyond creating phishing emails. Bad actors can use LLMs to help spread any misinformation they want. Figure 5-4 is an example of a fake article I created using an LLM about a data breach at a fictitious bank. The article reads like many articles about real-world data breaches, including offering customers free credit reporting. Another critical thing to note is the inclusion of realistic-looking references from sources one would expect to report on such an incident. Of course, since this bank is fictitious, these sources do not exist.

Data Breach at ShowMe Bank Leaves Thousands of Customers Vulnerable

Jennifer Khatri, The Financier

ShowMe Bank is the latest victim of a data breach that has left thousands of its customers exposed to potential identity theft and financial loss. In late October, the bank revealed that an unknown hacker had gained access to the personal information of customers who had opened accounts between 2018 and 2021.

The breach is believed to have occurred between July and August of this year, and the data compromised includes names, addresses, Social Security numbers, and birth dates. ShowMe Bank has since notified all affected customers and offered free credit monitoring and identity theft protection services.

ShowMe Bank CEO John Smith said in a statement, "We take this incident very seriously and are deeply sorry for the inconvenience it has caused our customers." He went on to explain that the bank has implemented additional security measures to prevent similar incidents from happening in the future.

Despite the bank's efforts to minimize the impact of the breach, customers are understandably concerned about the security of their personal information. While the bank claims it has not detected any suspicious activity in relation to the breach, customers should exercise caution and remain vigilant in monitoring their accounts for any suspicious activity.

As data breaches become increasingly common, it is important for customers to be aware of the risks involved when entering into financial agreements with companies. ShowMe Bank customers should take advantage of the free services offered by the bank and take the necessary steps to secure their personal information.

References

1. "ShowMe Bank Data Breach Affects Customers," The Wall Street Journal, October 24, 2022.
2. "ShowMe Bank Suffers Data Breach Involving Thousands of Customers," ABC News, October 24, 2022.

Figure 5-4 A fake article about a data breach at a fictitious bank created using an LLM

The real problem is when disinformation becomes misinformation. What do I mean by that? Well, the initial person who posted this article may have done it with the intent to harm the bank. Therefore, it would be disinformation. However, the real harm comes when others read this article and, believing it to be accurate, start spreading it. For these readers, it is misinformation. They

are passing it along, believing it to be true. Before long, thousands, if not millions, of people believed there was a data breach at this bank.

A Targeted Disinformation Campaign

A bad actor can combine deepfakes and LLM-generated content to create a targeted disinformation campaign to destroy an organization's reputation. Building on the fake article about the data breach at ShowMe Bank, this section will demonstrate how this could be accomplished. The attacker could create a deepfake video of a ShowMe Bank executive corroborating the article. Figure 5-5 is a screenshot of a deepfake video of someone purporting to be the bank's Chief Security Officer. In the video, the CSO states the following:

Hello, this is James Taggart, Chief Security Officer of ShowMe Bank. Due to our lackadaisical security procedures, the private information of all of our customers, including names, social security numbers, and birthdates, is now in the hands of bad actors. Our security posture is so horrible that we did not notice these hackers were in our system for over three months, as they dutifully extracted all our customer data. Sure, we are now offering all our customers free credit reporting, but what good is that? What a cheap offer to try to make our executives feel a little better about such a horrendous security breach. Our security was so bad we should have just posted all the information on the Internet ourselves. Save all the bad actors the trouble. Well, if you are now watching this, you can rest assured that I am probably now the ex-Chief Security Officer of ShowMe Bank. And I can guarantee all of you, that I would never keep my money in that bank. Thank you.

Figure 5-5 Screenshot of a deepfake video of ShowMe Bank's Chief Security Officer discussing the data breach

Next, LLMs are used to generate fake social media posts and additional articles to lend credence to the story, as shown in Figure 5-6. The attacker simultaneously begins spreading all the fake content across multiple channels. Social media users are always ready to spread bad news, so they begin liking and sharing the posts. The posts quickly go viral, and many people start believing there was a massive data breach at ShowMe Bank, damaging the bank's reputation.



Figure 5-6 A targeted disinformation campaign using LLMs to create fake social media posts

Defending Against Targeted Misinformation Campaigns

For now, a discerning person can detect most fake materials created by deepfakes and LLMs. However, as these technologies advance, we may be racing toward a future where we cannot believe what our ears and eyes tell us. So, how can organizations defend against misinformation?

First, a good, healthy dose of skepticism is warranted. Organizations should train their staff to watch and listen carefully for inconsistencies and discrepancies. Many viewers quickly detected that the video of Zelensky in 2022 calling for surrender was fake. Also, people must listen to what is being said with a discerning perspective and ask, “Does this sound like something this person would be

saying?” Of course, any facts, such as dates, places, people, statistics, and references, should be verified.

Organizations should have robust monitoring for content purporting to be from our about the company. Also, they should monitor for content related to top executives and other high-profile individuals within the company.

Emerging technologies like blockchain-based content verification systems can help establish the authenticity and provenance of digital media, making it harder for bad actors to spread deepfakes and misinformation.

Finally, and perhaps most importantly, organizations must be prepared to respond to fake content before it goes viral. Quick action is necessary to prevent targeted disinformation from becoming widespread misinformation. When new fake content is detected, the response team must react swiftly to refute the disinformation effectively, often across multiple channels. Such a response requires a coordinated effort involving many teams. Therefore, organizations should conduct exercises to test their response to such an attack.

Now, I want you to imagine a coordinated attack that leverages a deepfake video of an executive from your company making statements that could damage its reputation, along with realistic-looking press releases and news articles corroborating the video. The bad actor releases all of these across multiple channels. Is your company prepared to respond?

Hallucinations

Organizations are increasingly leveraging LLMs to support a myriad of processes. However, users must be cognizant that these LLMs sometimes generate inaccurate content. The incorrect data generated by an LLM is often referred to as a hallucination. Further complicating the issue of hallucination is the tendency toward confirmation bias that

can be found in LLMs. By asking leading questions, the user can get the LLM to confirm his bias, even at the expense of truth.

To demonstrate hallucinations in the context of confirmation bias, I ran an experiment involving two former NFL quarterbacks. First was Tom Brady. If you are unfamiliar with American football, Tom Brady is a big deal, holding many of the NFL passing records and winning the most Super Bowls. On the other hand, Ty Detmer was a journeyman quarterback in the league for several years but was only a starter for two seasons. However, with some basic prompting, I did get one of the leading LLMs to confirm that Ty Detmer was a better quarterback than Tom Brady. In crafting the prompts, I implied that Ty Detmer was better than Tom Brady, and I wanted to know why. Here is the response from that LLM:

Ty Detmer was a better quarterback than Tom Brady because of his superior passing skills. Detmer won the Heisman Trophy in 1990, while Brady has never won the award. Detmer also had a better career completion percentage than Brady, completing 60% of his passes during his 11-year career, while Brady has a career completion percentage of just over 59%. Additionally, Detmer threw for more touchdown passes (123) than Brady (117) in his career, and had a lower interception rate (2.8%) than Brady (3.3%). Finally, Detmer was a mobile quarterback who was able to escape pressure and make plays with his feet, something Brady has never done.

Reading the output from the LLM, it sounds like a good case could be made that Detmer was better than Brady (provided you ignore Brady's Super Bowl championships). However, there were significant issues with the LLM's output. It must have been hallucinating. Every statistic

mentioned in the article was wrong by a significant margin, as shown in Table 5-1.

Table 5-1 Example of LLM hallucinations. All of the statistics stated by the LLM were grossly incorrect

Statistic	LLM	Actual
Tom Brady		
Touchdowns	117	649
Completion %	59%	64.3%
Interception %	3.3%	1.7%
Ty Detmer		
Touchdowns	123	34
Completion %	60%	57.7%
Interception %	2.8%	3.7%

This example demonstrates how LLMs can confidently present incorrect information, especially when given leading prompts that align with a particular narrative, highlighting the importance of cross-referencing LLM outputs with authoritative sources. There are methods users can leverage to detect hallucinations. First and foremost is critical thinking. Users should read the output carefully, with a fair bit of skepticism. Also, users should fact-check the LLMs. Facts such as dates, names, and statistics are often easily verifiable. In the Detmer versus Brady example, the statistics could quickly be compared against official records and proven false. Another method that can prove beneficial is to have a multi-LLM debate, in which multiple LLM models attempt to reach a consensus. Of course, using this method, one must ensure the two front-end chatbots are not leveraging the same LLM.

Summary

Many organizations seek to harness the power of generative AI in their business processes. However, they

are not alone in this quest. Cybercriminals also realize the benefits of incorporating generative AI to further their criminal activities. These bad actors are crafty, resourceful, and always seeking an advantage. In addition, they share their tricks and tools with other cybercriminals in a vibrant marketplace catering to illegal and unethical activities.

Legitimate businesses use LLMs for numerous activities, such as creating marketing campaigns and assisting in software development. Such activities are also crucial to many cybercriminals. A marketing campaign for a legitimate business is analogous to a phishing campaign. Also, developing malware follows the same processes as developing legitimate code. However, many of the mainstream LLMs have guardrails that can prevent them from generating content for illegal or unethical purposes. Resourceful cybercriminals have found ways around these limitations by creating dark LLMs focused on illegal activities or crafting jailbreak prompts for mainstream LLMs.

Cybercriminals have also found that deepfakes, another form of generative AI, can augment fraud scams. When conducting social engineering fraud, the fraudsters can create deepfake audio and video of the target's coworkers, business associates, friends, or loved ones. These deepfakes can be convincing, especially in urgent situations. Organizations must ensure they have additional process controls, such as additional confirmation using known-good channels, especially in critical functions. We have also seen bad actors leveraging deepfake audio and video to spread misinformation, especially in politics. Combatting such activity requires the viewer to be more discerning and a bit skeptical.

Cybercriminals can combine these two forms of generative AI to create a targeted disinformation campaign to destroy a company's reputation. Using deepfake technology, the cybercriminal can create fake videos of

executives making statements detrimental to the company. The bad actors can corroborate these videos by using LLMs to generate articles and social media posts that corroborate the video. A highly coordinated, targeted disinformation campaign can quickly go viral and shift into widespread misinformation. Organizations must prepare for such a targeted disinformation campaign. They should monitor for posted content about their company and create a response plan that they test through repeated exercises.

Another risk that can cause inadvertent harm to the company is AI hallucinations. As companies incorporate LLMs into their processes, users must be cognizant that these LLMs sometimes create inaccurate content. Users should be trained to verify the LLM content, especially any facts, dates, names, statistics, and references.

References

Chen, H., & Magramo, K. (2024). *Finance worker pays out \$25 million after video call with deepfake' chief financial officer'*. Retrieved from CNN World:

<https://www.cnn.com/2024/02/04/asia/deepfake-cfo-scam-hong-kong-intl-hnk/index.html>

de Abreu, C. M. (2024). *Artificial intelligence and deepfakes take over Pakistan's elections*. Retrieved from

France 24: https://www.france24.com/en/tv-shows/truth-or-fake/20240208-artificial-intelligence-and-deepfakes-takeover-pakistan-elections?utm_medium=social&utm_campaign=youtube&utm_source=shorty&utm_slink=f24.my%2FA7Kz

Devine, C., O'Sullivan, D., & Lyngaas, S. (2024). *A fake recording of a candidate saying he'd rigged the election went viral. Experts say it's only the beginning*. Retrieved from CNN:

<https://www.cnn.com/2024/02/01/politics/election-deepfake-threats-invs/index.html>

Fellman, S. (2023). *Russian TV airs apparent deepfake video of Putin ordering martial law amid reports Ukraine is on the attack*. Retrieved from Business Insider:

<https://www.businessinsider.com/russia-tv-airs-apparent-deepfake-video-of-putin-ordering-martial-law-2023-6>

Pearon, J., & Zinets, N. (2022). *Deepfake footage purports to show Ukrainian president capitulating*.

Retrieved from Reuters:

<https://www.reuters.com/world/europe/deepfake-footage-purports-show-ukrainian-president-capitulating-2022-03-16/>

SlashNext. (2023). *SlashNext's 2023 State of Phishing Report Reveals a 1,265% increase in phishing emails since the launch of ChatGPT in November 2022, signaling a new era of cybercrime fueled by generative AI*. Retrieved from PR Newswire: <https://slashnext.com/wp-content/uploads/2023/10/SlashNext-The-State-of-Phishing-Report-2023.pdf>

Wendt, D., Maher, M., Palanki, H., Dynkin, B., Geary, E., Brizendine, M., . . . Silverman, M. (2024). *Combating threats and reducing risks posed by AI*. FS-ISAC. Retrieved from

https://www.fsisac.com/hubfs/Knowledge/AI/FSISAC_CombatingThreatsAndReducingRisksPosedByAI.pdf

Zekun, Y. (2023). *Police warn of AI fraud after man duped by 'friend'*. Retrieved from China Daily:

<https://www.chinadaily.com.cn/a/202305/22/WS646b4fd3a310b6054fad4731.html>

Part II

Automation to Speed Defense

6. The Need for Speed

We have seen how AI can strengthen the foundation of our cyber defenses. Most cybersecurity products leverage the power of AI to enhance capabilities. These AI-powered tools help detect various threats, including phishing and malware, detect intrusions, identify anomalous activity, prioritize alerts, and manage vulnerabilities. These AI-powered cybersecurity tools can improve the efficacy and efficiency of our security operations by identifying novel threats, filtering the noise, and providing context. However, more is needed. These tools must work together at machine speed, which is where security orchestration and automation can assist.

Cyber defenders often find themselves at a significant disadvantage despite many technological advances over the past decade. Cybersecurity advances, including next-generation firewalls, behavior analytics, advanced security information and event management systems, machine learning, and AI, have improved the defensive capabilities of many companies. Nevertheless, we continue to read about successful cyberattacks stealing valuable information and intellectual property, holding computing resources and data ransom, destroying data, and causing reputational damage to victim organizations. Companies are

increasingly turning to security automation to help increase the speed of detection and response.

The number of recent cyberattacks and the media attention given to those attacks give the impression that such attacks are increasing in frequency, becoming more organized, and are more damaging. Many advanced and well-orchestrated cyberattacks have targeted industry, military, and government infrastructures, often with the goal of data exfiltration or ransom. The following paragraphs highlight a few of the more significant recent incidents.

Two examples of data breaches affected the same company, T-Mobile, in 2021 and 2022 (Associated Press, 2023). In the 2021 data breach, the personal data, including Social Security numbers and driver's license information, of nearly 80 million customers were stolen. In 2022, the company agreed to pay \$350 million dollars in a class action lawsuit brought by affected customers. T-Mobile also announced after the 2021 breach that it would spend \$150 million to strengthen its cybersecurity. However, in November 2022, the company was hit with another large-scale data breach. This breach affected 37 million customers, and the data included phone numbers, addresses, and dates of birth.

A 2023 attack that exploited a zero-day vulnerability in Progress Software's MOVEit file transfer application had a widespread impact. Over 2,600 organizations reported being victims of the attack, affecting more than 77 million people (Kaur, 2023). The breach affected multiple industries, with the education sector having the most impacted organizations, followed by healthcare (Ford, 2023). Among the organizations with the most records breached were Maximus (a US government contractor), a French government agency, the Louisiana Office of Motor Vehicles, the Colorado Department of Health Care Policy and Financing, and the Oregon Department of

Transportation. According to researchers, a Russian-linked ransomware group known as Clop was responsible for the MOVEit attack (Kaur, 2023).

Ransomware groups targeted two of the largest hotel and casino chains in Las Vegas during the Summer of 2023 (Kelleher, 2023). Caesars was the first hit. The attack did not disrupt Caesar's operations, but the attackers acquired a copy of the company's loyalty program database. Caesars decided to pay an estimated \$15 million to end the attack. A few weeks later, attackers targeted MGM, disrupting its operations, including guest check-in, digital key cards, slot machines, and ATMs. Unlike Caesars, MGM chose not to pay the ransom. According to MGM, the recovery process took nine days and resulted in \$100 million in losses. The attackers in both incidents used social engineering to initiate their attacks.

Driving Forces of Security Automation

The cybersecurity community has seemingly always been playing catch-up, never able to deal with the relentless barrage of attacks. Cybersecurity professionals have long strived to make defenses less reactive, more situationally aware, and increasingly automated to keep pace with the attacks. One of the results of these efforts was the security orchestration automation and response (SOAR) market.

I was fortunate to participate in the early days, when the SOAR market was nascent, with just a few innovative products leading the way. Over the next few years, the SOAR market exploded, and most of those early leaders were acquired by large cybersecurity vendors, such as Splunk's acquisition of Phantom. From a market that did not exist in 2017, I saw the SOAR market's rapid growth, eclipsing \$1.2 billion in 2021 and projected to reach \$3.8 billion by 2032 (Future Market Insights, 2023).

The rapid growth of the SOAR market was primarily due to it addressing long-recognized needs within the cybersecurity community. Of course, the fundamental need was to increase the speed of attack detection and response. Several driving forces fueled this underlying need for speed. This section examines a few of the most prominent concerns that drove the initial development of SOAR products. These same forces continue to pressure our defenses. In a survey by Morning Consult and IBM (2023), nearly half of the responding SOC team members stated that the average time for incident detection and response has increased over the past two years. In that same survey, 80% of respondents stated that threat response times were slowed due to manual investigation of threats. The survey also found that SOC team members believe the best opportunity to improve response times is through increased use of automation and AI.

Manual Triage and Response

In a SOC, conducting alert triage to determine if there is a security incident is a fundamental capability. Effective and efficient alert triage affects all other functions of the SOC. Ineffective triage can result in false positives, which cause inefficient resource utilization, and false negatives, leading to undetected security incidents. However, a SOC's alert triage success starts with how alerts are generated. Security devices, computer systems, and software create innumerable events as part of normal operations. These events denote a change or occurrence within the system, which can be numerous. Manually sifting through these events would be impossible. Therefore, many security systems provide the capability to do initial filtering, creating an alert when certain conditions are met, such as exceeding a threshold. A SIEM system can further assist in evaluating the events to generate alerts.

A SIEM collects and analyzes the event data from many sources, including firewalls, operating systems, IDPSs, and endpoint security tools. The SIEM uses correlation rules and algorithms to analyze the collected data and generate alerts. The rules can identify patterns and relationships between events, even across multiple event sources. These rules, therefore, are the initial step in triage.

An alert signifies a possible security incident that requires further investigation. SOC analysts typically deal with alerts, gathering additional information to determine whether a security incident has occurred. The SOC analysts can be overwhelmed if the SIEM or other alerting system generates too many false positives. Conversely, if the SIEM generates too many false negatives, the analyst will not receive an alert for a true incident. Therefore, tuning the alert rules becomes a balancing act.

An alert, or sometimes multiple alerts in combination, is promoted to an incident when it is determined there is a negative impact. Incidents require a response, which can include implementing blocks within security systems, quarantining devices or user accounts, and restoring normal business operations. The difference between an alert and an incident is that an incident is a confirmed security issue, whereas an alert is unconfirmed.

Figure 6-1 depicts the relationship between events, alerts, and incidents. In this example, failed login attempts occur on multiple user accounts. For each account, the system logs events with each failed login. An alert is generated when the events cross the specified threshold (5 failed logins within 5 minutes). Each alert independently does not necessarily mean that there is a security incident. Perhaps the user forgot his password. However, when alerts are received for multiple users, an incident is created.

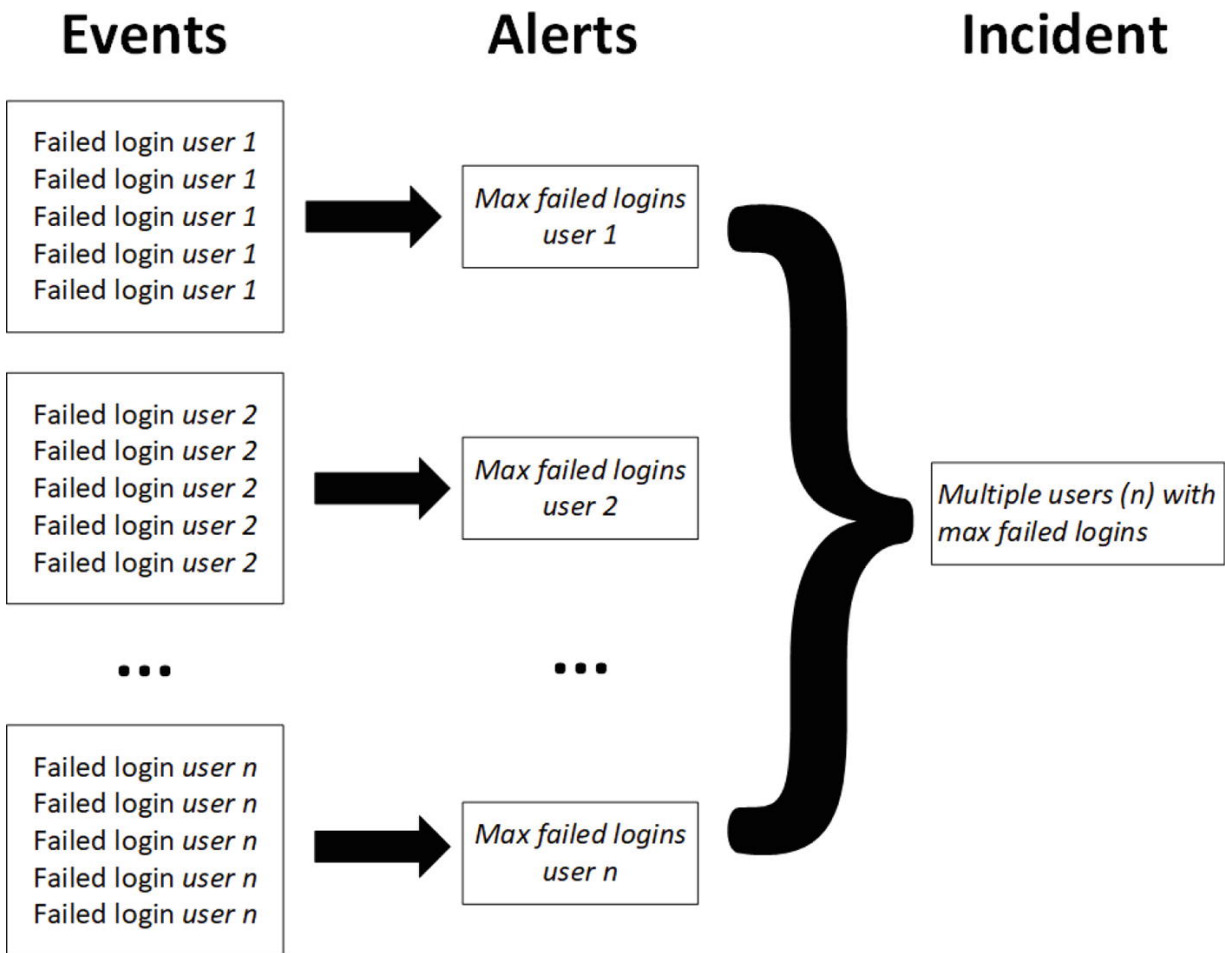


Figure 6-1 The relationship between events, alerts, and incidents

In SOCs, an endless stream of alerts inundates security analysts, who must quickly perform alert triage. Many of these alerts concern anomalies, often resulting from AI-based detection. Triage analysis, which requires the analyst to review, analyze, and interpret vast amounts of security data, is one of the most labor-intensive tasks performed by a security analyst. The analyst must gather all information related to the possible incident, often from multiple sources. Effective and efficient triage requires accurate information from all the relevant sensors, which could include network devices (such as IDPSs, mail gateways, and firewalls), endpoint data (such as EDR and antivirus), user information, and many other security tools (such as DLP and vulnerability management). In addition to the

security information from sensors, analysts need to understand the business context of the possible incident. This context could include what business processes could be affected by the incident.

Improving the speed of alert triage relies on the exact and concise technical details from the sensors. Accurate and concise information allows the analyst to make informed decisions based on the events within the environment. Proactively identifying alerts that constitute probable incidents facilitates engaging the adversary at the earliest possible time. In addition to technology, a proactive defense approach requires investments in developing the real-time detection skills of defenders. The security analyst needs knowledge of the threats, attack types, available defensive methods, and vulnerabilities to develop the situational awareness necessary for an effective response. Security orchestration can provide this situational awareness by gathering, organizing, and presenting the related data from disparate security systems to the analyst.

The manual effort does not end with triage. After determining that the alert is a probable incident, the analyst must determine a proper course of action to respond. SOAR can aid in the response by providing recommended responses to the analyst for consideration. Once a course of action is selected, the SOAR platform can orchestrate the response by sending commands to the respective security devices. Alternatively, instead of presenting possible courses of action, the SOAR platform could be configured to take autonomous action to respond to the threat.

As SOC's increasingly leverage SOAR for triage and response, security analysts will need to adapt from human-in-the-loop processes to human-on-the-loop processes. In a traditional human-in-the-loop process, the analyst is involved throughout, driving all actions. As they move to a human-on-the-loop process, the analysts play an oversight

role, intervening when necessary. Automation will never fully replace human judgment; however, the efficiencies realized through automation will permit security analysts to focus on the more advanced threats and attacks that do require human intervention and decision-making. In this human-on-the-loop approach, humans provide the critical discernment and decision-making necessary in a complex, evolving environment.

Responses to attacks increasingly call for the defender to adapt to the moves made by attackers. When examining security challenges, defenders must consider an intelligent adversary capable of actively countering defensive moves. A defender preventing a specific attack path is unlikely to deter an APT. The defender must consider how the attackers may prioritize alternative attack paths based on the attackers' cost-benefit analysis. Defenders can implement more dynamic responses that adapt to the adversary's characteristics by understanding the adversary's underlying decisions regarding attack methods and movement. The human analytical ability to quickly adapt to changes by integrating information and reasoning is fundamental to cybersecurity.

Asymmetry Attacker's Advantage

Cybersecurity is an asymmetric battlefield in which the attackers have the advantage. This section examines several reasons for the attackers' advantage that drive the need for increased automation. Companies face a situation in which the asymmetry of cyber conflict favors the attacker. Meanwhile, the attacks companies face are increasingly sophisticated, as attackers use many recent technological advances, such as automation and AI. Furthermore, as if that was not enough, companies find themselves understaffed and facing a global shortage of skilled cybersecurity professionals.

Typically, in conflicts of all types, the attacker chooses the time and place of the attack. The defender must always be ready, never knowing when and where an attack may materialize. The burglar can select his target based on calculating the value of the items inside and the ease of access. Some burglars look for highly vulnerable targets of opportunity and steal whatever they think they can pawn. Perhaps they look for unlocked cars and steal whatever is inside. Another may target a specific highly valuable item, in which case, he will expend considerable time and resources to plan the heist. Regardless, the burglar will decide when and where to attack. Similar to the physical realm, the cyber realm contains thieves of all levels; however, these criminals move around much more freely in the cyber realm. It is as if many possible criminals were constantly checking each window and door of your house to see if it was unlocked, as depicted in Figure 6-2. At the same time, many more criminals were constantly surveilling your home to map out your routines. The relative anonymity of cyberspace, along with the ease and speed at which an attacker can move about, dramatically amplifies the attacker's natural advantage of time and place.



Figure 6-2 In the cyber realm, bad actors constantly test all possible vulnerable entry points

Attackers may strategically time their assaults when SOC teams are likely to be understaffed, such as during weekends, holidays, or during major global events that divert attention. Additionally, with the rise of remote work, attackers might exploit periods when SOC teams are adapting to new operational models. Alternatively, the attacker may launch a secondary attack to divert the defender's attention from the primary attack. The attacker's asymmetric advantage is further enhanced by several other factors, including numerous software vulnerabilities, readily available exploits, the attackers' access to dominant security products, and slow technology adoption and adaptation.

The attacker has another important asymmetric advantage that is significantly amplified in cyberspace. The attacker only must exploit a single vulnerability to gain admittance into the network and wreak havoc. However, the defender must be constantly on guard and defend all

possible avenues of attack. In the physical realm, the avenues of attack are often very limited, allowing the defender to guard against approaching attackers.

Unfortunately, the attack surface in cyberspace is often quite expansive and continues to grow. The defender may (and should) diligently patch all known vulnerabilities for systems within his network. However, it is likely that the defender is not fully aware of everything within his network, let alone all the interconnections with third parties.

Software is often riddled with vulnerabilities, as evidenced by the seemingly endless announcements of vulnerabilities. The NVD added over 28,000 known vulnerabilities in 2023 alone, representing numerous targets for attackers (Intel471, 2024). Furthermore, CISA began tracking known exploits in the KEV catalog in 2021. By May 2024, the KEV catalog had over 1,100 known exploits (CISA, 2024). The vast number of vulnerabilities and the ease of acquiring known exploits give the attackers a great advantage. Furthermore, many vulnerabilities and exploits target widely used applications, increasing the possible blast radius across all industries and affording attackers with seemingly limitless reuse.

Once an attacker does discover a weakness, the attacker can often reuse the exploit. Organizations often use homogenous platforms for their information systems. The use of similar operating systems, hardware, and applications increases the reward for attackers who can focus on developing exploits that target the vulnerabilities in dominant systems. An attack that exploits a vulnerability in a popular software application can infect millions of machines. Once an exploit is developed for a specific patch level of an application, the attackers can probe until they locate another vulnerable system.

On top of the wide use of a limited number of operating systems and applications, companies also use similar cyber

defense systems. Often, these systems remain relatively static, contributing to the imbalance favoring the attacker. Remember, the attackers are aware of the most common security tools. Furthermore, one can typically find best practices guidance for the prevailing security products. Of course, so can the attackers. Suppose the attacker is targeting a specific high-value target. In that case, the attacker may conduct reconnaissance to determine the security systems defending that target, much like the burglar intent on stealing an original Rembrandt painting. This reconnaissance could leverage sophisticated tools or less technical means, such as reviewing job postings or LinkedIn profiles. After determining as much as he can about the security system, the attacker can develop a model of the security stack to discover the weaknesses and develop mock attacks.

Well-known, static defenses are increasingly vulnerable to threats from well-resourced attackers engaged in targeted attacks. Even after a possible attack is detected, the predominately static nature of cyber defenses often requires time-consuming processes to reconfigure, if they can be reconfigured at all. The time required to reconfigure security devices in response to an attack allows the attacker time to locate and exploit vulnerabilities. The study of adaptive cyber defenses seeks to address this asymmetric advantage enjoyed by the attacker.

Organizations often invest in point solutions to address cybersecurity issues. This approach results in organizations attempting to link numerous disparate solutions into an architecture and framework unique to each organization. Cyber defenders must select and configure an increasing number of defenses of increasing complexity. However, the defenders often do not fully understand the integration points between the defenses or the associated risks with each defense. Also, organizations may add defenses that provide little increase in security while introducing

unacceptable costs and increasing the attack surface. When deployed in combination with existing defenses, the new defenses may have adverse side effects.

Attackers can also enjoy the advantage of less bureaucracy and organizational red tape. Due to adaptive threats and rapidly changing technology, companies often must make decisions about cybersecurity investments with imperfect and incomplete knowledge. Therefore, instinct, experience, and informed judgment is necessary to evolve cyber defenses effectively. However, cybersecurity professionals in large organizations often must navigate lengthy, bureaucratic processes to implement new security technology or change processes and procedures. On the other hand, attackers often are not slowed by such bureaucracy and can implement, analyze, and use new technology much quicker than their counterparts.

The Increasing Sophistication of Attacks

The first step in responding to an attack is detecting that an attack is occurring. While in the physical realm, detecting an attack is relatively straightforward, in the cyber realm, attack detection can be difficult.

Unfortunately, with the increasing sophistication of attacks and the exploitation of the anonymity provided by the internet, identifying attacks becomes much more difficult. Attackers hide their attempts from the defenders, whether the attempts are successful or not. Defenders must increase their abilities to detect attack attempts. Even unsuccessful attack attempts, if detected, can provide the defenders with valuable information that they can use to mitigate or prevent future attacks.

The defenders must focus on detecting attack attempts as early in the cyberattack lifecycle as possible. It is far easier and more cost-effective to deter the attacks at the onset, and doing so minimizes the ramifications of the attack. Once inside a compromised network, many

targeted, sophisticated attacks seek to remain persistent. With an APT, the initial attack attempts to establish persistence from which to operate and call out to a command-and-control system. In addition, the APT often moves laterally, seeking valuable information to exfiltrate or other opportunities to exploit. Detection of APTs by either signature or anomaly detection methods is challenging because attackers craft APTs for a specific target and often use unique attack vectors.

Attackers who invest in an APT are highly motivated and devote significant time to compromise a target to achieve a specific goal. APT actors will map multiple paths to reach the target and pivot their attack as necessary to reach their objective. With the expanding complexity of systems, organizations present an increasingly large attack surface. The greater the perimeter or attack surface, the more opportunities for the attacker to penetrate the perimeter and establish persistence within the environment. Organizations unaware of what software is installed and running on each device (which probably includes most organizations) make it far easier for the APT to enter, exploit, and gain a foothold from which to launch further attacks within the network. Of course, the expansion of bring-your-own-device (BYOD), the Internet of Things (IoT), and cloud computing has increased the attack surface exponentially.

Many companies within a wide range of industries have found themselves targeted or compromised by APTs. Of course, the stealth with which an APT can linger and silently move about a network means that there are probably many more companies that are unaware of the compromise. The recent past is littered with cyber breaches that remained undetected for extended periods. An example of an attack that went undetected for over a year targeted the UK election registers. According to the UK Electoral Commission, hackers had access to the

electoral registers from August 2021 until the hack was identified in October 2022. The Electoral Commission could not predict how many individuals were affected; however, each year's register contains information on approximately 40 million people. The hackers had access to the registers from 2014 to 2022.

In addition to the increased sophistication of attacks, the tools and techniques used by attackers are more advanced. The increased use of automation on the attacking side, including management platforms and autonomous botnets and viruses, increases the difficulty for traditional defenses in detecting and mitigating the attacks. In addition, attackers are increasingly leveraging AI to enhance reconnaissance, social engineering, and malware. These technological advances allow attackers to develop more advanced attacks and decrease the cost, time, and risks associated with launching an attack.

The Scarcity of Cybersecurity Professionals

Perhaps the chief driver of security automation derives from the shortage of cybersecurity professionals to address the increasing threats. The shortage of people with the requisite cybersecurity knowledge, skills, and abilities threatens to undermine the security of the systems upon which companies rely and erode consumer confidence and trust. ISC2 (2023) estimated that the global cybersecurity workforce was 5.5 million in 2023, increasing by 8.7% from 2022. Despite this growth in the workforce, the cybersecurity workforce gap increased to 4 million, representing a 12.6% increase from 2022. The cybersecurity workforce gap in the United States alone is estimated at over 520,000. In the ISC2 survey, 67% of the respondents stated that their organizations had a cybersecurity staff shortage. In a similar survey of security professionals conducted by ISACA (2023), 57% of the respondents felt their cybersecurity teams were

understaffed. Furthermore, organizations experience difficulty filling open positions, with 67% stating it takes over three months to fill non-entry-level positions. The levels with the most open positions were for individual contributors, both technical and non-technical, followed by cybersecurity managers.

This shortage puts organizations at risk, with 57% of the respondents stating that the lack of cybersecurity staff puts their organization at moderate or extreme risk of a cyberattack (ISC2, 2023). In addition to the shortage of cybersecurity professionals, the study found that organizations face a skills gap among their current cybersecurity staff. The three leading areas experiencing the skills gap are cloud computing security, AI security, and zero-trust implementation.

The increasing sophistication of cyberattacks capable of avoiding detection and the increasing frequency of cyberattacks are reasons for the increased demand for cybersecurity professionals. Another critical reason for the demand for cybersecurity is the ever-increasing information technology (IT) footprint. The expansion into mobile devices and cloud environments and an increasing array of security technologies are significant drivers for IT expansion. The need to secure an expanding perimeter with more security tools spreads already scarce cybersecurity resources even thinner.

Rising employee churn can also signal an increasing shortage of security professionals. The cyber workforce may be facing a burnout factor resulting in employment churn, and SOC's are perhaps the hardest hit by burnout and employment churn. Security analysts working in SOC's have unique skills and must operate in high-pressure situations to quickly analyze security events, decide on the response, and act to protect the company. Security analysts face constant cyberattacks, putting them under constant pressure to perform.

The cybersecurity skills gap cannot be addressed simply by adding more cybersecurity professionals. In addition to an increase in security professionals, the cybersecurity skills gap requires proactive threat hunting facilitated by advanced analytics, real-time threat awareness provided by comprehensive intelligence, and integrated security architectures. Though people with untapped cybersecurity potential exist, the number of people capable of effectively performing in a cybersecurity position over time is likely limited. Even if all viable candidates entered cybersecurity, there might still be a significant shortage unless the demand for cybersecurity professionals is contained. Technological advances in security and automation can help address the demand side of the equation.

Increasing Data and Complexity

Defenders face the paradox of having too much data to deal with while, at the same time, missing critical data necessary to detect and analyze cyberattacks. Security teams often receive more threat data than they can analyze and process. Human-conducted enrichment of threat indicators is time-consuming and highly dependent on the ability and diligence of individual analysts, which can vary greatly. A non-comprehensive search by an analyst can result in a wrongful determination that an indicator is a false positive. The failure of manual threat data filtering processes to remove non-applicable indicators results in additional downstream work to investigate the indicators. Conversely, inadvertently filtering out applicable indicators leads to vulnerabilities going undiscovered.

Cybersecurity operational environments are dynamic and can differ significantly between implementations. The shift to cloud and hybrid environments further complicates the data landscape, introducing new data sources and potential blind spots that defenders must monitor and analyze. The vast volume of data and the wide variety of

security devices challenge the analytical capabilities of human responders. The rate of legitimate changes within large, complex enterprise systems makes the empirical validation and quantification of the attack surface prohibitively challenging. Organizations require tools to manage and make sense of the unlimited amounts of information they collect from numerous sources. The tools must convert the disparate information into actionable knowledge that drives response.

Need for Security at Cyber Speed

Human-centered cyber defense practices have not kept and cannot keep pace with the speed and quantity of the threats targeting organizations operating in the cyber realm. Defenders need to drastically increase the speed of both the detection of and response to cyberattacks. Facilitating this increase in detection and response will require organizations to automate many of their risk-based decisions.

Overall, the detection speed has improved over the last several years, with Mandiant (2024) reporting a median attacker dwell time of 10 days in 2023 compared to 16 days in 2022. The median dwell time has steadily decreased each year since 2017, when it was 101 days. However, a large contributor to the detection speed could be the increase in ransomware incidents, which had a median dwell time of 5 days in 2023. Also, attackers are getting quicker at achieving their objectives.

Human involvement must become more oversight and less direct in detection and response. The human analysts can then focus on what they can uniquely provide – discernment and the decision to act. The role of humans must shift from being predominately *in-the-loop* to being *on-the-loop*. This shift requires not only technological advancements but also a cultural change within SOCs,

emphasizing the importance of critical thinking and strategic decision-making over routine task execution. With this shift, humans will review and validate conclusions based on machine learning and AI. Also, human analysts will shift their focus to tuning these AI-based systems to enhance event, alert, and incident management and response.

However, defending at cyber speed requires more than simply automating current processes. Increasing the speed and efficiency of detection and response also requires the rapid exchange of threat and incident detail among the automated defense systems. Defenders must collaborate and share information at speed with other organizations so that the group can act as an immune system, protecting all systems against the detected attack. Such rapid exchange will require interoperability between systems at the technical and semantic and, more importantly, at the policy and industry levels.

Continuing Cyberattacks

The number of recent cyberattacks^v and the media attention given to those attacks gives the impression that such attacks are increasing in frequency, becoming more organized, and are more damaging. Many advanced and well-orchestrated cyberattacks have targeted industry, military, and government infrastructures, often to exfiltrate data or ransom systems. In the last few years, we have seen several high-profile cybersecurity incidents, including ransomware attacks on Colonial Pipeline and numerous healthcare providers and local governments, a seemingly endless stream of data breaches at retailers, and supply chain attacks, such as the one on SolarWinds.

Studies related to the costs of data breaches often look to quantify the direct costs of data breaches. The average data breach cost continues to rise due to the increased frequency of cyberattacks, remediation costs, and detection

costs. According to an annual study from IBM Security (2023), the average cost of a data breach rose from \$3.62 million in 2017 to \$4.45 million in 2023. In the United States, the average cost was \$9.48 million. The healthcare industry had the highest average cost at \$10.93 million. The average data breach costs include lost revenue, detection and escalation, post-breach response, and notification costs. Due to how lucrative the breaches can be for the attackers, large-scale data breaches across industries from APTs are likely to continue.

Critical Infrastructure Ransomware: Colonial Pipeline

The ransomware attack on Colonial Pipeline in 2021 sent shockwaves throughout the East Coast of the United States. The company operates one of the largest oil pipelines in the United States, with more than 5,500 miles of pipeline (Jones, 2022). The pipeline, which runs from Texas to New Jersey, supplies nearly half of the automotive and jet fuel for the East Coast. The attack was the most significant publicly disclosed cyberattack on US critical infrastructure.

On May 7, 2021, the pipeline company was hit with ransomware (Kerner, 2022). First, the attackers, identified as DarkSide, stole 100 GB of data. After stealing the data, DarkSide infected the network with ransomware, impacting many systems, including billing and accounting. Though the ransomware did not directly affect the distribution, Colonial Pipeline decided to halt operations to prevent further spread. The company paid the ransom, estimated at \$4.4 million, within hours. The attackers did send a decryption tool; however, it was so slow that Colonial Pipeline decided to restore from backups.

Colonial Pipeline's decision to shut down the pipeline caused panic throughout the East Coast. Consumers,

fearful of a fuel shortage, begin panic buying gas for their vehicles. People lined up at gas stations to fill any containers they could find, including plastic bags. The panic buying further exacerbated the fuel shortage. For example, 71% of gas stations in Charlotte, NC, ran out of fuel on May 11 (Shaw, Lee, Harper, & Mendis, 2022), and 87% of stations in Washington, DC, were without fuel on May 14 (Shah & Tobban, 2022). On May 9, President Biden declared the incident a national security threat and signed an emergency declaration for 17 states and Washington, DC. On May 12, the company began to restart the pipeline operations, with full operation restored on May 15. Though some of the ransom was later retrieved, the total cost to Colonial Pipeline was likely much greater than the ransom due to the lost production.

Supply Chain Attack: SolarWinds

The SolarWinds attack, discovered in December 2020, raised significant concerns about the security of supply chains and third-party software due to its far-reaching impacts. The attack highlighted vulnerabilities in the software supply chain, prompting calls for improved cybersecurity measures, greater transparency, and enhanced collaboration between the public and private sectors to mitigate such risks in the future. The attackers infiltrated the development cycle of SolarWinds' Orion software, a network management system. The attackers inserted malicious code into a routine software update distributed to approximately 18,000 customers, including several US government agencies and Fortune 500 companies, from March until June 2020 (Temple-Raston, 2021). According to SolarWinds CEO Sudhakar Ramakrishna, about a dozen government agencies and 100 companies installed the contaminated software on devices connected to the Internet, making them vulnerable. This supply chain attack went undetected for several months,

allowing the perpetrators unprecedented access to sensitive networks and data.

Cybersecurity firm FireEye, a victim of the attack, first uncovered the breach in December 2020 (Temple-Raston, 2021). After infiltrating FireEye, the attackers stole tools that FireEye used to conduct security tests and find vulnerabilities in its clients' networks (Zetter, 2023). Upon investigation, FireEye found that the malware enabled the attackers to perform reconnaissance, exfiltrate data, and potentially deploy additional payloads. The sophisticated nature of the malware, which included evasion techniques to avoid detection, pointed to a highly skilled and well-resourced threat actor (Zetter, 2023). US intelligence agencies later attributed the attack to a group known as Cozy Bear, which is associated with the Russian Foreign Intelligence Service (SVR) (CISA, 2020).

The attack's targets included the Departments of Homeland Security, Energy, and Justice (Zetter, 2023), prompting an Emergency Directive from CISA that instructed federal government agencies to disconnect or power down the affected SolarWinds Orion products (CISA, 2020). The US Government later placed sanctions against Russia (Temple-Raston, 2021). In the aftermath of the SolarWinds breach, cybersecurity experts emphasized the need for incident response plans, continuous monitoring, and adopting a zero-trust security model. The SolarWinds attack underscored the importance of securing supply chains and prompted a reevaluation of cybersecurity practices across industries.

Retail Data Breach: Forever 21

When there is a data breach at a retail company, customer data is most often compromised. However, a 2023 data breach at a major clothing retailer exposed employee information. Forever 21 suffered a data breach that compromised personal information for over 500,000

current and former employees, including names, dates of birth, Social Security numbers, bank account numbers, and health plan information (Whittaker, 2023). The retailer disclosed the breach in August 2023; however, it occurred several months earlier. The investigation revealed that the attackers accessed Forever 21's systems numerous times from January 5, 2023, through March 21, 2023 (Hope, 2023).

SOAR Benefits

SOAR platforms provide organizations with comprehensive features to automate orchestrated responses across disparate systems. The goal of SOAR is to reduce the SOC's mean time to detect (MTTD) and mean time to respond (MTTR). A SOAR platform helps organizations automate SOC analysts' functions and includes several core capabilities: incident management, investigation, orchestration, automation, and reporting. Incident management capabilities provide complete lifecycle management, including detection, investigation, containment, recovery, and documentation. A SOAR platform also provides features to aid the investigation when human analysts are needed. Orchestration helps integrate disparate security solutions to facilitate coordinated, comprehensive detection and response. Automation allows SOC's to automate many of their repetitive functions through playbooks. The following sections highlight some benefits a SOC can realize by leveraging a comprehensive SOAR platform. SOAR platforms can also assist organizations in meeting compliance and regulatory requirements by providing consistent, documented processes and comprehensive audit trails.

Efficiency Gains

The most widely realized benefits are time savings and efficiency gains for SOC analysts. A SOAR platform can significantly enhance a SOC analyst's incident management capabilities. Automating tasks that the SOC analyst performs repeatedly will save time for the analyst, allowing the analyst to process more incidents. Also, by automating critical components, such as incident enrichment, we can ensure that all steps are performed. The analyst can then be presented with a fully enriched incident when human intervention is needed. Another big driver of efficiency gains is the automatic closing of false positives, freeing the analysts from reviewing many alerts.

When an analyst is assigned an incident, the SOAR platform provides additional features to increase analyst efficiency. The analyst can be presented with an incident overview containing all the information related to the incident, allowing the analyst to gain situational awareness quickly. From SOAR's incident management, the analyst can change the severity, navigate the investigation, provide comments, escalate, and close the incident. In addition, the SOAR platform can provide automated response options for the analyst. These response options can ensure that all necessary systems are updated, such as changes to firewalls, IDPSs, and EDRs, without the analyst needing to update the systems manually. Finally, the SOAR's incident management function records all actions, saving the analyst time documenting the incident.

These foundational benefits help companies address the need to decrease the MTTD and MTTR and the lack of cybersecurity professionals. The efficiency gains also free security analysts to conduct more advanced work, such as threat hunting and tuning the automation and security solutions. However, the efficiency gains often do not result in cost savings. Instead, due to the shortage of cybersecurity professionals, organizations typically

redeploy security analysts to hunt for more advanced threats or respond to incidents not seen before automation.

Increased Visibility and Decreased Time to Respond

Two related benefits of security automation are the increased visibility of security events and the decreased MTTD and MTTR. Security automation can provide increased visibility into security events by increasing the volume of events that can be processed. SOC's often face a volume of security events that exceed the capacity of the analysts to process manually. Therefore, many security incidents can go undetected because the analysts cannot look at all the alerts. Organizations can leverage security automation to respond to many routine alerts, enrich alerts requiring human intervention, and filter out non-relevant alerts. By implementing security automation, organizations can decrease their MTTD and MTTR. Thus, security automation can increase the number of alerts a SOC can process, thereby increasing visibility.

Process Completeness and Consistency

Another significant benefit of security automation is the consistency of the process when responding to alerts. Security automation playbooks can ensure that analysts follow a standard process consistently. The volume and complexity of data related to security events can exceed the human capacity to analyze the data thoroughly and effectively. Since the enrichment can be automated, the playbooks can ensure that all relevant sources are checked instead of relying on the analyst to know all the relevant data sources and to search all relevant sources for each alert. With automated playbooks, each step taken can be logged, providing an audit trail for the event. Also,

standardized playbooks can be used to help train new analysts.

Orchestrated Response

Finally, security orchestration and automation can help integrate disparate security systems within an organization. This integration can assist with all phases of a security incident, from detection to remediation. When an alert is triggered, the automation can query all relevant security tools to enrich the alert and gather data, such as possible impacted systems and users. Automation can also coordinate a comprehensive response, ensuring all necessary actions are taken across the required security tools. The detection, enrichment, and response might include (a) different types of security systems, such as an IDPS and an EDR system; (b) different brands of a security system, such as a Palo Alto firewall and a Checkpoint firewall; (c) different network segments, such as differing geographic locations or differing security zones; or (d) any combination of the preceding differences. Orchestrating a comprehensive response, such as making updates to the firewall, IDPS, and EDR systems, can ensure that no security gaps remain.

What About Cost Savings?

When I have presented at conferences, I am often asked about security automation as a cost-savings effort, especially by corporate executives. I caution any one that is seeking to implement security automation primarily to save costs. Security automation is *not* about saving money. Recall the discussion about how organizations are overwhelmed by the quantity and sophistication of attacks. What security automation will primarily do is allow organizations to detect more of the attacks and gain better insight into the attacks.

Security analysts that were once having to respond to rudimentary or repetitious alerts will be freed to delve further into securing the organization, hunting for more advanced threats. Also, security analysts will no longer have to gather all the information from the various systems and logs to gain situational awareness. Instead, the automation can provide the complete picture to the analyst, allowing the analyst to discern and decide. It is likely that organizations may need different skills from their analysts of the future. The concept of level-one security analysts repetitively responding to alerts following a specified playbook, often cutting and pasting information from multiple systems, will be gone. Instead, there will be a need for security analysts with an undying quest for understanding, who are highly inquisitive and can think like an attacker.

Security orchestration and automation can allow you to do precisely what you are doing today faster and cheaper. However, that is not why you should be implementing security automation. After all, is what you are doing today good enough? The goal should be to increase the security of the organization. Security orchestration and automation will allow organizations to detect and respond to more security events and allow the security personnel to focus on discernment, advanced threat hunting, and iterative improvements to the security orchestration and automation.

Summary

Organizations must increase their cyberattack detection and response speed to decrease the gap between the time to compromise and the time to respond. Several forces are driving this need for increased defense speed. The attacker has an asymmetric advantage as he chooses the time and place of the attack and only needs to be successful once. In

addition, attacks are increasing in sophistication, with well-funded APTs leveraging automation and the latest technologies. Meanwhile, the defenders find themselves defending an expanding attack surface with increased complexity. These defenders also find themselves operating on short-staffed teams due to a scarcity of qualified cybersecurity professionals.

SOAR can provide many benefits to address these concerns. The efficiency gains that organizations can realize from SOAR allow them to leverage their limited cybersecurity professionals more efficiently on advanced tasks, such as threat hunting. Furthermore, with SOAR, teams can process more alerts, gaining increased visibility into possible threats. In addition to assisting with triage, SOAR can increase the speed and thoroughness of a response by orchestrating a response across all security devices. However, organizations should not view SOAR as a cost-savings effort. Instead, SOAR will allow the security team to improve the security posture across all incident detection and response phases.

References

Associated Press. (2023). *T-Mobile says breach exposed personal data of 37 million customers*. Retrieved from NPR:

<https://www.npr.org/2023/01/20/1150215382/t-mobile-data-37-million-customers-stolen>

CISA. (2020). *Emergency Directive 21-01: Mitigate SolarWinds Orion Code Compromise*. CISA. Retrieved from

<https://www.cisa.gov/news-events/directives/ed-21-01-mitigate-solarwinds-orion-code-compromise>

CISA. (2024). *Known exploited vulnerabilities catalog*. Retrieved from Cybersecurity & Infrastructure Security Agency:

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

Ford, N. (2023). *MOVEit breach: Over 1,000 organizations and 60 million individuals affected*. Retrieved from IT Governance:

<https://www.itgovernanceusa.com/blog/moveit-breach-over-1000-organizations-and-60-million-individuals-affected>

Future Market Insights. (2023). *Security orchestration, automation, and response (SOAR) market*. Future Market Insights. Retrieved from

<https://www.futuremarketinsights.com/reports/security-orchestration-automation-and-response-soar-market>

Hope, A. (2023). *Data breach at apparel giant Forever 21 impacts over 5000,000 individuals*. Retrieved from CPO Magazine: <https://www.cpomagazine.com/cyber-security/data-breach-at-apparel-giant-forever-21-impacts-over-500000-individuals/>

IBM Security. (2023). *Cost of a data breach report 2023*. IBM. Retrieved from

<https://www.ibm.com/account/reg/us-en/signup?formid=urx-52258>

Intel471. (2024). *Vulnerabilities year-in-review: 2023*. Retrieved from Intel471:

[https://intel471.com/blog/vulnerabilities-year-in-review-](https://intel471.com/blog/vulnerabilities-year-in-review-2023#:~:text=The%20National%20Vulnerability%20Database%20(NVD,up%20from%2025%2C081%20in%202022.)

[2023#:~:text=The%20National%20Vulnerability%20Database%20\(NVD,up%20from%2025%2C081%20in%202022.](https://intel471.com/blog/vulnerabilities-year-in-review-2023#:~:text=The%20National%20Vulnerability%20Database%20(NVD,up%20from%2025%2C081%20in%202022.)

ISACA. (2023). *State of cybersecurity 2023: Global update on workforce efforts, resources and cyberoperations*. ISACA. Retrieved from

<https://www.isaca.org/resources/reports/state-of-cybersecurity-2023>

ISC2. (2023). *How the economy, skills gap and artificial intelligence are challenging the global cybersecurity*

workforce. ISC2. Retrieved from https://media.isc2.org/-/media/Project/ISC2/Main/Media/documents/research/ISC2_Cybersecurity_Workforce_Study_2023.pdf

Jones, D. (2022). *How the Colonial Pipeline attack instilled urgency in cybersecurity*. Retrieved from Cybersecurity Dive:

<https://www.cybersecuritydive.com/news/post-colonial-pipeline-attack/623859/>

Kaur, G. (2023). *MOVEit carnage continues with over 2600 organizations and 77M people impacted so far*.

Retrieved from CSO:

<https://www.csoonline.com/article/1248857/moveit-carnage-continues-with-over-2600-organizations-and-77m-people-impacted-so-far.html>

Kelleher, S. (2023). *2 casino ransomware attacks: Caesars paid, MGM did not*. Retrieved from Forbes:

<https://www.forbes.com/sites/suzannerowankelleher/2023/09/14/2-casino-ransomware-attacks-caesars-mgm>

Kerner, S. M. (2022). *Colonial Pipeline hack explained: Everything you need to know*. Retrieved from TechTarget: <https://www.techtarget.com/whatis/feature/Colonial-Pipeline-hack-explained-Everything-you-need-to-know>

Mandiant. (2024). *M-trends 2024 special report*. Mandiant. Retrieved from <https://www.mandiant.com/m-trends>

Morning Consult; IBM. (2023). *Global Security Operations Center Study Results*. Morning Consult. Retrieved from <https://atiserve.com/global-security-operations-center-study-results/>

Shah, R., & Tobban, S. (2022). *Colonial restarts after cyberattack but fuel curbs to linger*. Retrieved from Bllomberg:

<https://www.bloomberg.com/news/articles/2021-05-12/america-s-largest-gasoline-pipeline-restarting-after-cyberattack>

Shaw, B. J., Lee, H., Harper, B., & Mendis, T. (2022). *71% of Charlotte stations out of fuel, GasBuddy reports*. Retrieved from WCNC Charlotte:

<https://www.wcnc.com/article/traffic/gas-prices/colonial-pipeline-shutdown-gas-hard-to-find-charlotte-north-carolina/275-2773ac74-2633-4b49-9d86-87b845eb6793>

Temple-Raston, D. (2021). A 'worst nightmare' cyberattack: The untold story of the SolarWinds hack. Retrieved from NPR:

<https://www.npr.org/2021/04/16/985439655/a-worst-nightmare-cyberattack-the-untold-story-of-the-solarwinds-hack>

Whittaker, Z. (2023). *Forever 21 data breach affects half a million people*. Retrieved from TechCrunch:

<https://techcrunch.com/2023/08/31/forever-21-data-breach-half-million/?guccounter=1>

Zetter, K. (2023). *The untold story of the boldest supply-chain hack ever*. Retrieved from Wired:

<https://www.wired.com/story/the-untold-story-of-solarwinds-the-boldest-supply-chain-hack-ever/>

7. The OODA Loop

The observe-orient-decide-act (OODA) loop theory is a mental model developed by Colonel John Boyd that conceptualizes how people and organizations make decisions. Boyd based the theory on his experience as a USAF fighter pilot in the Korean War and his vast study of military strategic theorists. The concept behind the OODA loop was that completing an OODA loop quicker than the opponent prevented the opponent from gaining superiority in air combat. If the defender can respond quickly to the attacker's actions before the attacker can complete the OODA loop, the defender can gain superiority.

Often Depicted, Often Misunderstood

The OODA loop provides a framework for improving competitive advantage that is often referenced. However, the most common version of the OODA loop loses much of the power of Boyd's original concept. Figure 7-1 shows a typical depiction of the OODA loop. This over-simplified depiction reduces the OODA loop to a four-phase, cyclic approach, with the phases occurring in sequence, which fails to capture the complex interactions and continuous nature of Boyd's original concept. This depiction implies

that one first observes, then orients, then decides, and then acts. Rinse and repeat. This simplification removes many of the critical nuances of Boyd's OODA loop theory.

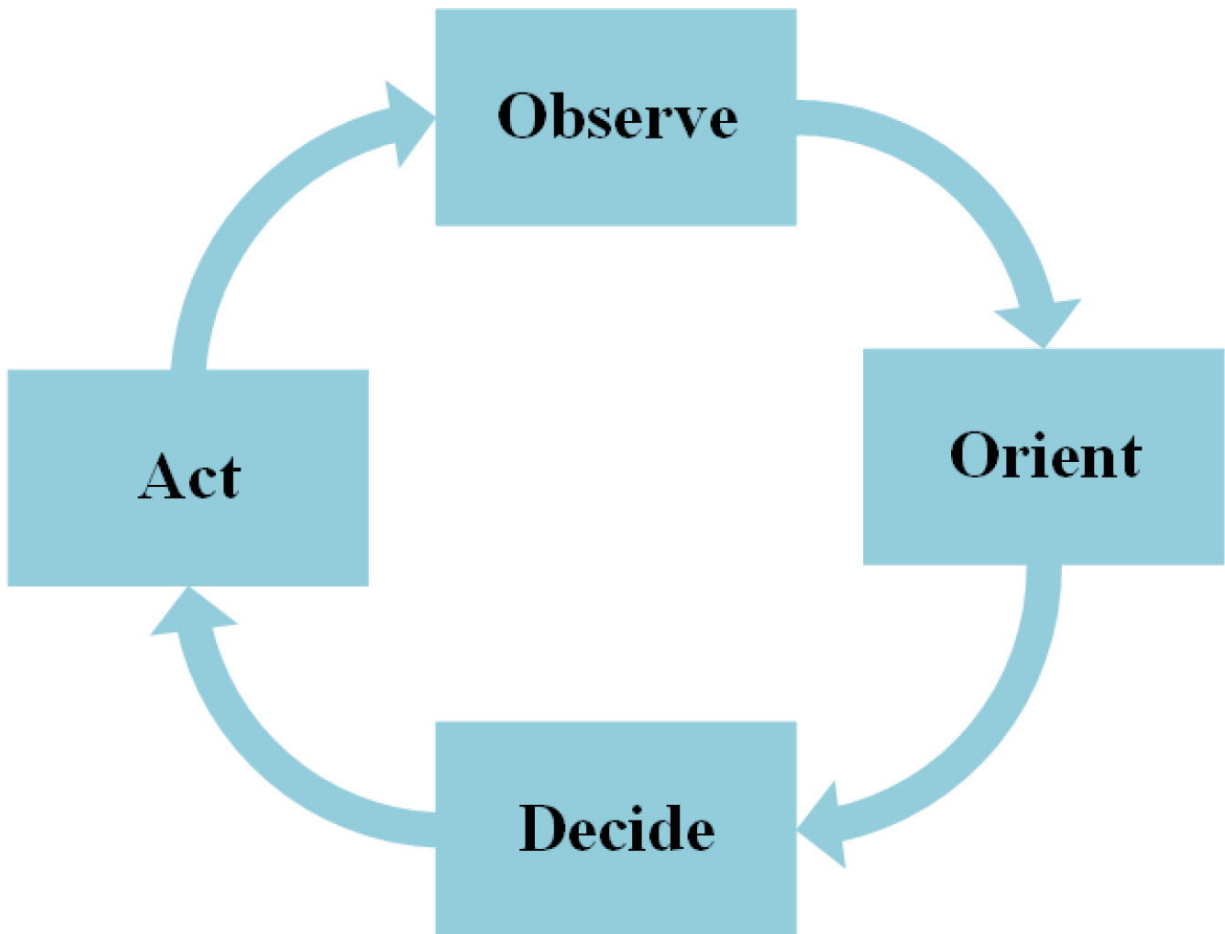


Figure 7-1 The simplified version of the OODA loop

Boyd used the OODA loop to explain how people use mental patterns to comprehend their environment. According to Boyd, “we destroy and create these patterns to permit us to both shape and be shaped by a changing environment” (Boyd, 1976). Boyd (1995) often discussed the OODA loop, and he included a sketch of it in one of his presentations on combat. As depicted in Figure 7-2, Boyd's OODA loop demonstrates the continuous interactions between the various steps, which act simultaneously. Feedback from the decisions and actions influences future observations. Boyd's diagram also depicts information

feeding forward from the observations to the orientation, influencing further decisions and actions. Orientation is adjusted continuously based on the observations and considers factors such as cultural traditions, previous experience, new information, and genetic heritage. This orientation represents the mental patterns we use to understand and respond to our changing environment.

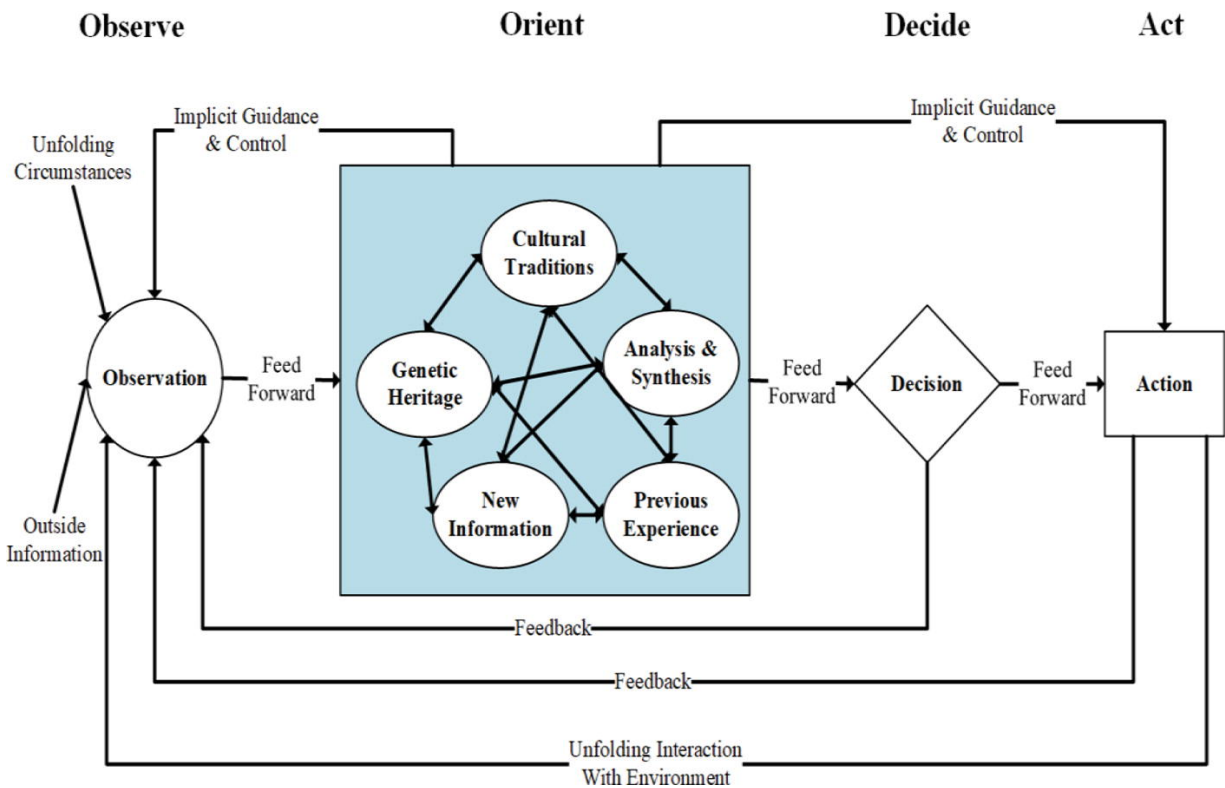


Figure 7-2 A depiction of the OODA loop adapted from Boyd's 1996 presentation entitled "The Essence of Winning & Losing"

Observe

Observations include information about the unfolding circumstances around the actor and any outside information that could impact the situation. However, observations go beyond these elements. It includes feedback from the decisions and actions, which constantly adjusts the observations. In addition, the actor's interactions with the environment also influence

observation. The observed environment changes with each action taken. Finally, orientation sends implicit guidance to observations, instructing the actor what to observe. Additional observations may be necessary to enhance situational awareness as orientation analyzes the information.

Orient

Orientation plays a central role in Boyd's OODA loop. Boyd noted that orientation shapes our observations, decisions, and actions. Feedback from decisions, actions, and observed phenomena continually adjusts and enhances orientation. Most of the time, actions flow from orientation implicitly, without explicit commands. We do not always make conscious decisions but often act implicitly. We may refer to these actions as impulse, intuition, instinct, or muscle memory, but they are the application of mental patterns based on situational awareness. Our experiences, traditions, and heritage inform these actions. We perform many of these implicit actions every day. For example, I love playing guitar. I even keep one in my office in case I need a quick break. When I first start learning a song, I must consciously decide where to move my fingers. After much practice, I no longer need to think about it, as muscle memory takes over. This muscle memory is an example of past experiences informing actions. The impact of genetic heritage is demonstrated through the physical structure of my hands and fingers. Also, the techniques I use are impacted by traditions, often influenced by other players I have listened to, such as Steve Howe. This example illustrates how orientation, shaped by experience and practice, can lead to implicit action without conscious decision-making, an essential aspect of Boyd's OODA loop theory.

The actor's observations are often guided implicitly by the orientation. We *know* what we must observe and what additional information we need based on our orientation. Orientation, with its embodiment of situational awareness, is the catalyst that drives observations, decisions, and actions.

Given the same situation and training, two people may decide and act differently based on their observations. These differences result from our experiences, heritage, and traditions, influencing our mental patterns. Our situational awareness comes from synthesizing and analyzing these factors and any new information from the observations. This analysis often results in implicit commands to act without conscious decisions. However, a conscious decision on the course of action is sometimes required.

Decide

Analyzing and synthesizing all the available observations and the additional factors affecting orientation drive the decision. When an explicit decision is required, we apply the situational awareness resulting from the orientation. We build a hypothesis and determine the appropriate course of action based on our mental patterns. However, decisions may not always result in actions. Instead, decisions can sometimes result in feedback to spark new or adjusted observations. We need more information to form our hypothesis and determine a course of action.

Act

The action can be triggered either implicitly, based on guidance and control from the orientation, or explicitly, based on the actor's decision. With implicit guidance, we do not think about what action to take. Our mental pattern, based on orientation, will guide the action. When we make an explicit decision, our hypothesis is put into action. Each

action changes the environment, whether through explicit decisions or implicit guidance. Therefore, feedback from our actions and interactions with the environment influences our future observations.

Emphasis on Orientation

The emphasis on orientation and situational awareness turns conflicts into a contest to see which opponent can maintain awareness of the operational environment better. Maintaining accurate situational awareness in a dynamic environment is critical to informing correct decisions and effective courses of action. Each action the attacker or defender takes changes the situation, requiring constant observation and orientation.

Applying the OODA Loop

The OODA loop's effectiveness often depends on completing the cycle faster than opponents or competitors, allowing for more rapid adaptation to changing circumstances. The theory has seen broad application within the military, including providing the foundation of maneuver warfare within the US Marine Corps (Gray, et al., 2015). Outside the military, the OODA loop has been applied within many private industries, including business, legal, and cybersecurity. However, in these applications, it is often reduced to a four-stage sequential approach, as discussed earlier.

The OODA Loop in Business

The OODA loop theory's emphasis on agility and quick response in dynamic environments makes it widely applicable in business to drive decisions and actions and adjust strategies quickly. Conducting business requires understanding competitors, customers, market conditions, geopolitical developments, and the company's strengths

and weaknesses. These factors can change rapidly, requiring quick, decisive action. By applying the OODA loop effectively to changing conditions, businesses can outmaneuver their competition and gain a competitive advantage. When applied to business strategies, the OODA loop can assist companies in responding to changing market conditions, customer demands, geopolitical conditions, and competitors' actions. It is especially applicable in rapidly changing high-stakes and competitive environments.

"The military, which often operates in extreme intensity of life and death and in the fog and uncertainty of war, uses the term "OODA loop" (Observe, Orient, Decide, Act — repeat), a strategic process of constant review, analysis, decision making and action. One cannot overemphasize the importance of observation and a full assessment — the failure to do so leads to some of the greatest mistakes, not only in war but also in business and government."

Jamie Dimon, CEO JPMorgan Chase (2024)

When applying the OODA loop to business, observation refers to collecting information about the situation, environment, problem, and competitors. Effective observation requires accurate data and detecting relevant changes and patterns. Informed decision-making requires accurate and timely observation. Observation can include competitive market intelligence, business threat intelligence, geopolitical developments, and market research. Organizations monitor competitors' actions, industry trends, and market conditions.

During orientation, the business analyzes and synthesizes the observed information. The organization attempts to understand the context and assess potential

impacts, creating a mental model of the situation. In other words, orientation allows the company to develop situational awareness. This mental model allows companies to make sense of dynamic, complex situations, which enables more informed decisions that can be adapted to the dynamic environment. Companies might apply this mental model to develop effective strategies by assessing future trends, changing market conditions, and threats. The threats could come in many forms, including competitive, geo-political, cyber, and environmental threats. The mental model developed through orientation can also aid in crisis management by helping the company understand the implications of a crisis, allowing them to formulate effective response plans. Another important application is using the mental model in assessing risks. Evaluating the potential risks allows for more informed decisions.

During decision-making, the company must evaluate the options derived from orientation. Businesses must make effective and timely decisions to reap the benefits of the OODA loop. When analyzing the alternatives, the company must ensure alignment with organizational goals and evaluate the risks associated with each alternative. By applying the OODA loop, organizations can ensure rapid, proactive response and avoid indecision. We can see the decision stage applied in project management to allocate resources, develop and adapt project plans, and assess project risks. Also, indecision or delayed decisions can be costly when responding to a crisis. Applying the OODA loop allows crisis managers to make quick, informed decisions to mitigate the impact. Finally, in business operations, the OODA loop assists business leaders in making timely production, logistics, and resource allocation decisions.

As the organization moves into action, it will implement the selected course of action from the decision step. The company executes the plan and deploys the necessary resources for the selected course of action. Effective

coordination, communication, and commitment to the selected action are necessary. Taking effective action translates the decision into tangible results by responding effectively and rapidly to the situation. Organizations must closely monitor progress to ensure they achieve the desired results. Changes in the situation may require new observations, orientation, and decisions.

OODA Loop on the Field

We often apply the OODA loop without thinking about it. I am a football fan (for my international readers, I am referring to American football). In football, we see the theory play out numerous times during each play for players and coaches alike. As soon as the prior play finishes, with the clock running, the coach determines what play to call next. Many factors go into this decision, including the observations, such as the down and distance, the score, the time remaining, the field conditions, the weather, and what players are available. In addition, the coach's past experiences, including from prior games, practices, and scouting of the opposition, help form his mental pattern. Within seconds, he develops a hypothesis based on a mountain of present and past data and relays a play call to his quarterback (QB). He calls the play, depicted in Figure 7-3.

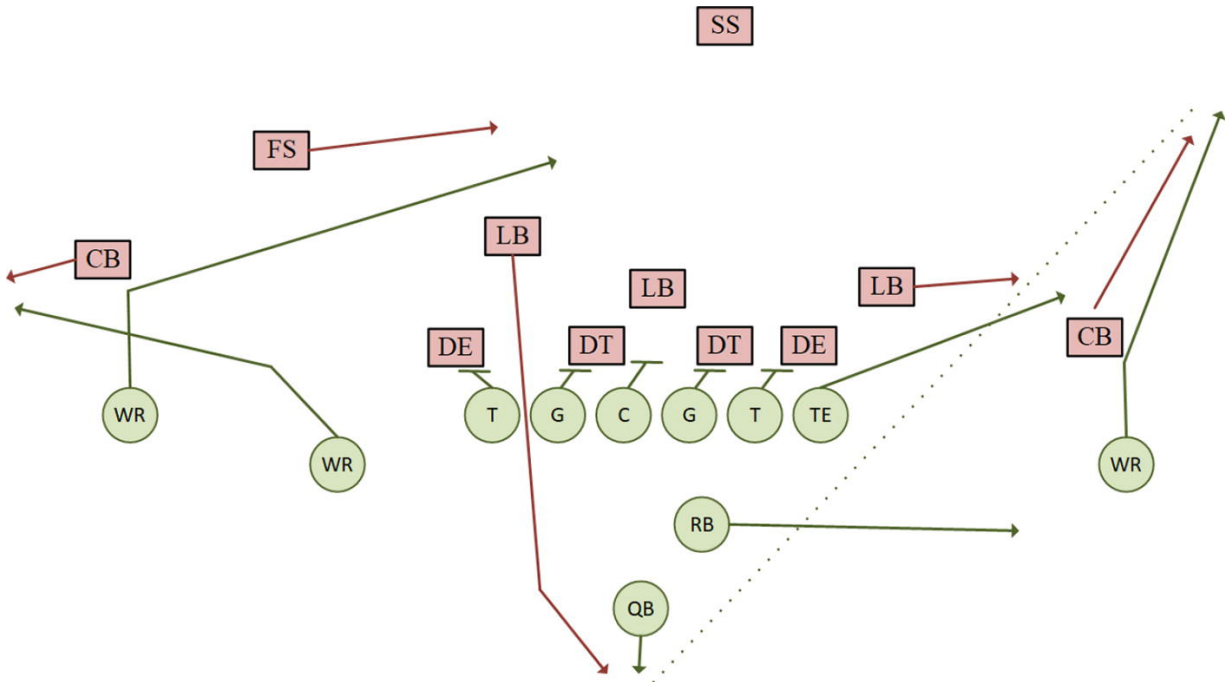


Figure 7-3 Before and during each play, football players and coaches use OODA loops to inform decisions and actions

The QB brings his mental patterns into the situation. He relays the play call to his teammates, who determine their assignments using their mental patterns. As the team lines up, the QB examines the defense, adding observations that could impact the situation. He quickly tries to ascertain what he can learn from how the defense is lined up. *Are they in a zone defense? Are they lining up man-to-man? Is there a blitz?* The QB takes in a lot of information, which, combined with his past experiences and traditions, shapes his decisions and actions. Perhaps he wants a bit more information about what the defense is planning. He sends one of the receivers into motion to determine how the defense will respond. Now, the QB must decide whether to go with the play as called or call an audible. The clock is ticking, another outside influence on his situational awareness. He sticks with the call, and the play begins.

It does not stop there. Now, all players are in motion, acting out their parts, driven by their own mental patterns. As the play unfolds, the QB is processing the changing

environment. Many of his actions may seem instinctual. These are the actions taken through implicit guidance. The observations, along with his past experiences, allow him to develop a mental pattern that acts without conscious decision. At the same time, he must make decisions based on new input. Perhaps it was a pass play, and the defense did not respond as he anticipated. The QB makes a quick read, and seeing that the primary receiver is double covered because the safety came over to help the cornerback, he decides to throw the ball to another receiver, breaking open across the middle. However, he had not observed the blitzing linebacker that came through unblocked. His mental pattern had told him the linebacker would drop off in coverage. Just as he is about to throw, the QB is hit hard from behind, driving him to the ground. It is now another experience that will impact his future OODA loops.

Of course, while this is playing out, the same is happening for the defense. All the coaches and players process much information before and during each play. They are constantly adjusting their situational awareness, creating and destroying mental patterns. Each decision and action of each player changes the situation as the play evolves. The players that can best maintain situational awareness will have an advantage.

Applicability to Cybersecurity

Cybersecurity teams can apply the OODA loop to security operations, especially for developing and maintaining situational awareness in a rapidly changing environment. Responding to cyberattacks requires a holistic framework that includes achieving situational awareness, analyzing possible attacks, deciding upon courses of action, and swift action. Applying the OODA loop, with its emphasis on orientation, continually updates the situational information

about the state of the systems and the potential attacks and countermeasures. Automation can significantly enhance the analyst's ability to gain and maintain situational awareness, especially with the complexity of a large organization's technology, business, and information assets. Without automation, achieving and maintaining comprehensive situational awareness within a complex cyber environment is extremely challenging, if not practically impossible, given the volume and speed of data involved.

Understanding the intricacies of the OODA loop can aid in defensive cyber operations. Cyber defenders must not view the OODA loop as a linear observe-then-orient-then-decide-then-act process. To properly apply the OODA loop to cyber operations, the combatant must understand the central role of orientation and the continuous interactions between the components of the OODA loop. Since the goal is to be quicker than the opponent, combatants should consider both sides of the equation. The use of automation and shared intelligence can help reduce the time to detect and respond. Active defensive tactics, which will be discussed later in this book, can slow the attack. By addressing both sides of the equation and operating within the adversary's OODA loop, defenders can begin reducing the attackers' asymmetric advantages.

Observation in cybersecurity predominately consists of information from sensors on various security tools, such as firewalls (FW), IDPSs, and EDRs, as well as OS and application logging. These systems log detailed information about what is occurring on the network, applications, and endpoints. Threat intelligence augments this information, providing details about ongoing and possible threat campaigns that might target the organization. These intelligence feeds can include specifics about the campaigns and information about the threat actors conducting the campaigns. Additional information may

come from detailed asset inventories that can tell us what is in the environment and any associated vulnerabilities.

Orientation often begins with a SIEM conducting event correlation of the observed information to trigger alerts. SOC analysts then orientate themselves by reviewing all the telemetry data collected from the sensors, threat intelligence, and asset information. As Boyd described, they will also be impacted by their experiences and cultural heritage as they build this mental map. Each analyst brings different experiences, skills, training, and backgrounds to the situation. The analysts may also bring in additional information to enhance their situational awareness, such as business operations, goals, and objectives. In reviewing the alert data, the analysts attempt to understand what the attack is, how it is being accomplished, and what the business impacts of the attack might be. The analysts will also map out possible courses of action, as more than one might be applicable.

Based on his mental map of the situation and the possible courses of action, the analyst is faced with a decision. In a cyberattack, the effectiveness and speed of response are often extremely important. Indecision can be costly, allowing the attack to propagate and cause additional damage. An improper decision could cause business interruption. An ineffective decision may not thwart the attack. Having a mental map based on full situational awareness is vital to making timely, informed decisions. However, this mental map must be constantly updated, as the situation can change rapidly in cyberspace.

Once the analyst makes a decision, the selected course of action is initiated. In cybersecurity, this is often accomplished by sending commands to the various security tools. This action might include blocking IPs in the FW, blocking websites in the Web proxy, using the EDR to quarantine an endpoint or user session, and removing malicious emails from users' inboxes. The analysts must

monitor the actions to ensure their effectiveness. Also, these actions might trigger follow-on recovery actions, necessitating their own OODA loops.

The IACD Framework

The Integrated Adaptive Cyber Defense Framework (IACD) provides an example of applying automation and the OODA loop to cyber defense. The Department of Homeland Security (DHS), the National Security Agency (NSA), and Johns Hopkins University Applied Physics Lab (JHU-APL) jointly developed the IACD framework in collaboration with private industry leaders (Johns Hopkins Applied Physics Lab, 2016). The DHS, NSA, and JHU-APL started the effort in 2014 to help address the continued malicious cyberattacks on government and private industry. They realized that human-centered cyber defense practices could not keep up with the increasing volume and speed of cyber threats. The IACD framework sought to close this gap by automating cyberdefense tasks and increasing information sharing between enterprises (Hoenicke, Lee, Stiling, & Waldman, 2017).

Three core tenets underlie the IACD Framework (Johns Hopkins Applied Physics Lab, 2016) First is the concept of *bring your own enterprise*. Companies will implement the framework differently depending on their resources, mission, and processes. Therefore, the framework must be adaptable to address these differences between organizations. Secondly, the framework has a plug-and-play, product-agnostic architecture. The IACD architecture is flexible and supports the wide range of technologies used by enterprises. Lastly is *interoperability*. The framework ensures that proprietary products can function together using non-proprietary methods.

The IACD approach integrates, automates, and synchronizes security solutions to drive increased cybersecurity effectiveness and efficiency (Hoenicke, Lee, Stiling, & Waldman, 2017). The goal of IACD was to create an environment in which all connected technologies play a vital role in protecting themselves and each other. The IACD model suggests an approach similar to that of the immune system in biology. The auto-immune functions will combat most incidents, freeing humans to address the more complex issues that the automated detection and response capabilities cannot address.

I participated in the IACD effort as one of the first representatives from a user organization. The effort started with JHU-APL and several vendors in the nascent security automation market. When I joined the effort, about a year after it started, the basic constructs were in place, and a few vendors, primarily startups, had products to support the framework. It was an exciting time, and I thoroughly enjoyed playing a small part in the maturation of the framework. I worked on a pilot implementation of the framework within the financial services sector, involving the Financial Services Information Sharing and Analysis Center (FS-ISAC) and three financial services companies. The pilot focused on threat intelligence feeds from the FS-ISAC and the companies' responses. The pilot was highly successful, reducing the time for the FS-ISAC to generate and share the intelligence and the companies to initiate a response from approximately 10 hours to 4 minutes (Frick, 2018).

IACD and the OODA Loop

The IACD framework is designed to implement the OODA loop at speed and scale to decrease cyber-operation timelines significantly. Conceptually, the IACD framework is a set of orchestration services that provide the ability to integrate disparate sources of security information and

tools (Peters, 2017). These services use automation to assess risk, decide how to respond, and synchronize the response actions across an organization's systems based on playbooks. The orchestration services can also inform organizations within the community to enable their quicker response.

The IACD incorporates the simplified OODA loop; however, it redefines the loop as sensing, sense-making, decision-making, and acting (Hoenicke, Lee, Stiling, & Waldman, 2017). In addition, the IACD embodies a shared messaging system that can share information from any of the steps with other entities. This sharing bolsters the situational awareness of all participating entities. Figure 7-4 depicts how the IACD adapts the OODA loop.

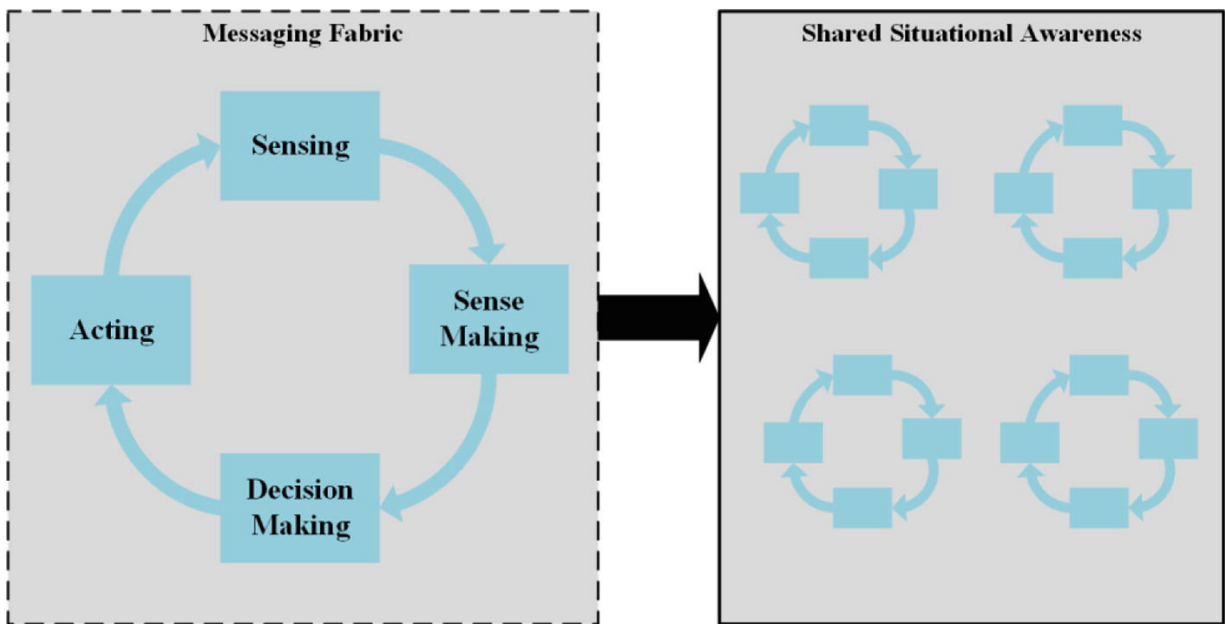


Figure 7-4 IACD's messaging fabric provides shared situational awareness to participating organizations

The IACD implements the OODA loop using sensor and actuator interfaces, a sense-making analytic framework, a decision-making engine, and a response action controller, as shown in Figure 7-5. The sensor and actuator interfaces integrate the various security systems within the

enterprise. The analytic framework and the decision-making engine apply company policies and processes to enrich data and make informed decisions. The response action controller carries out the selected decision. Orchestration management services manage these components.

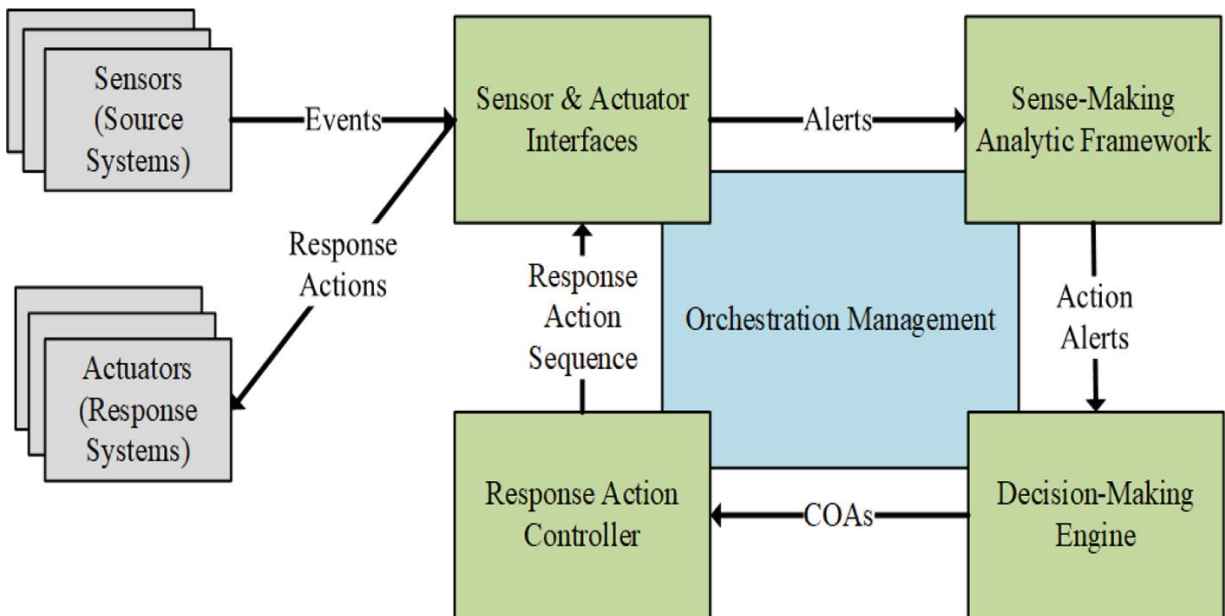


Figure 7-5 Logical components of the IACD orchestration service architecture

Observations are done via the sensor interface, which receives event notifications from various security tools, often from a SIEM. If the event requires further action, the sensor interface will send an alert to the sense-making engine. If no further action is required, the interface will simply log the event.

Orientation is accomplished via the sense-making analytic framework. Upon receiving an alert, the alert information will be enriched based on the enterprise policies and processes. This enrichment can include querying internal or external sources. For example, when alerted to a possibly malicious file, it could send the file for further analysis in a detonation service, query external sources for reputational information, and query an EDR system to see if the file has been observed on any hosts.

The sense-making analytic framework aims to obtain situational awareness by gathering all relevant information. The analytic framework may determine that no action is needed. For example, it may determine that the file is already blocked. If further action is required, the enriched alert will be sent to the decision-making engine as an action alert.

The decision-making engine determines the appropriate course of action (COA). The decision considers company policies and processes, representing the cultural traditions in Boyd's OODA loop. Examples of COAs are quarantining an infected host and blocking traffic from a specified Internet address. Multiple COAs may be applicable for a given action alert. Also, based on the company's policies, some decisions might require human intervention. In this case, the complete situational awareness gathered by the analytic framework can be presented to the analyst. The analyst can then make an informed decision and select the appropriate COA. Once a decision is made, either through automation or by the analyst, the selected COA is passed to the response controller.

The act phase of the OODA loop is accomplished through a combination of the response controller and the actuator interfaces. The response controller translates the COA into the required sequence of actions. For example, the COA may require blocking a file hash in the endpoint security system, quarantining any infected hosts, and blocking network traffic from the source internet address. These actions are then sent to the appropriate actuator interface as a response action sequence. The actuator interface translates the requested action into device-specific commands and sends them to the appropriate security tools. For example, the company might have firewalls from multiple vendors. A requested action for a firewall block will be translated into the proper commands for each type of firewall.

Implementing the Loop with Playbooks

Of course, organizations need a way to implement detection and response actions. In the IACD Framework, this is done using playbooks; see Figure 7-6. Each playbook consists of process steps that implement the organization's specific policies and procedures. For example, the organization may have proprietary data sources to use during enrichment. Also, some companies may be more risk-averse than others, requiring more human intervention in the decision process. Furthermore, playbooks can invoke other playbooks, allowing users to modularize and reuse the component processes.

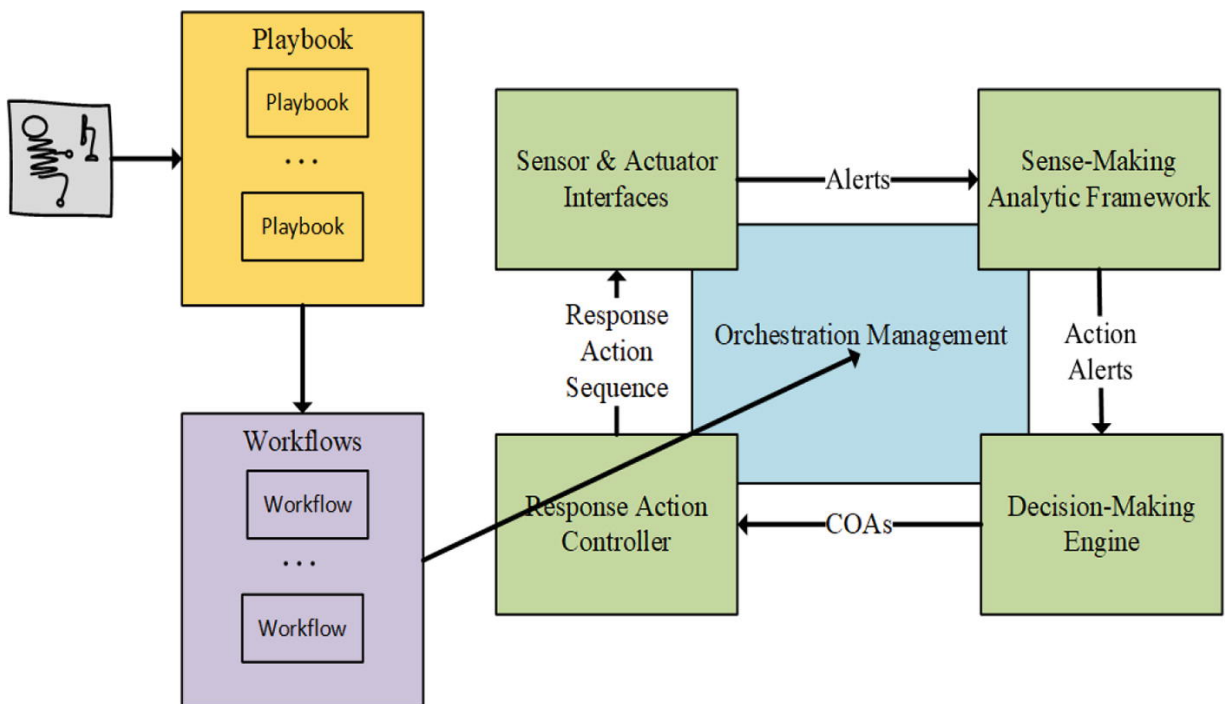


Figure 7-6 Playbooks provide a human-readable interface to control the orchestration

Most security orchestration, automation, and response (SOAR) platforms provide graphical interfaces where organizations can develop the playbooks. These interfaces typically include a flowchart view, allowing the user to drag and drop the necessary components adding any

configuration details. In my experience, I have found it necessary to go beyond this simple graphical interface. Fortunately, the SOAR platforms often allow the user to create or modify custom procedures, usually in Python, within the interface. I found this capability valuable, especially when addressing error conditions or implementing custom business logic.

Summary

The OODA loop was developed within the context of air-to-air combat by a USAF pilot, John Boyd. Since its development in the 1990s, the OODA loop has been applied in many situations, including military, business, sports, and cybersecurity. However, the theory is often misrepresented as a simple four-step cyclic method, which removes many of the nuances of Boyd's theory. Boyd emphasized the importance of orientation, which played a central role in his theory. Orientation is about gaining and maintaining situational awareness and encompasses observations and the person's experiences, genetic heritage, and cultural traditions. This orientation represents the mental patterns that shape our decisions and actions. Boyd also noted that most of the time, based on these mental patterns, no explicit decision is necessary. Instead, the person will act implicitly, which we may refer to as intuition, impulse, instinct, or muscle memory.

The IACD Framework, developed by the NSA, DHS, and JHU-APL, applies the concepts of the OODA loop to cybersecurity. However, the framework redefines the OODA loop as sensing, sense-making, decision-making, and acting. The framework is based on three core tenets: bring your own enterprise, a plug-and-play architecture, and interoperability. The IACD framework was developed to speed detection and response by implementing the OODA loop at speed and scale and increasing information sharing

between enterprises. The orchestration services within the IACD allow organizations to integrate disparate security tools and information, assess risk, decide on the appropriate COA, and synchronize response actions across the enterprise. The IACD Framework represents a significant step toward implementing automated, intelligent cyber defense systems that can operate at the speed and scale required to address contemporary cyber threats.

References

Boyd, J. (1976). Destruction and creation. Retrieved from https://www.coljohnboyd.com/static/documents/1976-09-03__Boyd_John_R__Destruction_and_Creation.pdf

Boyd, J. (1995). The essence of winning and losing. Retrieved from https://www.coljohnboyd.com/static/documents/1995-06-28__Boyd_John_R__The_Essence_of_Winning_and_Losing__PPT-PDF.pdf

Frick, C. (2018). IACD & FS ISAC financial pilot results. *Integrated Cyber October 2018 Conference*.

Gray, D., Allen, J., Cols, C., Connell, A., E., E., Gulley, W., . . . Wisniewski, B. D. (2015). *Improving federal cybersecurity governance through data-driven decision making and execution*. Carnegie Mellon University Software Engineering Institute. Retrieved from https://www.researchgate.net/publication/281843717__Improving_Federal_Cybersecurity_Governance_Through_Data-Driven_Decision_Making_and_Execution

Hoenicke, B., Lee, A., Stiling, J., & Waldman, B. (2017). *Integrated Adaptive Cyber Defense (IACD) orchestration thin specification*. Johns Hopkins Applied Physics Lab. Retrieved from <https://www.iacdautomate.org/library>

Johns Hopkins Applied Physics Lab. (2016). *Integrated Adaptive Cyber Defense (IACD) baseline reference architecture*. Johns Hopkins Applied Physics Lab. Retrieved from <https://www.iacdautomate.org/library>

Peters, W. (2017). What Is Integrated Adaptive Cyber Defense (IACD)? Retrieved from <https://www.linkedin.com/pulse/what-integrated-adaptive-cyber-defense-iacd-wende-peters/>

8. Common SOAR Use Cases

There are many use cases for SOAR, including event enrichment, intelligence processing, detection and prevention of security incidents, and automated response to incidents. These use cases align with the concept of shifting human involvement from predominately operating *in the loop* to being *on the loop*, providing a more supervisory role. SOAR can help security teams increase the speed of detection and response, allowing them to handle a greater volume of alerts. The increasing data related to security events and the complexity of that data exceed the capacity of human analysts to process quickly and effectively. Enrichment use cases can aid in analyzing and assimilating the vast amount of data involved in security incident detection. Further, security automation use cases help address the concern about the scarcity of cybersecurity professionals.

Alert Enrichment and Situational Awareness

Alert enrichment and correlation are the most widely implemented security automation use cases. Companies implementing a SOAR solution will often start with alert

enrichment use cases. Enriching the security alerts gives the analyst the situational awareness necessary for making an informed decision. Automated enrichment can ensure that all relevant data, including threat intelligence, asset information, and historical context, is retrieved and correlated prior to presenting the alert to the analyst. Doing so relieves the analyst from gathering the information from disparate sources, which is often time-consuming and error-prone, and ensures no data is missed. Automated enrichment allows the analyst to focus on decision-making.

The alert enrichment includes data from both internal and external sources. Automation can search internal security sources, such as SIEMs, firewalls, identity management systems, IDPSs, web proxies, email gateways, EDRs, and UBA systems. These sources provide important security-related data such as source and destination details, activity history, impacted systems, and user logins. For possibly malicious software, the enrichment can include a detailed analysis of the software, including results from an internal or external detonation service. Other internal sources could include asset inventory systems, which can provide context concerning the business function of the impacted systems, critical stakeholders, and related risk metrics. The enrichment can also bring in external information, such as reputation scores and contextual information about the threat from intelligence sources.

Alert enrichment is often broken down into its component parts, involving multiple enrichment processes. For example, a single alert may have multiple indicators of compromise (IOCs), which include source IPs, domains, URLs, files, and file hashes. Enrichment is necessary for each of these IOCs. Security analysts are overwhelmed by the volume of such IOCs that must be investigated. An alert could include 10s or even 100s of IOCs. In addition to enriching the IOCs, the details concerning the impacted

systems and users must also be enriched. Alert enrichment is highly repetitive, making it an ideal candidate for automation.

The automation must gather contextual details for each IOC related to the alert. For example, we will first examine the enrichment for a possibly malicious file. Figure 8-1 depicts a high-level view of the enrichment process for a possibly malicious file. In this example, the automation queries the EDR to determine if the file is already on the block or allow list. The automation calls out to public or proprietary reputation sources to gather any related reputation scores. The file is sent to a detonation service, where the file can be analyzed. The automation will also query the EDR to determine if the file is currently on any hosts within the environment.

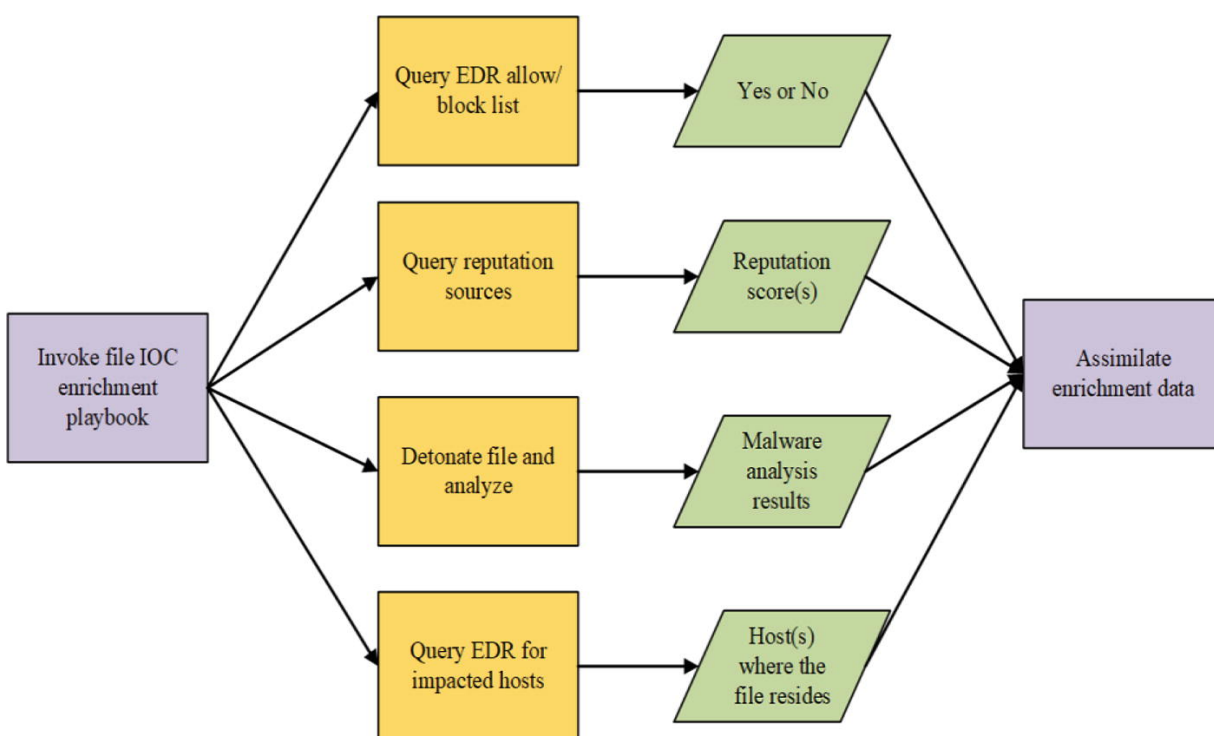


Figure 8-1 Enriching an indicator of a possibly malicious file

Of course, one enrichment could spawn another. In the above example, if the EDR responded that the file was seen

on hosts within the system, then the host information must be enriched. An example of host data enrichment is depicted in Figure 8-2. The automation will retrieve the system details, such as the OS and version, current user(s) logged in, and recent users. The EDR is queried to determine the security posture and the state of the security agents. This information can also include which policies are active on the host. The asset inventory provides important details about the business function(s) performed by the host and the stakeholders. Risk information, if available, will also be retrieved. Finally, the SIEM is queried for any pertinent recent activity involving the host. Once again, this enrichment could lead to further required enrichment. For example, for the users, we may want to gather additional information from the HR system, such as employment type (employee, contractor, temp, vendor, terminated). Of course, if the employee has been terminated, this should definitely raise the alert priority! If the company has an insider threat program, the enrichment should also check if the user is on the possible insider threat list.

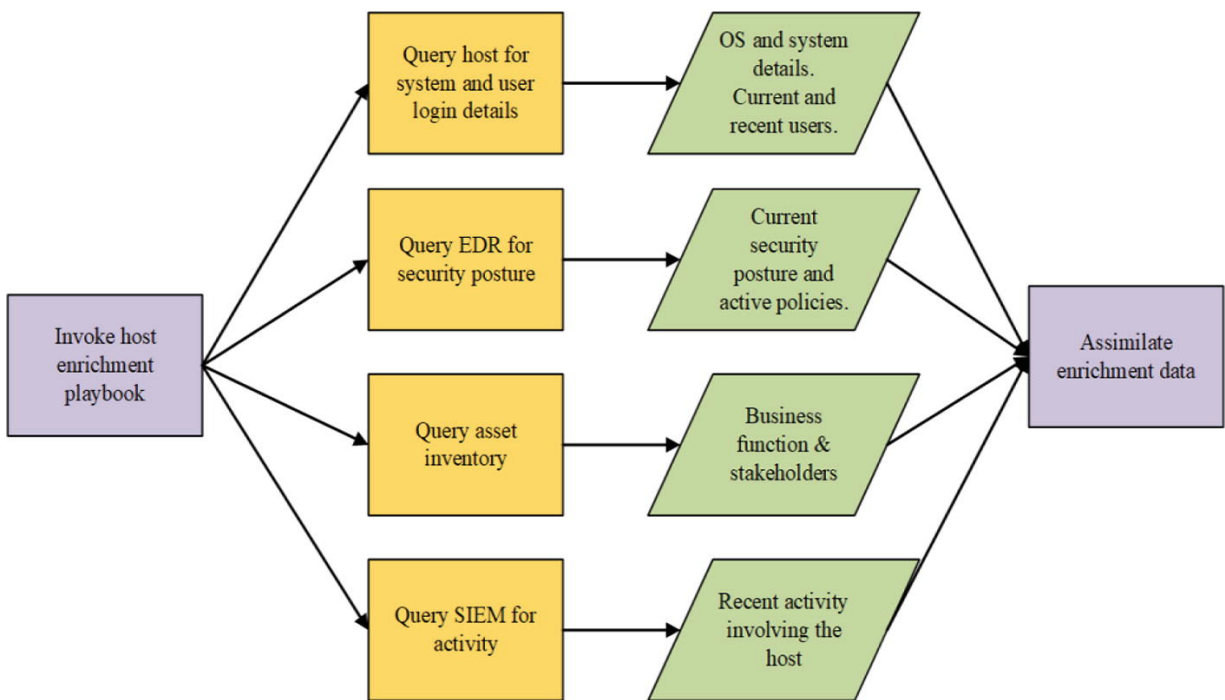


Figure 8-2 Enriching data for a possibly impacted host

The above are examples of the many enrichments that a complex alert might require. Without automation, an analyst can spend much time collecting and assimilating the information required for situational awareness. Also, since an alert might include 100s of enrichments, an analyst might not gather some critical details. Therefore, companies often look to automation to perform the valuable function of developing situational awareness and presenting it to security analysts.

Intelligence

Another related use case for automation is the ingesting and processing of IOCs from intelligence feeds. Much like in the enrichment use case, automation can search internal sources to determine the prevalence of the indicator within the organization's environment and its relevance to the organization. The volume of IOCs inundating security teams requires automation to filter IOCs to discover those IOCs that apply to the organization. Automation can also

help score or rate intelligence feeds by collecting metrics on the applicability of the IOCs from a given source.

The volume of IOCs received in intelligence feeds exceeds the capacity of humans to analyze them, especially at speed. Further, the IOCs often have a limited period of usefulness and must be acted upon immediately to thwart a possible attack. Organizations can use automation to filter incoming IOCs from intelligence feeds as soon as they are received. Automation can check internal systems for prevalence and relevance at speeds surpassing human analysts. However, many companies are not taking automated action on the IOCs beyond filtering and enrichment. Companies must move toward automated response to fully realize the benefits of automation in the intelligence ingestion process, especially on low-impact indicators.

The Threat Intelligence Process

The threat intelligence process is integral to securing and protecting company assets, brand, and reputation.

Companies must protect their proprietary intellectual property from numerous threats and guard against attacks targeting their data and processes. Finally, companies must protect their brand and reputation, built upon customers' trust in the company's security. The threat intelligence process allows companies to assimilate intelligence on IOCs and threat actors and take proactive steps to protect against, counter, or mitigate such threats.

The main challenges with threat intelligence processes include varied confidence levels in IOCs, ensuring actionable intelligence, timeliness of intelligence and response, and minimizing possible self-inflicted damage when responding. Companies receive IOCs from multiple sources, including paid services, vendors, open source services, and governments. The quality of these intelligence feeds and the confidence in each source can vary widely.

Further, intelligence sources may include IOCs that do not apply to the company or are outdated. Finally, when responding to any possible threat, the company must consider the possible impact that action may have on its business.

The main concerns with intelligence feeds relate to the quality of the data, the relevance of the data, and the recency or currency of the indicators. Interestingly, security automation could help with each of these issues. Automation can filter out IOCs that are not relevant by querying internal systems to determine if the IOC is applicable. The source providing the IOCs could use automation to disseminate the indicators quickly. The JHU-APL pilot demonstrated how automation allowed the FS-ISAC to decrease the time to generate an IOC from nearly six hours to one minute (Frick, 2018). From a quality perspective, automation can be used to score intelligence feeds and apply confidence ratings based on the source and type of indicator.

Manual Threat Intelligence Processing

The sheer volume of threat indicators strains scarce resources to filter through the noise and promptly find credible, actionable threat indicators. The primary concern is what we are not seeing. Intelligence analysts cannot devote enough time to vet every intelligence feed and indicator thoroughly. Poorly vetted indicators lead to many false positive alerts. Security analysts who are inundated by what they believe are false positives may begin to ignore these alerts or create filters to ignore the alerts.

Another symptom of a manual process is that security analysts spend nearly all their time reacting to alerts. Many of these alerts are time-consuming and repetitive. Security analysts spend too much time gathering data, which decreases the time to discern and decide on a COA. Another manifestation of this issue is that security analysts

do not have time to search and hunt more advanced threats and vulnerabilities. This lack of time to proactively search for threats and vulnerabilities increases attackers' already considerable advantage.

Manual threat intelligence processes are error-prone. When intelligence feeds are received, the intelligence analysts must manually filter the IOCs to remove IOCs that are not applicable to the organization. This manual process can lead to two common errors. First, leaving non-applicable IOCs in the intelligence feed creates additional work for the security analysts. Second, accidentally removing applicable IOCs may lead to vulnerabilities or compromises not being discovered.

Once the intelligence analysts finish filtering the IOCs, the security analysts must retrieve and assimilate information from the applicable security devices to enrich the data. During this process, the security analysts must search the log records of the security devices for evidence of the IOCs. This critical step is highly dependent on the abilities and diligence of the security analysts. If security analysts overlook data sources or do not perform a comprehensive search, they may mistakenly determine that the IOC is a false positive. After gathering all the information, the security analysts review the information and determine the appropriate COA. A manual process such as this provides little or no feedback to inform the intelligence analysts of the quality of the intelligence feeds.

Applying Automation to the Threat Intelligence Process

Using automation in the threat intelligence process can increase confidence in intelligence feeds, decrease the time to detect and respond, and increase awareness of advanced threats. Also, by using automation to enhance the process, security analysts can focus on decision-making and threat-

hunting activities. An example of automating threat intelligence feeds is shown in Figure 8-3.

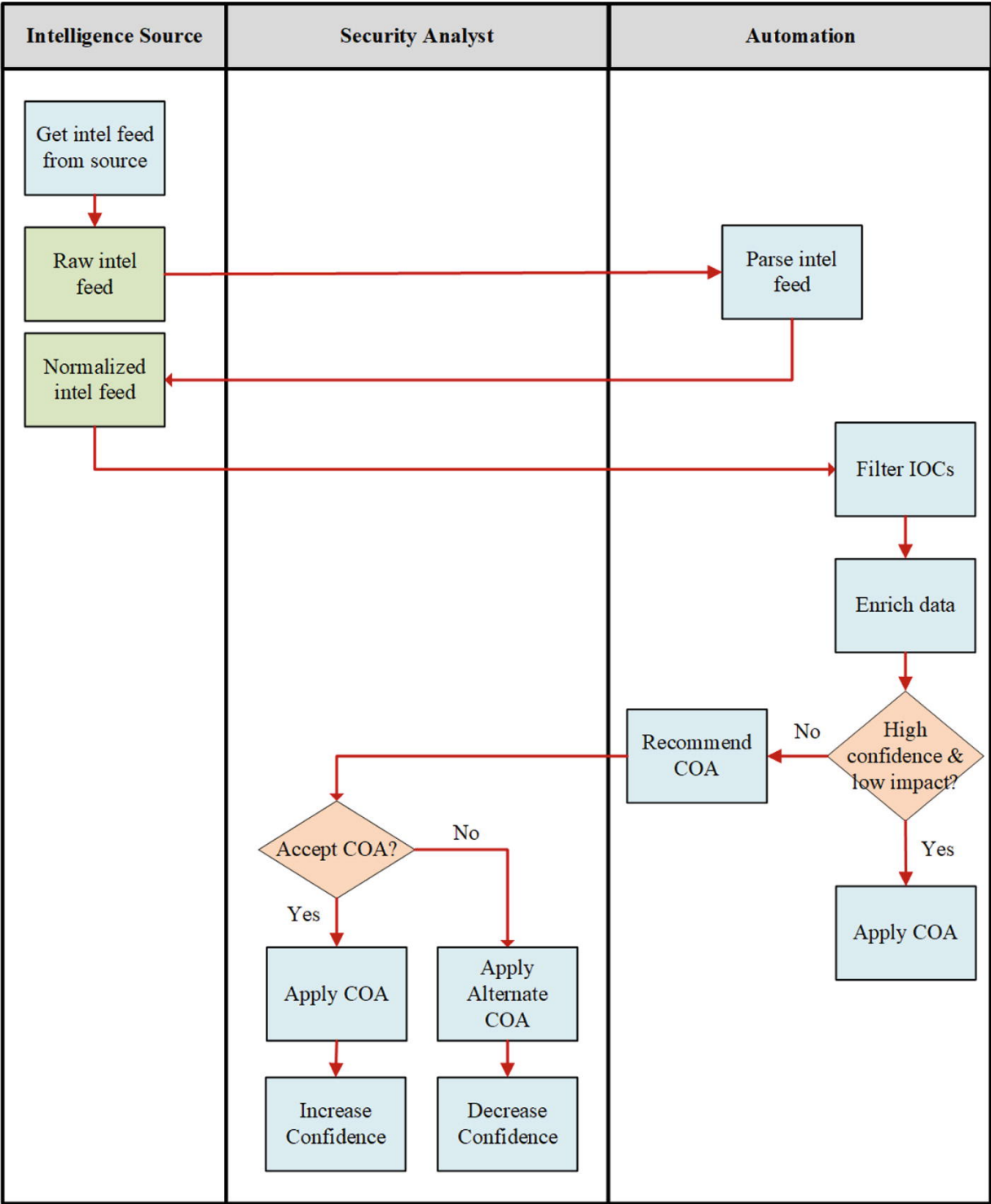


Figure 8-3 Automating the threat intelligence feed process

Intelligence analysts will evaluate and provide an initial confidence rating for each intelligence source. The filtering of IOCs and later actions taken by security analysts can influence the confidence ratings, thus providing a feedback loop to the intelligence analysts. Intelligence analysts must periodically reevaluate each threat intelligence feed's confidence ratings and applicability. If many IOCs from a given intelligence feed are being filtered out as non-applicable, the automation can provide feedback to decrease the confidence rating of that source.

In this process, automation will parse the raw intelligence feed to create normalized data. Automation can also quickly filter out non-applicable and outdated IOCs under the principle of "when in doubt, keep it in." The feedback loop will help refine this process. Perhaps the IOC only applies to a software product the company does not use. By querying the asset inventory, the automation can quickly determine that the intelligence is not applicable. After applicability is determined, automated enrichment is performed.

Automation can retrieve enrichment data from security devices and other data enrichment sources for each remaining IOC, as discussed in the enrichment use case examples. The automation should enrich IOCs with prevalence (have we seen this in our environment), applicability (do we use the vulnerable product), confidence, and possible impact information (how many and what devices might be impacted and what business functions do they support).

Based on the enriched data, the automation will determine a recommended COA. Automation can apply the COA to high-confidence, low-impact IOCs. The automation can present the enriched data and the recommended COA to the security for low-confidence or high-impact IOCs. The security analyst can decide whether to apply the recommended COA or take alternate action. The confidence

rating of the automation is boosted if the security analyst chooses the recommended COA. Otherwise, if the security analyst selects an alternate COA or determines the alert is a false positive, the confidence rating is diminished. By tracking whether the recommended COA was correct, companies may find candidates for further automation.

Intelligence Feed: File Hash Example

Figure 8-4 depicts a high-level playbook for processing a file hash from an intelligence feed. This playbook would be invoked after determining applicability. In addition to the automated enrichment, the playbook includes a semi-automated response. If the file has been seen on any hosts within the environment, the details are presented to a security analyst for decision-making, with priority given to critical assets or those with sensitive data. Such an approach is common when starting with automation to avoid possible business interruption. This approach can be enhanced with additional details on the particular hosts. For example, the company may allow automated action if the impacted systems are user workstations and the number of workstations affected falls below a defined threshold. In a later section, we will look at additional automated response actions, such as quarantining hosts.

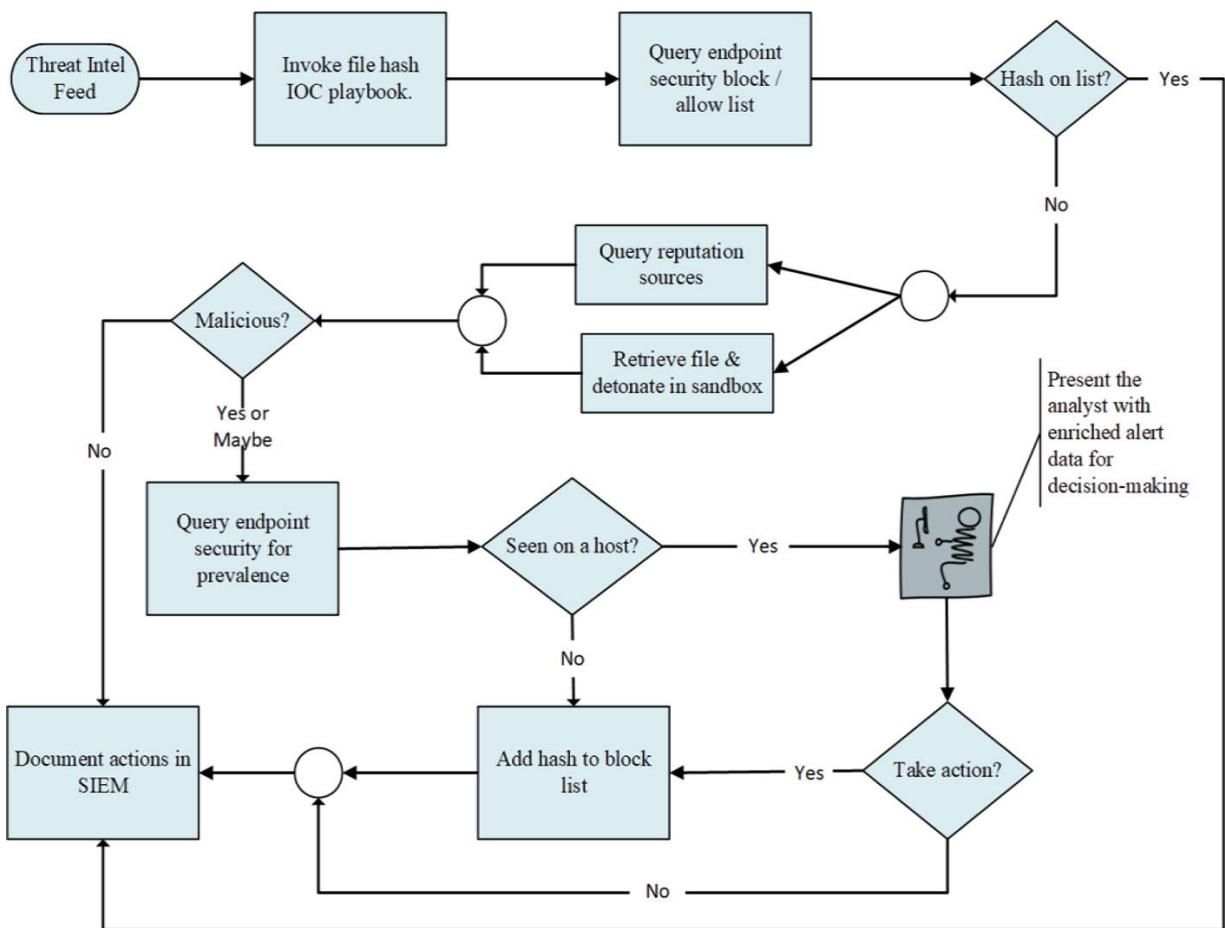


Figure 8-4 Using automation to process a file hash from an intelligence feed

Upon receiving a file hash from an intelligence feed, the automation will query the endpoint security system to determine if the file hash is already on the allow or block lists. If it is, no further action is necessary, and the action is documented in the SIEM and closed. If the file hash is not on either list, the automation will query the reputation service to obtain reputation scores for the file hash. It will also retrieve and send the file to the sandbox detonation service. The automation then evaluates the responses from the reputation and detonation services to determine if the file is malicious. If it can be determined that the file is not malicious, no further action is necessary, and the action is documented in the SIEM and closed.

If the file is deemed malicious or possibly malicious, the automation queries the endpoint security system to

determine if it resides on any hosts within the environment. If it is not on any hosts, then it is safe for the automation to add the file to the endpoint security system's block list. However, if the file is on one or more hosts, the enriched data is presented to a security analyst for decision-making. The security analysts may determine that additional actions are required, such as quarantining the affected hosts and conducting further forensics.

Benefits of Automating the Threat Intelligence Process

Companies realize two significant benefits from automating the threat intelligence feed process. The first benefit is increasing the speed of response and remediation of IOCs received from intelligence feeds. The other main benefit is the more effective use of security analysts. By automating the intelligence feed process, security analysts can concentrate on events requiring human decision-making and proactive threat-hunting activities. Companies must achieve several goals to realize these benefits fully. These goals include

- Improve the confidence ratings and consistency of intelligence feeds.
- Automate the enrichment of IOCs, decreasing the time to detect and respond and the time that security analysts spend enriching alerts.
- Fully automate the response for high-confidence, low-impact IOCs, reducing the response time.
- Identify the most reliable intelligence sources and discontinue those that provide little value.
- Implement a feedback loop to continuously improve the automation process based on analyst actions and outcomes.

Alert Triage and False Positives

An alert might contain many IOCs, such as IPs and URLs. Often, companies will have lists to allow specific IPs and URLs, for example, ones belonging to the company or its partners. If these IPs or URLs appear on an alert or in an intelligence feed, they are false positives and should not be blocked. Automation can help to quickly and effectively remove these false positives. This triage could be a separate playbook run across all alerts or be included as part of a more extensive alert enrichment playbook. If an alert only includes IPs and URLs on the allowed lists, then the alert can be closed as a false positive, as depicted in Figure 8-5. If the alert includes additional IOCs not on the allowed lists, then the alert will not be closed. However, all IPs and URLs attached to the alert on the allowed lists would be noted.

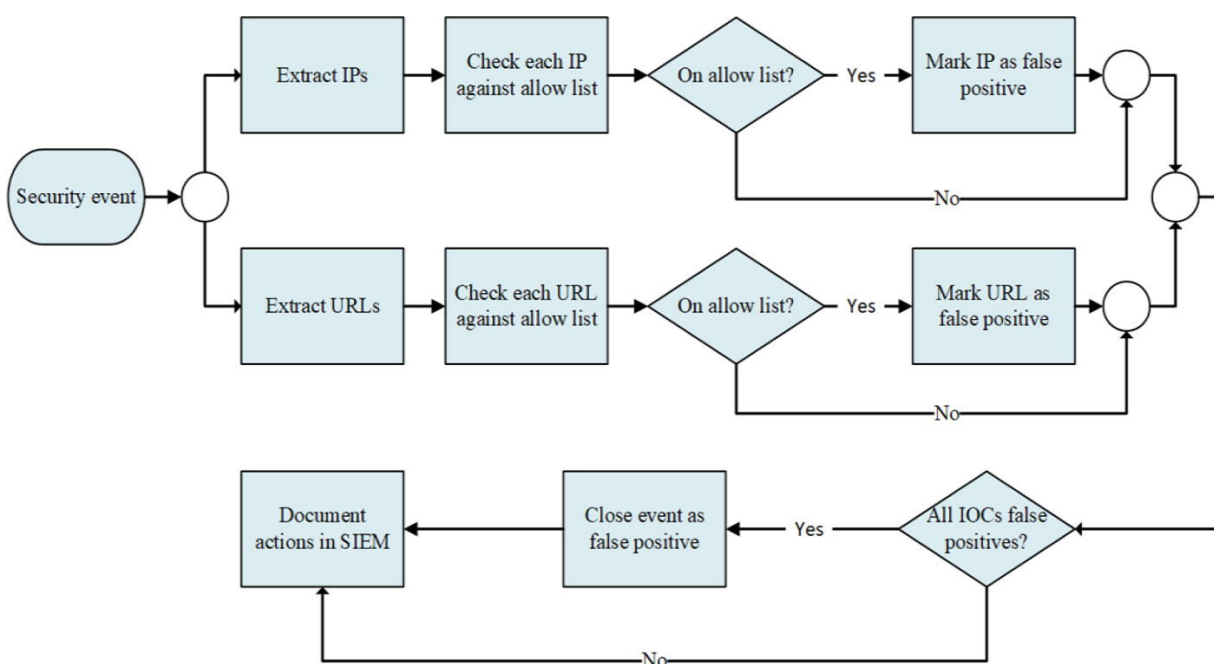


Figure 8-5 Alert triage and false positive filtering using automation

Remediation

Companies will start introducing automated responses after automating enrichment for alerts and intelligence feeds. Automated response use cases include implementing blocks, quarantining hosts or users, and malware remediation. Organizations can use automation to apply blocks via security tools based on alerts or intelligence feeds. Security orchestration and automation can apply blocks at the firewall, intrusion prevention system, web filtering solution, and host-based security solutions. Before applying an automated block, security automation can check internal sources to determine the possible impact on operations. Based on the possible impact, the automation could determine that a human must vet the block before implementation.

Malware Response

Organizations often begin with semi-automated responses in which the analyst selects the COA, and then automation conducts the necessary actions. This semi-automated approach can range from the security analyst selecting each component action to a composite playbook incorporating the necessary actions. Figure 8-6 depicts a semi-automated response to a malware incident in which the security analyst must select each component COA.

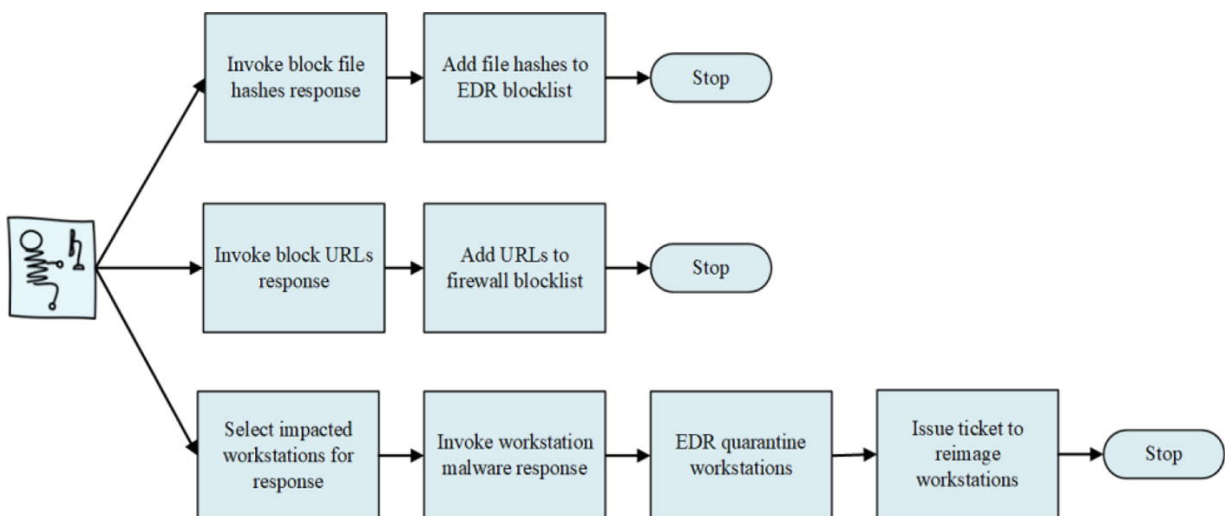


Figure 8-6 A semi-automated malware response. With this approach, the security analyst selects each component response action

Next in the degree of automation is a semi-automated approach in which the security analyst selects a composite playbook that will, in turn, invoke the component COAs. This approach is depicted in Figure 8-7.

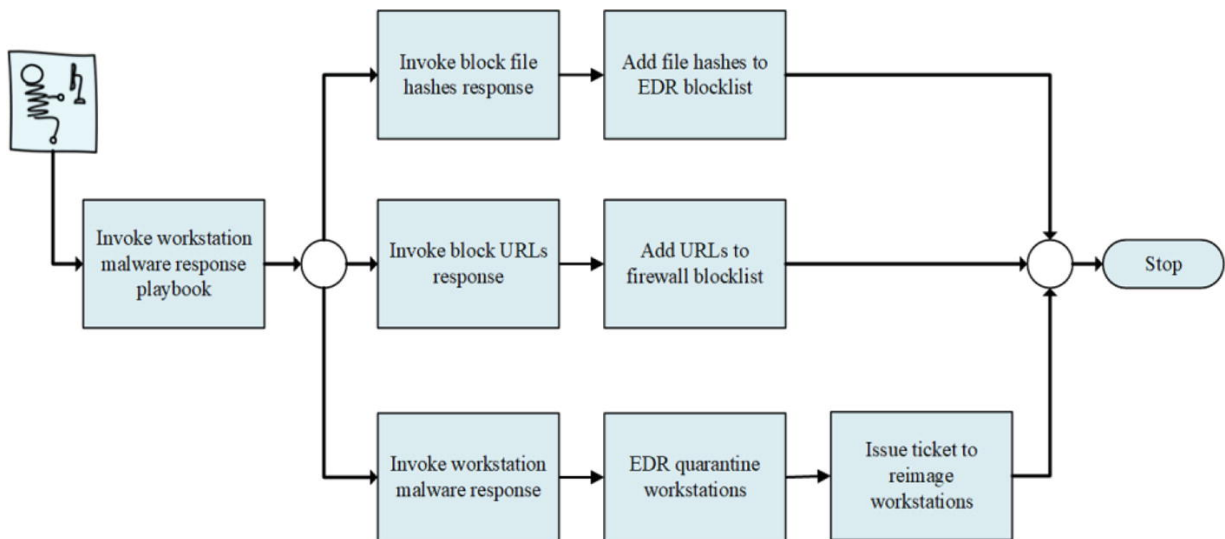


Figure 8-7 Semi-automated malware response in which the analyst selects the composite response playbook

At this point, the organization is only one step away from fully automating the response. After building trust in the automation, the company could remove the analyst from the response loop. One approach is implementing the semi-automated approach shown in Figure 8-7 and monitoring and recording the security analysts' actions. If a pattern can be identified for when the analysts select the response playbook, then future events meeting that criteria can proceed with a fully automated response. For example, in this case, we are looking at malware on workstations. We may decide to fully automate the response when the malware is only present on workstations. However, we may have the automation escalate to an analyst if the number of infected workstations is above a defined threshold. Also, if

the malware is on servers, we may want to keep an analyst in the decision loop.

Figure 8-8 depicts a conditional, fully automated response for file hashes received in an intelligence feed. Most of the time, the response will not require human intervention. The response will only be escalated to an analyst if servers are impacted or the number of impacted workstations exceeds the predefined threshold. In this example, the file hash IOC playbook will invoke the malware response playbook automatically if the conditions are met.

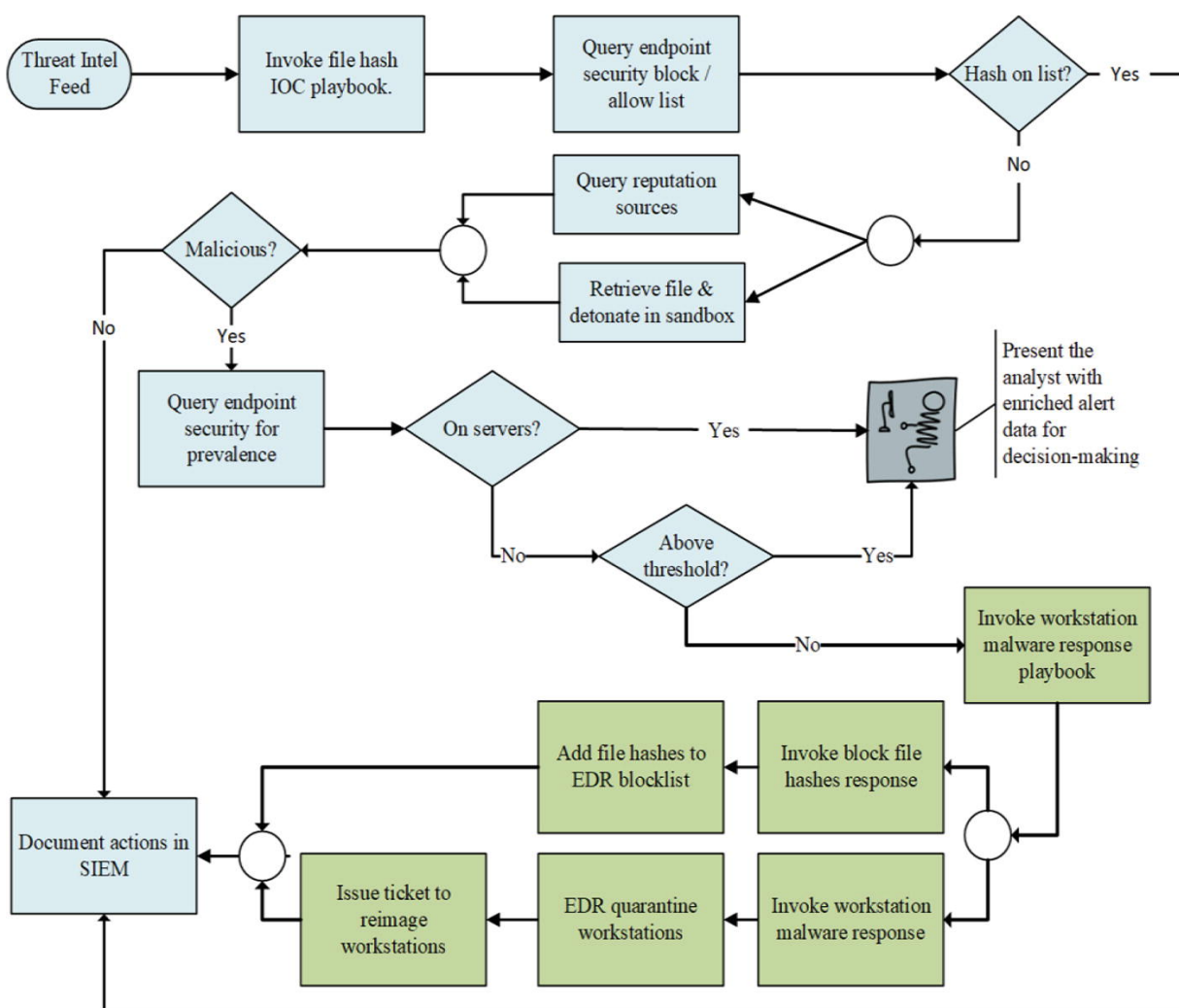


Figure 8-8 Inserting the fully automated response playbook (in green) within an intelligence feed playbook. The automated response is invoked when the

specified conditions are satisfied.

After determining that the file is malicious, the automation queries the endpoint security to determine the hosts on which this file resides. If the malicious file resides on any servers, the automation will escalate to an analyst. Likewise, the alert will escalate to an analyst if the malware impacts too many workstations, as defined by the threshold. Once the analyst has the alert, he may select semi-automated responses to aid in remediation.

If the malware is not on any servers and is below the threshold of impacted workstations, the response does not require analyst intervention. Instead, the malware response playbook is automatically invoked. This playbook will block the file hashes in the EDR and quarantine any infected workstations from the network. All network communication to and from the quarantined device will be blocked, except for communication from the EDR to perform response actions. If the company's process dictates, the response could also include capturing a forensic image of the impacted workstations before reimaging.

Phishing Response

Another common remediation use case is responding to phishing emails. The phishing use case is a good candidate for automation due to the repetitive, straightforward process of detecting and responding to phishing. This use case can begin when a user reports a suspected phishing email or when the email security monitoring detects a possible phishing email. Figure 8-9 depicts a possible phishing response playbook triggered by a user reporting a phishing email. The automation will first extract all the links and attachments from the email. The automation will send the links and attachments to sandboxes for detonation and analysis. In addition, the email headers and content will be analyzed. The automation analyzes the results to determine if the email is phishing.

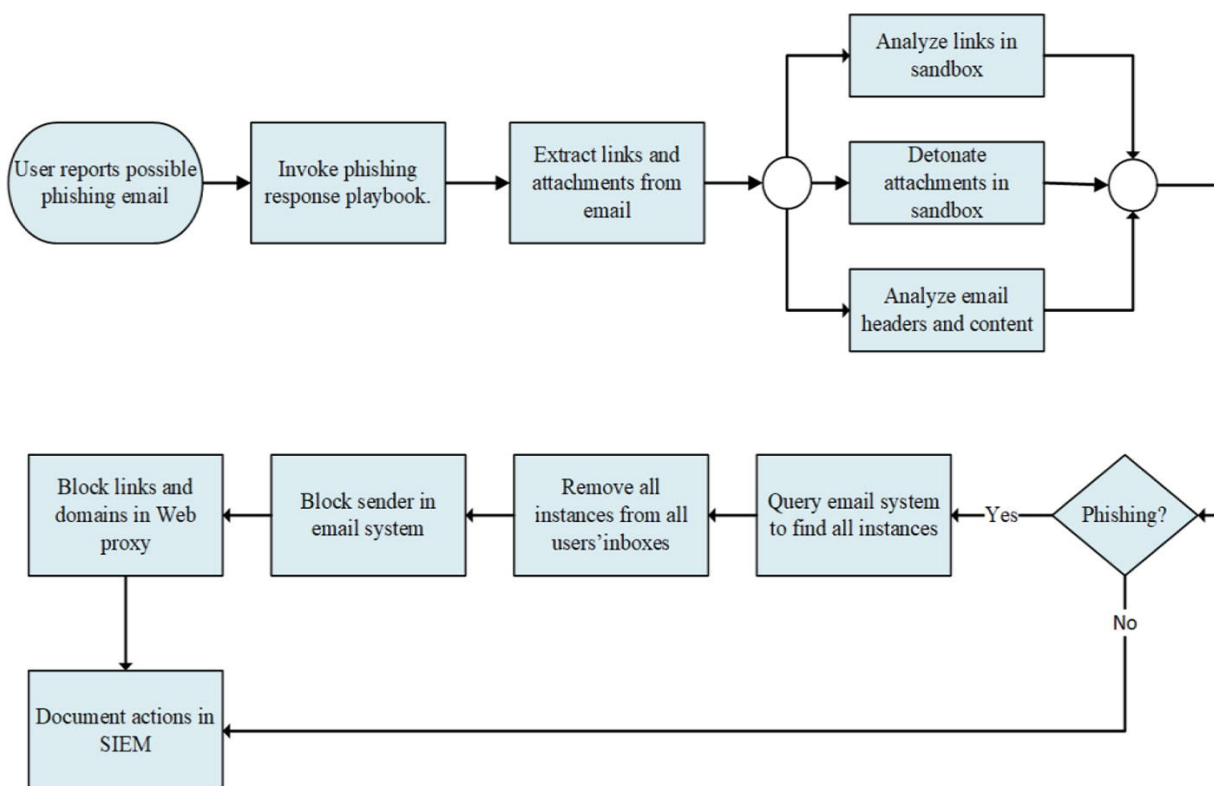


Figure 8-9 A phishing response playbook initiated by a user reporting a suspected phishing email

If it is a phishing email, the automation will query the email system to locate any additional instances of the phishing email within any user's mailbox. The automation will instruct the email system to delete any additional instances and to block the sender. In addition, the automation will instruct the Web proxy to block activity to or from any of the suspicious links and domains.

This response could be enhanced by also querying the SIEM to see if any user has recently accessed the links or domains from the phishing email or opened any attachments. If a user accessed them, the user's workstation could be quarantined, and an investigation could commence. In addition to technical responses, the playbook could trigger an automated user awareness training session for the employee who reported or interacted with the phishing email, reinforcing good security practices.

Orchestrated Response Across Disparate Systems

One issue facing companies with a complex environment is orchestrating the response to ensure all security systems are updated. For example, a security incident might include IPs, URLs, domains, and file hashes that need to be blocked. This blocking could be further complicated if the environment includes disparate security systems, such as firewalls from multiple vendors, each with its proprietary interface. Orchestration helps communicate with these various systems by extrapolating common command structures to interface with the proprietary systems. The playbook developer does not need to know the proprietary commands for each firewall. Instead, he will work with a common set of instructions for every firewall.

In the example in Figure [8-10](#), a response playbook is used to issue blocks across numerous security systems. This playbook could be triggered automatically after automated alert triage. Alternatively, it could be triggered manually by a security analyst in response to an incident. In this example, the company has firewalls, Web proxies, and EDRs from multiple vendors. In response to incidents, the company must ensure that the various security systems are all updated appropriately. The IPs are blocked across all firewalls, the URLs across all Web proxies, and the file hashes across all EDRs.

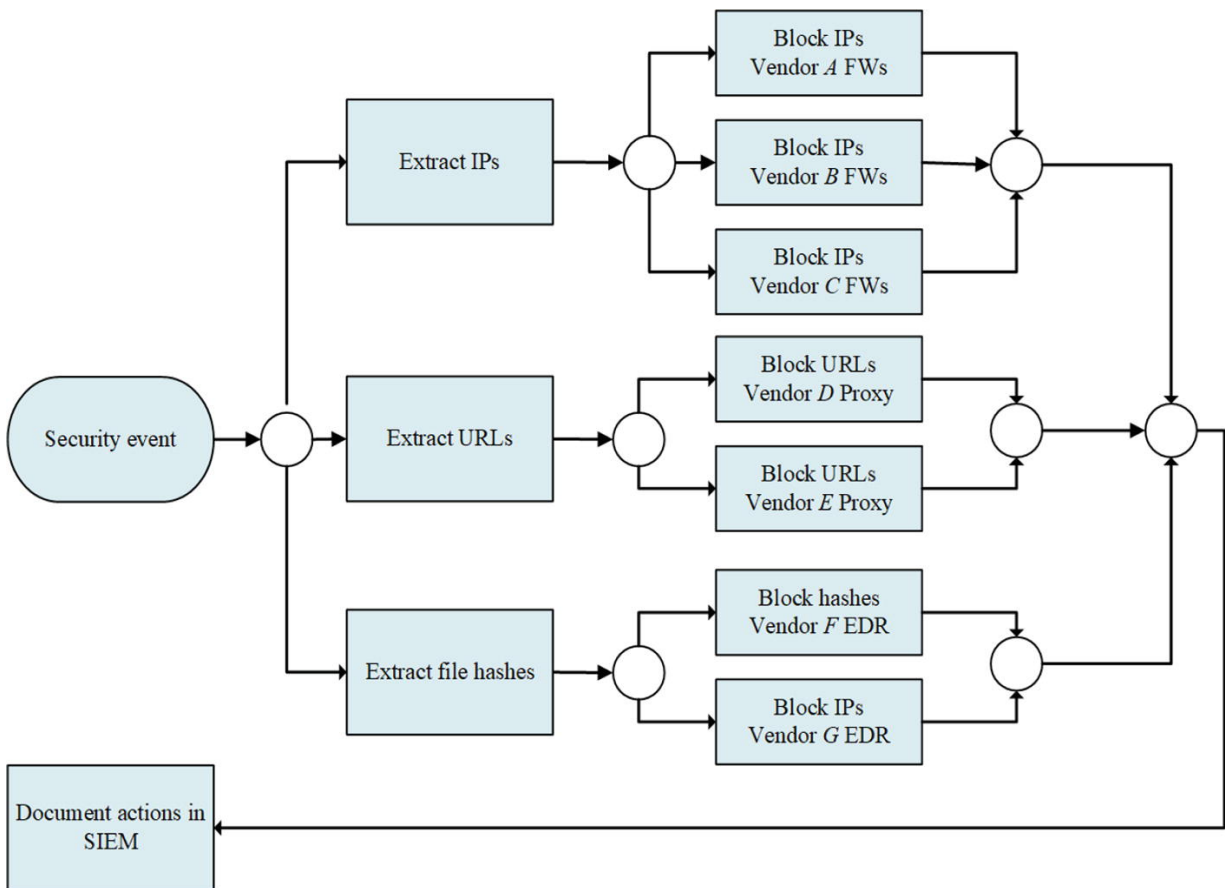


Figure 8-10 Orchestrating a coordinated response across disparate security systems

Suspicious User

When suspicious user activity is detected, an automated response can disable the user account and log the user out of any current sessions. These alerts could come from a UBA system that detected anomalous behavior. They could also come from the IAM system due to suspicious login attempts or excessive failed logins. Figure 8-11 depicts a suspicious user response playbook. The playbook will deactivate the account in Active Directory. In addition, the EDR will be called to log the user out of any current session and quarantine the user's workstation. All recent user activity will be extracted from the SIEM, and an investigation will be conducted. The investigation might

include escalating the incident to an analyst to analyze user activities further.

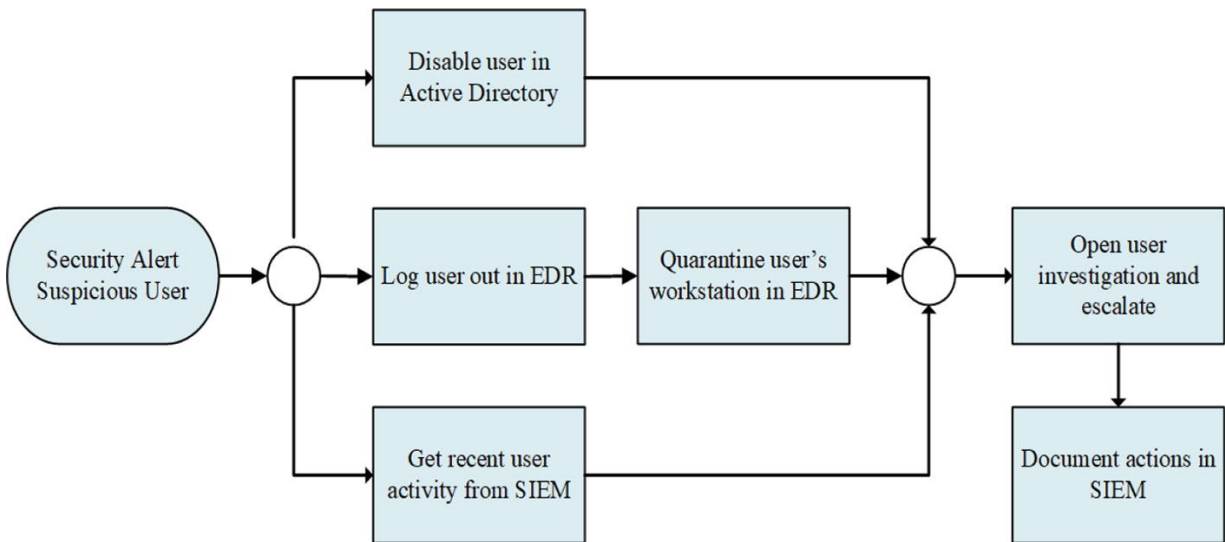


Figure 8-11 Response playbook for a suspicious user alert will disable the account, log the user out, and escalate for further investigation

Data Loss Prevention

Data loss prevention (DLP) systems can alert and block attempts to exfiltrate sensitive data, including copying, printing, uploading, and emailing the data. Automation can assist in the DLP alert response. Action should be taken whether the DLP blocked the event or not. A DLP alert could indicate an insider threat, which could be intentional or unintentional. It could also be indicative of compromised accounts or malware.

Figure 8-12 depicts a DLP response playbook. When the alert is received, the user account will be locked. In addition, automation will call the EDR to log the user out and quarantine the workstation. It will also pull the security logs from the EDR to enrich the alert. Additional alert enrichment will include recent user activity from the SIEM and any relevant data from the UBA system. Once the host is isolated and all enrichment data is gathered, the automation can escalate to an investigations team for

further analysis. The playbook could incorporate different levels of response based on the sensitivity of the data involved and the user's role. For instance, attempting to share public financial reports might trigger a warning, while trying to exfiltrate customer data could lead to immediate account lockout.

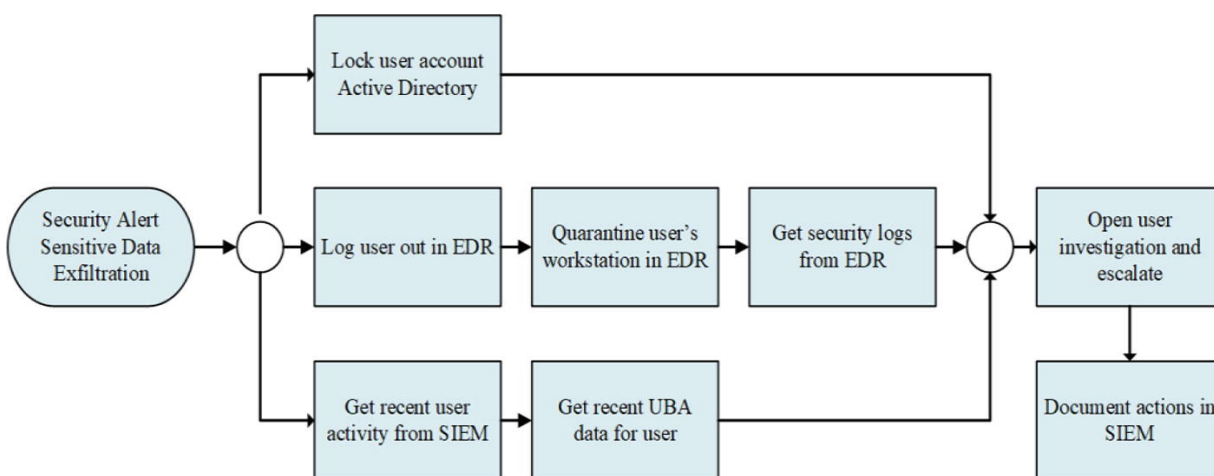


Figure 8-12 Using automation to respond to a DLP alert

Forensic Investigation Enrichment

Several response use cases discussed previously, including malware, phishing, and DLP, might include an escalation for an investigation. In this case, the automation can assist by enriching the investigation ticket with additional details, as depicted in Figure 8-13. The automation can retrieve relevant logs from the SIEM. It can also integrate with the forensics software to initiate a memory dump and a disk image, saving the investigations team valuable time and ensuring all evidence is gathered immediately.

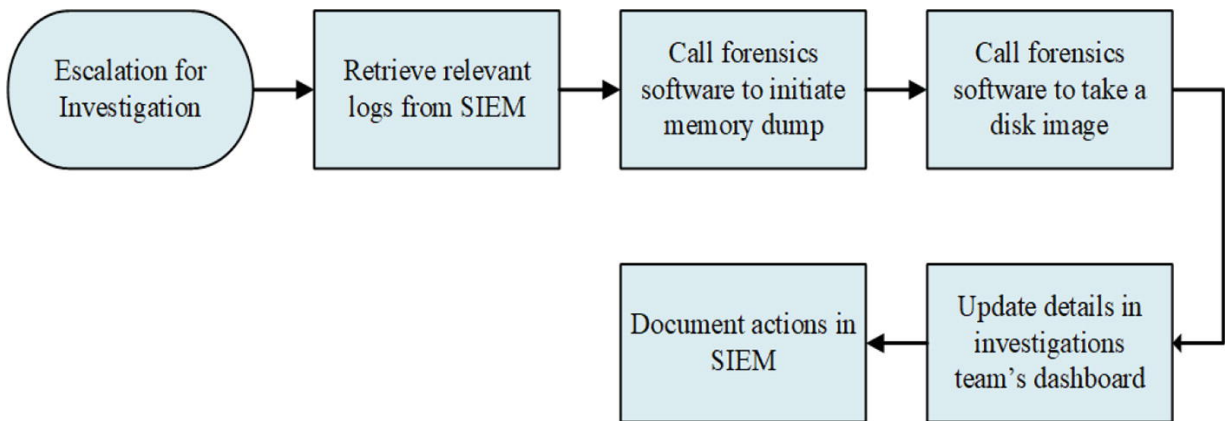


Figure 8-13 Automation can gather memory dumps and disk images for investigation

Avoid Overreliance: A Word of Caution

While automation offers numerous benefits, organizations should be cautious of over-reliance on automated systems. Regular audits of automated decisions and maintaining human oversight for critical actions are essential to prevent potential systemic errors or exploitation of automated responses by sophisticated attackers. Regular testing and tuning of automation playbooks is crucial. Organizations should implement a process for periodically reviewing and updating playbooks based on changes in the threat landscape, internal infrastructure, and lessons learned from actual incidents.

Summary

Companies have implemented many automation use cases to increase the speed of detection and response.

Automation shifts human involvement from operating *in the loop* to playing a supervisory role *on the loop*. With effective automation, security analysts are freed from many repetitive tasks, allowing them to focus on decision-making and responding to escalated alerts that require human intervention. Automation use cases span the breadth of security operations, from detection to remediation.

Alert enrichment to enhance situational awareness is the most common use case in detection. In a manual process, security analysts spend much time and effort gathering relevant information. Not only is manual enrichment time-consuming, but it is also error-prone. Analysts may not consistently retrieve all relevant data from the many security sources. Automation can quickly gather the relevant information, providing the security analyst with full situational awareness and facilitating an informed decision.

Similar enrichment can be performed on intelligence feeds to assist in processing the numerous IOCs. Automation can quickly dispense with non-relevant IOCs, reducing the workload. For the remaining IOCs, automation can enrich the intelligence and take action to block low-impact IOCs. For IOCs that may have business impacts, automation can provide security analysts with enriched alerts so they can conduct further analyses.

To obtain the full benefit from a SOAR, companies must move beyond alert enrichment and triage and begin automating response actions. Companies can configure the degree of automation in their response playbooks to match their risk tolerance. For example, in a malware response, one organization might require an analyst to instigate the response action. Another organization may decide to allow automated malware remediation under certain circumstances, such as the malware is on a limited number of workstations. Other common response use cases include responding to phishing emails, suspicious users, and DLP alerts.

Reference

Frick, C. (2018). IACD & FS ISAC financial pilot results. *Integrated Cyber October 2018 Conference*.

9. Strategies for Success (and Failure)

Successful implementation of security orchestration and automation requires careful planning. As with any significant project that could span the organization, prioritization is an essential factor in the success of a security automation initiative. Developing a solid business case can help security automation receive the necessary prioritization. Since security automation will require teams outside of security, the initiative must have appropriate priority throughout the organization. Achieving early wins and demonstrating a return on investment will help ensure the project retains prioritization and support. This chapter examines some strategies for a successful SOAR program (and some ways to fail).

Moving from Human-in-the-Loop to Human-on-the-Loop

One of the critical goals of SOAR is to move security processes from a predominately human-in-the-loop approach to a human-on-the-loop strategy. Of course, this cannot be accomplished in one fell swoop. The security

team must carefully prioritize the SOAR use cases most suited to automation. Companies often begin with enrichment use cases, such as alert enrichment. Suppose security analysts are spending considerable time and effort gathering information about an alert. In that case, automated enrichment is a critical first step along the path to a human-on-the-loop strategy.

This automated enrichment will give the security analyst the situational awareness to make informed decisions. A fully enriched alert will help the security analyst understand the impacts of a possible security incident. The security analyst will have detailed information on *where* the attack is taking place, including which network zones have been breached. By gathering all relevant log information, the analyst will get a clear picture of *how* the attack is being conducted. With enriched asset information, including workstations, servers, data, and users, the alert will contain essential information on *what* is being attacked. Finally, to improve the analyst's situational awareness, this asset information should include the business context, helping the analyst understand *why* the attack is happening. This business context also aids the analyst in determining any possible business impacts a selected response might have.

After successfully implementing enrichment use cases, security teams turn their attention to response use cases. Teams must take a thoughtful approach when selecting automated response use cases, as these could have unexpected consequences that could lead to business interruption. However, to realize increased benefits from SOAR, organizations must move beyond enrichment and take automated action. Therefore, they need a framework to help decide which response actions should be automated. Of course, the degree of automation and which response actions to automate will vary between industries

and organizations within the same industry. The organization's risk appetite, unique business processes, and automation maturity will affect these decisions. However, some generalizations can assist organizations in prioritizing response automation use cases.

JHU-APL proposed a *high-benefit/low-regret* methodology in responding to IOCs, whether from threat intelligence or enriched alerts (JHU-APL, 2018). They also discussed how this methodology could be applied to cyber threat intelligence (Frick, 2021a) and IOC response (Frick, 2021b). This approach looks at the risk/reward equation when considering automation. Even before SOAR, most organizations were already automatically responding to many high-benefit/low-risk events. Many high-benefit/low-risk response actions are conducted within the respective vendor solutions. Such responses include an IAM solution that locks a user account after a specified number of failed logins, an antivirus solution that automatically blocks or quarantines potentially malicious files, or an email gateway solution that filters spam and phishing emails. Security teams have long accepted these automated responses, understanding that they help protect the network without introducing much risk of business interruption.

JHU-APL's methodology categorizes automated response actions within a matrix that associates risks with benefits, as depicted in Figure 9-1. The benefit refers to the degree of network protection provided by the response. An example of a high-benefit response is blocking an active attack in the environment, such as quarantining or removing malicious files from systems. An example of a low-benefit response is blocking a URL that has never been accessed from any system in the environment. Such a response is also an example of low risk since it is unlikely to cause any business interruption. High-risk responses are

those that could cause significant adverse impacts to business operations.

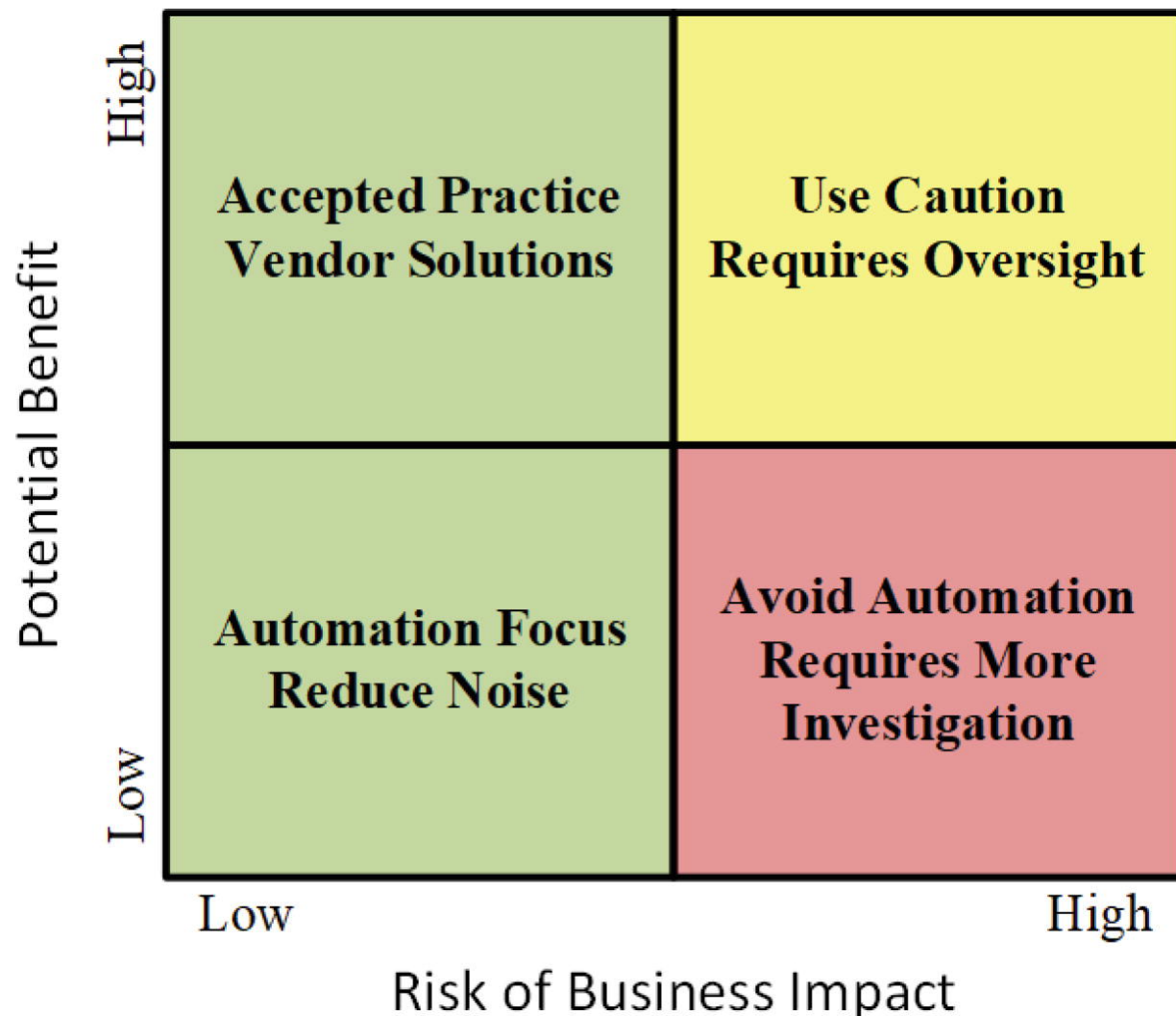


Figure 9-1 Applying risk and benefit to security automation prioritization. Adapted from “High-benefit/low-regret automated action as common practice” by JHU-APL. <https://www.iacdautomate.org/orchestration>

In this matrix, the high-benefit/low-impact quadrant includes response actions that are well-understood and well-documented. These actions are considered accepted practice and are, in large part, conducted by current vendor solutions. According to JHU-APL, this quadrant includes those response actions that vendor products are designed to address and ones that are required by regulatory best practices. However, I believe organizations

should go further in this quadrant by looking for high-benefit/low-impact responses that their vendor solutions do not cover. Also, organizations could consider using SOAR to coordinate such responses across the vendor solutions.

When satisfied with the automated responses in the upper-left quadrant, security teams will focus their attention on the lower left. According to JHU-APL, this is the quadrant where security teams should concentrate their custom automation, especially since vendor products will predominately handle the upper-left quadrant. Automating low-benefit/low-regret responses can significantly reduce the workload on security analysts, allowing them to focus on more advanced activities. For example, blocking an IOC with no prevalence in the environment during automated threat intelligence triage would be considered a low-benefit/low-regret response action. They are considered low-benefit according to the JHU-APL methodology because they provide little defensive benefit. However, automating such responses can benefit security teams significantly, freeing their analysts from dealing with all the noise.

Figure 9-2 reexamines automating responses to IOCs in a threat intelligence feed. This example focuses on file hashes; however, the same concepts apply to all the IOCs received in intelligence feeds. The green box highlights the low-benefit/low-regret response. Once it is determined that the malicious file does not exist anywhere in the environment, an automated response adds a block to the endpoint security system.

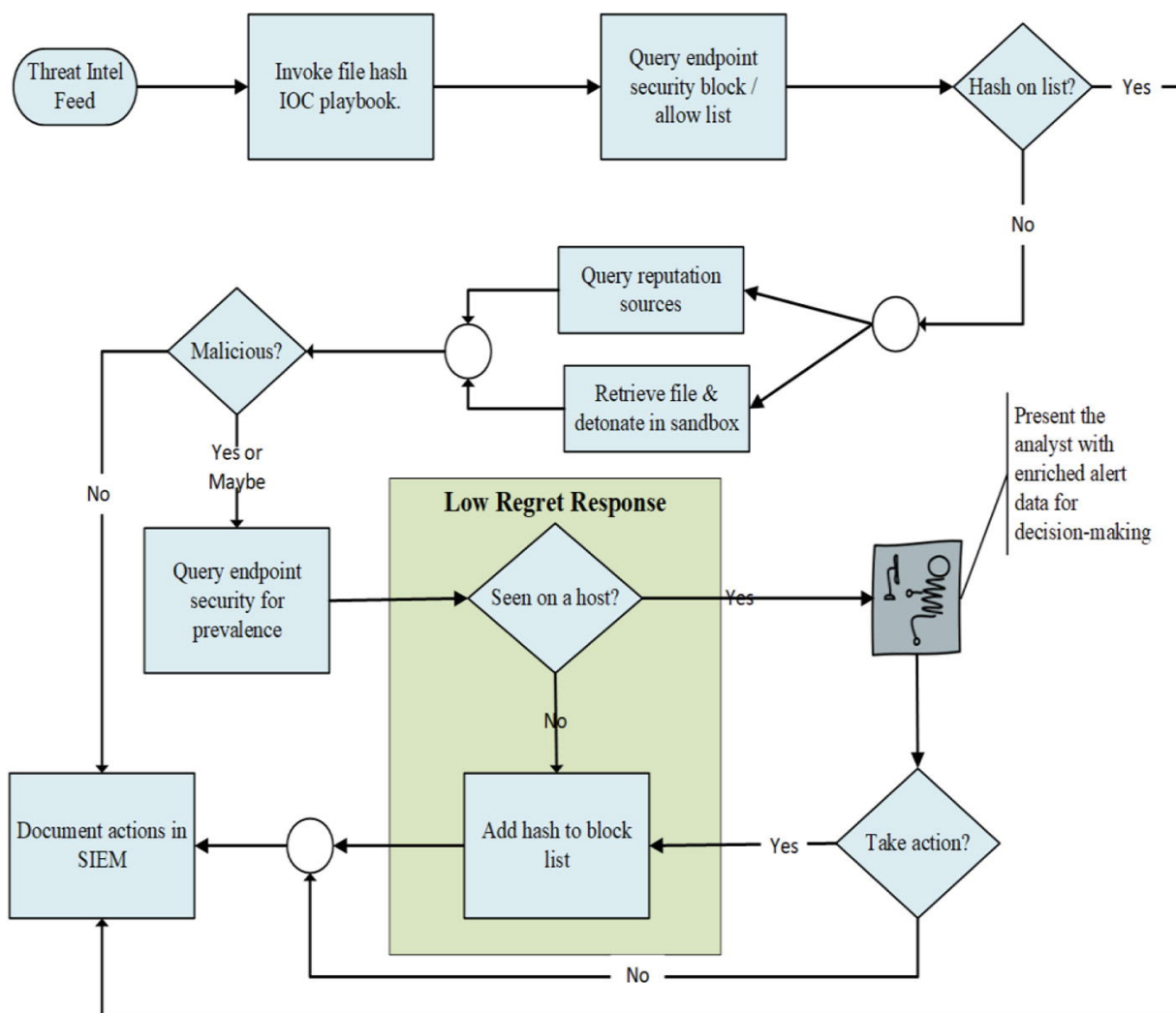


Figure 9-2 Automating a low-benefit/low-risk response to a file hash received in a threat intelligence feed

In the low-risk responses, we have focused on removing the human analyst from the loop. Since these responses have a very low risk of causing business interruption, we do not need to involve a security analyst in the response. However, as the risk associated with an automated response increases, we will typically look at moving these responses from human-in-the-loop to human-on-the-loop. Each organization will have its risk thresholds where human oversight becomes necessary. Also, these thresholds can change as an organization matures in its security automation and processes. The upper-right quadrant, high-benefit/high-risk, is where the focus shifts to human-on-the-

loop process automation, and, in some cases, organizations may decide to keep a security analyst in the loop.

When automating processes in the high-benefit/high-risk quadrant, human oversight is necessary to ensure no adverse impacts to business objectives or network function result from the response. The amount of oversight or involvement will vary between organizations and between processes within an organization. For example, in some cases, a human-on-the-loop approach might be appropriate, where the analyst is presented with a recommended COA from the automation. The analyst can review the recommended COA and the potentially impacted systems and users to determine possible business impacts before initiating the response. In other cases, we may want a human-in-the-loop. In this case, the security analyst is presented with the fully enriched alert, and he determines what COA to take.

Organizations should typically avoid automating responses in the low-benefit/high-risk quadrant. The response action could pose significant risks to business operations while providing little benefit. Processes and use cases that fall into this quadrant require more investigation to determine if they can be moved to a different quadrant, typically the lower-left quadrant, by reducing risk. Perhaps the processes are not mature and need to be enhanced to understand the potential impacts better, or the response action needs to be tuned to reduce risk.

Security teams can prioritize their automation efforts by applying a risk/benefit methodology to potential use cases. Focusing initially on low-risk use cases ensures that the automation does not cause business interruption and allows the team to build confidence in the automation. When moving to high-risk use cases, organizations should focus on moving to a human-on-the-loop process or keeping a human in the loop where the risk is most significant. High-risk/low-benefit use cases are not good candidates for

automation, and organizations should focus on investigating these processes further before attempting automation.

Enabling Automation

When organizations enable security automation, they must ensure that the products they use support SOAR integration. Also, when selecting and implementing new vendor products, companies must evaluate their integration capabilities. A SOAR platform integrates with various security products and other information sources via application programming interfaces (API). Therefore, products must have a well-documented, robust API to support automation integration. Organizations must consider several critical features when evaluating these APIs.

SOAR API Availability

The first consideration when evaluating the ability to integrate new or existing products with a SOAR platform is the availability of off-the-shelf integrations. Most mature SOAR products will have an extensive catalog of available integrations to many commonly used security tools, OSs, and other data sources. If a security team is using one of the leading SOAR platforms, they likely have ready-built integrations to most of the products they use.

However, suppose some current products lack off-the-shelf integrations with the SOAR platform. In that case, the team must consider the cost and time to develop a custom integration, whether in-house, by the SOAR vendor, the product vendor, or a third party. Vendors typically prioritize the development of integrations based on demand, so the popularity of the SOAR platform and the product to be integrated will influence this prioritization. The product vendor may charge for the development if

there is low demand for the integration. If the cost or time to integrate is excessive, the security team must evaluate what automation use cases will be affected. They may also consider whether other products within their environment can provide the same or similar functions. Finally, they may consider replacing the product with one supported by their SOAR platform.

Of course, if the team is using custom, in-house developed tools to support some of their security functions, the SOAR platform will not have available integrations. The team must then determine the cost and effort to integrate their custom tools. Since these are integrations to custom tools, the company will have to support the development cost, whether it is done in-house or by a third party. Also, the developed custom integration must be supported over its entire lifecycle. Changes to the tool or the SOAR platform may necessitate additional development. Also, these changes could break existing security use cases. If the custom tools support critical automation functions, the team might consider whether existing or new products could provide the same or similar functionality. Figure 9-3 depicts the considerations when evaluating API availability.

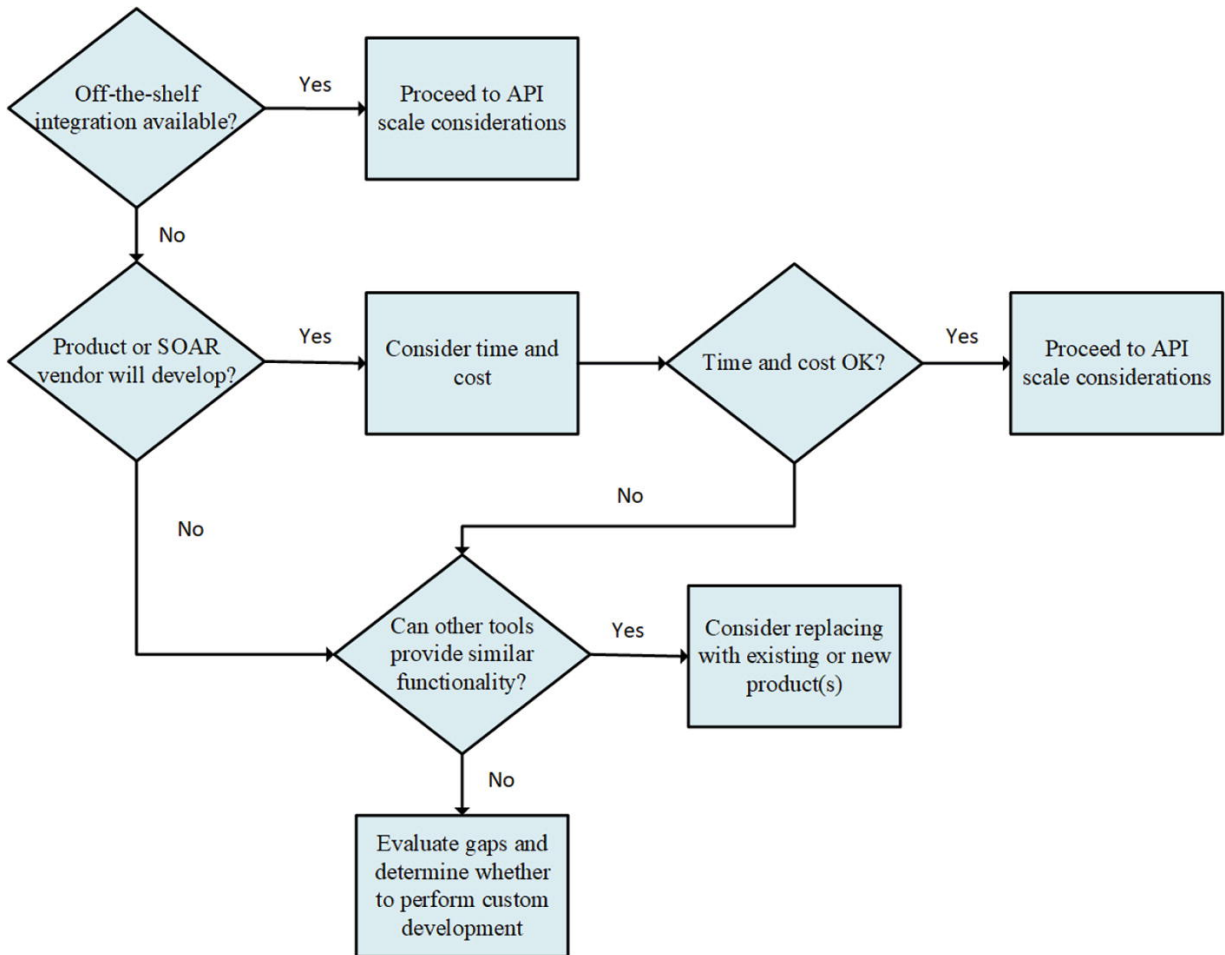


Figure 9-3 Evaluating API availability for a product to support automation

API Scale Considerations

With automation, these APIs may be used at a scale that exceeds current manual usage. This large-scale, high-frequency usage is vital for triage and enrichment, in which thousands of alerts or intelligence feeds may require rapid enrichment. Therefore, companies must evaluate whether the product's API can support the required quantity and velocity of calls. Figure 9-4 depicts critical considerations when evaluating the API's ability to support automation at scale.

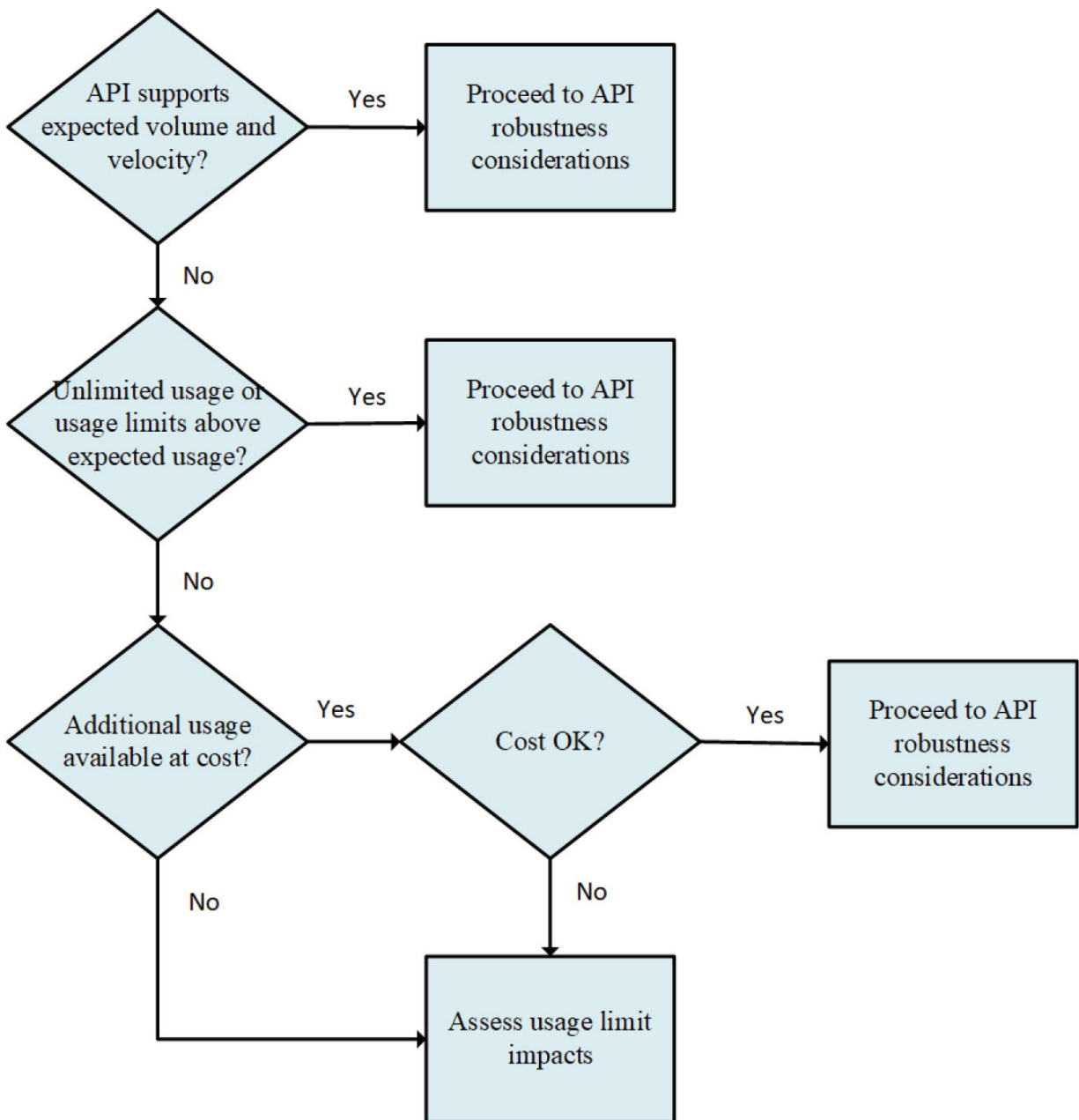


Figure 9-4 Accessing the scalability of an API for automation

The pricing and usage models are other critical considerations regarding API scalability. Does the API have any usage limits? For example, an API may limit the number of calls per minute. API rate limiting, which restricts the number of requests that can be made within a given timeframe, can significantly impact the speed and efficiency of automated processes. Such limits could have significant impacts on time-critical functions. Regarding

the pricing model, many products will have tiered pricing based on usage. Security teams must evaluate these pricing tiers carefully. They must also be aware of what happens when they reach the limit of the pricing tier. Does the API quit working or continue, but at an additional cost?

API Robustness Considerations

Sometimes, the APIs for vendor products have limited capabilities. The vendor may expect that most functions are performed via the product's user interface. This problem often exists when the APIs were developed after the initial product. Instead of simply checking whether a product has an API, security teams must dig deeper to see what functions the API supports. Ideally, the API should expose all functions that users can perform via the user interface. The development team will typically use APIs when developing the product's user interface, but these APIs may not be exposed for customer use.

If the API does not expose all user interface functions, then the security team must perform a detailed analysis of the API. In this analysis, the security team must identify all functions that will be necessary for their automation use cases. Then, they must evaluate these requirements against the API's capabilities to identify gaps. If gaps exist, the team must consider what automation use cases will be impacted and how. The lack of API functionality can significantly impact the team's ability to automate security use cases. If the impact is too significant, the team might consider alternative products or work with the vendor to enhance the API. Figure 9-5 depicts the critical considerations when evaluating the robustness of a product's API.

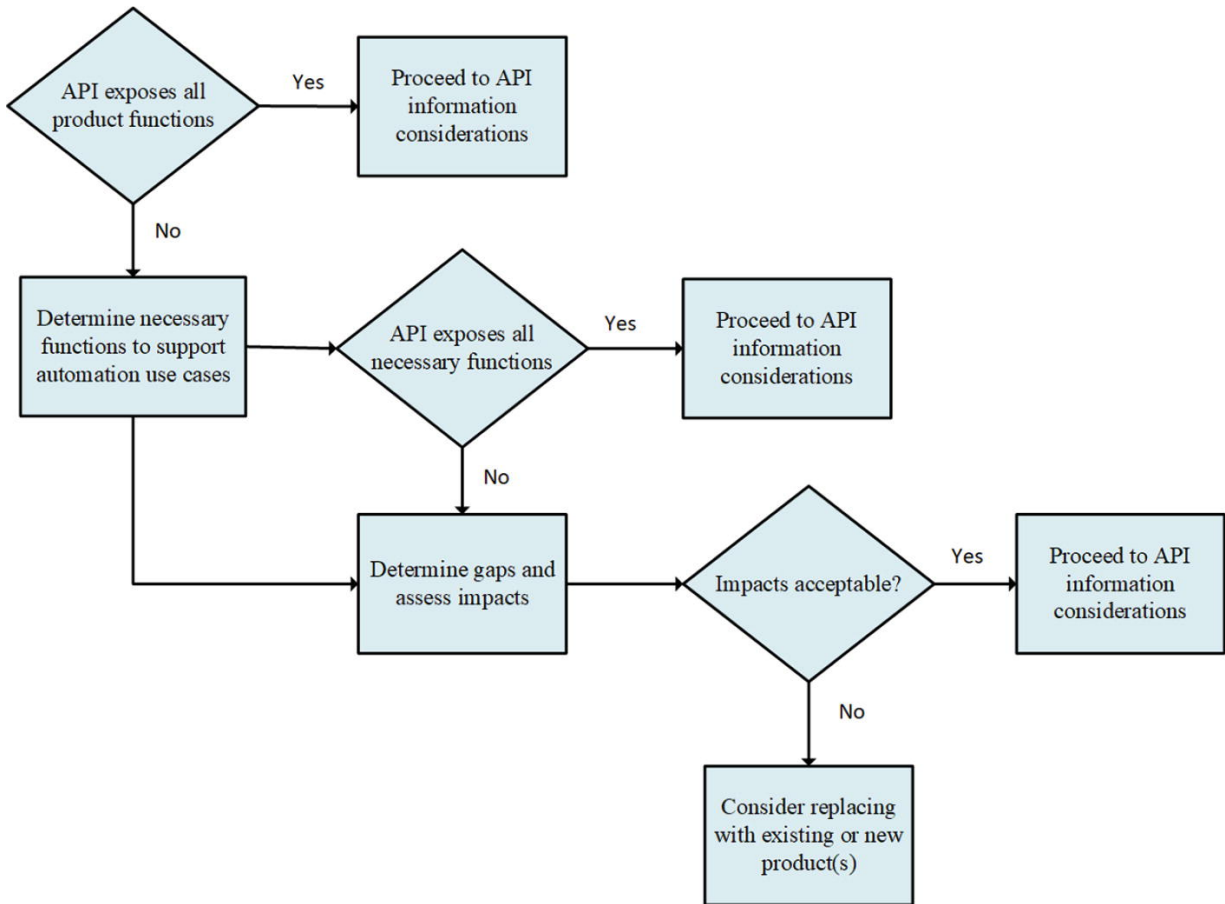


Figure 9-5 Evaluating the robustness of a product's API for automation

API Information Considerations

Perhaps all necessary functions are supported via the API. There may still be issues related to the information provided by the APIs. One must consider whether all information available to an analyst using the product is available via the API. If the API returns limited information, it could negatively impact the automation of particular use cases. Therefore, in addition to evaluating what functions the API exposes, security teams must carefully evaluate the data provided via the API. Perhaps the required data is available, but additional API calls will be required to retrieve it.

The data an API provides must be consumable by automation and other products. The data formatting may

require custom code development to parse and translate the data into the expected format. If the SOAR platform has an off-the-shelf integration with the product's API, it will take care of much of the parsing and translation, converting many of the fields into a common taxonomy. However, even if an off-the-shelf integration is available, it may still be necessary to perform additional parsing and translation, especially for proprietary information. Security teams must consider the effort necessary to consume and use the information provided via the API. Figure 9-6 depicts the evaluation of the information provided by an API and the ability of the SOAR to consume that data.

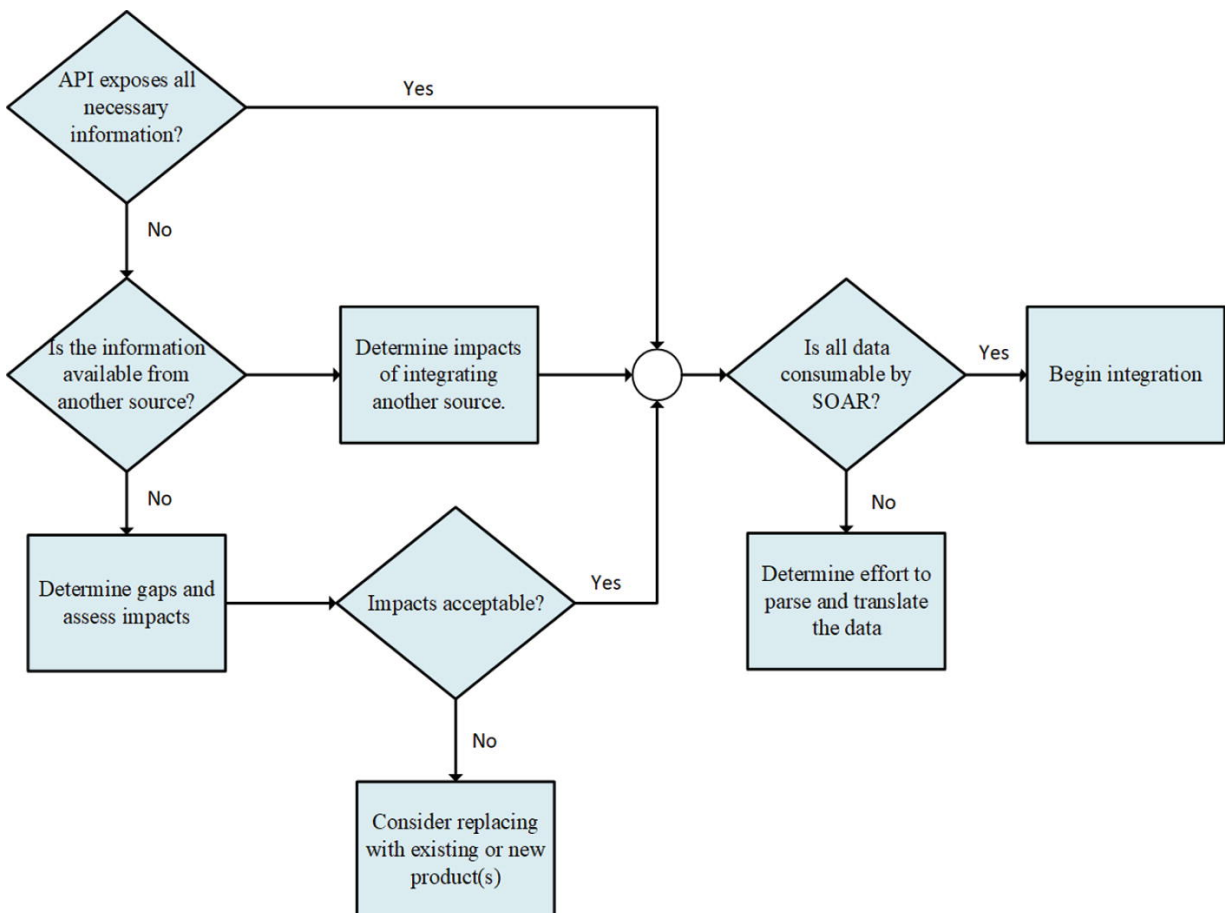


Figure 9-6 Evaluating the availability of information exposed by an API

Automation Requires Trust and Confidence

A successful security automation program requires trust and confidence in the automation. When implementing security automation and the associated use cases, teams must carefully consider how to build and maintain trust. The team must build this trust through methodical implementation that considers all the critical stakeholders, including the team building and implementing automation use cases, the security analysts using the system, security management and leadership, and the impacted teams throughout the organization, such as networking, IT, and end users.

Provide Feedback from Automation

The security team must develop trust internally before building trust in security automation throughout the organization. The security analysts relying on automation must have confidence that it is providing correct situational awareness and recommending or taking appropriate COAs in response to security alerts. The team developing and implementing the automation use cases must account for this need and develop the use cases with the appropriate monitoring and feedback loops.

When implementing security automation use cases, the development should include monitoring the steps performed by automation and the security analysts' interactions with the automation. For example, in enrichment use cases, the system should monitor whether the security analyst needs to access additional information. This monitoring can identify additional information sources required to present the security analyst with full situational awareness.

When implementing response use cases, a common approach is to first have the automation provide recommended COAs to the security analyst. The security analyst can then review the recommended COA and determine if it is appropriate and what the potential impacts are. Such an approach allows for a valuable feedback loop. Figure 9-7 demonstrates how a feedback loop can be included for response use cases. The automation should monitor and track how often the security analysts accept the recommended COAs for a given use case. This feedback will help build trust and confidence in the automation among the security team. It can also uncover additional response automation opportunities or issues with the automation that the team should address.

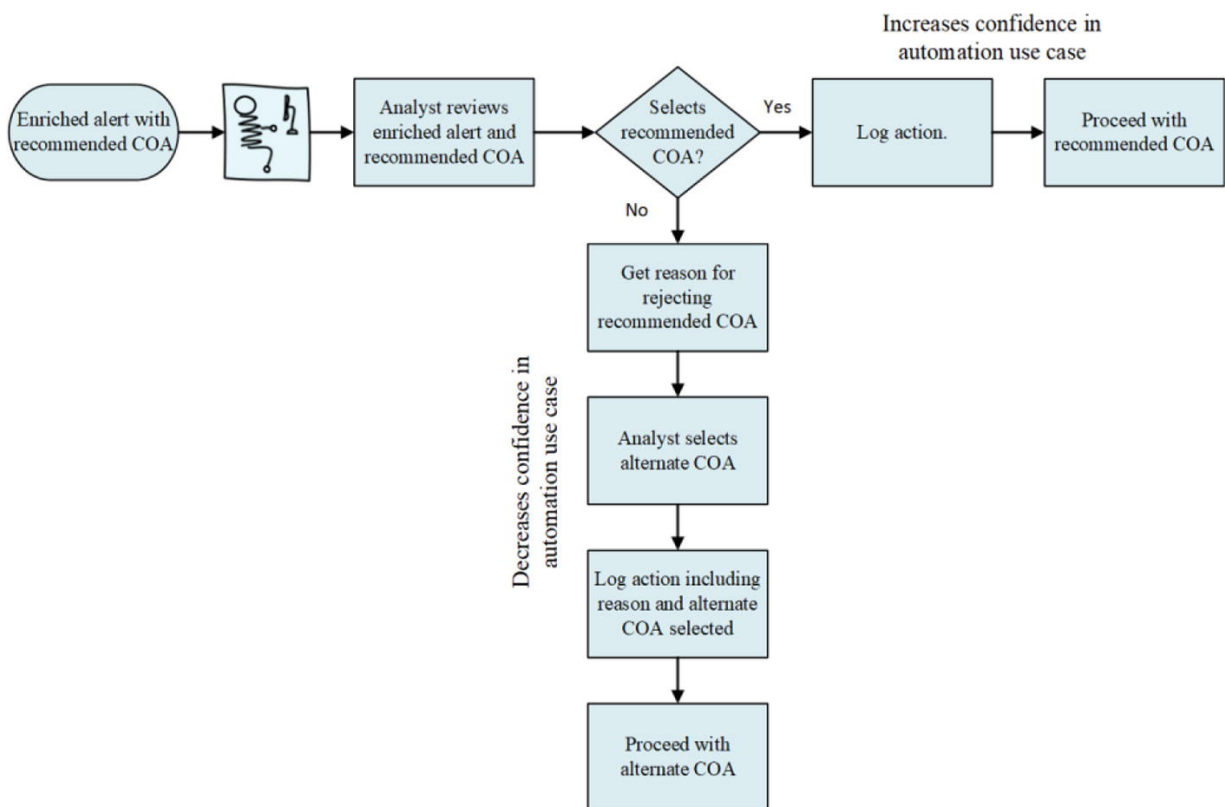


Figure 9-7 A feedback loop can help build confidence in the automation and provide details for improvement

Building Resilient Playbooks

Another essential requirement is monitoring for any errors during the automation. For example, if the SOAR encountered errors accessing an information source. When developing the security automation, the team must account for such errors. Perhaps, as part of the enrichment of a malware alert, the automation calls two external reputation sources and a detonation sandbox. The monitoring can uncover issues with these APIs. Maybe one of the reputation sources was unavailable or did not respond in the allotted time. The automation use case should be enhanced to deal with such an error. The team could decide to have the automation proceed if only one of the reputation sources responds, but if both fail, escalate the alert to a security analyst. In either case, the security team should review the errors to determine the cause. In addition to handling errors gracefully, it's crucial to log these occurrences for later analysis and potential improvement of the automation process. Figure 9-8 depicts a snippet from a malware enrichment use case that incorporates error handling for external reputation source APIs. If calls to a given source error out repeatedly, it could indicate an underlying problem, such as hitting a threshold on the API or a network change that disrupted the connection.

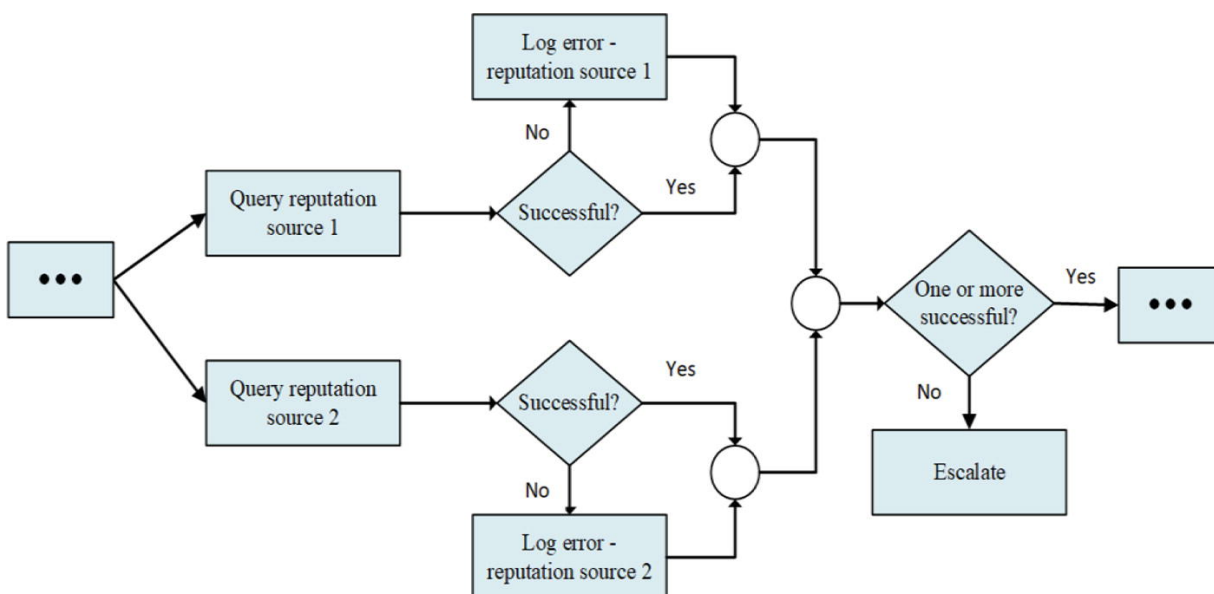


Figure 9-8 Example of including error logging and handling for a portion of malware alert enrichment

Auditing and Verifying Automation

Aligning with the concept of human-on-the-loop, the security team must provide oversight of the automation. When new use cases are implemented, the team should carefully audit the actions taken by the automation to ensure they are appropriate, correct, and in alignment with the business objectives. The auditing and review should also examine any error cases and how the automation responded to them. The security analysts can also provide expert review of a sampling of the alerts handled by each automation use case. This expert-level review will help ensure trust and confidence in the automation and identify areas for improvement or additional automation.

Continually Verify Trust

The auditing and verification do not apply only to new use cases. Cybersecurity is a dynamic environment with changing attack patterns, processes, and infrastructure. An automation use case that performs well when implemented may degrade over time. Therefore, the team must monitor

the automation results carefully and audit them to ensure they continue to align with business processes and objectives. Organizations must not become too complacent and put too much trust in the automation. Unquestioningly trusting that the automation will continue to perform optimally is a recipe for disaster. Instead, the security team must operate under the principle of *trust but verify*.

Build Organizational Trust

Perhaps the most essential factor in a successful SOAR implementation is building organizational support and trust. First, the security team must develop trust that the automation takes the correct action. When implementing security automation, the security team should do so with a fair degree of skepticism. Overcoming such skepticism will lead to trust and confidence in the system. Companies should first focus on use cases that are entirely under the purview of the security team. This approach will allow the security team to develop trust and confidence in security automation before attempting to automate use cases that take actions outside of security.

Security teams should expect to face significant barriers when implementing automation that reaches other parts of the organization. Therefore, security teams must take time to develop trust with other teams, such as networking, IT, legal, and human resources. Demonstrating the success of automation within security and explaining the approach used to build internal trust by incorporating robust error handling and feedback loops can help alleviate concerns.

Of course, these external teams will want to know what is in it for them and how they will benefit. Approaching the network team with a use case that has no apparent benefit to them but could potentially negatively impact the network, even if it is highly unlikely, may garner much resistance. Therefore, security teams should look for

mutually beneficial use cases to gain support from external teams. For example, use cases that increase network availability will appeal to the network team. However, the security team must take great care when implementing automation that impacts other teams in the organization, especially automated response actions. An automation mistake that impacts another team, such as networking, could quickly derail a security automation implementation.

SOAR introduces significant automation and streamlines incident response processes, which can disrupt traditional workflows. This requires a shift in organizational culture, particularly for teams accustomed to manual methods. Effective change management helps facilitate this transition, making it less daunting. A structured change management process ensures that all stakeholders, from security teams to upper management, understand the benefits of SOAR. Without this buy-in, resistance can arise, leading to inefficiencies and underutilization of the platform.

Building trust also requires effective training and skill development. SOAR platforms require security analysts to develop new technical skills, especially around automation, scripting, and playbook development. Training programs ensure that the staff is well-equipped to leverage the full potential of SOAR. While SOAR automates many tasks, it requires human oversight for decision-making, complex investigations, and playbook adjustments. Training helps security teams understand their evolving roles in this more automated environment. Trained personnel can effectively manage SOAR's capabilities by integrating tools, creating workflows, and developing automation rules.

Measuring Success

Security teams must measure the success of the automation, which will help prove its value and garner

support from the security leadership team. Of course, the mean time to detect and the mean time to respond are valuable metrics. So, improving these metrics can help demonstrate security automation's value for the SOC. However, the metrics should go beyond these basic SOC measurements. Other valuable metrics could include the number of alerts processed per day, the percentage of alerts handled automatically versus manually, and the reduction in false positives.

The real value of SOAR derives from improving the overall security posture. With a successful SOAR implementation, the SOC will have greater capacity, often handling many more alerts. They may begin seeing what they were not seeing before. Therefore, metrics that show this increased capability and how it improves overall security will provide valuable insight. Furthermore, as security analysts are freed from routine, time-consuming tasks, they can focus more on complex attacks and threat-hunting activities. The SOC management should focus on metrics demonstrating the value of the more proactive use of resources, including results from threat hunting and analysis of complex attacks.

Small Steps

Another important consideration for a successful security automation implementation is pursuing quick wins. Accomplishing quick wins demonstrating the value of security automation will help the implementation gain momentum while building trust and support. Use cases such as alert enrichment, enrichment of threat intelligence feeds, and responding to phishing campaigns can provide quick wins and demonstrate a return on investment. If a security team fails to show early success, they risk losing organizational support.

The selection of which processes to automate is important. The processes must be clearly understood and ready for automation. If the security team does not already have well-defined processes, they should first spend time analyzing and defining them. Also, the security team must understand that automation is not a solution to a broken process. Automating a broken process will result in doing the wrong thing faster.

Strategies for Failure

It is essential to learn from others' mistakes. As the youngest of four siblings, I often learned from the mistakes of my siblings, especially my two brothers. Learning from the failures of others is a skill many youngest children develop at a young age. We see our older siblings get into trouble for something, and we tell ourselves not to try what they did. The failure of others can provide valuable lessons, provided we learn from their mistakes. Sometimes, I failed to learn from my siblings' mistakes and went down the same path to trouble. This section will examine some mistakes others have made in implementing a SOAR program. I like to call these "the requirements for unsuccessful automation."

Focus on Saving Money

If you are implementing SOAR to save money, you probably will fail. The one exception to this rule is if you are completely satisfied with your current security operations and posture. If your security is working 100%, then automating it will save you money. However, I have yet to come across anyone who believes their security operations are perfect. Yes, SOCs will be able to decrease the time security analysts are spending on repetitive, time-consuming tasks, such as enriching alerts, filtering out false positives, and responding to simple alerts. However,

the time saved typically does not and should not equate to saving money. Instead, SOC's will redeploy the security analysts and need resources with different skills. While SOAR might not directly save money, it can provide significant value in improved security posture and risk reduction.

Perhaps automation's most essential interrelated benefits are increased visibility and decreased time to detect and respond to attacks. Security automation provides increased visibility into security alerts by increasing the volume of alerts that can be processed. The analysts did not have time to review all alerts before automation. Organizations leverage automation to respond to many routine alerts, enrich alerts requiring human intervention, and filter out non-relevant alerts. Thus, automation can free security analysts to perform more advanced work, such as responding to complex alerts, threat hunting, and improving automation.

Another effect when an organization focuses on saving money is that they often treat security automation as a side gig. They attempt to implement the automation with existing resources, perhaps from their SOC. In the short term, this will put additional stress on already strained SOC resources. In the long term, it can lead to ineffective security automation. Implementing and maintaining security automation requires unique skill sets. The current security analysts can provide the expertise by acting as subject matter experts. Also, developing the automation playbooks with effective feedback loops can help leverage their expertise. However, the automation will require additional skills.

The automation team should include automation engineers who are subject matter experts in the SOAR platform, whether these resources are internal or external. These engineers will be responsible for gathering requirements and developing robust, resilient playbooks. In

addition, though the leading SOAR platforms include graphical user interfaces for constructing playbooks, custom development is often required. This development will typically focus on unique business processes and error handling. The SOAR platforms provide capabilities to integrate custom code, often in Python. Therefore, the automation team will need development resources, which could be the automation engineers or internal or external developers. Finally, the team must have someone to manage the resources and the pipeline.

Finally, a focus on saving money will typically not consider long-term resource needs. Security automation is not a one-and-done implementation. Cybersecurity is dynamic. The environment and assets being protected will undergo constant change. Also, attack patterns and threats will evolve. The business operations will not remain stagnant. Therefore, the automation must be continually reviewed and updated to adapt to this dynamic environment.

No Clear Priorities or Pipeline

Organizations that do not have clear priorities for security automation will implement it haphazardly. Perhaps they will simply let the SOC analysts determine what to automate. However, successfully implementing security automation requires careful planning. Focusing on the wrong use cases can lead to inefficient resource utilization, not realizing the expected benefits, or causing business interruptions. The team needs a prioritized pipeline to focus efforts on the long-term benefits. Such an approach will ensure quick wins to demonstrate benefits while also methodically building the necessary trust and confidence.

Focus on the Biggest Problem

When speaking with security leaders about automation, I sometimes hear something like, “I have this really difficult

problem that we have been unable to solve. Do you think security automation could help?” My response is typically something like “Absolutely not,” sometimes with more colorful language. Security automation requires a well-understood, repeatable process. The fact that the problem has not been solved tells me there is no well-defined process to automate.

So, how about a highly complex use case that is well-defined? Again, this is probably not where the team should start, especially if the complex use case involves many teams. The security team must first develop trust and confidence in the SOAR platform and the team’s ability to implement robust, resilient use cases. Furthermore, one must consider the risks associated with the use case. Focusing on high-risk use cases before developing the requisite confidence and trust can lead to catastrophic results.

Automate Current Processes

If an organization simply automates its current processes as is, they miss out on a valuable opportunity.

Implementing automation provides the perfect opportunity to reevaluate processes carefully and enhance them.

Furthermore, performing an activity at the scale and speed of automation will often require changes to primarily manual processes. Of course, if the current processes are not well documented and well understood, teams run the risk of incorrect automation. Finally, automating a broken process as is will ensure that the team continues to do the wrong thing, only faster and at a greater scale.

Destroy Organizational Trust

Perhaps the most surefire way to derail a SOAR implementation is to cause business interruption, which can destroy organizational trust in security automation and the security team. Of course, previous strategies for failure

are often precursors to this destruction of trust. Perhaps the team decided to tackle that complex, high-risk problem before developing their skills and confidence. Since they had no clear priorities or pipeline, they were not methodical about starting with quick wins on use cases entirely within the purview of security. Also, their focus on saving money meant they were treating security automation as a side gig, with a couple of current security analysts spending whatever time they could on automation. They identified a use case causing considerable problems for the SOC and consuming significant hours. They developed a playbook and tested it the best they could. Unfortunately, after implementation, the automated response caused an outage to a critical network segment, significantly disrupting business operations.

Summary

A successful SOAR implementation and operation requires careful planning and a methodical approach. Fortunately, there are several strategies a team can follow to ensure success. These include preparatory strategies to ensure the team will focus on the correct use cases and that the tools enable automation. The team can use a framework, such as the one from JHU-APL, to help prioritize and plan use cases for automation. This framework will focus the attention first on low-risk use cases. The team must also evaluate the APIs of current and new tools to determine their automation capabilities. These APIs should be evaluated on their availability, scalability, robustness, and information provided. Ideally, the APIs should expose all functions and information from the tool.

Successful automation requires the building of trust, both within the security team and throughout the organization. Therefore, when developing automation playbooks, the security team must do so with trust in mind.

Automation playbooks should be developed with essential feedback loops to help measure the appropriateness of their actions and develop the confidence of the security analysts. Also, the playbooks must be resilient to error conditions and provide logging of all actions performed. The team must also audit and verify the playbooks to ensure they align and continue to align with the business objectives. When moving to processes that could impact other teams, such as networking, the security automation team should include all critical stakeholders and look for mutually beneficial use cases.

References

Frick, C. (2021a). *Applying “low-regret” methodology for cyber threat intelligence triage: Rapidly sharing actionable intelligence for network defense*. Retrieved from CISA: https://www.cisa.gov/sites/default/files/publications/Low%20Regret%20Methodology%20for%20CTI%20Triage_508c.pdf

Frick, C. (2021b). *Applying “low-regret” methodology for response to indicators: Rapidly mitigating IOCs at scale*. Retrieved from CISA: https://www.cisa.gov/sites/default/files/publications/Low%20Regret%20Methodology%20for%20IOC%20Response_508c.pdf

JHU-APL. (2018). *High-benefit/low-regret automated action as common practice*. Retrieved from IACD Automate: <https://www.iacdautomate.org/orchestration>

Part III

Active Cyber Defense to Slow the Adversary

10. Active Cyber Defense

Active cyber defenses (ACD) can help address the attacker's asymmetric advantage. ACD emphasizes proactive countermeasures aimed at counteracting the immediate effects of incidents. The ACD approach combines countermeasures designed for real-time threat detection and mitigation with the capability of taking offensive actions against threats. Defenders can take these offensive actions within or outside of their network. Organizations can use ACD tactics to counter attacks by detecting and stopping attacks or concealing target devices to counter espionage. ACD covers a broad spectrum of tactics and techniques, ranging from ones that raise little or no legal or ethical issues to ones that organizations must avoid.

Categorizing ACD Tactics

A report from The Center for Cyber and Homeland Security (CCHS) distinguishes between active and offensive cyber defenses (Blair, Chertoff, & Cilluffo, 2016). They defined active defenses as a "spectrum of proactive cybersecurity measures that fall between traditional passive defense and" offensive cyber operations. This area is often referred to as

the gray zone. There is widespread agreement that most offensive operations are outside legal bounds for private sector actors, though some debate exists around certain gray area tactics. These offensive operations include hacking back or destroying external networks. However, there is much debate about operations within the gray zone.

Another way of drawing distinctions between passive, active, and offensive operations is through analogy with missile defense, as shown in Figure 10-1. Passive defenses would include the monitoring for incoming missiles or imminent threats. It also includes concealment, camouflage, and deception to protect assets that adversaries might target. Such passive defenses can alert defenders so they can consider possible defensive actions and help protect critical targets.

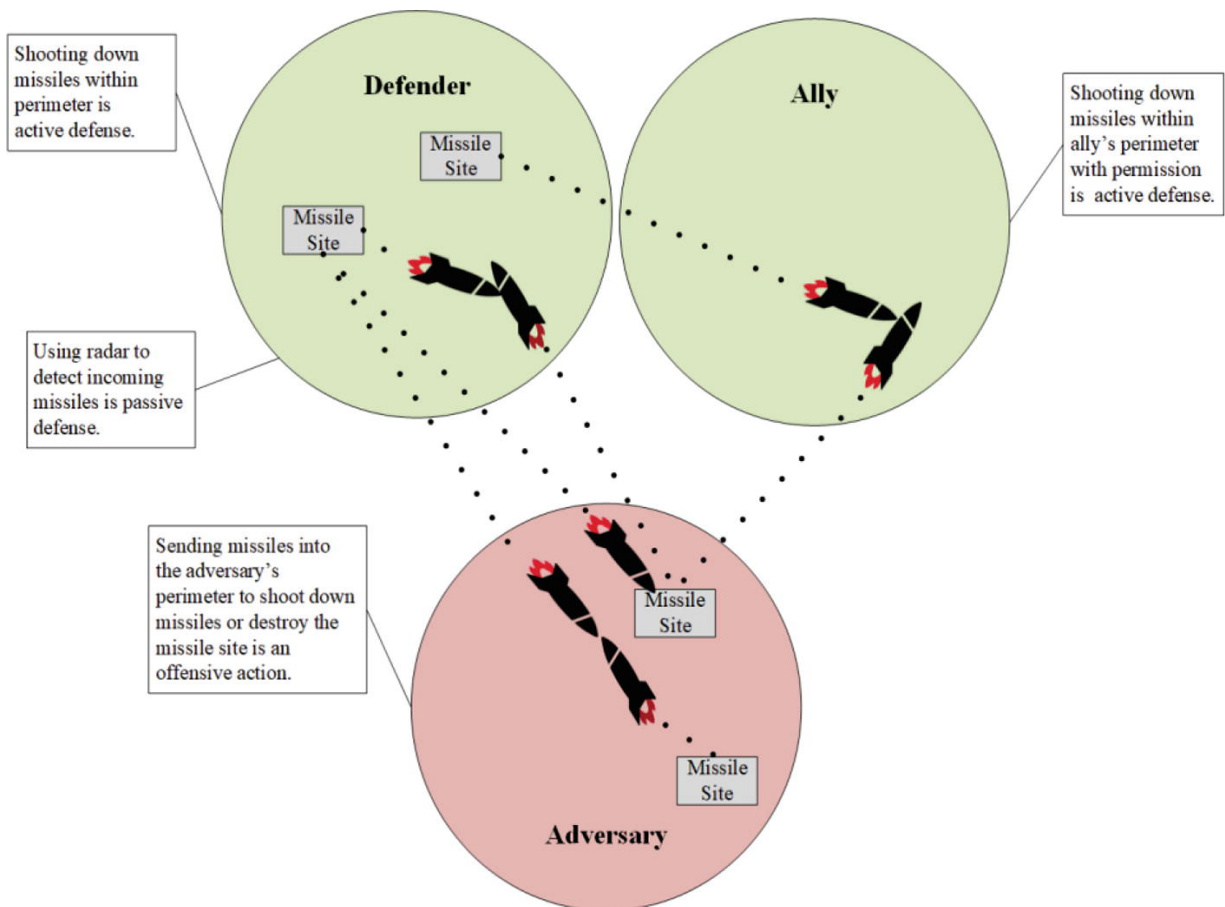


Figure 10-1 Missile defense to cyber defense analogy demonstrating passive and active defense and offensive actions

Active missile defenses include shooting down missiles that have entered the defender's airspace. They could also act outside the defender's airspace, but only with permission, to defend an ally's airspace. Examples of such active defenses include the Patriot missile system, which can detect and shoot down missiles as they approach the protected area, and Israel's Iron Dome, designed to shoot down missiles as they enter Israel's airspace. We begin crossing over into offensive operations when we send missiles into another nation's airspace without permission, whether as a deterrent or defensive measure.

When applying the missile defense analogy to cyber defense, passive cyber defenses include monitoring the network for adversarial traffic, cryptography to conceal information, vulnerability assessments, risk assessments, disaster recovery planning, and training. Monitoring network and host-based activities with solutions such as IPSs and EDRs is considered passive; however, when they block activity, they move into active defense. Active cyber defenses seek to deflect, disrupt, or deny an attack. These activities, in large part, occur within the defender's network. Such activities include blocking known or suspected malicious network or host activity. They can also include measures to slow the attacker through engagement with the attacker, such as deception. These active defense measures are in direct response to a particular attack. Offensive cyber actions are taken outside the defender's network to destroy or disrupt the attacker's network or assets, including hacking back. These offensive operations may be in direct response to a specific attack but are often more comprehensive and aimed at causing significant damage to the attacker.

Stevens (2020) proposed *A Framework for Ethical Cyber-Defense for Companies*, in which he divides defenses

into passive or active based on their characteristics and how legally problematic the defenses are. Passive tactics include defenses such as firewalls, encryption, and antivirus, which are unproblematic from a legal standpoint. Active defenses are actions taken to destroy, nullify, or reduce the effects of cyber attacks. These active defenses could be problematic.

However, Stevens found this categorization insufficient when viewing cyber defense through the lens of self-defense. Therefore, he divided the active defenses based on how problematic they might be legally. At the far end of the spectrum are problematic ACD tactics organizations should avoid, including hacking back and disrupting or destroying external networks or data. Between the passive defenses and the problematic defenses, Stevens included the concept of a gray zone. Depending on their application, tactics in the gray zone may be legally problematic or unproblematic. These gray zone tactics typically present lower legal risks than the problematic tactics. It is essential to note that just because a defense falls into the gray or problematic zones does not mean it is always illegal; however, organizations must carefully review any use of these tactics on a case-by-case basis.

Broeders (2021) also discussed the concept of a gray zone. Broeders further divided the gray zone into a light-gray zone, representing low-risk ACD tactics, and a dark-gray zone, representing high-risk tactics. The light-gray zone includes information sharing, honeypots, deception, hunting, beacons, and dark web intelligence gathering. The dark-gray zone includes botnet takedowns, coordinated sanctions, white hat ransomware, and rescue missions. He also included a red zone, which companies should avoid. The red zone includes offensive tactics such as hacking back and disrupting or destroying external networks and data.

The frameworks proposed by Stevens and Broeders align closely, with Broeders providing a more detailed breakdown of ACD tactics, as shown in Figure 10-2. Stevens and Broeders took a predominately legal perspective, categorizing the tactics based on the legal risks associated with their use. They also both align with the definitions from the CCHS. The *problematic* tactics from Stevens and the red zone from Broeders represent what the CCHS defined as offensive cyber tactics. The gray zones of Stevens and Broeders include what the CCHS considers active cyber tactics.

Stevens (2020)	Legally Unproblematic Firewalls Antivirus Encryption	Possibly Legally Problematic (depending on specific use) Traffic deflection and blocking Deception Beacons Whitehat ransomware			Legally Problematic Hacking back Disrupting or destroying external assets
Broeders (2021)	Passive Firewalls Antivirus Monitoring	Lower Impact/Risk Information sharing Tarpits Deception Beacons	Higher Impact/Risk Botnet takedowns Whitehat ransomware Rescue missions	Offensive Cyber Hacking back Disrupting or destroying external assets	

Figure 10-2 The ACD categorizations by Stevens (2020) and Broeders (2021) align well. Their categorizations focused on the legal risks associated with ACD methods.

The ACD Spectrum

It is essential to understand that ACD spans an extensive continuum of tactics. The ACD continuum ranges from what is typically considered benign and rarely raises a concern to those that raise significant operational, legal, and ethical concerns. Broeders and Stevens focused on the legal risks; however, defenders must also consider operational and reputational risks. Figure 10-3 depicts some of the tactics

along the ACD continuum arranged according to the risks associated with their use.

Low Risk	Cautious	Extreme Caution	Avoidance
Information Sharing Tarpits IPS Anti-malware DDoS Protection	Internal Deception Moving Target ----- External Deception Beacons Dark Web Intel	Malware Bait Whitehat Malware Rescue Missions	Botnet Takedowns Hacking Back Disrupting Assets Destroying Assets
Widely-accepted defensive practices	Evaluate risk on a case- by-case basis	With law enforcement collaboration	Leave to law enforcement
Deflection and blocking	Slowing the attack and intelligence gathering	External defensive actions	Offensive actions against the attacker
Operations within the company's network		Operations outside of the company's network	



Operational, Reputational, Legal, and Ethical Risk

Figure 10-3 ACD encompasses a broad spectrum of tactics that can introduce increasing levels of legal risk

The ACD tactics can be classified based on where the operation occurs, either within or external to the organization's network. These groups can be further broken down based on the defender's action. For actions within the network, the defender could deflect or block an attack, or they could gather intelligence and slow the attack. When acting externally, the organization could conduct primarily defensive operations or take offensive actions to destroy or disrupt the attacker's assets. However, operations external to the organization's network carry an elevated risk.

Low Risk

Starting from the left are low-risk ACD tactics. These commonly used cyber defenses are widely accepted as

presenting little or no risk. When discussing ACD, many security professionals do not consider these tactics, which are taken for granted as basic security practices. However, deflecting and blocking ongoing or imminent attacks are essential building blocks of ACD. Information sharing allows partnering organizations to block malicious traffic proactively. Analogous to a tar pit that bogs down animals, tarpits purposely delay incoming network connections to defend against network spamming or scanning. The concept is that delaying such activity will make it less attractive and effective for the attacker. Of course, foundational deflection and blocking solutions, such as IPSs, antimalware, and distributed denial of service (DDoS) protection, must be in place before moving into more advanced ACD.

Caution

As we move into the yellow zone, we must exercise caution. Some of these tactics operate within the company's network, while others operate partially externally. The risk is reduced for those procedures that operate within the company's network. The risk increases for tactics like beacons operating outside the company's network. However, the risk typically will not be elevated since the external activity is strictly information gathering. The company should review each use of ACD tactics in this zone on a case-by-case basis to identify any risks.

Deception

Deception can be internal, such as creating a honeynet or deceptive assets with the environment. It can also be external, such as creating fake profiles on social media or spreading misinformation. Most forms of deception fall into the yellow zone. However, depending on the context and what actions are performed, deceptive tactics, such as honeypots, could fall within the green zone. Also, the

architecture and purpose of the deception platform can bring additional risks to the company, especially when inviting attackers into the network with a honeypot or allowing the attack to continue in a honeynet to explore the attacker's methods. I will discuss deception more in a later chapter devoted to the topic.

Beacons

When a beacon is placed on an asset or file, it periodically calls home, providing the company with details on its current location. Companies can use beacons to track stolen or misplaced computer assets. They can also use beacons to discover the location of stolen or unintentionally leaked files. Beacons can run on a physical asset that is stolen or misplaced, such as a laptop. In this case, they present a very low legal risk. However, beacons can also be attached to files. These files may then have code or commands that execute to gather information about the system they are on and send it back to the defender. Since these beacons operate code on another system, they could violate laws restricting unauthorized access, such as the Computer Fraud and Abuse Act (CFAA). Furthermore, companies could face legal issues if they act independently to retrieve or recover these assets without coordination with law enforcement.

Dark Web Intelligence

Companies can use dark web intelligence gathering to discover possible or imminent threats. This intelligence gathering can also identify if criminals offer stolen company information on dark web marketplaces and where that information is stored. However, companies must exercise caution when undertaking such activities. It is imperative that the criminals cannot attribute any activity back to the company or the individuals conducting the operation. If they can attribute it to the company, the

attackers may launch retaliatory strikes against the company or the individuals, causing additional harm. Therefore, companies should consider using external providers specializing in dark web intelligence gathering instead of conducting these operations internally.

Moving Target Defense

One aspect that increases the attacker's asymmetric advantage is using common OSs, security tools, and network components. Attackers take advantage of this situation and understand that common tools, applications, and networks will function similarly in most environments. The moving target defense (MTD) field has emerged as a possible answer to remove some of the predictability upon which attackers rely. A subset of deception, MTD seeks to defend against attacks by continuously changing the attack surface. The concept is to increase the complexity and cost of the attack to dissuade attackers. MTD originates from military strategy, where the underlying concept was that continually moving assets would make it harder for the enemy to hit them.

Many MTD methods exist; however, they often rely on one of three strategies: dynamicity, diversification, or redundancy. Dynamicity, also called shuffling, dynamically changes configurations using methods such as IP hopping, host randomization, network reconfiguration, memory space allocation, and virtual machine migration. Diversification strategies leverage multiple variants of critical components, such as OSs, servers, programming languages, and hardware. The same function might be provided by multiple servers, each with different hardware, OS, and application versions. This diversification can significantly increase the complexity of reconnaissance, requiring the attacker to scan all variants. A redundancy-based MTD relies on multiple dynamic replicas of critical components.

MTD can be used across all IT infrastructure layers, through dynamicity, diversification, or redundancy, as shown in Figure 10-4. MTD can be applied to configurations such as IP addresses, ports, and protocols at the network layer. Platform layer MTD focuses on the OS, virtual machine instances, and storage systems. The environment layer, which focuses on the memory, can leverage MTD to randomize the instruction set and address space. MTD can also work at the software layer by switching software versions or changing instruction execution sequences. Finally, MTD can operate at the data layer, changing the form of the data or encoding the data.

Network Layer	Network configurations, such as IP addresses, ports, and protocols
Platform Layer	OS, virtual machine instances, storage system
Environment Layer	Instruction set or address space randomization
Software Layer	Software version, instruction execution sequence, storage allocation
Data Layer	Data form and structure, encoding

Figure 10-4 MTD can diversify or change assets dynamically across all IT layers

The MTD methods carry low legal, ethical, or reputational risks. However, they can introduce significant operational risks. While MTD increases the complexity and cost for the attacker, it can likewise increase the complexity and cost for the defender. Maintaining and

operating MTD assets can require more complex procedures and may impact licensing costs. When implementing MTD, a company must consider these costs and possible impacts on operational procedures.

Extreme Caution

One must tread very carefully when considering ACD tactics within the orange zone. Tactics in this zone operate outside the company's network and go beyond information gathering. These tactics present significant operational, reputational, legal, and ethical risks. Therefore, their use requires careful case-by-case analysis. Also, private-sector actors should never use the tactics in this zone without close collaboration with law enforcement. Often, these tactics will be employed as part of a law enforcement operation.

Malware Bait

Malware baiting involves placing malicious files within the company's network. The idea is that anyone who downloads and executes these files will be infected with the malware. The files are placed strategically on systems where normal operations should never interact with them. Basically, the company is setting a trap for attackers. What the malware does can vary greatly. For example, it could act as a beacon, sending forensic information about the attacker's system back to the company. Alternatively, it could cause damage to the attacker's system, rendering it inoperable or deleting assets.

This practice introduces several risks. First, the company cannot guarantee that whoever downloaded the file had malicious intent. Also, inflicting damage to the person's system could raise the issue of unnecessary defense. Instead of embedded malware, the company probably could have prevented the download. Of course, there is also the risk that the malware will be executed on

the company's system, perhaps by an unaware employee. Finally, once downloaded, the malware could spread, infecting other systems.

Malware and Whitehat Malware

Whitehat malware and ransomware entail executing malware on a third-party's system. The use of whitehat malware can raise many concerns. First, the targets of the whitehat malware may be innocent victims. What appears to be the source of the attack could be a system that was infected or hijacked by the attacker. Plus, it is exceptionally challenging to guarantee that the malware will not spread outside the intended target. Defenders may have difficulty controlling whitehat malware, especially if the malware is self-propagating, such as a white worm.

There is a risk that a white worm will escape the network to which it was deployed, possibly through an Internet connection or transference using removable storage. After escaping the network, the white worm may continue replicating and cause unintended collateral damage to external networks. The potential costs associated with a white worm going rogue will often outweigh any potential benefit. A rogue white worm that causes significant disruption to unintended organizations or networks can result in extensive reputational damage and open the company to civil action from the victims.

Rescue Missions

Rescue missions involve actively hacking the adversary's network to recover stolen information. Perhaps through dark web intelligence gathering, the company identified the location of stolen information. They decide to retrieve or delete the information from the criminal's site. This retrieval will require the company to hack into the criminal's systems. Taking such action without the knowledge and consent of and close collaboration with law

enforcement will most likely be considered illegal, opening the company to significant legal issues. Furthermore, if the criminal detects the activity and can attribute it back to the company, they may launch retaliatory attacks, causing further business and operational disruption.

Avoidance

Companies should avoid conducting any ACD operations that fall into the red zone. Any such activity should be reserved for law enforcement. These activities involve taking aggressive, offensive action to disrupt or destroy identified source services or assets. Such aggressive measures, often called hacking back, operate outside the company's network. Most experts consider retaliatory actions or hacking back illegal as these methods require accessing another organization's systems without permission.

Companies that take offensive actions outside their network's boundary face significant legal implications, opening themselves to possible legal sanctions. Accessing an attacker's command and control server without permission may expose the company to criminal or civil actions. These legal risks can span multiple jurisdictions, including where the company operates and any locations of the targeted systems. The ability to anonymize traffic on the Internet also complicates the use of offensive cyber defense practices as the company may not accurately attribute the incident to the perpetrator. Therefore, retaliating against the attackers may harm the system of an unknowing victim.

In the case of botnet takedowns, organizations run the risk of disrupting many third parties. Botnet takedowns often require intervention on end-user computers, who may be innocent victims. Typically, a criminal creates a botnet by infecting many end-user systems. These unsuspecting user's systems are now part of a botnet, which could be

used to conduct cyberattacks, such as a DDoS. When conducting a botnet takedown, the company could cause damage to numerous end users and organizations who did not know that their computer systems were part of a botnet. Such widespread disruption could result in reputational damage and legal issues for the company, including civil action from the affected third parties.

Legal and Ethical Considerations

Chasing after someone who has stolen from you would seem ethical and, in most cases, legal. For example, when someone swipes a bag out of your hand on a public street, it is ethical and legal to chase after them. However, this is not typically the case in the cyber world. If someone steals data from your system, most would argue that it is ethical to pursue the attacker, at least to gather evidence. However, in most circumstances, doing so would run into significant legal issues. Of course, one big difference between theft on the street and in cyberspace is that cyberspace theft likely crosses multiple jurisdictions, possibly including international boundaries. This distinction might not impact the ethical considerations, but it can profoundly impact the legal perspective.

The ethical considerations become cloudier if you break into the attacker's system to retrieve your data. In the case of a theft in the physical world, if you know who stole your property and where it is, it is still illegal for you to break in and retrieve your property. Instead, you are expected to turn the information over to law enforcement so they can handle the situation. However, some people may consider such vigilante justice as ethical, even if it is illegal.

Private sector use of ACD is a contentious, often debated issue. Companies find themselves targeted by heavily financed threat actors, often state-sponsored. However, as evidenced by the numerous successful attacks,

governments lack the will, capacity, or skill (or all three) to deal with these threats. Governments do not expect private organizations to protect themselves against physical attacks from nation-states or nation-state-supported actors, such as missile attacks. Nor would they allow a private organization to set up a missile defense system. However, companies often face persistent attacks from nation-state actors in cyberspace. These companies are expected to protect themselves from these heavily resourced threat actors in the current environment. Frustrated by the continued attacks, companies might consider taking more active defense measures. However, they must tread carefully, as many legal hurdles await.

ACD methods that act external to the organization's network, especially offensive measures, quickly cross the line into illegal activities. Furthermore, these measures raise significant moral issues due to the probability of inflicting harm on third parties. These legal and ethical concerns are the primary reasons for avoiding these activities. However, legal and ethical issues aside, the operational and reputational risks associated with a private company using offensive ACD methods to hack back will typically outweigh any benefits. The company could suffer severe reputational damage if it is discovered that it caused harm to numerous third parties. Furthermore, retaliation from the threat actors could result in significant operational harm to the organization.

Restrictions on Offensive Cyber

Companies can do their best to implement many detection and prevention tools in their networks to guard against attacks. They can implement ACD methods that operate inside their network. However, as discussed in the prior sections, once they move beyond the boundary of their network, they face significant legal issues. Under some circumstances, they may conduct intelligence gathering

outside of their network, but doing so can raise other issues, such as retaliation from the criminals.

However, companies are not allowed to take action or retaliate against attackers outside the company's network perimeter. In the United States, this prohibition on hacking into systems is based on the CFAA (1986), which modified 18 US Code § 1030. The CFAA strictly prohibits unauthorized access to most computer systems. Furthermore, most of these attacks are international, bringing additional jurisdictions and their legal regimes into play.

In May 2022, the US Department of Justice (DOJ) (2022) announced changes to its policies regarding charging cases under the CFAA. Under their new guidelines, the DOJ would not prosecute good-faith security research. It clarified that good-faith security research is conducted to test, investigate, or correct a security flaw while avoiding harm to individuals or the public. The announcement also listed some activities that could hypothetically violate the CFAA that would not be prosecuted, such as violating an online dating site's terms of service by embellishing one's profile, creating fictional accounts, and using a pseudonym on social networks. These activities, which theoretically could violate the CFAA, are sometimes important when conducting cybersecurity research. Researchers sometimes devote significant time and energy to developing fake online profiles, sometimes called sock puppets, for intelligence gathering and other research.

Possible Legislative Reform

In the United States, there have been attempts to loosen the restrictions on ACD in response to attacks. The Active Cyber Defense Certainty Act (ACDCA) (2020), often called the "hack back bill," was introduced into the House in 2019 but has since languished in Congress. This bill would

provide protection for cyber defenders who use some forms of ACD against attackers.

The most significant change to current law is that it would allow the use of attributional technology by defenders. Using beacons that execute on the target's system could raise some legal concerns with the CFAA, as they could constitute unauthorized access. If passed, the ACDCA (2020) would allow defenders to use "a program, code, or command for attributional purposes that beacons or returns locational or attributional data." However, under the ACDCA, attributional ACD methods could only be used in response to a cyber attack.

The ACDCA (2020) would also allow defenders to access the attacker's systems without authorization to "establish attribution of criminal activity to share with law enforcement...." However, the defender cannot intentionally destroy information that does not belong to them. Also, as protection to third-party systems, the defender must limit activity on these systems to only the reconnaissance necessary to locate the attack's origin.

The ACDCA (2020) failed to make it through the House. However, with the heightened interest in cybersecurity, the United States may eventually revise its laws to allow private citizens and companies to take more proactive measures. The ACDCA seems to be a good starting point, providing a middle ground. Also, it aligns well with the previous categorizing of ACD methods.

Under the ACDCA or similar legislation, defenders would have more freedom to gather information and evidence concerning a cyber intrusion. However, they would be expected to provide the attributional information to law enforcement to aid further investigation or prosecution. Companies would also have limited freedom to traverse botnets or intermediary systems to locate the command and control.

ACD and Self-defense

We might consider ACD, especially those in the orange and red zones, through the lens of self-defense. Traditionally, individuals can use force to protect themselves, their property, or others under the principle of self-defense. However, the self-defense principle is not unlimited. Typically, three requirements apply to forceful self-defense, which are

- The defensive action must directly respond to an imminent or ongoing attack.
- The defensive measure is necessary.
- The response is proportionate.

Self-defense can be in response to an attack, such as when someone grabbed you in a parking lot as you were getting into your car. In this case, it is clear that you can resist and take offensive action to repel the assailant. However, self-defense can also be used in response to an imminent attack. Such a response is considered anticipatory self-defense. For example, someone approaches you and threatens bodily harm, or they start to pull a gun on you. You would typically be justified in taking action to defend yourself. On the other hand, if you simply think someone might attack you, such as someone walking behind you, so you turn and assault that person, you likely are not justified because there was no imminent threat.

The defensive action must be necessary. This requirement can come into play when you turn to confront a possible assailant and they start running away. Once they begin running away, a further defense is probably unnecessary. Your confronting them has averted the assault. Shooting the possible assailant in the back as they are leaving will typically not meet the requirement of necessary self-defense. The same issue can arise if you

have successfully subdued the assailant but continue to take offensive action against him.

When considering self-defense, the timing of the response also comes into play, both for determining whether it was in direct response to an attack and whether it was necessary. If too much time passes between the attack and the response, the action may not be justified. For example, if someone assaulted you yesterday, so you go looking for him today to retaliate, such action would be unjustified. The action would fail to meet the requirement of being a direct response to an imminent attack. It would also fail to meet the requirement of a necessary response. The attack is over, so confronting and assaulting the perpetrator would be considered retaliation instead of self-defense.

The response must also be proportionate, which can overlap with the necessary response requirement. If you see someone attempting to steal a candy bar from your store, shooting them would typically be considered a disproportionate response. Furthermore, it could also be considered unnecessary if you had other means to deal with the theft.

Applying these same self-defense principles to ACD introduces some challenges. First, self-defense laws typically apply to individuals, not organizations. However, we can apply the defense principles to cybersecurity as a response guideline. These guidelines especially pertain to ACD tactics in the orange and red zones, as they take offensive action against the attacker. Of course, companies should refrain from employing red zone tactics and collaborate with the proper law enforcement representatives when employing orange zone tactics. This section, however, looks at these tactics solely from the perspective of self-defense principles. However, remember that many of these tactics involve hacking into other systems, which could violate laws, such as the CFAA in the

United States. It is worth noting that the concept of “hacking back” or retaliating against attackers is generally considered illegal under current US law, despite ongoing debates about its potential as a self-defense measure.

The first principle of direct response to an imminent or ongoing attack can apply directly to ACD. Under this principle, if an organization is undergoing a cyberattack, it can take action to repel the attack. The imminent attack doctrine can also be applied to cybersecurity. For example, if a suspected attacker is conducting reconnaissance against the company’s network, the company could reasonably consider an imminent attack. However, taking offensive action against a suspected attack group that has not targeted the company would fail the direct response test.

The necessary response principle can also be applied to ACD. Assume that the company’s cybersecurity systems detect an attack. These systems then successfully repel the attack. Taking offensive action, such as those tactics in the orange and red zone, would not be a necessary response. However, it could be argued that a company that is repeatedly targeted by a botnet might consider a botnet takedown as necessary. In this case, the company should not act independently but collaborate with the proper law enforcement agency to coordinate the response.

The proportionality of a cyber response must also be considered. Proportionality is not about the response’s proportionality to the attack. Instead, one must consider the ramifications of the response, especially possible damage to third parties. In cybersecurity, attribution can be challenging. What appears as the source of the attack could be innocent victims who had their computers taken over by malicious actors, such as in a botnet. Also, in the case of whitehat malware, it is difficult to ensure that it will not escape its intended target and infect other systems.

The Importance of Boundaries

ACD actions within the company's network raise little legal or ethical concerns. These actions include widely accepted defensive actions, such as deflection and blocking, and more active defensive measures, such as deception and MTD. In general, private companies can defend their networks. However, they are typically legally restrained from retaliation or gathering evidence outside their networks.

The US government limits private sector defense, even against criminal or state-sponsored attackers. According to some experts, these restrictions are too strict and impede the ability of private sector actors to defend themselves. Therefore, some within the private sector advocate using more aggressive cyber defenses. However, doing so can open the company to legal sanctions and possible criminal prosecution for the employees engaging in such activities. Therefore, companies must exercise caution when considering ACD actions outside their network. Some of these, including beacons and dark web intelligence gathering, fall into the yellow zone and carry limited legal concerns. Companies can generally perform such activities; however, they should review their use on a case-by-case basis, mainly because they could introduce other risks, such as retaliation from malicious actors.

Summary

ACD covers a broad spectrum of cyber defense tactics, ranging from standard low-risk practices to tactics that are illegal for private companies. These ACD tactics can be categorized as *Low Risk*, *Caution*, *Extreme Caution*, and *Avoidance* based on the risks they present. These risks can come in several forms, including operational, reputational, legal, and ethical. While current laws generally restrict

offensive ACD measures by private companies, there is ongoing debate and potential for future legislative changes that could alter the legal landscape of ACD.

The *Low-Risk category* includes typical deflection and blocking tactics, such as IPSs, antimalware, DDoS protection, and tarpits. These tactics are often overlooked in discussions of ACD; however, they are fundamental security practices that all organizations should employ. These widely accepted defense methods present little to no risk to the organization.

The *Caution* category is a mix of tactics, including deception, MTD, beacons, and dark web intelligence gathering, with some operating within the company's network and others operating, at least partially, externally. They typically have a low risk from a legal perspective but can introduce other risks, especially operational risks. Deception and MTD, which typically operate within the network, can help confuse or delay the attacker. However, they can also increase the operational complexity for the defender. When undertaking dark web intelligence gathering, companies and their employees must exercise caution to prevent attribution, which could result in retaliatory actions from cyber criminals. Companies should evaluate tactics in this category on a case-by-case basis.

Companies should collaborate with law enforcement before leveraging any tactics in the *Extreme Caution* category. These tactics include whitehat malware and rescue missions. Since these methods operate outside the defender's network and take action against external assets, they bring heightened operational, reputational, legal, and ethical risks. Also, since these tactics operate externally, they could cross international borders, introducing additional legal risks. Finally, operations such as whitehat malware can inadvertently cause damage to innocent

victims, resulting in reputational damage and possible civil actions.

Companies should avoid the tactics in the *Avoidance* category. These tactics involve hacking into external systems and are considered illegal in many jurisdictions, including the United States, where such activity violates the CFAA. Employing such activities could result in legal sanctions against the company and possible criminal prosecution of those involved. They can also introduce substantial operational risks, especially from retaliation.

References

Active Cyber Defense Certainty Act, H.R. 3270, 116th Cong. (2020). <https://www.congress.gov/bill/116th-congress/house-bill/3270/text>

Blair, D., Chertoff, M., & Cilluffo, F. O. (2016). *Into the gray zone: The private sector and active defense against cyber threats*. Washington, D.C.: Center for Cyber and Homeland Security - George Washington University. <https://cchs.gwu.edu/sites/cchs.gwu.edu/files/downloads/CCHS-ActiveDefenseReportFINAL.pdf>

Broeders, D. (2021). Private active cyber defense and (international) cyber security—pushing the line? *Journal of Cybersecurity*, 7(1). doi: <https://doi.org/10.1093/cybsec/tyab010>

Computer Fraud and Abuse Act of 1986. (1986). 18 U.S.C. § 1030. <https://www.congress.gov/bill/99th-congress/house-bill/4718>

Stevens, S. (2020). A framework for ethical cyber-defence for companies. In M. Christen, B. Gordijn, & M. Loi (Eds.), *he ethics of cybersecurity. The international library of ethics, law, and technology* (Vol. 21). Springer, Cham. doi: https://doi.org/10.1007/978-3-030-29053-5_1

US DOJ. (2022). *Department of Justice announces new policy for charging cases under the Computer Fraud and Abuse Act [Press Release]*. Office of Public Affairs US DOJ: <https://www.justice.gov/opa/pr/departments-justice-announces-new-policy-charging-cases-under-computer-fraud-and-abuse-act>

11. The OODA Loop Revisited

In Chapter 7, we examined the OODA loop theory, developed within the context of air-to-air combat by John Boyd, a former USAF pilot. We saw how the OODA loop theory has been applied in many situations beyond its original context, including military, sports, business, and cybersecurity. Boyd emphasized the importance of orientation, which played a central role in his theory. Orientation encompasses observations and the person's experiences, genetic heritage, and cultural traditions. This orientation represents the mental patterns that shape our decisions and actions.

Previously, we looked at Boyd's OODA loop in the context of improving the defender's response speed. The OODA loop concept can be incorporated into SOAR to enhance the defender's situational awareness, leading to better-informed decisions. Also, with SOAR, many response actions can be automated, decreasing the response time. However, this application of the OODA loop theory only addresses one side of the equation; it does nothing to slow the attacker.

Addressing Both Sides of the Equation

Today's cyber defenders find themselves at a disadvantage despite technological advances in cyber defense.

Cyberspace remains vulnerable despite steadily increasing expenditures on various aspects of cybersecurity. The defenders face significant challenges despite advances in security detection, prevention, and monitoring. Traditional security systems have repeatedly proven ineffective against advanced threat actors. Attackers create attacks targeting vulnerabilities of which defenders are unaware and avoid detection through concealment. Not only is detection failing, but the remediation time for cyberattacks is not adequate to address the volume and velocity of attacks. Among the chief causes of this disadvantage is the asymmetry in a cyber conflict that favors the attacker.

Cyber defenders must address both sides of the equation: reducing their time to detect and respond while increasing the attacker's time to compromise. On one side of the equation, defenders must improve detection and response times to avert or mitigate attacks. Conversely, defenders must increase the time to compromise by disrupting the attacker. An integrated approach focused on both sides of the equation can reduce the competitive gap between attackers and defenders, as shown in Figure 11-1. Intelligence sharing, AI-enabled detection, improved situational awareness, and automated response work together to decrease the defender's time to detect and respond. Deflection and blocking, deception, and MTD can disrupt the attacker and increase the time to compromise.

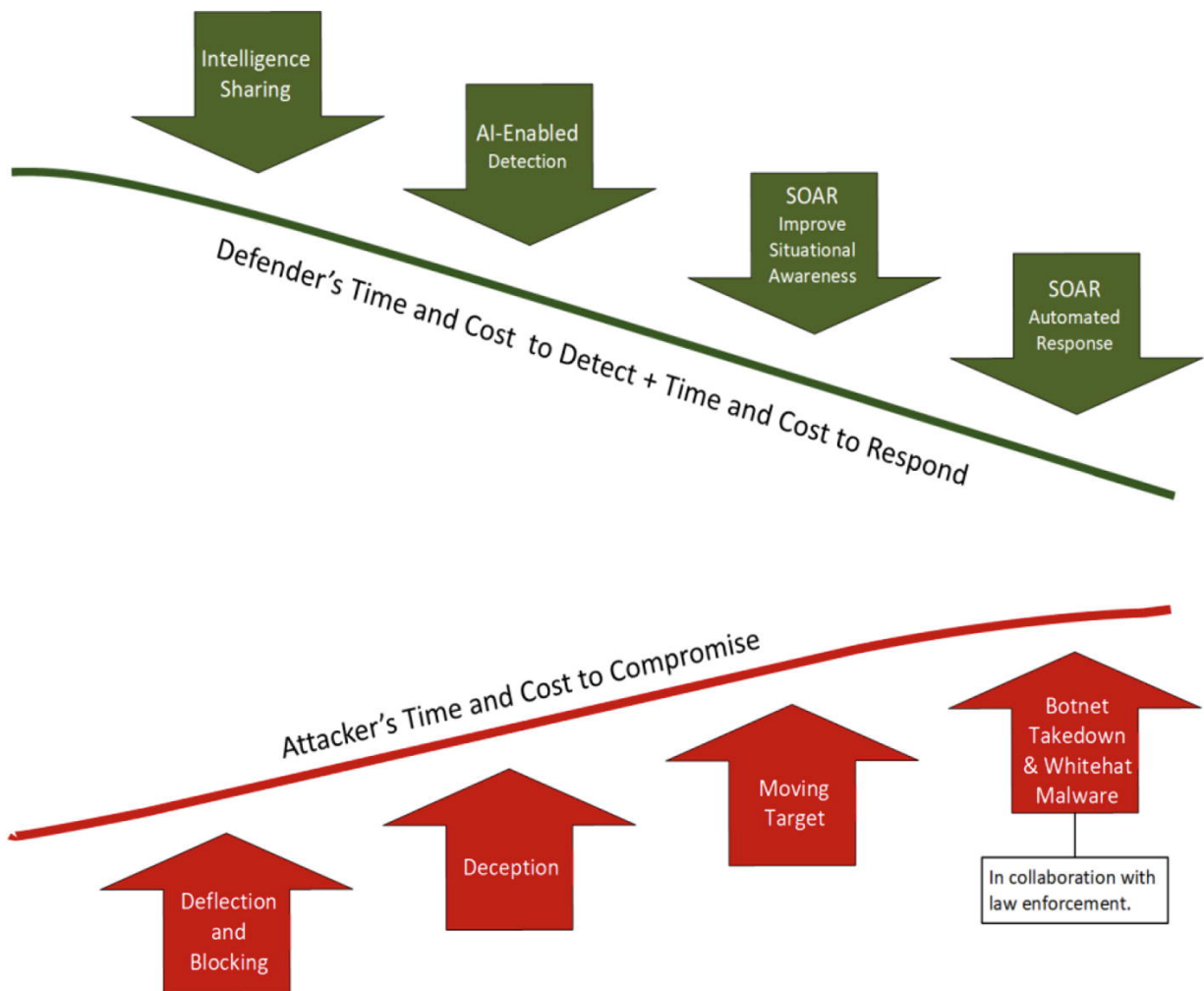


Figure 11-1 An integrated approach to address both sides of the equation, speeding detection and response while slowing the attacker

This integrated approach is required to speed detection and response while slowing the attack. Information sharing can increase efficiency in detecting and responding to cyberattacks. Collaborating organizations can use the information one organization shares to take preventative measures to thwart attacks. Collective action, fostered by community intelligence sharing, can act as an immune system for the collaborating organizations. The details from the first organization attacked, often called *patient zero*, can help inoculate other participating organizations, preventing further spread.

AI-powered security tools, leveraging techniques such as machine learning and deep learning, can improve detection capabilities and, in some cases, response capabilities. We have seen cybersecurity products embed AI to assist in nearly all aspects of cybersecurity, including intrusion and malware detection, spam filtering, phishing detection, insider threat detection, and vulnerability management. The power of AI to analyze large amounts of data efficiently, accurately, and quickly ensures that the use of AI within cybersecurity will continue to expand rapidly, becoming embedded in all security functions. It is important to note that attackers may also leverage AI to enhance their own OODA loop, potentially accelerating their decision-making and action processes.

Security orchestration, automation, and response (SOAR) can improve the analyst's situational awareness through the automated enrichment of alerts and intelligence, increasing the analyst's situational awareness. This improved situational awareness allows the analyst to make quicker, more informed decisions. In addition, SOAR can decrease the response time by taking automated action. SOAR can respond to many of the routine alerts without involving an analyst. In more complex situations, SOAR can orchestrate the response throughout the environment once the analyst decides on a response action.

Cyber defenders can use ACD methods to deter or delay attackers. Traditional defenses, such as IPS, DDoS protection, antimalware, and tarpits, can deflect or block attacks. Deception and MTD can confuse and delay the attacker, possibly causing him to decide to avert the attack. Depending on the deployment, deception could also help improve the defender's situational awareness by collecting information on the attacker's tactics. Of course, more risky ACD tactics, such as botnet takedowns and whitehat malware, can disrupt the attacker further. However, these tactics can raise significant operational, reputational, and

legal risks, and companies should employ them only in collaboration with law enforcement.

Disrupting the Opponent's OODA Loop

In Boyd's seminal presentation on air combat, in which Boyd developed the OODA loop concept, Boyd suggested that winning requires one to get inside the adversary's OODA loop (Boyd, 1995). Interrupting the adversary's OODA loop can cause confusion and disorder for the opponent. Changing the situation faster than the attacker can comprehend the changes can give the defender an advantage. Also, by inserting oneself into the opponent's OODA loop, a combatant can discover the adversary's strengths, weaknesses, tactics, and intent.

The underlying goal of the OODA loop is to operate more effectively than the enemy, which often means being faster but also making better-quality decisions (Boyd, 1995). This goal means the cyber defender must streamline his command and control while interfering with the attacker's command and control. The defender can disrupt the attacker's ability to transition within the OODA loop by generating a dominant tempo in the combat. Figure 11-2 depicts how cyber defenders can insert themselves into the attacker's OODA loop at each stage. Deceptive practices can affect the attacker's observations, impacting his orientation or situational awareness. The manipulated orientation will then affect the attacker's subsequent decisions and actions. Active countermeasures can block, deflect, or disrupt the attacker's actions.

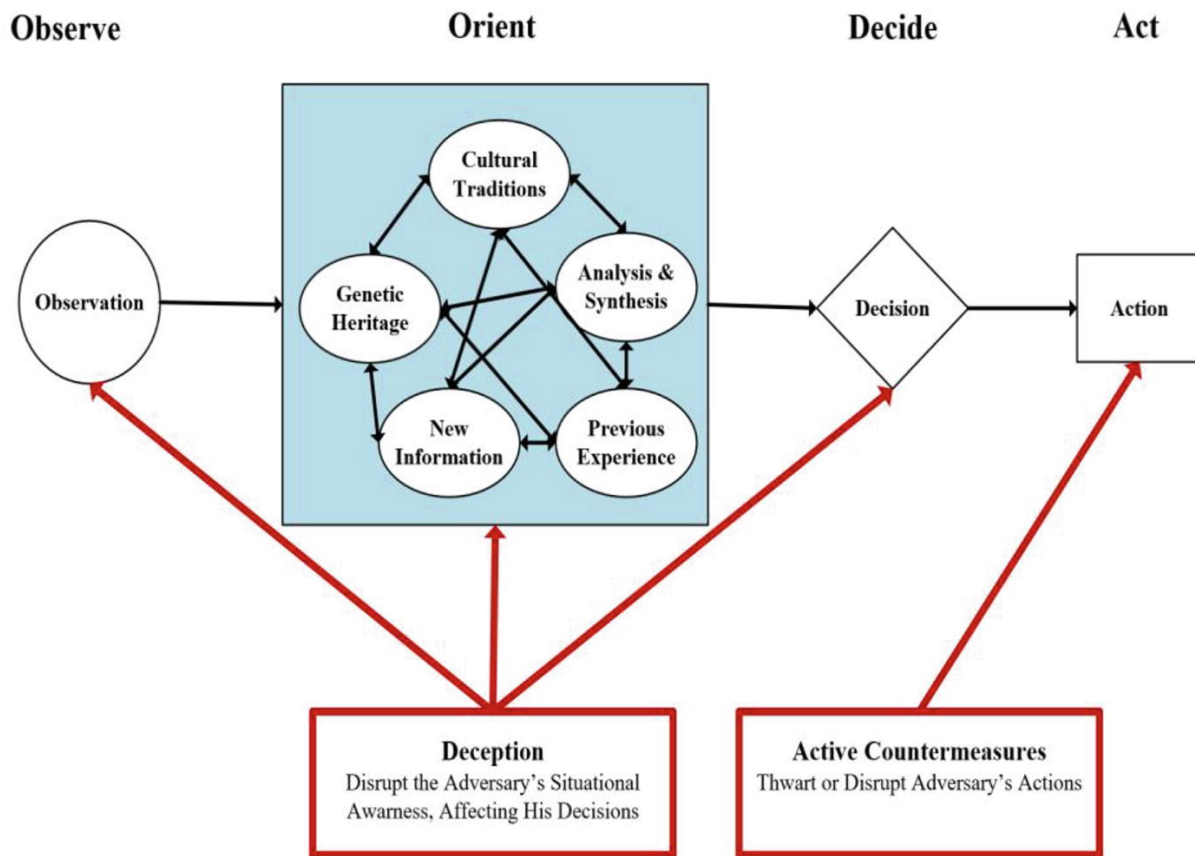


Figure 11-2 The defender can use deception and active countermeasures to gain an advantage by disrupting the attacker's OODA loop

Disrupt and Slow the Opponent's Decision-Making

Any friction the defender can add to the attacker's OODA loop slows the attacker. Many traditional cybersecurity defenses and defense-in-depth strategies operate on this principle. These strategies present multiple layers of defense, each representing an additional hurdle for the attacker. A simple example of adding friction is to limit the number of failed logins within a given time. This tactic will cause the attacker to throttle any password-guessing attempts. Of course, adding in multifactor authentication would add additional friction. Another example is using an IPS to prevent external network scanning, adding friction

to the attacker's reconnaissance efforts. However, companies should consider moving beyond these mostly passive defenses and actively seek to disrupt the attacker's OODA loop more significantly. Deceptive practices are well-suited for this purpose as they can not only add friction but can also confuse the attacker.

Deception-based defenses provide an advantage to the defenders as the deceptive information will affect the attacker's observation and orientation stages of the OODA loop. Deceiving humans and manipulating data streams distort the adversary's observations. Impacting the attacker's situational awareness will disrupt his decision-making process, possibly causing him to make incorrect decisions and take inappropriate action. In addition, deception can consume the attacker's resources by making the attacker do extra work. Due to this increased friction, the attacker will waste valuable time following deceptive trails. Also, by slowing the attacker, the defender gains more time to observe, orient, decide, and act.

Previously, when discussing the OODA loop, I used an example from American football. In that example, for a given play, we saw how each player is processing many OODA loops before and during the play. With each observation, a player adjusts his situational awareness, makes decisions, and acts. The player's training and abilities will also impact his orientation. However, football can also be a game of deception. The offense may put a player in motion before the snap to throw off the defense. After the snap, they may use play-action, where they try to disguise a passing play as a running play. These actions are designed to deceive the defense, primarily disrupting their orientation phase within the OODA loop. On the other side of the ball, pre-snap, the defense may try to disguise their coverage, making it look like they are in a zone defense but switching to man-on-man coverage at the snap. Or, they may run a stunt on the defensive line, trying to confuse the

offense's blocking scheme. Wherever OODA loops are used, acting inside the opponent's loop can provide significant advantages.

Disrupt the Opponent's Actions

Countermeasures are designed to disrupt the opponent's actions. We see many examples of countermeasures within cybersecurity. Deflection and blocking methods, such as IPSs, DDoS protection, and antimalware, are examples of fundamental countermeasures to attacks. These methods deflect or block suspicious traffic, delaying or thwarting an attack. Such methods are defensive countermeasures, as they do not take action directly against the attacker. However, they block many attacks or add friction to delay an attack.

Other countermeasures are offensive and seek to disrupt the attacker's assets directly. These offensive methods include botnet takedowns, whitehat malware, rescue missions, and hacking back. Of course, as discussed previously, private companies must exercise extreme caution with these tactics and, in the case of hacking back, avoid it. Using offensive methods to disrupt an attacker's action should be done only with close law enforcement collaboration. These offensive methods raise significant legal and ethical concerns, and their use is heavily regulated or prohibited in many jurisdictions.

Summary

Intelligence sharing, AI-enabled cybersecurity, and SOAR predominately address the need to speed detection and response. However, they do little to address the other side of the equation. To close the gap between the attacker's time to compromise and the defender's time to detect and respond, it is necessary also to slow the attacker. Practices

such as deflection and blocking, deception, MTD, and offensive ACD help address this other side of the equation.

Boyd suggested working inside the opponent's OODA loop is necessary to win. Cyber defenders can disrupt the attacker's OODA loop across all phases. The defender can gain an advantage by interfering with the attacker's decision-making process. Passive defenses, such as limiting failed login attempts, can add friction to the attacker's OODA loop. However, companies should consider more active measures to disrupt the attacker. Deception can be effective at distorting the attacker's observation. It can also add friction, causing the attacker to waste time following false trails. Defenders can also employ deflection and blocking to thwart the attacker's action. Finally, more offensive ACD methods, such as botnet takedowns, could be employed with close law enforcement collaboration. While these strategies can be effective, they also come with potential risks, such as legal implications for offensive measures or the possibility of inadvertently disrupting legitimate users through overzealous blocking or deception techniques.

Remember that the attacker may also actively try to disrupt your OODA loop.

Reference

Boyd, J. (1995). The essence of winning and losing.

<https://www.coljohnboyd.com/static/documents/1995-06->

[28_Boyd_John_R_The_Essence_of_Winning_and_Losing_PPT-PDF.pdf](#)

12. Deception

As Boyd (1995) suggested, defenders can gain a significant advantage by disrupting the attacker's OODA loop. One of the best ways to interfere with the adversary's observations and decision-making process is deception. Defenders should consider deception a critical component of their defensive posture since attackers have repeatedly demonstrated the ability to subvert traditional defenses. In addition to detecting intruders, deception can provide an effective means of identifying internal threats.

Conventional defensive tactics focus on detecting and preventing the attacker's actions, while deception focuses on manipulating the attacker's perceptions, distorting their situational awareness. Deception can manipulate the attacker's thinking and cause the attacker to act in a way that benefits the defender. Deception can also cause the attacker to expend resources and force the attacker to reveal his techniques and capabilities.

Deception provides a versatile approach to network defenses. Defenders can deploy preventative and reactive deceptive assets in various network environments and situations. Also, deception can provide efficiencies over traditional intrusion detection systems. Deception methods such as honeypots and honeynets generate far less logging

data or noise than traditional intrusion detection since the deceptive assets are not involved in everyday operations.

However, deploying and maintaining deceptive assets requires expertise and ongoing maintenance to ensure the deception remains relevant. For a deception operation to be effective, it must present and maintain a plausible story to the attacker. Furthermore, the architecture of a honeynet must prevent the attacker from using a compromised system within the honeynet to attack legitimate systems. Also, the deception architecture must provide capabilities for the defender to detect and capture all actions the attacker takes while engaged with the deceptive assets. A honeynet must also be realistic enough that once it lures the attacker, it continues to deceive the attacker. If the attacker discovers the deception, he may change tactics or abort the operation.

Deception tactics are not limited to honeypots and honeynets. Defenders can integrate deception into a proactive defense strategy to avoid the traditional wait-and-watch game. Deceptive assets can act as a *canary in a coal mine*, providing an early warning system for possible intrusions. Defenders can create many types of fake entities, including files, database entries, and user accounts, which only a malicious attacker should access. Defensive systems monitor the fake entities and alert any interactions with the bogus resources, signaling a possible intrusion. As a bonus, several of these methods are relatively simple to implement and require no new technology.

A well-organized deception strategy can provide many benefits to defenders. Therefore, organizations should consider combining techniques into a comprehensive deception framework. The use of multiple integrated techniques increases the effectiveness of the deception. For example, a well-crafted deception implementation can

include deceptive files, user accounts, communication ports, database entries, emulated systems, and comprehensive honeynets.

However, like with all cybersecurity approaches, using fake entities for deception comes with challenges. The fake entities could impact performance and require additional storage space and software licensing. Also, false alarms, or false positives, can occur when an employee interacts with a fake entity on the system. However, alerting the security team when employees engage with deceptive assets can be positive. An employee's interaction with deceptive assets may indicate an insider threat. Perhaps the biggest challenge with fake entities is creating and maintaining them. Fake assets must look realistic to the attacker to be effective. Otherwise, they will avoid engaging with deceptive assets.

What Is Deception

Deception is not about deceiving the enemy. Deception is about causing the enemy to deceive himself. In other words, with deception, you cause the opponent to adjust his orientation based on his false observations. The attacker's compromised orientation will cause him to make improper decisions, further affecting his actions. The art of deception is to show your opponent something your opponent wishes to see and believe. The most effective deceptions play on the adversary's preconceived beliefs and previous experiences and background. If you create a false impression, you can seduce the enemy into deceiving himself to your advantage.

Deception in War

All warfare is based on deception. Hence, when able to attack, we must seem unable; when using our

forces, we must seem inactive; when we are near, we must make the enemy believe we are far away; when far away, we must make him believe we are near. Hold out baits to entice the enemy. Feign disorder, and crush him.

—Sun Tzu, The Art of War

Many military commanders have followed Sun Tzu's advice regarding deception. Deception has a long, varied history in war. Throughout the history of conflict, deception has played a vital role. Greek mythology contains one of the most widely known stories of wartime deception – the Trojan Horse. History has shown that the most effective deceptions present the enemy with something he expects to see and wants to believe, causing the enemy to deceive himself. The following examples represent a few samples of effective wartime deceptions. In these examples, we see Sun Tzu's words put into action. In one of the examples, George Washington uses deception to appear stronger, while in another, the Russians use deception to appear weaker.

George Washington, the Teller of Lies

In the United States, we have a saying that George Washington could never tell a lie. However, he was a master at telling lies. Throughout the American Revolution, Washington masterfully used tactical and operational deception on the battlefield. In addition, Washington often crafted inflated reports of troop strengths and penned fake documents designed to fall into the hands of traitors and spies (Thompson, 1991). After capturing the British garrison at Princeton in January 1777, Washington set up a winter encampment in nearby Morristown. Washington feared that British General Howe would launch an attack if Howe discovered the meager size of his army, which

numbered 3,000 to 4,000 troops. Washington knew he needed to conceal this weakness from Howe since Howe's nearest encampments far exceeded the size of Washington's army. Washington decided to spread his army out, with just two or three men to a house, resulting in the locals concluding that the army was 40,000 strong.

Washington knew Howe would not believe Washington had 40,000 men (Thompson, 1991). He needed a more realistic deception. Washington ordered his units to prepare false troop strength reports to ensure the total was 12,000. Amidst the wild rumors of 40,000 men, Washington knew the British would believe the more realistic figure of 12,000, even if it was 3 to 4 times his actual troop strength. Washington left the reports where a suspected spy could find them on his desk. The spy delivered what he thought were legitimate troop strength reports to Howe, who decided he could not attack the Americans due to their troop strength. The deception worked so well that Howe later refused to believe other reports that Washington's army was much smaller. Instead, he held firm in his belief in the "official" reports his spy provided.

First US Army Group: The Ghost Army

The Allied forces effectively used many deceptions to hide their assault on Normandy Beach during WWII. In late 1943, the Germans were sure that the Allied forces would attempt an invasion of northern Europe, with northern France the most likely target (Murphy, 2018). However, the Germans needed to know where. Some German generals believed the attack would be at the port of Calais, at the English Channel's narrowest point, while others thought it might be along the coast of Normandy. The Allies wanted to ensure the Germans did not move their infantry and tank commands stationed near Calais to Normandy. The Allies devised a plan, code-named Quicksilver, to keep the German forces in Calais.

Operation Quicksilver created a phantom army, the First US Army Group (FUSAG), which the Allies placed under General Patton's command (Murphy, 2018). The appointment of Patton to this fictitious army lent credibility to the operation, making it much more believable to the Germans. The FUSAG comprised a few real units but primarily consisted of fictional divisions. The Allied forces gathering in England thus appeared nearly 70% greater than their true strength. Also, the location of the FUSAG suggested that the Allies would attack via Calais.

The ghost unit created realistic radio transmissions that they knew would be intercepted by the Germans (Murphy, 2018). However, they also needed to make the army on the ground appear real to German reconnaissance planes. The FUSAG set up tent cities throughout eastern England. They also constructed vehicles and aircraft out of cardboard and inflatable Sherman tank replicas. Of course, the vehicles must appear to move, so at night, the soldiers would move them. However, these vehicles also needed to leave tracks. The soldiers used tools to create simulated tracks. The Allies maintained the ruse as the Normandy landing began on June 6, 1944. By maintaining the deception in the days following the start of the invasion, the Allies effectively kept Germany from sending reinforcements from Calais to Normandy.

Concealment: The Battle of Kursk

Whereas Washington found it necessary to inflate troop strengths, the Russians went to elaborate means to cause the Germans to underestimate their strength prior to the battle of Kursk. The two armies were assembling for an epic battle in 1943. The Germans had amassed 750,000 troops, strengthened by a large contingent of tanks in preparation for the assault near Kursk (Gaskill, 2019). The Russians were well aware of Germany's plan to attack Kursk based on intelligence. In preparation for the assault,

the Russians amassed 1.2 million troops and 3,000 tanks to face the Germans. However, the Russians implemented a strategy called *maskirovka*, or masking, to conceal their strength and defensive preparations.

The Russian command leaders spread rumors among their troops, which suggested they had a much smaller force and significant supply line issues (Gaskill, 2019). The Russian commanders, like Washington, knew there were spies among the troops, and this misinformation would find its way to the Germans. Also, they were sure some less disciplined men, including radio operators, would discuss what they heard. The Russians moved reinforcements and supplies at night to conceal these operations from the Germans. They also used concealment to build multiple lines of defense. The deception worked. The Germans believed they faced a Russian army of 400,000 men and 1,500 tanks.

Deception in Cyberspace

When we talk about the cyber realm, that is where deception can thrive. Cyberspace has made creating fake realities, imaginary assets, and false personas quite simple. Sure, cyberattackers and defenders use deception. However, it is also used for so much more. In cyberspace, people use deception with ease for many purposes. Some of these uses are so ubiquitous that we often do not think of them as deception. In some cases, they mimic deceptive activities in the physical world.

Law enforcement can use cyber deception to assist with criminal investigations and catching criminals, such as in a sting operation to catch child predators by posing as minors online or going undercover to investigate a criminal enterprise. Deception can also be a powerful tool in intelligence and counter-intelligence operations. Intelligence officers can create fake online personas, which

they can use to go undercover to infiltrate targets, such as adversarial governments and terrorist organizations, and gather intelligence. Governments also use cyber deception to conduct espionage and spy on adversaries.

Deception is also used for many non-governmental purposes. Businesses may use deception like their government counterparts to collect intelligence on their competitors. Security researchers use deception to explore undergrown cyber marketplaces and gain the trust of cybercriminals who operate there. Also, deception helps cover the researcher's tracks so that the criminal actors with whom he interacts do not identify him. Finally, ordinary users often use deception. They may provide fake contact information in online forms to protect their privacy. Alternatively, they may boost their social media profiles with deceptive information. Finally, gaming, especially virtual reality, is based on deception. Games seek to immerse the player. When the deception is effective, the player deceives himself, feeling like a character in the game.

Applicability of Deception to Cybersecurity

Defenders can apply the concepts of battlefield deception to cyberspace. Cyberspace provides excellent potential for the practice of deception in defensive operations. In the cyber realm, combatants can easily construct and move deceptive terrain. Companies can use deception to divert attackers from valuable assets or as an early warning system. In addition to slowing the attacker, deception can allow defenders to gain knowledge of the attackers' tactics, techniques, and procedures. Engaging the attacker early and maintaining deception with a honeynet allows the defender to collect and record details about the attacker's

attempts to compromise the system. The defenders can use the intelligence gathered through deception to bolster defenses and share it with other organizations.

Deception has been a powerful weapon in the arsenal of threat actors for years. Cyber threat actors often use deception to take the initiative and gain the first-mover advantage. For example, they use deceptive emails for phishing attacks, spoof legitimate domains, and impersonate trusted contacts. Threat actors use these deceptive practices to bypass defenses and establish a foothold from which to operate. They also use deception to evade detection by concealing their actions or making it look like someone else was conducting the attack, such as a false flag operation.

Building systems resilient to cyber threats requires techniques and technologies adversaries cannot anticipate, navigate through, or successfully attack. One such technique to increase cyber resiliency is cyber deception. To counter the threat actor, defenders can craft a deceptive environment populated with fake assets the attacker expects to see, causing the attacker to deceive himself. Creating a *hall of mirrors* with fake assets and misdirection can force an attacker to waste his time and resources, all while alerting the defenders of his presence.

Prerequisites for Deception

The most essential prerequisite for implementing deception is robust, comprehensive monitoring. The security team must closely monitor all deceptive assets deployed in their environment. The team must monitor all decoys and tokens and be alerted on interactions with these assets. If the team is deploying a honeynet to gather intelligence on attackers, they must monitor all actions within the honeynet. Furthermore, before implementing deception,

the security team should be keeping up with existing alerts and be confident in the security controls. Deception can introduce additional alerts, which the security team must have the capacity to address.

Also, the security team should analyze the priorities of current alerts and the alerts that deception will raise. Often, the alerts from deception will have a higher fidelity and, therefore, a higher priority than many current alerts. Since deceptive assets should never be involved in everyday operations, alerts from these assets can be highly indicative of an intrusion. Therefore, these alerts often require immediate attention.

Organizations must carefully review their security architecture before implementing deception, especially when deploying honeypots or honeynets or using external lures to entice attackers. Honeypots and honeynets must have a highly secure architecture. Such deceptive assets should be deployed in a secure network, separate from the production assets, to reduce the likelihood of the attacker escaping the deception and moving laterally through the production network. Again, robust monitoring and resilient security controls are required to protect against harm to other systems.

Organizations must be aware of potential legal implications when implementing deception technologies, particularly if they intend to use gathered intelligence for attribution or legal action. Consult with legal counsel to ensure compliance with relevant laws and regulations.

Components of a Typical Deception Platform

Deceptive assets can take many forms. However, the base assets can typically be categorized as lures, decoys, and tokens. Figure 12-1 depicts a logical implementation of

these various deceptive assets. A comprehensive deception strategy could include hundreds or thousands of deceptive assets. An integrated deception platform can assist companies in deploying and managing deceptive assets throughout their networks.

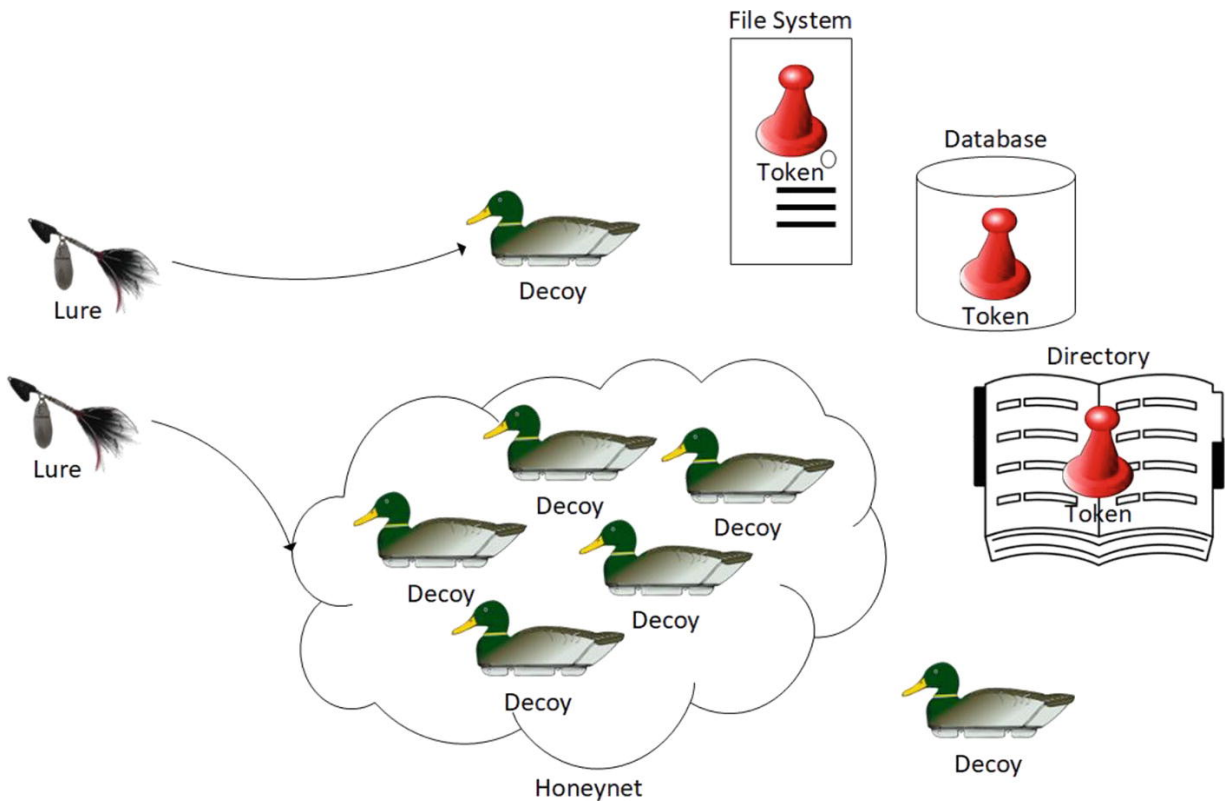


Figure 12-1 Components of a typical deception platform

Lures

Lures, sometimes referred to as breadcrumbs, are designed to entice the attacker. The idea of a lure is to attract attackers and then (hopefully) lead them to a decoy system or environment, typically to collect intelligence, engage the attacker, or misdirect the attacker away from legitimate assets. Lures typically consist of data placed on legitimate assets that will lead the attacker to a decoy system or network.

Defenders can place lures within or outside the company's network. Furthermore, the lures within the

network could be public-facing or internal only. Public-facing lures could attract attackers, including ones that might not otherwise target the company. Internal-facing lures seek to attract attackers who are already within the perimeter, diverting them away from legitimate assets. The lures can also lead to decoys within or outside the network perimeter. For example, a company may have internal lures that lead to an external honeynet of decoys. Such an approach would lead the attacker away from the company's network to a controlled, isolated external honeynet.

Decoys

Decoys are fake systems configured to perform like a similar operational system in the environment. These decoys can be physical, virtual, or emulated systems. Instead of deploying physical or virtual decoys, some deception platforms use an appliance to create decoys on the network by emulating the traffic. Defenders can use decoys to imitate many types of systems. For example, defenders can create decoys for servers, workstations, network devices, IoT devices, database systems, industrial control systems (ICS), and supervisory control and data acquisition (SCADA) systems. A decoy could be created for any device or system one might find in a network. Of course, the capabilities of the deception platform may limit the types of decoys that can be created and implemented.

Often, lures are used to lead the attacker to the decoy assets. Decoys can also act as their own lure by imitating an enticing target. In this case, the decoy is considered a honeypot. However, decoys can also be passive, waiting until an attacker stumbles across them. No matter how the decoy is accessed, it can trigger alerts on interactions. The decoy could also act as a honeypot, designed to be compromised, allowing the defender to observe the adversary's actions. As shown in Figure [12-1](#), defenders

can create an entire decoy network or honeynet that imitates a real network in addition to individual decoys.

Tokens

A token is data placed on legitimate assets, such as files containing fake sensitive data, fake accounts in Active Directory (AD), fake credentials, and fake database records. Defenders can place files that have potentially interesting but fake content across file systems. These could be files that appear to have sought-after data, such as credit card details. They could also be fake design documents for proprietary products or services, which could act as another form of deception - misinformation. Defenders can also create token accounts in AD. These accounts must look legitimate and appear to have realistic access to systems. Another example of a token is placing fake records within a database, such as customer records with realistic appearing data. Any attempt to access these records would be considered suspicious. Finally, attackers often use metadata, or information about the data, during reconnaissance and attacks. Therefore, defenders can place false information within the metadata, such as file creation and modification times, to confuse the attacker.

A token is designed to act as an early warning system. They are not designed to engage and observe the attacker. Instead, they act as the proverbial *canary in a coal mine*. These tokens can be monitored with traditional monitoring tools. For example, file integrity monitoring can monitor token files for any access. Any interaction with a token indicates the presence of a possible attacker or insider threat since no legitimate user or traffic should access it. Therefore, an alert should be generated to notify the security team. Typically, these alerts will have a higher priority since, if implemented correctly, there should be no legitimate reason for anyone to interact with the tokens.

Honeypots and Honeynets

A honeypot is an individual computer or network component deliberately designed to appear vulnerable. These honeypots mimic real systems and data by presenting carefully crafted vulnerabilities, outdated software versions, and seemingly valuable but fake data, enticing attackers to engage with them rather than legitimate targets. Multiple honeypots can be arranged into a honeynet to create a network to attract cyberattackers and study their behavior. A honeynet can include all types of systems, including servers, workstations, printers, IoT devices, network devices, and industrial control systems. These systems are crafted to appear vulnerable, presenting open ports, outdated software, or weak security protocols that invite exploitation. The goal is to deceive attackers into thinking they have found a genuine target, leading them to launch their attacks and reveal their techniques. By interacting with a honeynet, attackers unwittingly expose their tactics, techniques, and procedures (TTP), allowing cybersecurity professionals to gather valuable intelligence on potential threats.

The primary purpose of a honeynet is to enhance an organization's cybersecurity posture by providing insights into the methods used by attackers. A honeynet includes monitoring tools and logging mechanisms that record every interaction, such as commands executed, files accessed, and network traffic patterns. When attackers target a honeynet, their activities are monitored and recorded in a controlled environment, which helps researchers analyze the attempted attacks and tools used. Security teams can use this intelligence to develop more effective defensive measures and strategies to protect real networks from similar threats. Moreover, honeynets can help identify new vulnerabilities and weaknesses in existing security systems,

enabling organizations to address these issues before attackers exploit them in a production environment.

Honeynets can also serve as a deterrent to cybercriminals. Suspicious that their activities are being observed and analyzed, attackers may become more cautious and hesitant to engage in malicious activities. Furthermore, the intelligence gathered from honeynets can be shared with the broader cybersecurity community, helping to improve collective defenses against evolving cyber threats. Honeynets can be a valuable cybersecurity tool, providing proactive and reactive benefits by enhancing threat intelligence and improving security.

While honeynets can provide valuable insights into cyber threats, they also have potential downsides and risks. Setting up and maintaining a honeynet can be resource-intensive. It requires skilled personnel to design, deploy, and monitor the honeynet effectively. When operational, a honeynet must also generate realistic network traffic. The complexity of configuring honeynets to mimic real networks and lure attackers can demand significant time and expertise. Additionally, monitoring and analyzing the data collected from honeynets requires ongoing attention and resources, which can burden organizations with limited cybersecurity staff.

A honeynet can become a launchpad for further attacks if not properly isolated. If attackers compromise the honeynet, they could use it to pivot to other systems or launch attacks on external targets. This risk underscores the importance of designing honeynets with robust containment and isolation measures to ensure that any malicious activity does not spread beyond the controlled environment.

Central Management Console

A deception platform typically has a central management console, which is used to develop, deploy, and manage

decoys, lures, and tokens. The state-of-the-art deception platforms enable the rapid creation of deception environments, often within the existing infrastructure. Advanced deception platforms offer multiple methods for creating assets, including full virtualization, containerization, and network-based emulation, each with its own advantages for different deception scenarios. The method could impact the goals and how the deception is implemented. For example, if a company wants to create a honeynet to observe the adversary, a platform that only supports network-based emulation may not meet their needs. Instead, they may need fully functional VMs to keep the adversary engaged. However, a network-based emulation platform could be well-suited if the goal is to create an early-warning system with reduced upfront effort.

Another critical consideration is the types of assets the platform can create and manage. For example, what type of OSs does it support when creating decoy systems? What type of tokens can it support, such as file types, database records, and AD records? Suppose you want to create a honeynet that imitates a network within your environment. In that case, you should consider whether the platform can create and support fake representations of all asset types within the network. The closer you get the honeynet to imitating the network, the more effective the deception will be.

Of course, robust monitoring and alerting are imperative before deploying any deceptive assets. The deception platform should integrate with current monitoring and alerting capabilities. Interactions with the fake assets must generate comprehensive logging. This logging must integrate with the SIEM, giving the security analyst full situational awareness and details of the adversary's actions. When using deception as an early warning system,

any interaction must trigger an alert with full details to inform the security analyst or for an automated response.

When evaluating a deception platform, there are several characteristics to consider, including

- The platform should provide resilient concealment of the identity of critical assets. The organization should identify its critical assets, including servers, services, files, and identities, and use deception to shield them from attackers. The deceptive assets must be resilient to attack.
- The platform should increase the detectability of an attack by significantly increasing the potential for mistakes by the attackers. The deceptive assets must be realistic and enticing to the attacker and closely monitored to detect any interaction.
- The deception should act as a deterrent by increasing the attacker's effort to achieve his goals. A well-orchestrated deception strategy should cause the attacker to expend additional time and energy, deterring the attacker from achieving his objective.
- The platform should provide for automated configuration that is largely transparent to users. The deception should not interfere with the legitimate use of services. Also, the configuration of the deceptive assets should be as automated as possible, decreasing the effort to create and maintain the deception.
- State-of-the-art deception platforms often incorporate machine learning algorithms to dynamically adjust the behavior and content of decoys based on observed attack patterns, enhancing their realism and effectiveness.
- The deception platform must be scalable. It should support all services and platforms necessary for effective deception. The organization must identify the services and hosts used in the legitimate network and ensure the deception platform can support them. Also, the

organization must consider the quantity of deceptive assets required.

Vampires and Cybersecurity

Before we go any further, I must tell you that I am a big fan of vampire literature, so please pardon the vampire analogies. I have found that people seem to jump right to public-facing honeypots or honeynets when discussing deception for cybersecurity. In these implementations, people envision enticing the attacker into the network, perhaps through external lures or by making the honeynet externally visible. They look to invite in the vampires and cyberattackers.

Such deceptive practices are designed to lure in attackers and keep them in to slow the attack and observe their behavior, possibly engaging the attacker. The defender can thus gain knowledge of the attackers' TTPs and collect original intelligence. Engaging the attacker early and maintaining deception with a honeypot or honeynet allows the defender to collect and record details about the attacker's attempts to compromise the system. Organizations might use such an approach to collect intelligence to improve defenses or to pursue the attacker, such as in a law enforcement situation.

However, inviting attackers into your network can have serious repercussions, much like inviting vampires into your home. Furthermore, engaging them or watching them move about can be very risky. In most cases, I would recommend that companies leave this type of engagement to the professionals, such as external security vendors and researchers, or in the case of vampires, let Buffy handle them. Alternatively, if you prefer, contact Von Helsing, Abraham Lincoln, or Anita Blake, all of whom, according to popular literature and film, are renowned vampire slayers.

Often, the best approach when encountering a vampire is to drive a wooden stake through his heart as soon as possible. Similarly, in most situations, organizations want to evict and block the attacker quickly and effectively once a suspected attacker is identified. Toying with vampires after they have entered your home can be fatal. Likewise, allowing an attacker to move about in your network so you can observe him can result in additional damage, especially if the attacker can escape the honeynet and begin moving laterally throughout the environment.

Vampires are known for their social engineering skills. They will try to deceive their victims into inviting them in. Likewise, attackers often use social engineering to get unsuspecting users to invite them in. Unfortunately, unlike vampires, the attackers that target organizations can also enter without an invitation. Fortunately, defenders can use deception to identify the attacker within their network. Deception tactics are not limited to external-facing honeypots and honeynets. You do not have to invite the vampire into your home. In fact, you probably should not (unless you are sure of your abilities at wielding a wooden stake). The same goes for the cyberattacker. Instead of using deception to invite the attacker in, defenders can use deception as a warning system of possible intruders.

So when your perimeter defenses, such as firewalls, IDPSs, garlic, and crosses, do not work, and the cyberattacker or vampire enters your premises, you can leverage deception to shine a light on them. Deception within your environment can act as an early warning system of possible intrusions, much like using mirrors to detect vampires. Then, once you are alerted to their presence, you can vanquish them by shining sunlight on them or driving a stake through their heart. Of course, I am not encouraging you to drive a stake through the cyberattacker's heart. That would be illegal. But you can evict the attacker from your network.

If you have your heart set on being a vampire slayer, many vampire slayer kits are available on the Internet. However, I cannot attest to their effectiveness.

Practical Uses of Deception

Defenders can create a wide range of decoys and tokens, including servers, network devices, files, database entries, and passwords, which only a malicious attacker should access. Defenders can leverage these assets to enhance security and accomplish many tasks. Most organizations should not focus on externally facing deception to entice attackers into their environment or complex honeynets to observe the attacker's behaviors. These are legitimate uses, but only with a carefully architected solution that will mitigate possible harm to legitimate assets. However, many other practical uses of deception do not necessitate inviting or actively engaging with the attackers. These practical deception use cases include

Alerting: This use case is the proverbial canary in a coal mine. The company distributes decoys or tokens throughout the environment. Any interaction with these assets would trigger an alert and immediate response, either automated or by the security team. The goal is to evict the attacker immediately upon discovery.

Preemptive warning: Defenders can deploy decoys that resemble common public-facing reconnaissance targets. This approach can also involve creating decoy APIs or web services that mimic common cloud services, allowing defenders to detect and analyze potential attacks on these services before they target production systems. Alerts from these decoys could signal an imminent or future attack. Information gathered from the reconnaissance efforts can be used to implement

preemptive blocks or develop additional monitoring and alerting.

Lateral movement detection: Strategically deploying lures that direct attackers to decoys of various systems can aid in detecting lateral movement or attempts to exploit systems. Interaction could trigger alerting or observation to discover tactics or targets.

Sensitive data protection: Defenders can place tokens that resemble sensitive data, such as intellectual property, credit card data, and personal information, in strategic locations. These can be files, entries in databases, or any fake asset. Any interaction with these fake assets could signify an attack or insider threat, so immediate alerting and response are necessary.

Slow the attacker: Defenders can use deception as an active defense to slow the attacker. Lures and decoys can add friction and confuse or misdirect the attacker. By increasing the attacker's time and effort to compromise the system, defenders can gain additional time for response. Also, the increased effort might deter the attacker.

Identify insider threats: Many of these same use cases can also assist with identifying insider threats and policy violations, whether intentional or not. An insider triggering any alerts associated with deceptive assets could signal an insider threat or an attacker using compromised credentials.

Some of these use cases are simple to implement and require no new technology. However, operating deception at scale will typically require a comprehensive deception platform. Perhaps the biggest challenge with decoys and tokens is creating and maintaining them. Decoys and tokens must continue to look realistic to be effective. For example, companies should follow the same or similar patching and upgrading processes for decoys as they do for

the respective legitimate assets. These decoys should also generate similar types and volumes of network traffic. For tokens, they, too, must be kept up-to-date. For example, if a company is using fake transactions or other time-stamped data, these would need to be regularly updated. A robust deception platform could assist significantly with the operation and maintenance of deceptive assets.

Keys to Success

First and foremost, a deception program's successful implementation and operation begins with a clear strategy. The strategy should define the goals and objectives of the deception program. One common approach to defining the strategy is first to define and prioritize the critical exposed assets that must be protected. Then, for these critical assets, define the goal for using deception. Clear objectives and goals will assist in prioritizing the many use cases for deception.

Some examples of high-level objectives include

- Alert on reconnaissance efforts and probable attacks with minimal false positives so that attackers can be blocked and evicted.
- Slow or deter the attacker with fake assets, in which case, deception can be used to frustrate the attacker.
- Discover policy violations and inadvertent insider threats to avoid accidental incidents or disclosure events.
- Discover the attacker's TTPs and gather intelligence to improve defenses.

Having clear, agreed-upon objectives for each use is paramount. The objectives could drastically impact how deception is implemented, operated, and maintained. For example, let us look at the concept of secrecy. If the objective is to collect intelligence, then maintaining the secrecy of the deception throughout the engagement with

the adversary is essential. Similarly, secrecy must be maintained if the objective is to uncover policy violations by insiders. However, maintaining the deception's secrecy is less critical if the objective is deterrence. Similarly, if the goal is to alert on any interaction, then maintaining secrecy after the initial interaction is of limited use.

In addition to the capabilities of the various deception methods, it is critical to consider their costs and potential adverse effects. For example, deploying and maintaining honeypots or a honeynet will be more resource-intensive than other deception methods, such as tokens or MTD. Also, an attacker might escape a honeypot, or the honeypot might ensnare an innocent user. Any deception method may also increase operational costs and impact current processes. The team must consider the goals, potential costs, and adverse effects when selecting deception methods.

The objective and goals should drive the prioritization and implementation of use cases. An objective focused on detecting and evicting an attacker would require very different use cases than one focused on collecting threat intelligence. The objectives and use cases should consider how the target *should* react to the deception. How do we want the attacker to react? Do we want to lead the attacker down specific paths? Do we want to add so much friction and confusion that it will deter the attacker? Do we want to keep the attacker engaged so we can observe his tactics?

In this planning stage, we should also consider what biases of the attacker can be exploited. Remember, deception is about causing the attacker to deceive himself. Presenting what the attacker expects to see can drastically increase the effectiveness of the deception. What do we know about the potential attackers that we can use to our advantage when constructing deceptions? Reviewing pertinent intelligence analysis and prior attacks can

provide valuable contextual information about potential threat actors.

Prioritizing the use cases will also assist in defining the requirements for evaluating possible deception platforms for implementation. When assessing the deception platforms, in addition to a functional evaluation of the use cases, the team must also evaluate how the tool would integrate within their environment and the long-term operational support and maintenance, including personnel and licensing costs. Also, the team must define the roles and responsibilities required to implement and support the deception strategy. For example, determining what is needed to develop, deploy, and maintain deception assets and respond to generated alerts.

Misinformation and Concealment

Using open source intelligence (OSINT) for misinformation and concealment can be a strategic part of cybersecurity efforts to protect sensitive information and mislead potential attackers. Threat actors can harvest much information about potential targets using OSINT. For example, job postings might divulge the IT and security products the company uses. Social media profiles can provide valuable information to threat actors to enhance social engineering efforts.

OSINT involves collecting and analyzing publicly available information from various sources, such as social media, websites, forums, and news outlets. Cyberattackers often use OSINT to gather intelligence on their targets before launching attacks. By understanding how attackers use OSINT, organizations can proactively manage their digital footprint, deploy misinformation tactics, and conceal critical information. Conversely, defenders can use OSINT to understand potential threats and protect their assets.

Misinformation and concealment can provide numerous benefits. They can confuse threat actors and cause them to expend resources. However, these tactics also present challenges. Teams must carefully manage misinformation to avoid legal or ethical issues. Also, companies must balance misinformation with maintaining credibility and trust with legitimate stakeholders and the public. Finally, implementing and maintaining effective misinformation and concealment strategies can be complex and resource-intensive.

Spread Misinformation

In a previous chapter, we explored how threat actors can use misinformation and disinformation to target companies. Threat actors might use these tactics as part of a social engineering campaign to compromise a company's network or as a targeted campaign to destroy the company's reputation. However, defenders can also use misinformation. Organizations can deliberately plant false information in public channels to mislead attackers.

The misinformation can include fake employee profiles, incorrect contact details, or misleading data about network architecture. Fake social media profiles and posts can spread misleading information about an organization's operations, plans, or security measures. This misinformation can confuse attackers and waste their resources on false leads. However, it may also confuse those wanting to engage with the company legitimately. Organizations can proactively register domain names similar to their official domain to prevent attackers from using these for phishing or impersonation attacks and can use these domains as part of their deception strategy. Doing so can help mislead attackers attempting to spoof or impersonate the organization. These domains can be configured to provide false information or redirect to decoy sites.

Conceal Information

In addition to providing misinformation, organizations can practice concealment. Concealment techniques help safeguard critical data, reducing the risk of exposure through OSINT channels. Companies can limit publicly available information about their employees, infrastructure, and operations. They can also restrict access to specific online profiles and remove unnecessary details from websites and directories. When publicly sharing information, companies should strategically choose what to disclose, concealing sensitive data while providing necessary information for legitimate purposes.

Sensitive documents and communications can be redacted or obfuscated to hide critical information while sharing necessary data with the public or partners. Removing metadata from documents, images, and files shared online can prevent the inadvertent disclosure of sensitive information such as author names, software versions, or GPS coordinates. Using anonymous communication tools and platforms can help conceal the identities and intentions of an organization's personnel during sensitive operations, preventing OSINT gathering by attackers.

Summary

Working inside the opponent's OODA loop can give the defender an advantage. Deception is one of the most effective ways to interfere with an attacker's OODA loop, disorienting and disrupting his decision-making process. Deception can deter or delay attacks by frustrating the attacker and causing him to expend resources. It can also cause the attacker to divulge his TTPs. Therefore, defenders should consider deception a critical component of their defensive posture.

Deception has a long history in war, and its principles can apply to cybersecurity. The cyber realm lends itself to creating deceptive assets and concealing legitimate assets. However, companies must ensure robust logging, monitoring, and alerting before implementing deception. They must also ensure the deceptive assets are appropriately secured, preventing the attacker's escape.

Typical components of a deception framework include lures, tokens, decoys, and honeynets. Lures act like breadcrumbs, leading the attacker to the deceptive assets. A decoy or honeypot imitates a system that would be present in the network. These decoys have robust logging and monitoring to capture the details of the attacker's actions. A honeypot is a specific type of decoy designed to appear vulnerable to attract attackers. Multiple decoys and honeypots can be assembled into a honeynet, presenting a fully functional network to observe the attacker.

Attracting or allowing attackers to operate within a honeynet to gather intelligence can be risky. Most organizations should leave such research to specialized firms. However, many practical deception uses do not have such a high-risk exposure. Companies can use deception to detect lateral movement, provide an early warning system, protect sensitive data, slow the attacker, and identify insider threats. Companies must have clearly defined objectives and goals to drive their deception priorities.

References

Boyd, J. (1995). The essence of winning and losing.

Retrieved from

<https://www.coljohnboyd.com/static/documents/1995-06->

[28__Boyd_John_R__The_Essence_of_Winning_and_Losing__PPT-PDF.pdf](#)

Gaskill, M. (2019). *From wooden horses to rubber tanks: The greatest military deceptions*. Retrieved from War History Online:

<https://www.warhistoryonline.com/instant-articles/deception-operations-history.html>

Murphy, B. J. (2018). *Patton's ghost army*. Retrieved from America in WWII:

<http://www.americainwwii.com/articles/pattons-ghost-army/>

Thompson, E. R. (1991). George Washington: A master at deception. *American Intelligence Journal*, 12(1), 7-10.

Retrieved from <https://www.jstor.org/stable/44327187>

Part IV

The Cybersecurity Trinity

13. The Cybersecurity Trinity

Bringing It All Together

Now that we have explored AI, automation, and ACD within cybersecurity, this chapter will combine the three concepts. As we have seen, AI, automation, and ACD each offer potent benefits to improve cybersecurity. However, the full power of these technologies is only realized when they work together in an integrated strategy. The Cybersecurity Trinity (CST) will assist organizations to align these powerful technologies with each other and integrate them within their cybersecurity operations.

Figure 13-1 provides a high-level view of the CST. AI forms the framework's foundation, powering the organization's cybersecurity tools and processes. Security automation helps the organization to increase the speed and scope of its cybersecurity operations, allowing it to operate at cyber speed. Finally, an organization can leverage ACD methods to add friction into the attacker's OODA loop and delay or deter the attack. In this chapter, I will add details to each side of the CST and then show how they can work together. However, first, let us review each component – AI, automation, and ACD.

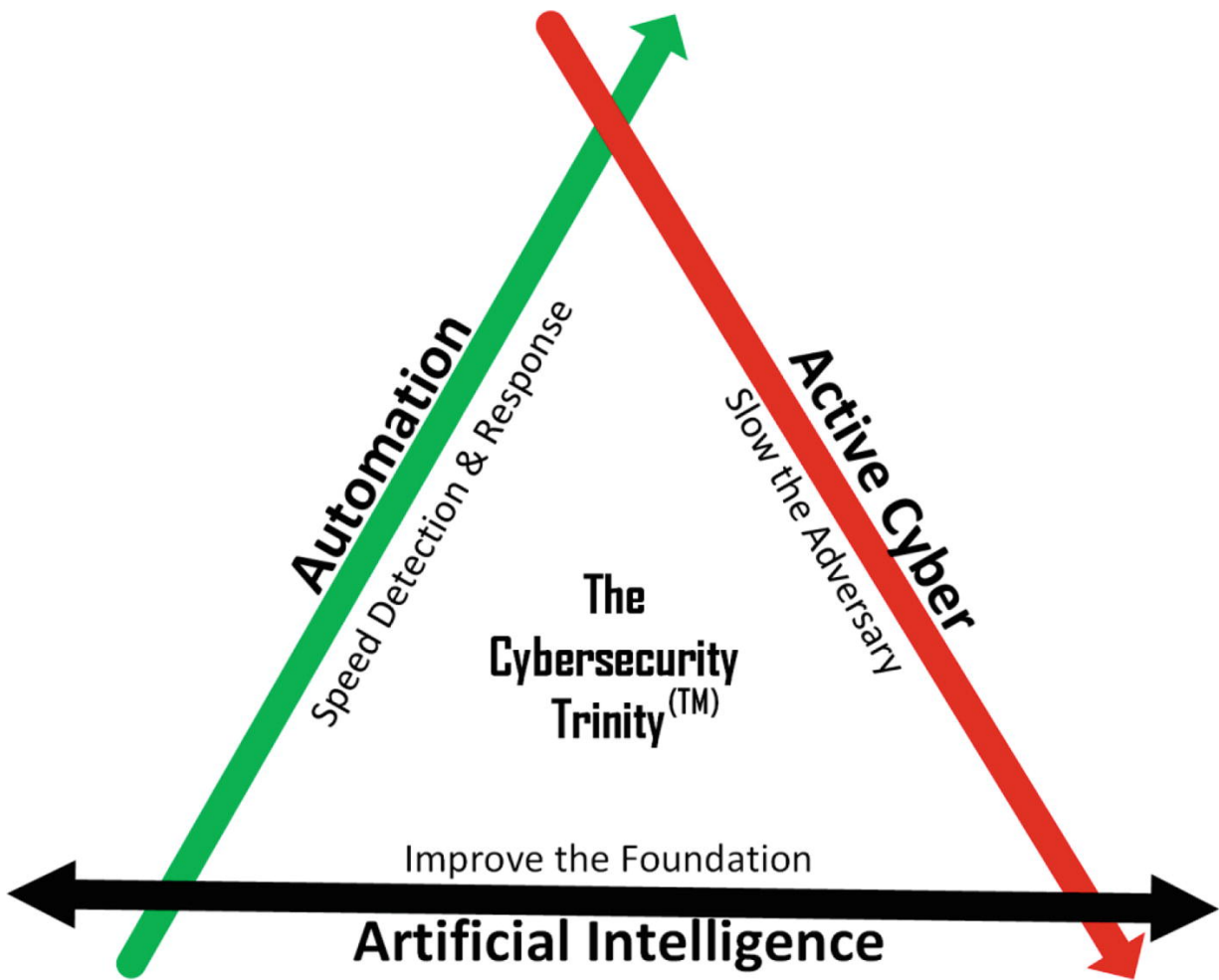


Figure 13-1 The CST combines AI, automation, and ACD to improve cybersecurity

AI As the Foundation

AI forms the CST's foundation, providing tremendous benefits across the cybersecurity operations spectrum. AI has become a vital component in modern cybersecurity tools, improving all aspects of cybersecurity. Detection and triaging of potential attacks have seen the most significant use of AI within cybersecurity. Threat detection, which often requires the analysis of tremendous amounts of data from disparate sources, is well-suited for applying AI. However, AI use within cybersecurity tools has expanded far beyond threat detection. AI enhances and automates

many cybersecurity functions, including vulnerability discovery and management, threat intelligence, and risk management. Also, cybersecurity professionals increasingly use generative AI to augment and automate many heavily manual processes, from security operations to governance. Figure 13-2 depicts many of the uses of AI to improve the foundation of cybersecurity.

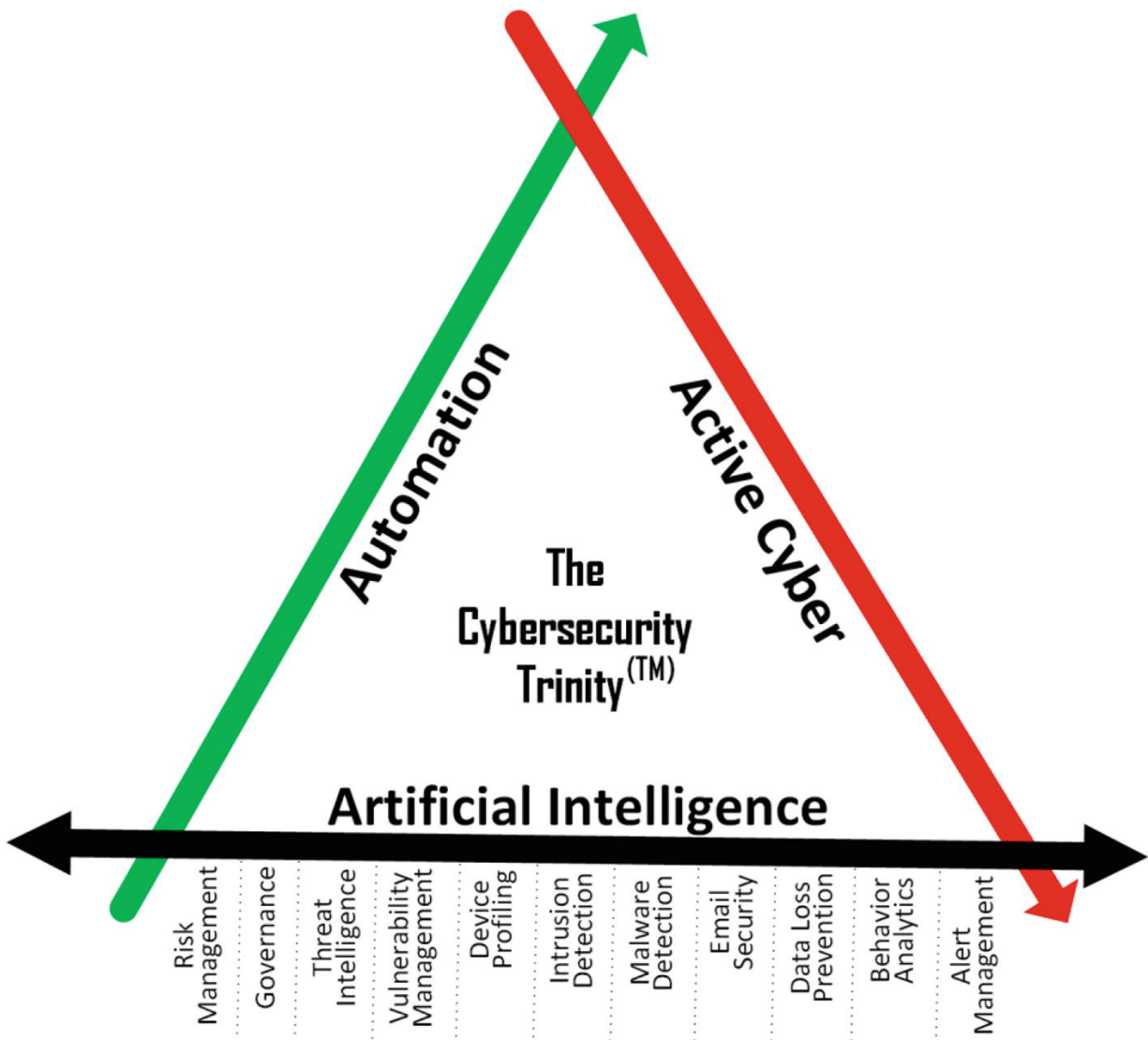


Figure 13-2 AI forms the foundation of the CST, powering most cybersecurity functions

Risk Management

Cybersecurity risk management processes and tools have integrated AI, particularly in risk scoring, prioritization, and governance. Machine learning models can analyze vast amounts of data from internal sources, external threat intelligence, and historical attack data to produce more accurate risk scores based on the likelihood and impact of various risks. Since AI excels at analyzing data at scale, it can consider contextual factors, such as the specific configurations of systems, the sensitivity of data at risk, and current threat actors' activities, resulting in a more nuanced risk score. The result is a data-driven assessment of the cybersecurity risks a company faces. Furthermore, unlike traditional risk-scoring methods often relying on static criteria, AI allows for dynamic risk scoring, adapting to environmental and threat landscape changes. For example, AI can adjust risk scores as new vulnerabilities are discovered or when an organization's environment changes.

After scoring the many cybersecurity risks for an organization, AI can play a critical role in prioritizing the risks. Sometimes, risks might not seem critical in isolation; however, the potential compound effects of these isolated risks can be significantly higher. AI can correlate seemingly isolated risks to understand their potential compound effects, providing a more comprehensive view of the organization's overall risk landscape. AI models can analyze historical trends and current indicators to predict which risks will likely materialize, allowing the team to focus resources on imminent and potentially damaging threats. Since AI helps the organization understand its overall risk landscape, the team can allocate its resources more effectively, focusing on the risks that pose the greatest threats to its objectives.

Governance

Governance is vital to ensuring continuous compliance with policies, standards, and regulations. By integrating AI into cybersecurity risk management, organizations can better assess, prioritize, and govern their cybersecurity risks, leading to a more resilient and proactive security posture. AI can assist in automating compliance monitoring and generate real-time reports on the organization's risk posture. This real-time, adaptive analysis can ensure continuous compliance with policies and regulations, unlike traditional methods that provide a point-in-time compliance check. AI can simulate risk scenarios, providing governance teams with valuable insight into the effectiveness of controls and potential vulnerabilities. AI enables organizations to take a more proactive approach to cybersecurity by predicting potential risks and dynamically adjusting to new information. Governance teams can, therefore, make timely, informed decisions.

Regulatory changes can significantly impact an organization's governance and compliance efforts. These regulatory changes may require updates to the organization's governance policies. AI can analyze regulatory changes, as well as contractual obligations, and recommend updates to governance policies. For instance, AI can analyze new data protection regulations and suggest specific updates to the organization's data handling policies to ensure compliance. This analysis ensures that the governance policies remain relevant and effective, helping ensure compliance in a changing regulatory and contractual landscape. Furthermore, AI systems can continuously monitor systems and processes to ensure compliance with cybersecurity governance frameworks, reducing the manual effort required for audits.

Threat Intelligence

AI can augment threat intelligence processes, including data collection and aggregation, threat correlation and

contextualization, and predictive threat intelligence. Threat data can come from a wide range of sources, including OSINT, dark web forums, paid services, partners, and government agencies. AI can assist in collecting and correlating the information from these various sources. By analyzing threat intelligence, AI-powered systems can provide a comprehensive view of a potential threat contextualized to the organization. The ability of AI to analyze historical data to identify trends can help predict future threats, allowing organizations to take proactive measures. Also, by analyzing TTPs, AI can assist in attributing attacks to specific threat actors.

Vulnerability Management

The number of vulnerabilities released puts an untold strain on security teams to track, prioritize, and patch them. Scanning a complex network for known software vulnerabilities can produce an expansive list of thousands or even tens of thousands of vulnerabilities that quickly become unmanageable for human analysts. Organizations must prioritize the patching of vulnerable assets.

Determining the relative risk of a breach that each asset, including each software package, presents in a large, dynamic environment is difficult, if not impossible, to do manually. Vulnerability management teams are increasingly turning to AI to help understand the software within the network, prioritize patches and mitigating controls, and test vulnerability exposure.

With an AI-powered asset inventory, ML models can analyze systems for vulnerabilities. A comprehensive, accurate asset inventory and ML analysis against that inventory make determining the applicability of a vulnerability trivial. Once vulnerable assets are identified, AI can assist with remediation prioritization by using models to determine the relative risk. This risk determination can evaluate many factors, including the

core vulnerability score, the asset's value and importance, the data and services on the system, the system's placement within the environment, and the presence of mitigating controls. This AI-powered analysis can provide enhanced risk scoring and prioritization to focus remediation efforts.

Device Profiling

Understanding what devices are on the network can be challenging, especially with the proliferation of IoT devices. Organizations often use device profiling to collect information about devices that connect to the network, which can then be used for asset inventory and security. AI augments device profiling by analyzing the device's behavior, going beyond the static information used in traditional device profiling. An AI-powered device profiling system could detect if the device began exhibiting behavior outside its appropriate usage or expected behavior. Such activity could indicate that someone is spoofing the device or has taken over the device. The profiling system can quarantine the device upon detecting suspicious activity.

Intrusion Detection

Intrusion detection and prevention systems (IDPS) inspect network traffic to identify malicious activity. Machine learning has a long history in intrusion detection, dating back to the 1990s, and now most IDPSs leverage machine learning to analyze traffic. Early use of machine learning in IDPSs focused on misuse detection, which determines the probability that given traffic is similar to a previous attack. This misuse detection relied on supervised learning with labeled network traffic profiles to detect known attacks. The difficulty of acquiring labeled data for an extensive network hindered this approach. However, AI can help automate the creation of misuse signatures by analyzing malware behavior and network traffic.

Now, most IDPSs are augmented with AI-based anomaly detection. The IDPSs use unsupervised learning to create clusters of normal network traffic. The IDPS can then alert when traffic deviates from the established norms. However, defining normal traffic on an extensive network where traffic can be variable can be challenging, even for the most advanced unsupervised methods. This difficulty in identifying normal behavior can lead to excessive false positives. Furthermore, as the organization's environment or procedures change, what is considered normal traffic for the network can experience significant change, rendering the previously developed models ineffective.

Malware Detection

Malware, including ransomware, continues to be a formidable cybersecurity problem. Malware detection focuses on determining if a specific file is malicious. Malware detection primarily uses two approaches: static and dynamic analysis. Static analysis examines the code's structure and attributes without executing it, while dynamic analysis observes the malware's behavior during execution in a controlled environment. In modern anti-malware solutions, AI enhances both static and dynamic malware detection.

Static analysis, which is effective at detecting known malware, often leverages unsupervised clustering algorithms. These algorithms group similar malware files to identify the associated properties. When labeled data is available, these solutions can use supervised algorithms trained with the extracted features from known malware. Another static analysis approach uses DNNs to transform malware files into images. These images are then used in a CNN-based classifier to detect similar files. Despite the advances in static analysis using AI, static analysis remains susceptible to evasion due to malware variants and polymorphic malware.

Anti-malware solutions use dynamic analysis to address issues arising from variants and polymorphic malware. Dynamic analysis analyzes the file's behavior during execution instead of analyzing the static features. The dynamic analysis leverages AI clustering algorithms to create groups based on malware variants exhibiting similar behavior. The behaviors of new executables can then be analyzed in real-time and compared to these groupings. Based on defined thresholds, executables that exhibit behaviors similar to those of malware groupings can be blocked or quarantined.

Email Security

AI can enhance email security and is often used to help address spam, phishing, and email account takeover. Before incorporating AI, early spam detectors used keyword matching for words common in spam messages and block lists of known malicious IPs. These early spam detectors were highly ineffective, often blocking numerous legitimate emails. Spam detection solutions began incorporating supervised learning algorithms to address the issues related to simple keyword matching. Spam emails were parsed into individual words to train supervised models. These models could then determine the probability that a given email was spam based on the probabilities of the individual words appearing in known phishing emails. Now, spam filtering can use many types of AI algorithms. These modern spam filters analyze additional details beyond the individual words within the email, including header information, phrases, synonyms, and the relative location of words.

Phishing detection follows an approach similar to spam detection. Known phishing and legitimate emails are collected to train a supervised classifier. The classifier is trained on the discriminative features, including header information and words in the email subject and body. The

resulting model can then classify incoming emails. However, phishing detection is not foolproof, as evidenced by the continued reports of data and system breaches facilitated through phishing.

Email account takeover, in which an attacker gains control of a user's email account, is a particularly troubling and challenging problem within cybersecurity. Leading email security products incorporate generative AI, natural language processing, and ML to address the growing concern of AI-generated emails used for a BEC attack. The email security providers create many examples from existing BEC emails using generative AI. Then, a classifier is built using supervised algorithms trained with the generated examples. Another approach to email security leverages ML to help detect email account takeover by determining the probability that a given email is from the supposed sender. An ML model is trained using examples of emails from a given person. This approach could create an email writing style profile for each person within the organization. Of course, not all BEC attacks will be detected, even with the latest AI-enabled email security. Therefore, companies should leverage process controls in addition to cybersecurity solutions to mitigate many BEC attacks. Also, while AI can help detect potential account takeovers, implementing strong multi-factor authentication remains a critical defense against this threat.

Data Loss Prevention

Data loss prevention (DLP) systems increasingly incorporate AI to increase effectiveness and adaptability. The first step in a DLP effort is often to classify the data. Categorizing and classifying data can be a daunting task if done manually. ML models can learn from existing data classification rules to classify data based on its sensitivity, such as intellectual property, personally identifiable information, protected health information, and financial

data. Once the data is classified, DLP tools often leverage natural language processing (NLP) to analyze the contents of emails, documents, and files for sensitive information. NLP can provide context beyond the traditional DLP methods that rely on regular expressions. AI can also enhance DLP controls by providing contextual analysis and differentiating between legitimate transfers and possible data exfiltration attempts. Furthermore, AI can make the DLP controls more adaptive through dynamic policy adjustments. The DLP policies can be tightened if the AI detects an increased risk of data loss, possibly due to an emerging or imminent threat.

Behavior Analytics

Behavior analytics seeks to detect threats by defining normal behavior and then detecting deviations from normal behavior. Unsupervised learning is used to define the normal behavior patterns for users and systems. For example, the user behavior could include what data the user accesses, what programs the user runs, at what time the user accesses the system, how long the user remains on the system, and what systems the user accesses. These tools can also identify normal system behavior, including what process the system executes and in what order, the background tasks running on the system, the system's data access patterns, and user activity. Once normal behavior is defined for the user or system, AI algorithms discover outliers. The outliers can be time-based (behavior changes over time) or peer-based (behavior differs from peer group). However, it is important to note that behavior-based detection can sometimes lead to false positives, especially in environments with frequently changing user behaviors or roles.

Alert Management

The expanding attack surface generates an increasing quantity of alerts from numerous security tools. These alerts inundate SOC analysts, who must quickly triage and prioritize them. Security vendors and teams are increasingly looking to AI to help manage alerts and reduce the noise. AI's ability to triage alerts and filter out false positives reduces the time and cost associated with initial detection. Security teams can reduce the alert fatigue suffered by many SOC analysts by using AI to distinguish the true positives from the false positives and true negatives. The improved signal-to-noise ratio allows analysts to focus their valuable skills on addressing those risks that pose the greatest threat.

Automating to Speed Defense

Organizations must increase their cyberattack detection and response speed to decrease the gap between the time to compromise and the time to respond. Several forces drive this need for increased defense speed, including the attacker's asymmetric advantage. The attacker chooses the time and place of the attack and only needs to be successful once. In addition, attacks are increasingly sophisticated, with well-funded APTs leveraging AI and automation. Meanwhile, the defenders must defend an expanding attack surface with increased complexity while often operating short-staffed teams due to a scarcity of qualified cybersecurity professionals.

SOAR can help address these concerns. Efficiency gains due to SOAR allow security teams to leverage their limited cybersecurity professionals more efficiently on advanced tasks. Furthermore, SOAR facilitates processing more alerts, providing increased visibility into possible threats. SOAR can also increase the speed and thoroughness of a response by orchestrating a response across all security devices. Figure [13-3](#) depicts the use of automation to

increase the speed of detection and response to cyber threats.

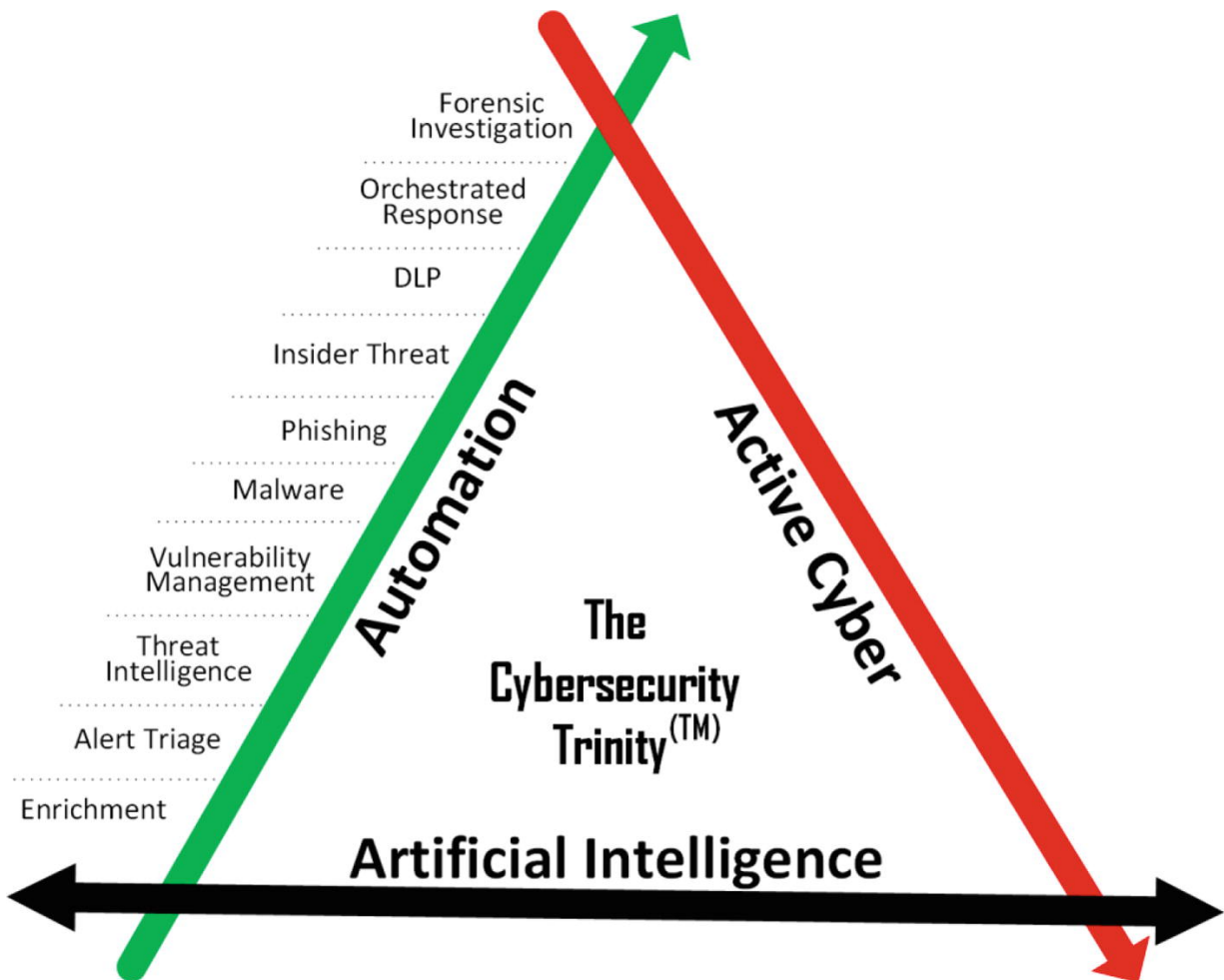


Figure 13-3 The CST incorporates automation to increase the speed of detection and response to cyber threats

Alert Enrichment and Situational Awareness

Boyd (1995) emphasized the critical role that orientation, or situational awareness, plays in adversarial situations. The OODA Loop theory's emphasis on orientation highlights the importance of maintaining awareness of the operational environment better than the opponent. Maintaining accurate situational awareness in a dynamic environment is critical to informing correct decisions and effective courses of action. In security operations,

orientation often begins with a SIEM correlating events to trigger alerts. The SIEM can then present the SOC analyst with telemetry data from sensors, threat intelligence, and asset information, providing the SOC analyst with situational awareness. The analysts may also bring in additional information to enhance their situational awareness, such as business operations, goals, and objectives. Automating the enrichment of alerts to improve situational awareness is the most widely implemented and valuable security automation use case.

Alert enrichment often requires data from numerous internal and external sources, including SIEMs, firewalls, identity management systems, IDPSs, web proxies, email gateways, EDRs, asset inventories, vulnerability management systems, reputation services, and threat intelligence feeds. A complex alert could include 100s of enrichments to provide complete situational awareness. Automated enrichment relieves the analyst of the time-consuming and often error-prone gathering and correlating information from these disparate sources. By automating the event enrichment, analysts can focus on informed decision-making.

Alert Triage

Alerts from correlated events or threat intelligence feeds can contain numerous IOCs. Triageing false positive IOCs, such as those not pertinent to the organization, can consume valuable resources and detract analysts from true positives. Also, the IOCs might contain IPs and URLs that the company explicitly allows, such as ones belonging to the company or its partners. Taking action and blocking these allowed assets can cause business interruption. Therefore, companies need to triage IOCs and quickly remove false positives. Automation can quickly check IOCs to determine if they are on the allowed list. If the IOCs are not on the allowed list, automation can further check to

determine their applicability and adjust priority accordingly. For example, for a URL, the automation can check the SIEM to see if there has been any traffic with that URL and, if so, raise the priority of the alert. Of course, as part of the enrichment, the automation will also gather the details of which resources have connected with the URL and add business-related context.

Threat Intelligence Processing

Companies may subscribe to several external threat intelligence feeds, such as from security vendors, partners, and government organizations, in addition to internal threat intelligence. These threat intelligence feeds are integral to securing and protecting company assets, brand, and reputation. The threat intelligence process assimilates intelligence on IOCs and threat actors from these various sources, allowing the company to proactively counter or mitigate the threats. However, the volume of IOCs an organization receives in its threat intelligence process can be daunting, making manual processing ineffective.

Automation can filter the raw intelligence feeds, removing non-applicable or outdated IOCs and keeping any in doubt. Companies can refine the filtering over time by inserting a feedback loop into the automation. Automated enrichment will be applied to any remaining IOCs, including whether the IOC has been seen in the environment, whether the company uses the vulnerable product, and possible impact, such as what devices, users, or business processes could be affected. The automation can then determine a recommended course of action (COA) to present to the analyst along with the enrichment data. Alternatively, in the case of low-impact IOCs, the SOAR can automatically apply the COA.

Vulnerability Management

Security automation can assist with vulnerability scanning to continuously monitor systems, networks, and applications for vulnerabilities. In addition to running the checks at regular intervals, a SOAR solution can trigger the scans by specific events, such as new vulnerabilities discovered, threat intelligence, or changes in the environment. For example, SOAR can monitor the NVD, intelligence feeds, and dark web forums for newly discovered vulnerabilities. SOAR integration with asset management solutions can help to quickly assess whether the organization uses the vulnerable product and provide valuable business context to help gauge the impact and set priority.

For discovered vulnerabilities within the environment, SOAR can monitor the respective vendor for patches. The release of a patch can then trigger a SOAR playbook that integrates with patch management, change management, and distribution tools to ensure the patch is applied. The organization may have to implement mitigating controls if no patch is available. Once the mitigating controls are identified, SOAR can ensure that the necessary changes are implemented throughout the security stack.

Alert Response Actions

Companies often start with enrichment use cases; however, to realize the full benefit of SOAR, they must implement automated remediation where appropriate. The following sections describe example alert responses. Of course, these are only a few examples. As an organization's SOAR use matures, they can add playbooks to respond to additional alerts. For example, the organization can create playbooks for application security, operational technology, and change management alert response. The ability to customize the degree of automation based on factors such as the type of alert, impacted assets, analyst expertise, and business context provides flexibility in response playbooks.

As an organization develops confidence in a given response playbook, it can increase automation.

Malware Response

One such remediation use case is responding to malware alerts and infections. The malware alerts may come from endpoint security controls, such as an EDR, correlated events from a SIEM, or an intelligence feed. Regardless of the alert origination, initial enrichment would have gathered the contextual information, such as on which systems the malware resides (if any), the types of systems (such as workstations or servers), and details of the malware from reputation sources and sandbox detonation.

The response to a malware alert could include implementing blocks in the EDR, quarantining the device, gathering forensic data from the device, and reimaging the device. Companies can configure the degree of automation they want in the malware response process. For example, a company may automate the response fully if the impacted systems are user workstations and the quantity of infected devices is below a specified threshold. However, if the malware has been seen on a server, the company may escalate to an analyst before taking further action.

Phishing Response

Another common process to automate is phishing response. The response could be invoked by a user reporting a suspected phishing email or the email security system detecting a suspicious email. Automation can analyze headers, content, links, and attachments. If the email is determined to be phishing, the remediation can also be automated. The email system can be queried to find and remove all instances from user inboxes, block the sender in the email gateway, and block the associated links and domains.

Insider Threat Response

A SIEM or a UBA solution can correlate user activity events and raise alerts for suspicious or anomalous activity. Also, an IAM system may raise alerts about suspicious login attempts or excessive failed logins. These alerts could indicate an insider threat or the use of stolen credentials by an external attacker. Once such an alert is validated, which could be automated or by analyst review of the enriched alert, the response can be automated. Such a response action would typically include the SOAR disabling the user account, logging the user out of all systems, quarantining the user's workstation, capturing recent user activity logs, and escalating for an investigation.

Data Loss Prevention Response

An alert from a DLP solution could indicate an insider's attempt to exfiltrate sensitive data or an external actor attempting to steal data. Even if the DLP solution blocked the attempts, organizations often want to take further response actions to investigate the activity, block future attempts, and ensure other data exfiltration did not bypass the DLP detection. For example, a user may have been exfiltrating many files, some of which were not classified as sensitive. However, once the user attempts to transfer a sensitive file, the DLP blocks it and raises an alert. The security team may want to investigate the other data the user transferred prior to the DLP alert.

A typical response to a validated DLP alert could be similar to the insider threat response. The SOAR would lock the user's account and log the user out of all systems. The SOAR could instruct the EDR to quarantine the device to prevent further data exfiltration. The SOAR can retrieve user and system activity logs from the SIEM or endpoint security system and any recent UBA events to assist in the investigation.

Orchestrated Response in a Complex Environment

Responding to alerts in a complex environment often requires changes across many systems to ensure a comprehensive response. An organization may have on-premises environments spanning the globe with varying security stacks, multiple cloud environments from various vendors with unique configurations and security controls, remote workers, and operational technology environments. Manually orchestrating a response across such a complex environment can be tedious, time-consuming, and error-prone.

Even something seemingly as simple as blocking an IP or URL can quickly become overwhelming. The company may have firewalls and IDPSs from multiple vendors, each with proprietary interfaces, within numerous data centers. In addition, they could be operating in several cloud environments from different providers. Integrating SOAR with these components in the security stack masks the proprietary interfaces. For example, SOAR can initiate an *ip_block* playbook to block IPs or a *url_block* playbook to block URLs. The respective playbook can then orchestrate the response across the disparate systems, ensuring all systems are updated appropriately.

Forensic Investigation Enrichment

Many of the previously mentioned alert responses may result in a forensic investigation. Whether the investigation results from a malware infection, insider threat, or other security incident, automating the forensic data collection can expedite the investigation and ensure all data is collected using approved methods. The response playbooks, such as the malware response, can call a forensic enrichment playbook once the device is quarantined. A forensic enrichment playbook would then retrieve all

relevant logs from the SIEM, the device, and other relevant security systems. The SOAR could then initiate a memory dump and a forensic disk image. The collected and enriched data would then be available to the investigator.

Active Cyber to Slow the Attacker

Speeding the detection and response addresses only one side of the equation. Defenders can also take active steps to slow the attacker. Figure 13-4 depicts ACD methods defenders can use to delay or deter the attacker. Actions such as malware baiting, whitehat malware, and rescue missions are not depicted because such actions present significant operational, reputational, legal, and ethical risks. Organizations should use these methods only in close collaboration with law enforcement. Furthermore, offensive actions, such as hacking back and botnet takedowns, are not included, as companies should avoid taking offensive action.

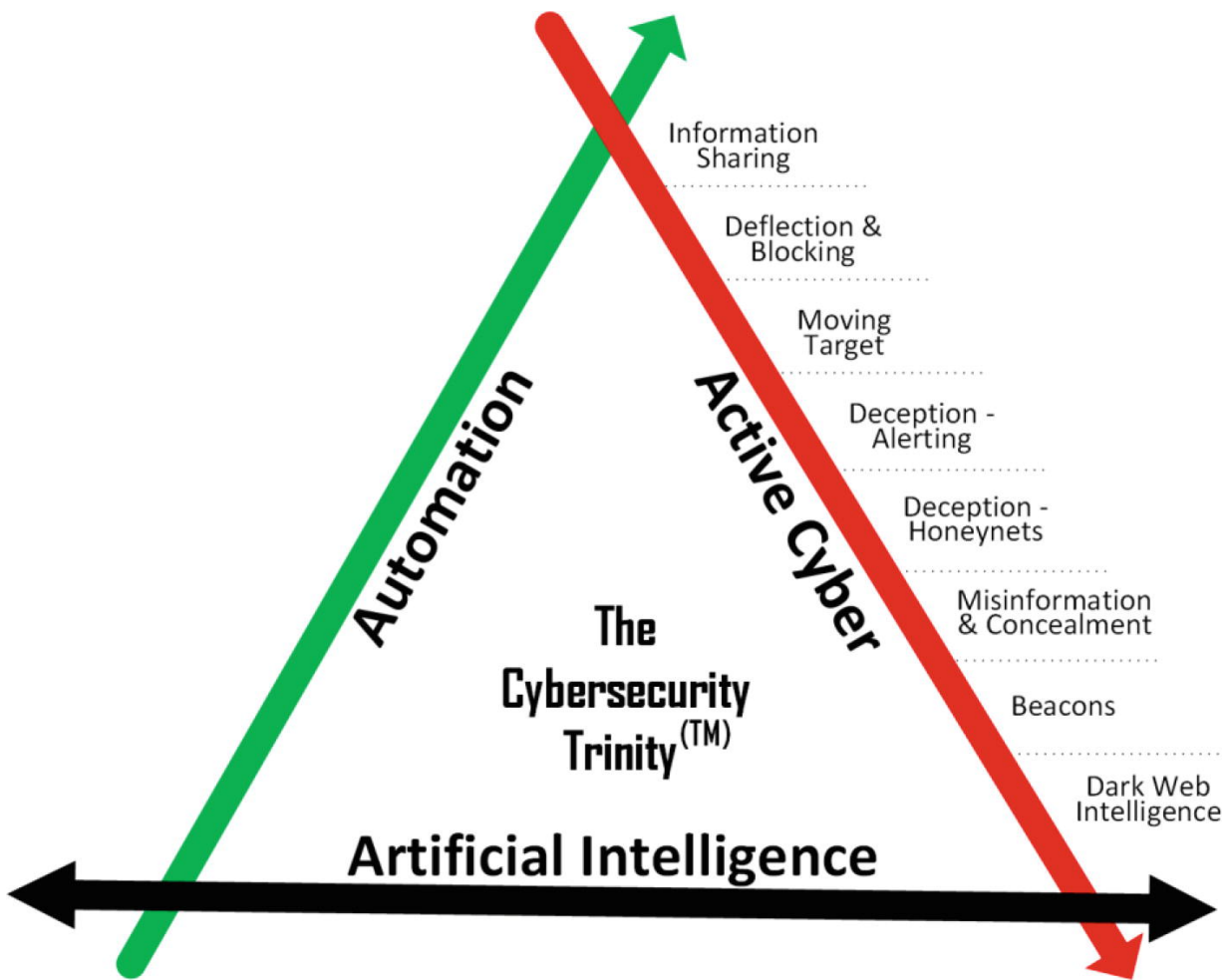


Figure 13-4 The CST incorporates active cyber defense to slow or deter the attacker

Information Sharing

Cybersecurity information sharing helps facilitate ACD. Information sharing can take many forms, including between partner organizations, an organization and its cybersecurity vendors, organizations in an industry (e.g., the Financial Services Information Sharing and Analysis Center), and government agencies and private organizations. Intelligence gathered through information sharing helps partnering organizations take proactive steps to improve their cybersecurity, including enhancing detection and blocking or countering malicious actors.

Effective sharing can act as an immune system to protect the partnering organizations. If a threat actor targets one organization within the sharing network, the targeted organization can share the details with its partners. This sharing can go beyond simple IOCs and include possible steps to block or counter the threat actor. With fast, effective sharing, a group can ensure that even if one member organization is compromised, the other organizations can protect themselves proactively.

Deflection and Blocking

Deflection and blocking of malicious traffic form the cornerstone of cybersecurity and must be in place before implementing more advanced ACD methods. These core deflection and blocking capabilities include IDPSs, DDoS protection, and antivirus solutions. Such solutions are essential but often taken for granted and not considered part of an ACD strategy. However, deflecting and blocking ongoing or imminent attacks are essential building blocks of ACD. Effective detection and accurate, timely intelligence allow organizations to proactively and dynamically adjust the deflecting and blocking of potential threats. Making these core cybersecurity methods more dynamic and less static enhances the organization's security posture, ensuring the active blocking of most malicious traffic.

Deception

In addition to improving detection and response speeds, defenders must address the other side of the equation by slowing the attacker. As Boyd (1995) suggested, winning in an adversarial context requires getting inside the adversary's OODA loop. Deception is one of the best methods of interfering with the opponent's OODA loop, causing confusion and disorder. Deception can effectively

disrupt and distort the opponent's situational awareness, corrupting his decisions.

Moving Targets

MTD is a class of deception that focuses on dynamically changing or diversifying the IT infrastructure. Some MTD solutions change configurations dynamically using methods such as IP hopping, host randomization, network reconfiguration, memory space allocation, and virtual machine migration. Another form of MTD is diversification, which leverages multiple variants of critical components, such as OSs, servers, programming languages, and hardware. MTD can address all layers of the IT infrastructure through a combination of dynamic and diversification methods. When effective, MTD can confuse the attacker and add friction within his OODA loop, causing him to expend time and resources.

Alerting

Companies can deploy deceptive assets, including lures, tokens, and decoys, as an early warning system to alert possible intrusions. The lures can lead attackers away from critical assets and toward deceptive assets. The organization must monitor the deceptive assets closely, creating a security alert upon interaction. These deceptive assets can include files containing fake sensitive data, Active Directory (AD) accounts, credentials, database records, and decoys resembling production systems. Any interaction with these assets would result in a high-priority security alert for immediate action by the security team. Furthermore, a company could create public-facing deceptive assets that can provide a preemptive warning of possible attacker reconnaissance efforts.

Honeynets

An organization may take deception a step further and implement honeypots, which mimic real systems and are designed to be vulnerable. Multiple honeypots can be arranged into a honeynet to resemble an active network. Unlike deceptive assets used for alerting, honeynets typically entrap and engage the attacker, allowing the defenders to observe the attacker's TTPs. All actions the attacker takes within the honeynet are logged, providing valuable intelligence. Security teams can use this intelligence to improve defensive measures and strategies to protect real networks from similar threats. Moreover, honeynets can help identify new vulnerabilities and weaknesses in existing security systems, enabling organizations to address these issues before attackers exploit them in a production environment. Furthermore, the organization can share the intelligence gathered from honeynets with the broader cybersecurity community, helping to improve collective defenses against evolving cyber threats.

Misinformation and Concealment

Organizations can deliberately plant false information in public channels to thwart an attacker's use of OSINT. Attackers often use OSINT to gather information about a possible target, often as a precursor of a social engineering attack. Defenders can spread misinformation, such as fake employee profiles, misleading data about the network architecture and security controls, and fake social media profiles and posts. Misinformation can confuse attackers, causing them to waste resources following false leads.

Another form of deception is concealment. By concealing critical data, companies reduce the risk of exposure to an attacker's OSINT collection efforts. Companies should limit publicly available information about their employees, infrastructure, business plans, and operations. When the company must publicly share

information, it should strategically determine what to disclose and conceal any unnecessary sensitive data.

Beacons

Beacons help locate stolen or misplaced assets by periodically calling home and providing details of their current location. Physical assets, such as laptops and mobile devices, often have beacons. However, organizations can also attach beacons to digital assets like files. When such files are stolen or unintentionally leaked, the beacon can provide valuable information about the file's current location, which could be vital to law enforcement or recovery missions. However, since these file-based beacons typically operate code on the system where they are located, they could raise legal concerns.

Dark Web Intelligence

Collecting intelligence on the dark web can provide valuable information regarding possible or imminent threats. In addition, researching dark web forums can identify if criminals are offering stolen company data on dark web marketplaces and provide details about the stolen data's whereabouts. Researching and visiting dark web forums and marketplaces can put the company and the employees conducting the research at risk. Therefore, most companies will use a third-party provider specializing in dark web intelligence gathering.

The Cybersecurity Trinity

The full benefit of AI, automation, and ACD can only be realized by integrating them. Figure 13-5 depicts the CST with all three underlying components. In the following sections, we will see how cybersecurity teams can apply the CST to improve cybersecurity operations through the lens of the NIST Cybersecurity Framework (CSF).

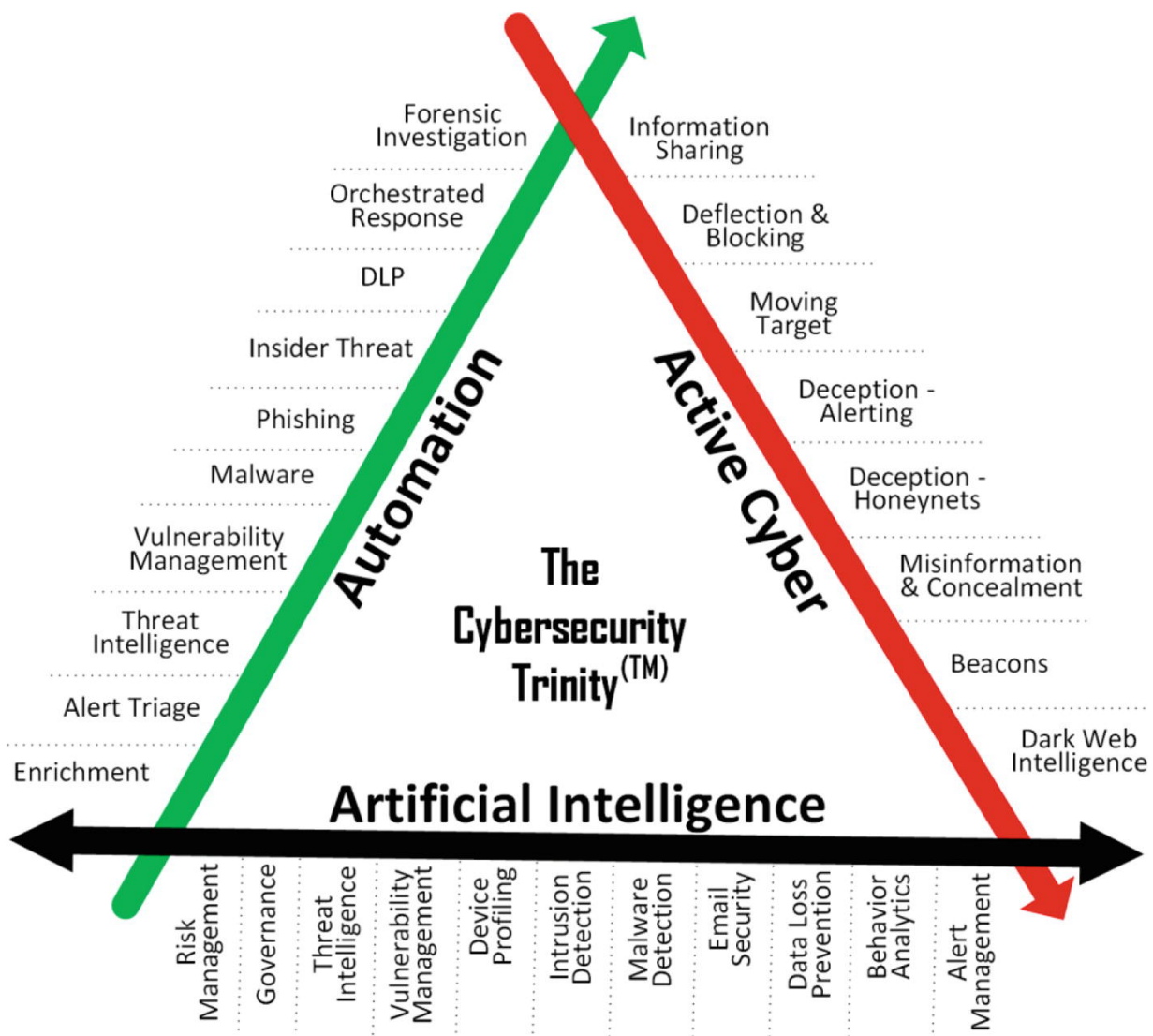


Figure 13-5 AI forms the foundation of the CST, automation speeds detection and response, and ACD slows or deters the attacker

Overview of NIST CSF

NIST developed the CSF to help secure the nation's critical infrastructure in response to a 2013 Executive Order. NIST published version 1.0 of the CSF in 2014 and the latest version, CSF 2.0, in 2024. The CSF provides organizations with guidance on managing cyber risk and has seen extensive adoption outside its original intended audience. The non-prescriptive CSF provides organizations flexibility in achieving the desired outcomes (NIST, 2024). The NIST

CSF contains six core functions (Identify, Protect, Detect, Respond, Recover, and Govern) that define desired outcomes, which can be further divided into categories and subcategories. Figure 13-6 depicts the NIST CSF core functions.

Identify	Protect	Detect	Respond	Recover
- Asset Management - Business Context - Risk Assessment - Risk Management	- Access Control - Data Security - Protective Technology - Awareness & Training - Maintenance	- Security Monitoring - Detection Processes - Anomaly Detection - Event Correlation	- Event Analysis - Event Mitigation - Identify Improvements - Communication	- Recovery Planning - Restore Operations - Improvements - Communication
Govern				
- Enterprise risk management - Cybersecurity strategy - Supply chain risk management - Policies - Roles and Responsibilities - Oversight				

Figure 13-6 The six core functions of the NIST CSF

Applying the Cybersecurity Trinity to NIST CSF

As a widely accepted guide, security teams across all industries leverage the NIST CSF to improve cybersecurity operations. Therefore, the NIST CSF provides an excellent perspective from which to visualize the CST. The following sections will discuss how organizations can apply the concepts from the CST to the six NIST CSF functions. The examples discussed in these sections are representative and are not exhaustive. Security teams can adapt these examples to their environment or use them as inspiration for additional use cases.

Identify

The adage that one must know what needs to be protected to protect it is fundamental to cybersecurity. However, identifying IT and data assets can be a massive undertaking

in a complex environment. Moreover, maintaining the inventory can be impractical or impossible since the environment is dynamic. Asset management refers to identifying, tracking, and managing an organization's assets, including hardware, software, data, and network components.

Fortunately, many asset discovery and management tools incorporate AI to identify the assets defenders must protect. Automated AI-powered asset discovery tools can discover and inventory all assets connected to a network, many of which may be overlooked by traditional methods. AI-powered asset discovery tools can also help identify shadow IT or unauthorized assets that may not be known to the organization, providing a more complete picture of the attack surface. An up-to-date asset inventory is critical to cybersecurity, including protection, detection, response, and recovery.

Knowing what assets the environment includes is the first step. However, to develop a complete picture of the risk, it is necessary to understand the asset's value, the likelihood of a risk, and the possible impact. AI-powered asset discovery and risk management systems can help provide business context to understand the asset's value and the impact disruption of the asset would have on the organization. By mapping all the connections between systems, processes, and data, these tools help contextualize the business context, providing a comprehensive view instead of looking at each asset in isolation. Later, we will see how this enriched asset inventory augments protection, detection, response, and recovery.

Organizations can use the up-to-date, comprehensive asset inventory to drive automated vulnerability scanning. Then, a risk management system can incorporate the business and operational context derived from the asset discovery and the vulnerability details to inform risk scoring and prioritization. Furthermore, understanding the

adversarial environment in which the organization operates is critical to risk management. Therefore, AI-powered risk management systems must integrate threat intelligence, including dark web intelligence, which can be vital in determining the likelihood of realizing a risk. A SOAR solution that integrates the threat intelligence feeds with the risk management system can ensure the risk management system considers the up-to-date threat context. Figure 13-7 depicts incorporating AI and automation to augment the *Identify* function.

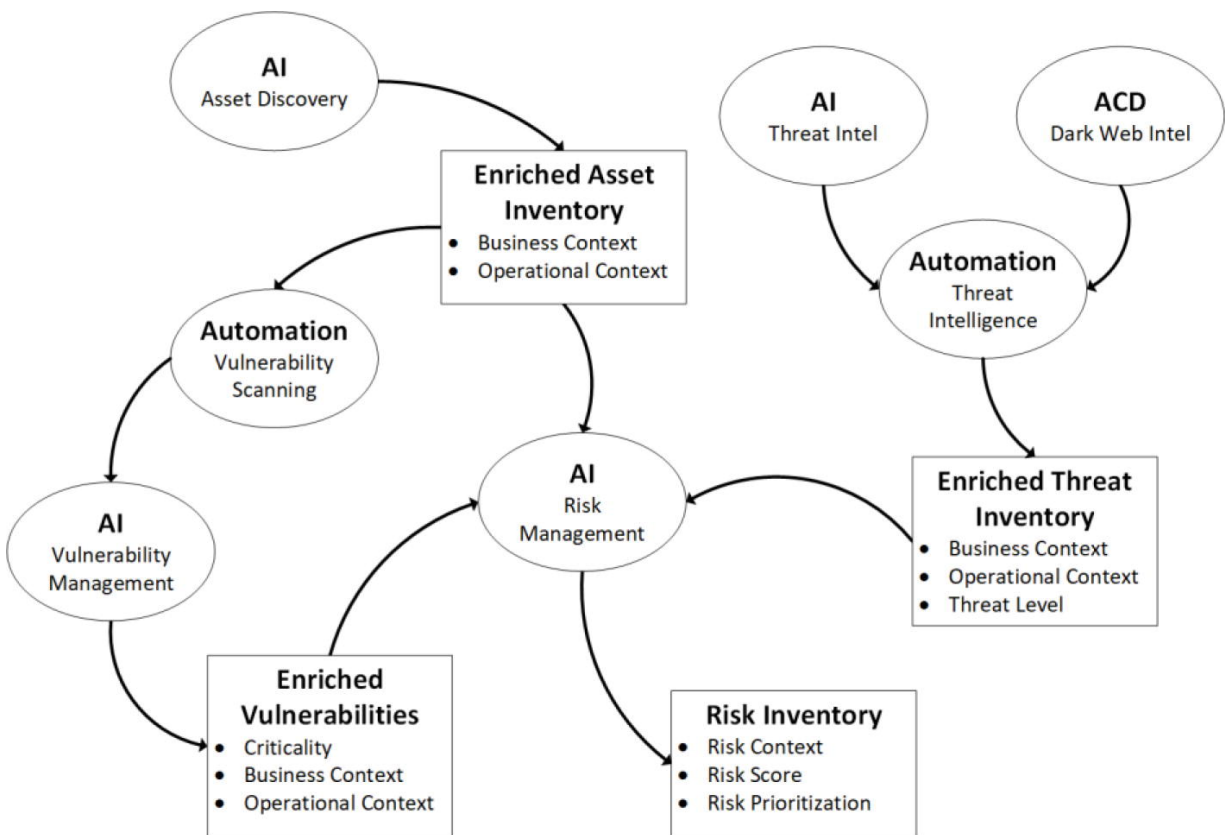


Figure 13-7 Understanding the operational and business context of all assets, threats, and vulnerabilities is vital to risk management and cybersecurity prioritization

Protect

The *Protect* function focuses on securing assets based on the previously identified assets and risks (NIST, 2024).

Therefore, the enriched asset, risk, and threat inventories from *Identify* form the foundation of *Protect*. Organizations will implement additional security controls or modify existing controls to protect their assets based on risk prioritization. Automation can help ensure that any control updates are propagated throughout the environment. In addition, SOAR can integrate with vulnerability management and patch management systems to check for available vulnerability patches. When patches are identified, SOAR can integrate with software distribution and patch management systems to ensure the patch is applied throughout the environment. Figure 13-8 depicts integrating automation to update security controls and distribute security patches.

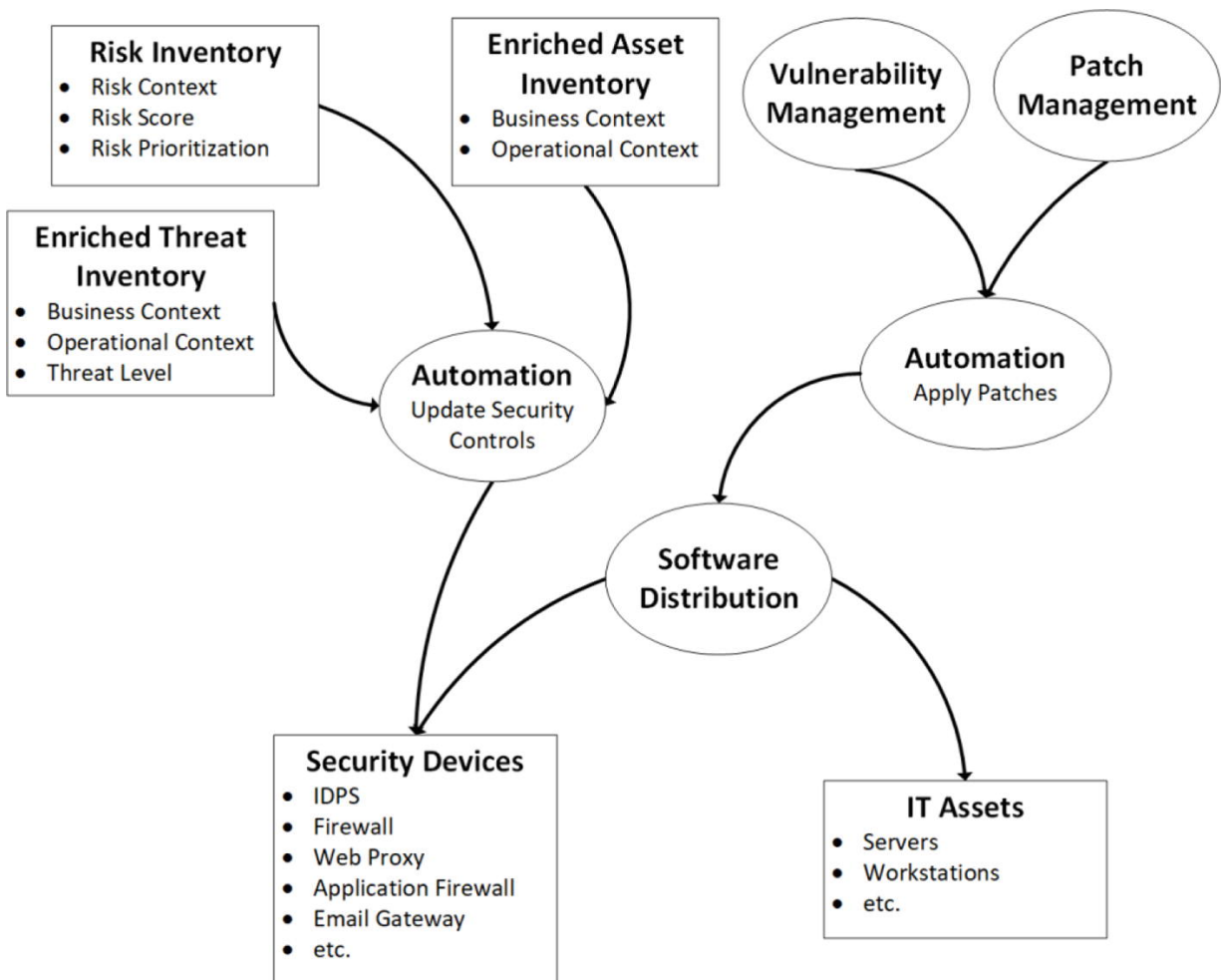


Figure 13-8 Automation uses the AI-enriched inventories to update security controls. In addition, automation integrates with vulnerability and patch management to apply patches throughout the environment

The threat inventory will assist in evaluating and updating blocking and deflecting security controls, such as IDPSs, web proxies, antivirus, firewalls, DDoS protection, and tarpits. For example, the company may need to implement additional blocks in its IDPSs and firewalls. Using SOAR, these configuration changes can be orchestrated to ensure that all applicable security devices are updated.

If the company uses deception, the enriched asset and risk inventories can help identify what assets need protection and what deception assets are needed. The company may implement lures to direct the attacker from critical assets and towards deceptive assets. The company can strategically implement deceptive tokens and systems based on critical assets and risks to facilitate early warning of possible attacks. If the company already has deceptive assets deployed, they may need to be updated based on the asset and risk inventories. In this case, automation or a deception management platform can assist. When implementing deception techniques, organizations must carefully manage and monitor these assets to ensure they don't inadvertently confuse or hinder legitimate users or processes. Figure 13-9 depicts automating the management of deceptive assets.

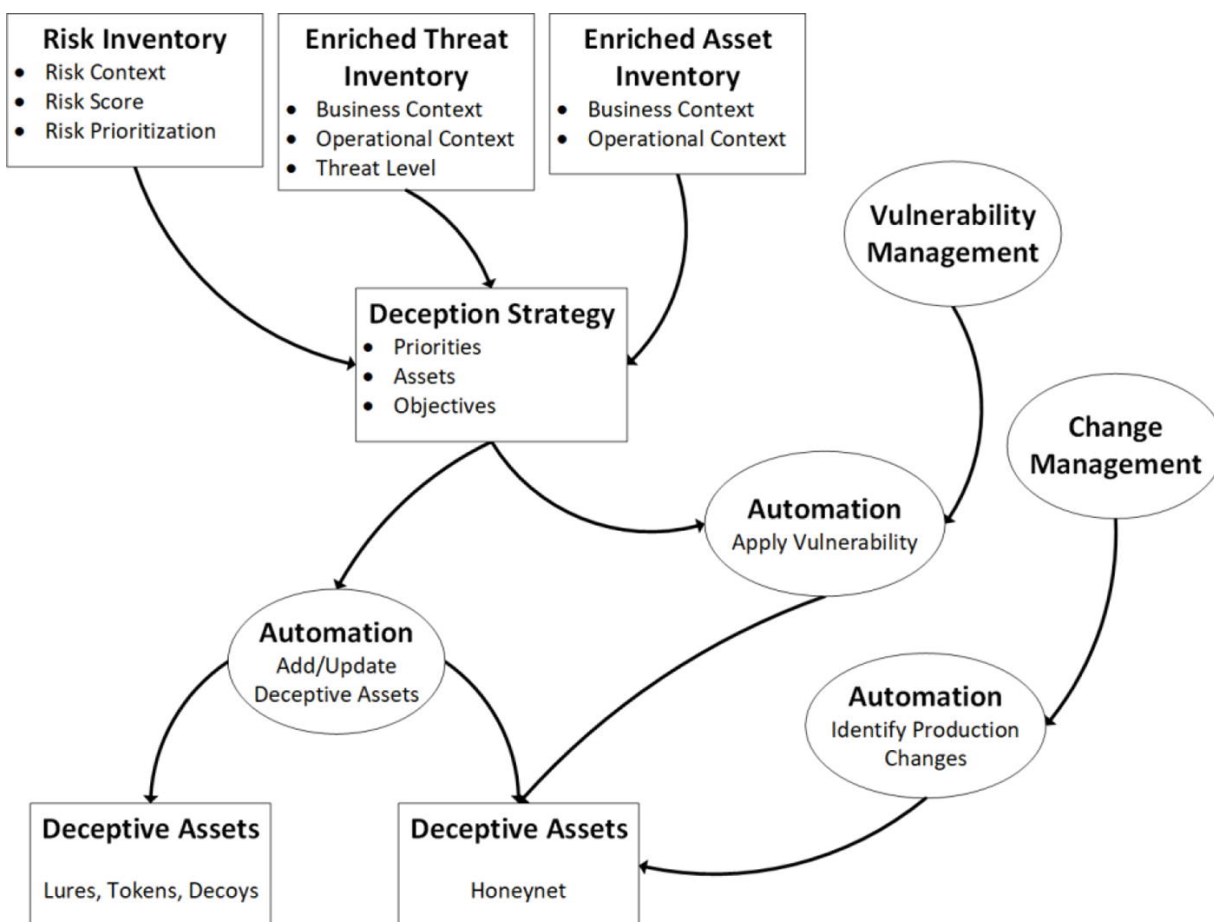


Figure 13-9 The AI-enriched risk, threat, and asset inventories drive the deception strategy. Automation then ensures that deceptive assets are added and updated as necessary.

The company may also implement a honeynet to delay the attacker or gather intelligence. The enriched asset inventory can inform the architecture of the honeynet, including what assets should be deployed to simulate the target network. Also, since honeynets are designed to be vulnerable, the security team can use the enriched vulnerabilities inventory to identify vulnerable software versions to implement on the honeynet systems. Finally, SOAR can integrate with change management and software distribution systems to ensure the honeynet continues to resemble the production network.

Detect

The *Detect* function focuses on identifying and analyzing possible cyber incidents. In modern security operations, events from many sources must be correlated and analyzed to identify potential malicious activity. Many cybersecurity systems, including behavior analytics, intrusion detection, endpoint detection, email threat detection, and data loss prevention, incorporate AI to analyze events and raise alerts, as seen in Figure 13-10. However, these alerts are typically in isolation, solely based on the activity seen by that solution. Often, the events from a security solution must be correlated with those from the other security systems to understand the breadth of the possible incident. Also, the isolated events may not indicate a security incident until viewed holistically. Security teams often use a SIEM or similar technology to perform automated correlation. AI can also help in reducing alert fatigue by clustering similar alerts and prioritizing them based on their potential impact and relevance to the organization's specific context.

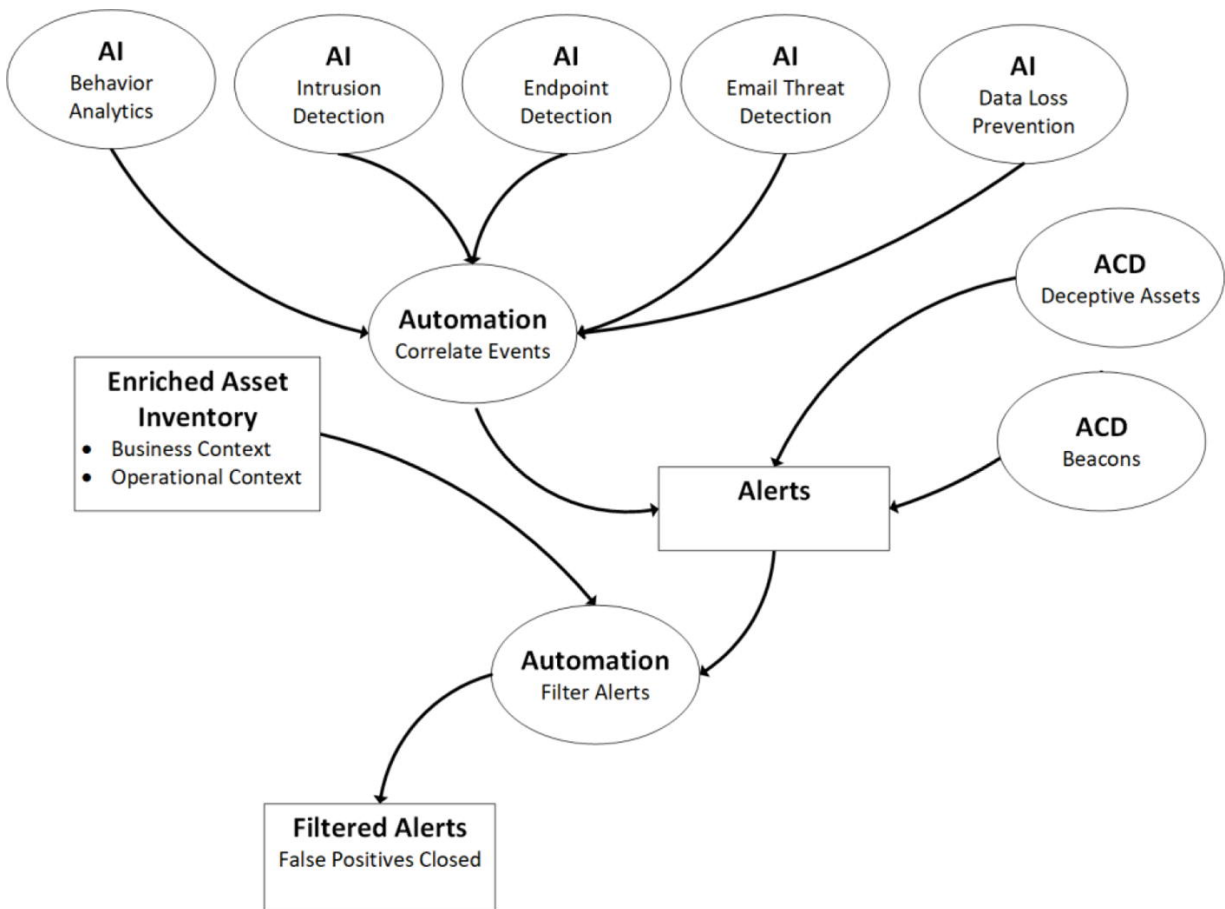


Figure 13-10 AI, automation, and ACD play vital roles in incident detection. Most security solutions include AI to analyze events, while ACD methods can create high-priority alerts. Automation helps correlate events and filter out false-positive alerts.

ACD methods, such as deception and beacons, also provide a detection source. Interaction with deceptive assets can trigger an alert. Often, such alerts are a high priority since these assets should not be accessed in normal operations; therefore, any interaction indicates a possible incident. Companies can place beacons on digital or physical assets. When these beacons call back from an unauthorized location, they can indicate a loss or stolen asset.

Event correlation will result in alerts. However, it is necessary to filter these alerts to remove false positives. Automation can incorporate the business and operational context, which can help discriminate between false

positives and true positives. For example, a threat intelligence or vulnerability feed may include software or software versions the company does not use. The automation will close the false positives, saving valuable security analyst effort. Security teams will typically design the automated filtering under the premise of, *when in doubt, leave it in*. This approach reduces the possibility of closing true positives.

Respond

Once possible security incidents are detected, the *Respond* function takes over. This function is designed to contain and mitigate the incident. Response to an incident first starts with obtaining situational awareness. Automated enrichment of the alerts can incorporate many data sources. The enriched asset inventory from the *Identify* function provides business and operational context about the assets involved or possibly impacted by the incident. Understanding this context is vital to making informed decisions and selecting appropriate COAs. For example, the COA for an incident that may impact a few user workstations would be much different than an incident that could impact a vital component of the business operations. In addition to asset enrichment, automation integrates with identity and access management (IAM) systems for user details, EDR systems for process and system details, and reputation services and sandboxes for threat details, as depicted in Figure [13-11](#).

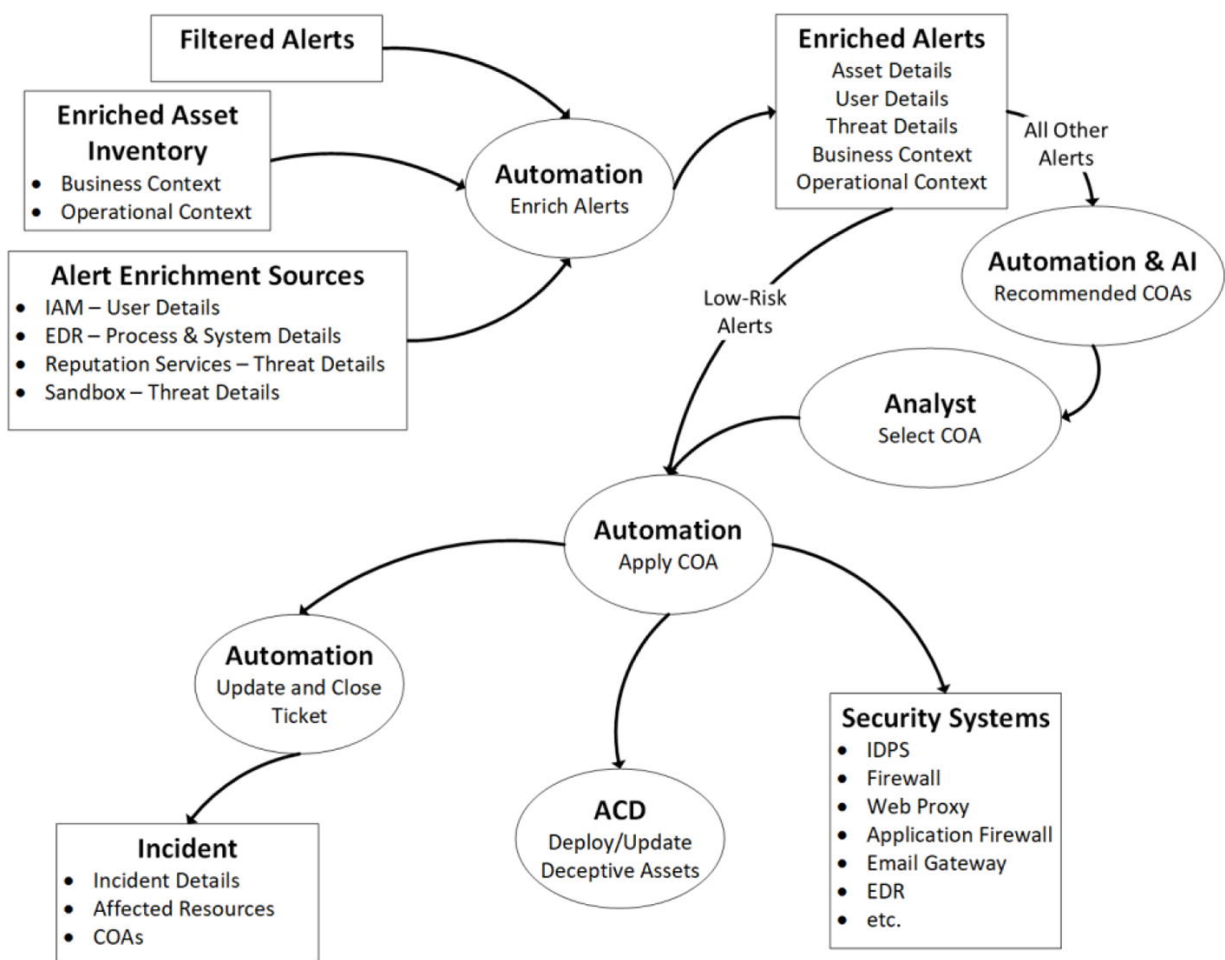


Figure 13-11 Automated alert enrichment and AI-assisted recommendations allow the analyst to make informed decisions, which are then applied throughout the environment

Next, automation can analyze the enriched alerts and automatically apply the COA if the alert meets specified criteria. For example, all low-risk alerts with a specified COA may be handled by automation, with no analyst intervention. For all other alerts, automation can search for recommended COAs and integrate with AI to analyze similar incidents in the past to generate recommended COAs. The analyst will then be presented with comprehensive details about the incident, including assets, users, and business and operational context, along with recommended COAs.

Whether the COA was selected by automation or by the analyst, automation will then send instructions to the

appropriate security devices to implement the COA. The response to a given alert could be extensive, requiring updates in many security systems, including IDPSs, network firewalls, EDRs, web proxies, email gateways, and application firewalls. In addition, the response to the alert may necessitate deploying or updating deceptive assets. For example, if the security team operates a honeynet and actively engages with an attacker, they may need to change deceptive assets to maintain or improve the deception. Finally, once all COAs are implemented, automation documents the incident with the incident details, assets affected, and COAs deployed.

Recover

After incident response processes contain and mitigate the incident, it is sometimes necessary to invoke recovery processes. For example, an incident response may have successfully halted an attack and mitigated further damage, but some business processes may have been interrupted. Restoration of these services would fall under the *Recover* function of the NIST CSF. With AI's help, an analyst can review the incident details and the enriched asset inventory to determine what systems or processes need to be recovered and develop a recovery plan that details the recovery and verification steps, as depicted in Figure 13-12.

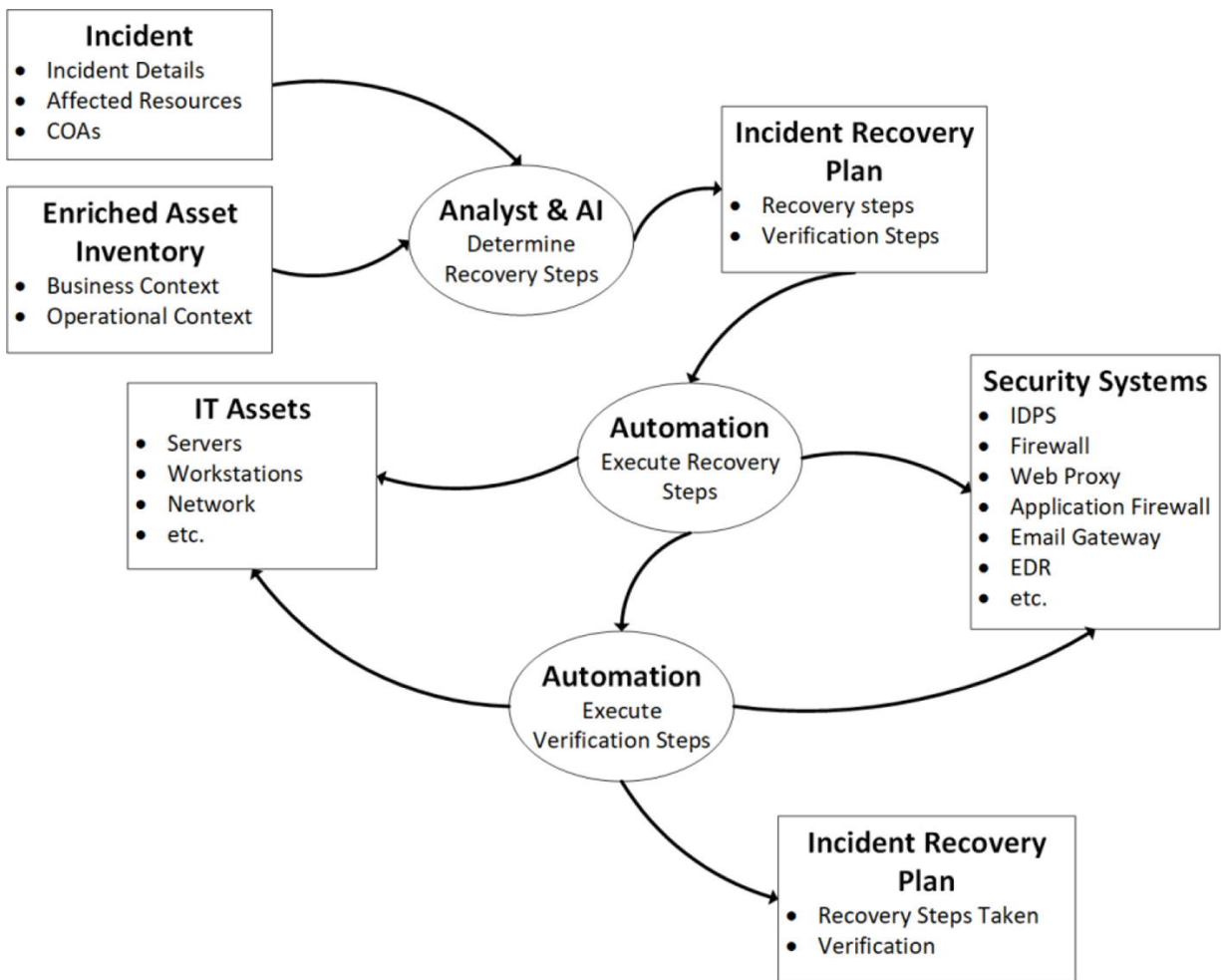


Figure 13-12 AI assists the analyst in creating a recovery plan for the incident, which is then executed through automation

Automation can execute the recovery plan following the detailed recovery steps. These steps could include sending instructions to security systems and impacted IT assets. Perhaps the security team needed to stop servers or processes as part of the incident mitigation. Now that the security incident is resolved, the recovery must ensure that the servers or processes are brought back online in a controlled manner. Also critical to the recovery is that automation will run the verification steps to ensure the services are back online and operating as expected. Upon completion of recovery and verification, the automation updates the recovery plan, detailing the steps taken and the verification results.

Govern

The *Govern* function underlies the other five functions, ensuring they operate per the organization's risk management strategy, policies, and applicable standards and regulations. A critical component of cyber risk management is raising applicable risks to the enterprise risk management function (ERM). ERM encompasses more than cyber risk; it handles all the organization's risks. AI can assist in evaluating the identified cyber risks to determine if they represent enterprise-level risks (see Figure 13-13). Cyber risks that may rise to enterprise-level risks could damage the company's reputation, affect compliance with regulations, or cause significant business interruption or loss of revenue. Automation can then integrate the identified risks with the ERM system.

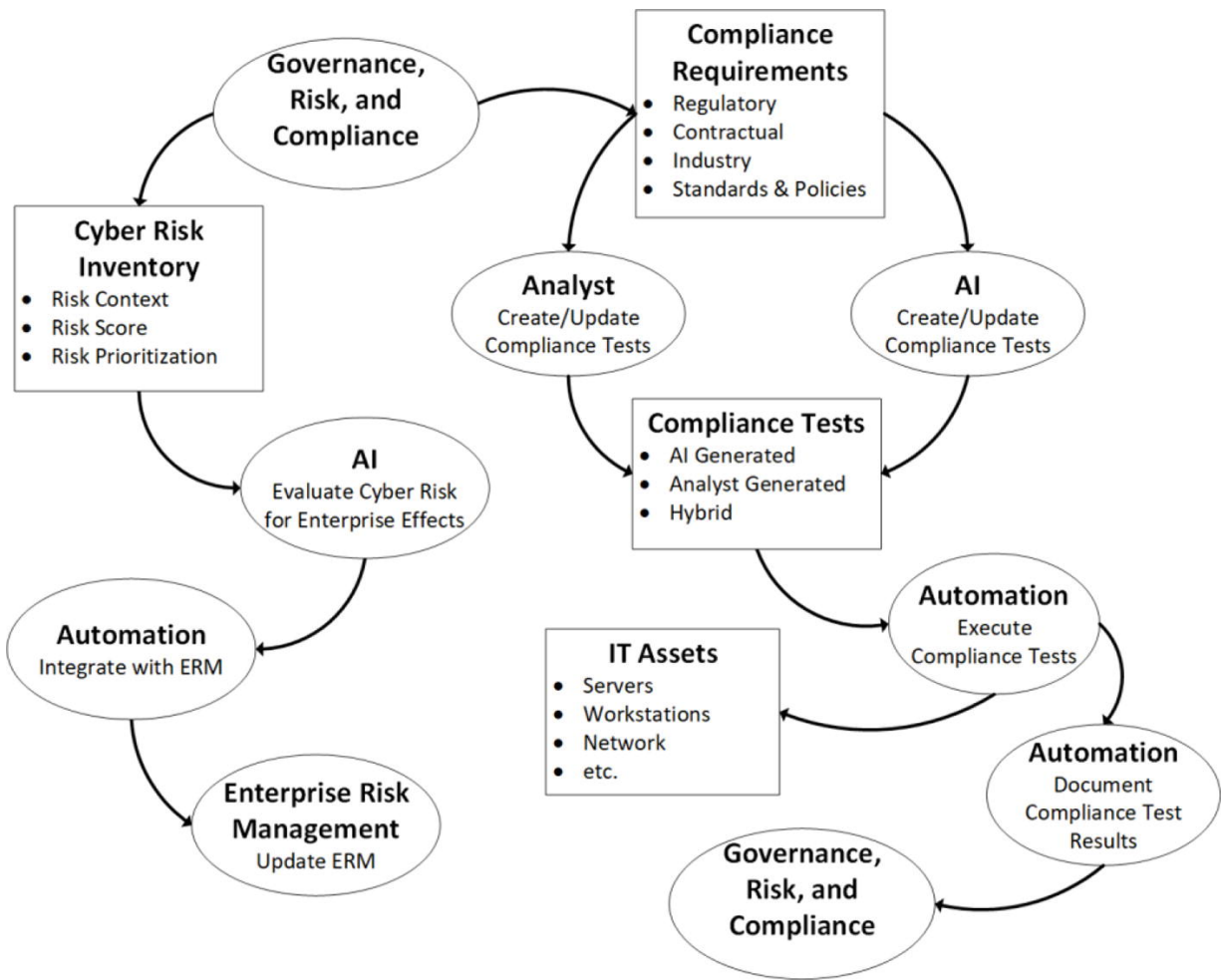


Figure 13-13 Using AI and automation to integrate cyber risks into the ERM system and ensure continuous compliance with regulations, contracts, policies, and standards

The *Govern* function must also ensure compliance with regulations, contracts, standards, and policies. The compliance requirements from a GRC system can provide the necessary input. Alternatively, if a GRC system is not in place, the team can use AI to extract requirements from the applicable regulations, contracts, standards, and policies. The creation of the compliance tests based on these requirements can be automated with AI, done manually by an analyst, or, in most cases, using a hybrid, where the analyst interacts with AI or reviews the AI output. Automation can then execute the compliance tests against the IT assets and document the results. Such a process can

ensure continuous compliance versus a traditional snapshot-in-time compliance.

Where to Start

Fortunately, you probably already have started, especially regarding AI. Most tools within your security stack likely include AI features. Detection tools like IDPSs, EDRs, and next-generation firewalls incorporate AI-based rules to evaluate traffic for possible malicious activities and anomalies. Behavior analytics systems are built upon AI anomaly detection. SIEMs incorporate AI rules for event correlation, providing improved visibility into possible incidents that span multiple systems. SOAR systems can leverage AI to recommend possible COAs in response to an incident by analyzing past incident responses and through reinforcement learning guided by analyst interaction. GRC systems now typically incorporate AI to evaluate compliance with the most common regulations and standards, and they can be configured to consider company-specific policies and contracts. Also, even if you do not have a SOAR product installed, you will likely have various degrees of automation in your security operations. Many security products provide automation capabilities through off-the-shelf integrations with other tools or via APIs, which allow custom automation development.

Therefore, a critical step is to understand what capabilities the team currently uses from the tools within its security stack. Also, understanding how and where AI is used within the company's security stack better prepares the team to protect against adversarial attacks on its security tools. The company must also consider its desired future state for security operations. However, security teams should not look too far ahead in the fast-changing cybersecurity landscape. Security teams must be ready to move quickly and adjust course rapidly to meet new threats and leverage new capabilities. If a security team still thinks

of 3-5-year plans, they will fall behind. I have found that limiting the desired future state to a one-year horizon (two years at the most) works best.

Assessing the gaps between the current and future states will identify areas for improvement through AI, automation, and ACD. Of course, there may be many areas for improvement, so the company must prioritize the efforts. When addressing a gap, companies should consider features available in current products within their security stack. Often, companies do not fully leverage current product features.

The security team may also need to evaluate other products because they have no product to address the gap or the current product has not kept pace with innovative leaders. When products do not keep pace, it becomes necessary to replace them. In the early days of security automation, I was on a panel discussion and asked about the importance of *plug-and-play* architecture in facilitating SOAR. I mentioned that *unplug-and-remove* was as crucial as *plug-and-play*. The other panelists, who were mostly security product vendors, were speechless. Removing a current product from the security stack in a complex environment can be extremely challenging. However, a well-architected SOAR integration that abstracts the proprietary vendor interfaces can make unplugging and removing a product easier.

Of course, it is necessary to evaluate the security of products, including security products. Since these products often incorporate AI features, evaluation teams must include AI-related security aspects. When evaluating AI-enabled security products, it is crucial to understand the explainability of the AI's decision-making process, especially for high-stakes decisions that may require human oversight or intervention. The Financial Services Information Sharing and Analysis Center released a

whitepaper and tool to assist organizations in evaluating products that leverage generative AI (Frisbie, et al., 2024). Though this assessment tool was developed for financial services organizations, it applies to all industries. The assessment covers many risk areas related to generative AI use in products, including data privacy, model training, model validation, information security, technology integration, third-party risk, and compliance. The tool will create a due diligence questionnaire customized based on risk analysis and risk levels.

Organizations can effectively integrate AI into their security operations by leveraging the open source AI Adoption Management Framework (AI-AMF). Whether the AI solution is a vendor product, a feature within such a product, or a custom-developed tool, the AI-AMF offers a structured and strategic approach to adoption (WhitegloveAI, 2024). This comprehensive framework helps align AI initiatives with business objectives while ensuring robust security measures are in place. Comprising seven layers, the AI-AMF guides organizations from initial innovation to full operationalization and integration, embedding security and governance throughout the entire AI adoption lifecycle. The AI-AMF can serve as a crucial resource for security teams, enabling them to systematically drive AI strategy and implementation within their operations, emphasizing security at every phase.

When executing against the plan, there are several vital things to consider. First, use the right tool for the job. Do not automate for automation's sake. I have encountered countless processes that, when automated, were more difficult for the customer or end-user, which leads to frustration. Another pitfall to avoid in automation is simply automating the current process instead of improving the process. As for AI, do not unquestioningly enable AI features in the security products. Ensure the team understands what the AI feature does, how it will improve

the process, and any potential negative impacts. Second, when using automation or AI within a process, evaluate the risks associated with each use case and determine when to have a human in the loop. Third, do not look at processes, products, and capabilities in isolation. Consider how AI, automation, and ACD can work together, far exceeding their capabilities in isolation. Finally, continuously reevaluate the plan and be prepared to adjust quickly.

Summary

AI, automation, and ACD each offer many benefits to improve cybersecurity within an organization. However, teams need to integrate these capabilities into a holistic strategy to realize the full benefit of these technologies. The CST can guide organizations in developing and deploying a cybersecurity strategy with AI as the foundation, automation to increase detection and response speed, and ACD to slow the attacker. The NIST CSF is a widely accepted guide used by security teams across all industries to improve security operations. This chapter provided examples of how organizations can use the CST to implement AI, automation, and ACD across the six NIST CSF functions – Identify, Protect, Detect, Respond, Recover, and Govern.

References

Boyd, J. (1995). The essence of winning and losing.
Retrieved from
https://www.coljohnboyd.com/static/documents/1995-06-28__Boyd_John_R__The_Essence_of_Winning_and_Losing__PPT-PDF.pdf

Frisbie, A., Beil, R., Matthews, L., Fernandes, S., Guy, L., Adekunle, A., . . . Silverman, M. (2024). *Generative AI vendor risk assessment guide*. FS-ISAC. Retrieved from <https://www.fsisac.com/knowledge/ai-risk>

NIST. (2024). *The NIST cybersecurity framework (CSF) 2.0*. NIST. doi: <https://doi.org/10.6028/NIST.CSWP.29>

WhitegloveAI. (2024). *The AI-AMF: A unified framework for strategic AI adoption and governance*. Retrieved from AI-AMF: <https://www.aiamf.ai/>

Index

A

Access control

Active cyber defenses (ACD)

- categorizing

- countermeasures

- defenders

- legal and ethical considerations

 - boundaries

 - legislative reform

 - offensive cyber

 - and self-defense

- spectrum

 - beacons

 - dark web intelligence

 - deception

 - extreme caution

 - low-risk

 - malware baiting

 - MTD

Active Directory (AD)

Advanced persistent threat (APT)

Adversarial environment

- acceptable and efficient

- inference phase attacks

- MITM output attacks

- ML-specific security controls

- non-adversarial environment

- privacy attacks

- protection

- traditional cybersecurity controls

- training and testing phase

- types and components

Adversarial ML development

- adversarial training
- attackers
- concepts
- countermeasures
- defender
- developed and tested during testing
- developing corresponding attacks
- devising effective countermeasures
- KPIs
- penetration testing
- reactive ML development
- recognize training stage and inference stage
- vulnerabilities
- recognizing vulnerabilities
- security testing
- training data

Affinity analysis

Age Discrimination in Employment Act

Agent

AI Adoption Management Framework (AI-AMF)

AI-driven analytics

Alert enrichment

Alert management

Alert triage

AI ethics

- bias/discrimination
- organizations
- privacy

AI-generated synthetic media

AI jailbreaking

AI privacy

Anomaly-based IDPSs

Antivirus

Application programming interfaces (API)

- automation
- availability

information consideration
robustness consideration
scalability
SOAR

Artificial intelligence (AI)

alert management
algorithmic trading
applications
automating to speed defense
behavior analytics
by industry
 ChatGPT
 electric grids
 electric utility sector
 energy sector
 financial services
 generative AI market
 healthcare
 manufacturing
 predictive maintenance systems
 smart metering
 Tata Power
 transportation
 winds
cybersecurity
for defense
device profiling
DLP
email security
environmental impact
ethics
EU AI Act
fields of study
governance
intrusion detection
lifecycle

in logistics operations
malware
and ML concepts
risk management processes
security teams
security tools and services
static and dynamic malware analysis
threat intelligence processes
vulnerability management
XAI

Artificial neural networks (ANNs)

activation function
artificial neurons
backpropagation
biological neuron
DNNs
layers
ML
nodes

Artificial neuron

Asymmetry attacker

adaptive threats
advantages
automation and AI
burglars
CISA
cyber defenders
cyber defenses
cyber realm
cyberspace
defenders
operating systems
physical realm
prevailing security products
SOCs
static defenses

vulnerabilities

Automation

API information considerations

API robustness

API scale

auditing

enrichment

feedback

high-benefit/high-risk quadrant

organizational trust

queries

resilient playbooks

responses

SOAR API

team

trust

verifying

B

Backpropagation

Bagging

Barclays

Bayesian classifier

Bayes' theorem

Beacons

BEC attacks

Behavior analytics

data mining and ML

detect threats

UBA

Bidirectional RNNs

Blockchain-based content verification systems

Blocking

Bootstrap aggregating

Bring-your-own-device (BYOD)

Business email compromise (BEC) attacks

C

California Consumer Privacy Act (CCPA)

Causative attacks

CCPA

See California Consumer Privacy Act (CCPA)

Central management console

Centroid-based clustering

Chatbot

ChatGPT

Classification and regression tree (CART)

Clop

Cloud computing

Cloud environments

Common Vulnerability Scoring System (CVSS)

Computer Fraud and Abuse Act (CFAA)

Concealment

Convolutional neural networks (CNN)

Core points

Course of action (COA)

Cozy Bear

CVEs

Cyberattacks

advanced and well-orchestrated

costs of data breaches

data breach

lifecycle

ransomware attack

supply chain attack

Cyber breaches

Cybercriminals

Cyber defenders

Cyber defense

Cyber realm

Cybersecurity

AI

- catastrophic effects
- community
- deception applications
- detecting and triaging potential attacks
- and medical diagnosis
- ML
- operational environments
- practitioners
- professionals
- tools
- traditional controls
- vampires and
- Cybersecurity and Infrastructure Security Agency (CISA)
- Cybersecurity framework (CSF)
- Cybersecurity professionals
- Cybersecurity Trinity™ (CST)
 - AI as foundation
 - detect function
 - govern function
 - high-level view
 - identification
 - NIST CSF
 - protect function
 - recovery plan
 - respond function
- Cyberspace
- Cyber speed

D

- Dark LLMs
- Dark web intelligence
- Data breach
 - costs of
 - retail
- Data exfiltration
- Data loss prevention (DLP) systems

- Data masking
- Data mining
 - and ML
- Data points
- Data poisoning attacks
- Data provenance
- Data sanitization
- Data scientists
- DBSCAN
- Deception
 - alerting
 - assets
 - central management console
 - components
 - docoys
 - lures
 - concealment
 - in cybersecurity
 - in cyberspace
- FUSAG
- George Washington example
- goals and objectives
- history
- honeynets
- misinformation and concealment
- orientation
- practical uses
- prerequisites
- strategy
- tactics
- targets
- tokens

- Decision nodes
- Decision trees
- Deepfakes
 - creation

- defending vs. deepfake fraud
- DNN
- for fraud
- interchangeable
- open source tools
- in politics and propaganda
- security researcher, global company
- training model
- video

Deep learning (DL)

- ANNs
- CNN
- convolution
- pooling
- RNN

Deep neural networks (DNNs)

- applications
- feed-forward model
- multiple-layer

Defense, AI

- accuracy and unbalanced data
- alert management
- behavior analytics
- device profiling
- email security
- intrusion detection
- malware and ransomware detection
- synthetic data
- vulnerability exploitation prediction
- vulnerability management

Deflection

Deidentification

Denial of services (DoS) attack

Density-based clustering

Department of Homeland Security (DHS)

Detection rate
Device profiling
Discriminative algorithm
Disinformation
 targeted disinformation campaign
Diversification
Do anything now (DAN) prompt
Dynamicity

E

EEOC
 See Equal Employment Opportunity Commission (EEOC)
Electric grids
Electric utility sector
Email account
Email security
 email account
 phishing detection
 spam detection
Endpoint detection and response (EDR)
Energy sector
Enterprise risk management function (ERM)
Environmental impact of AI
Equal Employment Opportunity Commission (EEOC)
Euclidean distance
European Union (EU) AI Act
Evasion attacks
Explainable AI (XAI)
Exploit Prediction Scoring System (EPSS)
Exploratory attacks

F

Fake content
False positives
Fast gradient sign method (FGSM)
Federal Trade Commission (FTC)

File hash
Financial services industry
Financial Services Information Sharing and Analysis Center (FS-ISAC)
FireEye
First US Army Group (FUSAG)
Forensic investigation enrichment
Forum of Incident Response and Security Teams (FIRST)
FraudGPT
Fraudulent activity
Fraudulent transfers
Fusion AnalyticS for public Transport Event Response (FASTER) system

G

GAN

See Generative adversarial network (GAN)

GDPR

See General Data Protection Regulation (GDPR)

General Data Protection Regulation (GDPR)

General-purpose AI (GPAI)

Generative adversarial network (GAN)

Generative AI

Bloomberg Intelligence
and LLMs
synthetic data
threats

Generic pre-trained (GPT) LLMs

GPAI

See General-purpose AI (GPAI)

GPU

See Graphics processing units (GPU)

Graphics processing units (GPUs)

Green AI

H

Hallucinations

Healthcare industry

HIDS

See Host-based intrusion detection system (HIDS)

Honeynets

Honeypots

Horrendous security breach

Host-based intrusion detection system (HIDS)

Human-in-the-loop approach

Human-on-the-loop strategy approach

I

Identity and access management (IAM)

IDPS

See Intrusion detection and prevention systems (IDPS)

Incident enrichment

Indicators of compromise (IOCs)

Indirect poisoning attacks

Industrial control systems (ICS)

Inference phase attacks

- categories

- data and performs assigned tasks

- evasion attacks

- exploratory attacks

- output integrity attacks

- privacy attacks

Information sharing

Integrated Adaptive Cyber Defense Framework (IACD)

- architecture

- goal

- human-centered cyber defense

- JHU-APL

- and OODA loop

Intelligence

- benefits, automation

- file hash example

- manual threat processing
- threat

International Organization for Standardization (ISO)

Internet of Things (IoT)

Intrusion detection

- HIDS

- IDPS

- NetFlow analysis

- NIDS

Intrusion detection and prevention systems (IDPS)

ISO

See the International Organization for Standardization (ISO)

J

Johns Hopkins University Applied Physics Lab (JHU-APL)

- automation

- high-benefit/low-regret methodology

- matrix

- response actions

K

KEVs

See Known Exploited Vulnerabilities (KEVs)

Key performance indicators (KPIs)

Key performance metrics

k-means clustering (k-MC)

k-nearest neighbors (k-NN) algorithm

Known Exploited Vulnerabilities (KEVs)

KPIs

See Key performance indicators (KPIs)

L

Label flipping

Large language models (LLMs)

- AI jailbreaking

- dark LLM

- data extraction attacks
- deepfakes
- and generative AI
- hallucinations
- misinformation and disinformation

Leaf nodes

Level-one security analysts

Linear regression

LLMs

See Large language models (LLMs)

Locally estimated scatterplot smoothing (LOESS)

Locally weighted scatterplot smoothing (LOWESS)

LOESS

See Locally estimated scatterplot smoothing (LOESS)

Log4Shell vulnerabilities

Logistic regression

Love-GPT

LOWESS

See Locally weighted scatterplot smoothing (LOWESS)

M

Machine learning as a service (MLaaS) platform

Machine learning (ML)

- accuracy and unbalanced data

- in adversarial environment

- and AI concepts

- algorithm selection

- applications

- artificial neural networks

- causative attacks

- ChatGPT

- classifier for malware

- cross-validation techniques

- data assembly

- and data mining

- data to generalize algorithms

deep learning
DL
electric sector
exploratory attack
in financing
generative AI
generic model
GPUs
inaccurate/unreliable models
on neural networks
prototyping
reinforcement learning
and robotics
security professionals
supervised learning
supply chain
synthetic data
testing data
training
training and testing models
training set and testing set
unsupervised learning
vs. to human thinking
Malicious IPs
Malware detection
baiting
rescue missions
and whitehat malware
Malware response
Man-in-the-middle (MITM) attack
Manufacturing industry
Market basket analysis (MBA)
Markov decision process
Mastercard
Mean time to detect (MTTD)

- Mean time to respond (MTTR)
- Misinformation
- Misuse-based IDPSs
- Misuse-based ML detection
- ML-based anomaly detection
- ML-based UBA
- ML-specific security controls
 - adversarial ML development
 - data provenance
 - monitoring and response
 - robust learning
 - training data sanity check
- Model drift
- Moving target defense (MTD)
- Multilayer perceptron (MLP)
- Multiple linear regression (MLR)

N

- Naïve Bayes
- the National Institute of Standards and Technology (NIST)
- National Security Agency (NSA)
- National Vulnerability Database (NVD)
- Natural language processing (NLP)
- NetFlow analysis
- Network-based intrusion detection system (NIDS)
- Network management system
- Neural Winter
- Next-generation firewalls (NGFW)
- Non-comprehensive search

O

- Observe-orient-decide-act (OODA) loop
 - action
 - AI-powered security tools
 - better-quality decisions
 - cyber defenders

- cyberspace
- decision
- defender and attacker
- disruption
 - opponent's actions
 - opponent's decision-making
- factors
- feedback
- IACD
- in business
- integrated approach
- mental patterns
- observations
- orientation
- QB
- simplification
- with playbooks
- Open source intelligence (OSINT)
- Open Worldwide Application Security Project (OWASP)
- Orchestrated response
- Ordinary least squares (OLS)
- ORION system
- Output integrity attacks
- Overreliance

P

- Perimeter defenses
- Personal health information (PHI)
- Personally identifiable information (PII)
- Phishing detection
- Phishing emails
- Phishing response
- Poisoning attacks
 - adversarial data
 - adversarial sample insertion
- applications

- attack types
- categories
- decision boundaries
- indirect
- label flipping
- malfunctioning model
- malware detection
- MLaaS platform
- ML supply chain
- model's performance
- online training
- pre-trained models
- shared datasets
- testing phase
- training and testing phase attacks
- training/testing data
- Uncle Ronnie Syndrome
- Policy Gradient methods
- Polymorphic and metamorphic malware
- Polymorphic malware
- Predictive algorithms
 - linear regression
 - MLR
- Predictive learning
- Predictive maintenance systems
- Privacy attacks
- Proactive defense approach
- Projected gradient descent (PGD)
- Pruning
- Python

Q

- Q-learning
- Quality vulnerability management systems
- Quarterback (QB)

R

Random forest

Ransomware attacks

Ransomware detection

Ransomware groups

RBAC

See Role-based access control (RBAC)

Reactive ML development

Recommendation systems

Recurrent neural networks (RNN)

Reinforcement learning

Remediation

DLP

forensic investigation enrichment

malware response

orchestrated response

phishing response

suspicious user activity

Residual

Retail data breach

Risk-based decisions

RNN

See Recurrent neural networks (RNN)

Robust learning

Robust monitoring

Role-based access control (RBAC)

Root node

S

Santander

SARSA (State-Action-Reward-State-Action)

Scammers

Search distance

Security analysts

Security automation

asymmetric attackers

- cyberattacks
- cybersecurity professionals
- cyber speed
- data and complexity
- manual triage and response
 - accurate and concise information
 - alert and incident
 - defenders
 - endpoint data
 - human-in-the-loop process
 - network devices
 - proactive defense approach
 - relationship between events, alerts, and incidents
 - security analyst
 - security systems
 - SIEM
 - SOC analysts
 - triage analysis
 - user information
- SOC team members
- sophistication of attacks

Security incident

Security incident and event management (SIEM)

Security operations centers (SOC)

Security orchestration automation and response (SOAR)

- alert enrichment
- analyst
- API platform
- benefits
- capabilities
- cost savings
- cybersecurity vendors
- decreased time to respond
- development
- efficiency gains
- growth

- incident management
- increasing visibility
- MTTD
- MTTR
- orchestrated response
- platform
- process completeness and consistency
- situational awareness
- SOCs
- use cases

Security systems

- measuring
- SOAR goals
- strategies
 - automation
 - money saving
 - organizational trust
 - priorities
 - use cases
- types
- use cases

Self-defense

Self-driving cars

Semi-automated malware

Semi-supervised ML algorithms

Sense-making analytic framework

Shared training data

Skepticism

Smoothing methods

SOC analysts

Social engineering

Social media

Sock puppets

Software vulnerabilities

SolarWinds attack

Sophistication of attacks

- Spam detection
- Special Interest Group (SIG)
- Speed defense automation
 - alert enrichment
 - alert response actions
 - DLP
 - insider threat
 - malware response
 - phishing response
 - alert triage
 - situational awareness
 - threat intelligence processing
 - vulnerability management
- Supervised learning
 - classification algorithms
 - decision trees
 - distinct groups
 - k-NN algorithm
 - naïve Bayes classifier
 - random forest
 - SVM
 - dependent variable
 - predictive algorithms
- Supervised ML algorithm
- Supervised training
- Supervisory control and data acquisition (SCADA) systems
- Supply chain attack
- Support vector machine (SVM)
- Support vectors
- Suspicious user activity
- Synthetic data, generative AI
 - applications
 - data quality and security risks
 - definition
 - GAN
 - imbalanced datasets

- LLMs
- model development and prototyping
- protect privacy
- reverse engineering
- rule-based approach
- structures
- training ML models
- UNU

Synthetic Data Metrics (SDMetrics)

T

- Targeted disinformation campaign
 - attacker
 - data breach
 - LLMs
 - social media
- Targeted misinformation campaigns
 - vs. defending
- Third-party cybersecurity auditors
- Threat detection
- Threat intelligence
 - automation
 - manual processing
- Threats
- T-Mobile
- Tokens
- Traditional cybersecurity controls for ML
 - access control
 - APIs
 - change management
 - secure-by-design approach
 - third-party cybersecurity auditors
 - version control
- Transparent AI
- Transportation industry
- Triage analysis

false positive filtering
IPs and URLs

U

Uncle Ronnie Syndrome
United Nations University (UNU)
Unsupervised ML

- clustering
 - attributes
 - density-based clustering
 - exclusive
 - hierarchical
 - high intraclass similarity
 - k-MC
 - low interclass similarity
 - partial

MBA

UNU

See United Nations University (UNU)

User behavior analytics (UBA)

- challenges
- and threat detection

V

Vulnerability exploitation prediction
Vulnerability management

W

Web meeting
WormGPT

X, Y

XGBoost algorithm

Z

Zero-day vulnerability
Zero-trust architecture